OPEN 출처표시 상업용금지 변경금지
공공누리 공공저작물 자유이용허락

2026.07.

클라우드서비스 보안인증기준 해설서

Cloud Service
Security Certification Standards
Manual



과학기술정보통신부
KISA 한국인터넷진흥원


클라우드 서비스 보안인증
CSAP
Cloud Security Assurance Program



클라우드서비스 보안인증기준 해설서

Cloud Service Security Certification Standards Manual

들어가기

클라우드컴퓨팅서비스(이하 '클라우드서비스'와 혼용) 보안인증제도는「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」제23조의2에 따라 클라우드서비스 제공자가 제공하는 서비스의 정보보호 수준이 보안인증기준에 적합한지 여부를 확인한 클라우드서비스에 대하여 보안인증을 수행하는 제도입니다.

클라우드서비스 보안인증제도는 IaaS, SaaS(간편등급, 표준등급), DaaS, 하등급, 하등급 SaaS 인증으로 구분되고 인증의 유효기간은 5년입니다.

클라우드컴퓨팅서비스 보안인증에 관한 고시(2023.01.31.)의 부칙 제1조에 따라서 상, 중등급은 별도 기준 마련 후 시행한다. 또한 같은 고시 부칙 제3조에 따라 상, 중등급 시행 전까지 기존 IaaS, SaaS(간편등급, 표준등급), DaaS 인증에 대하여 신청할 수 있습니다.

클라우드서비스 보안인증의 대상은 클라우드컴퓨팅 기술을 이용하여 정보 시스템의 인프라, 응용프로그램, 개발환경 중 어느 하나 이상을 제공하는 클라우드서비스가 해당됩니다.

클라우드서비스 보안인증제도는 안정성 및 신뢰성이 검증된 클라우드서비스를 공급하고, 객관적이고 공정한 클라우드서비스 보안인증제도를 통하여 이용자의 보안 우려를 해소하고 클라우드서비스의 경쟁력을 확보하는 데 그 목적이 있습니다.

이 해설서는 지속적인 보완 작업을 통하여 변경될 수 있으므로 항상 최신 버전 여부를 확인 후 사용해야 합니다. 또한, 해설서에 포함된 법령, 고시, 참고자료는 해설서 발간 시점 (2026.05.)을 기준으로 작성된 것으로 수시 개정될 수 있으므로 해당 시점에서 최신 버전을 확인하여 적용해야 합니다.

이 해설서는 홈페이지(https://isms-p.or.kr)에도 게재되며, 기타 문의 사항이 있는 경우 아래 전자우편으로 문의하기 바랍니다.

E-mail : cloud@kisa.or.kr

제1장 클라우드컴퓨팅서비스 보안인증 개요 ····· 1

1. 클라우드서비스 보안인증기준 구성 ····· 2

2. 용어 정의 ····· 6

제2장 클라우드컴퓨팅서비스 보안인증기준 설명 ····· 13

Ⅰ. 관리적 보호조치

1. 정보보호 정책 및 조직 ····· 14
1.1 정보보호 정책 ····· 14
1.2 정보보호 조직 ····· 23

2. 인적보안 ····· 28
2.1 내부인력 보안 ····· 28
2.2 외부인력 보안 ····· 41
2.3 정보보호 교육 ····· 47

3. 자산관리 ····· 53
3.1 자산 식별 및 분류 ····· 53
3.2 자산 변경관리 ····· 60
3.3 위험관리 ····· 65

4. 서비스 공급망 관리 ····· 74
4.1 공급망 관리 정책 ····· 74
4.2 공급망 변경관리 ····· 78

5. 침해사고 관리 ····· 81
5.1 침해사고 대응 절차 및 체계 ····· 81
5.2 침해사고 대응 ····· 89
5.3 사후관리 ····· 95

6. 서비스 연속성 관리 ····· 99
6.1 장애대응 ····· 99
6.2 서비스 가용성 ····· 108

7. 준거성 ····· 116
7.1 법 및 정책 준수 ····· 116
7.2 보안 감사 ····· 122

Ⅱ. 물리적 보호조치

8. 물리적 보안 ····· 127
8.1 물리적 보호구역 ····· 127
8.2 정보처리 시설 및 장비보호 ····· 138

Ⅲ. 기술적 보호조치

9. 가상화 보안 ····· 154
9.1 가상화 인프라 ····· 154
9.2 가상 환경 ····· 167

10. 접근통제 ····· 175
10.1 접근통제 정책 ····· 175
10.2 접근권한 관리 ····· 180
10.3 사용자 식별 및 인증 ····· 188

11. 네트워크 보안 ····· 197
11.1 네트워크 보안 ····· 197

12. 데이터 보호 및 암호화 ····· 211
12.1 데이터 보호 ····· 211
12.2 매체 보안 ····· 225
12.3 암호화 ····· 231

13. 시스템 개발 및 도입 보안 ····· 236
13.1 시스템 분석 및 설계 ····· 236
13.2 구현 및 시험 ····· 247
13.3 외주 개발 보안 ····· 255
13.4 시스템 도입 보안 ····· 257

Ⅳ. 국가기관등이 이용하는 클라우드컴퓨팅서비스 보호조치

14. 국가기관등의 보안요구 사항 ····· 261
14.1 관리적 보호조치 ····· 261
14.2 물리적 보호조치 ····· 271
14.3 기술적 보호조치 ····· 275

제1장

클라우드컴퓨팅서비스 보안인증기준 개요



1 클라우드컴퓨팅서비스 보안인증기준 구성

클라우드컴퓨팅서비스 보안인증기준은 크게 '관리적 보호조치', '물리적 보호조치', '기술적 보호조치', '국가기관등이 이용하는 클라우드컴퓨팅서비스 보호조치' 4개의 영역으로 구성되어 있다.

기존 인증제의 인증을 받고자 하는 신청기관은 IaaS 116개, DaaS 110개, SaaS 표준 79개, SaaS 간편 31개의 인증기준을 적용받게 된다. 등급제 하등급 인증을 받고자 하는 신청기관은 하등급 IaaS 64개, SaaS 하등급 30개의 인증기준을 적용받게 되며 아래 표와 같다.

신청기관은 이 해설서를 참고하여, 인증받고자 하는 클라우드서비스의 등급과 유형에 따른 인증기준 및 점검항목을 준수하여야 한다.

클라우드컴퓨팅서비스 보안인증기준

영역		분야	적용 여부					
			기존 인증제				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			116개	79개	31개	110개	64개	30개
관리적 보호조치 (48개)								
1. 정보보호 정책 및 조직	1.1 정보보호 정책	1.1.1 정보보호 정책 수립	○	○		○	○	
		1.1.2 정보보호 정책 검토 및 변경	○	○		○		
		1.1.3 정보보호 정책문서 관리	○	○		○		
	1.2 정보보호 조직	1.2.1 조직 구성	○	○	○	○	○	○
		1.2.2 역할 및 책임 부여	○	○	○	○		
2. 인적보안	2.1 내부인력 보안	2.1.1 고용계약	○	○		○		
		2.1.2 주요 직무자 지정 및 감독	○	○	○	○	○	○
		2.1.3 직무 분리	○	○		○		
		2.1.4 비밀유지서약서	○	○		○		
		2.1.5 퇴직 및 직무변경	○					
	2.2 외부인력 보안	2.2.1 외부인력 계약	○			○		
		2.2.2 외부인력 보안 이행 관리	○			○		
		2.2.3 계약 만료 시 보안	○			○		
	2.3 정보보호 교육	2.3.1 교육 프로그램 수립	○					
		2.3.2 교육 시행	○	○	○	○	○	○
		2.3.3 평가 및 개선	○					
3. 자산관리	3.1 자산 식별 및 분류	3.1.1 자산 식별	○	○		○	○	
		3.1.2 자산별 책임 할당	○			○	○	
		3.1.3 보안등급 및 취급	○			○		

영역		분야	적용 여부					
			기존 인증제				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			116개	79개	31개	110개	64개	30개
	3.2 자산 변경 관리	3.2.1 변경관리	○	○		○		
		3.2.2 변경 탐지 및 모니터링	○			○		
		3.2.3 변경 후 작업 검증	○			○		
	3.3 위험관리	3.3.1 위험관리 계획 수립	○			○		
		3.3.2 취약점 점검	○	○		○	○	
		3.3.3 위험분석 및 평가	○			○		
		3.3.4 위험처리	○			○		
4. 서비스 공급망 관리	4.1 공급망 관리 정책	4.1.1 공급망 관리 정책 수립	○	○		○	○	
		4.1.2 공급망 계약	○	○		○		
	4.2 공급망 변경 관리	4.2.1 공급망 변경 관리	○	○		○		
		4.2.2 공급망 모니터링 검토	○			○	○	
5. 침해사고 관리	5.1 침해사고 대응 절차 및 체계	5.1.1 침해사고 대응 절차 수립	○	○	○	○	○	○
		5.1.2 침해사고 대응 체계 구축	○	○		○	○	
		5.1.3 침해사고 대응 훈련 및 점검	○	○		○	○	
	5.2 침해사고 대응	5.2.1 침해사고 보고	○	○	○	○	○	○
		5.2.2 침해사고 처리 및 복구	○	○		○	○	
	5.3 사후관리	5.3.1 침해사고 분석 및 공유	○	○		○		
		5.3.2 재발 방지	○	○		○	○	
6. 서비스 연속성 관리	6.1 장애대응	6.1.1 장애 대응절차 수립	○	○		○	○	
		6.1.2 장애 보고	○	○	○	○	○	○
		6.1.3 장애 처리 및 복구	○	○		○	○	
		6.1.4 재발 방지	○	○		○	○	
	6.2 서비스 가용성	6.2.1 성능 및 용량 관리	○	○	○	○	○	○
		6.2.2 이중화 및 백업	○	○		○		
		6.2.3 서비스 가용성 점검	○			○		
7. 준거성	7.1 법 및 정책 준수	7.1.1 법적요구사항 준수	○	○	○	○	○	○
		7.1.2 정보보호 정책 준수	○			○		
	7.2 보안감사	7.2.1 독립적 보안감사	○	○		○		
		7.2.2 감사기록 및 모니터링	○	○		○	○	
물리적 보호조치 (11개)								
8. 물리적 보안	8.1 물리적 보호 구역	8.1.1 물리적 보호구역 지정	○			○	○	
		8.1.2 물리적 출입통제	○			○	○	
		8.1.3 물리적 보호구역 내 작업	○			○		
		8.1.4 사무실 및 설비 공간 보호	○			○		
		8.1.5 모바일 기기 반출입	○			○		
	8.2 정보처리 시설 및 장비보호	8.2.1 정보처리시설의 배치	○			○		
		8.2.2 보호설비	○			○		

영역		분야	적용 여부					
			기존 인증제				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			116개	79개	31개	110개	64개	30개
		8.2.3 케이블 보호	○			○		
		8.2.4 시설 및 장비 유지보수	○			○		
		8.2.5 장비 반출입	○			○		
		8.2.6 장비 폐기 및 재사용	○			○		
기술적 보호조치 (47개)								
9. 가상화 보안	9.1 가상화 인프라	9.1.1 가상자원 관리	○	○		○	○	
		9.1.2 가상자원 회수	○			○	○	
		9.1.3 가상자원 모니터링	○			○	○	
		9.1.4 하이퍼바이저 보안	○			○	○	
		9.1.5 공개서버 보안	○	○	○	○	○	○
		9.1.6 상호 운용성 및 이식성	○					
	9.2 가상 환경	9.2.1 악성코드 통제	○	○		○	○	
		9.2.2 인터페이스 및 API 보안	○	○				
		9.2.3 데이터 이전	○	○				
		9.2.4 가상 소프트웨어 보안	○	○		○		
10. 접근통제	10.1 접근통제 정책	10.1.1 접근통제 정책 수립	○	○		○	○	
		10.1.2 접근기록 관리	○	○	○	○	○	○
	10.2 접근권한 관리	10.2.1 사용자 등록 및 권한부여	○	○		○	○	
		10.2.2 관리자 및 특수 권한관리	○	○		○	○	
		10.2.3 접근권한 검토	○	○		○	○	
	10.3 사용자 식별 및 인증	10.3.1 사용자 식별	○	○		○	○	
		10.3.2 사용자 인증	○	○	○	○	○	○
		10.3.3 강화된 인증 수단 제공	○	○	○	○	○	○
		10.3.4 패스워드 관리	○	○	○	○	○	○
11. 네트워크 보안	11.1 네트워크 보안	11.1.1 네트워크 보안정책 수립	○	○		○	○	
		11.1.2 네트워크 모니터링 및 통제	○	○		○	○	
		11.1.3 네트워크 정보보호시스템 운영	○	○		○	○	
		11.1.4 네트워크 암호화	○	○	○	○	○	○
		11.1.5 네트워크 분리	○	○	○	○	○	○
		11.1.6 무선 접근통제	○			○		
12. 데이터 보호 및 암호화	12.1.1 데이터 보호	12.1.1 데이터 분류	○	○		○		
		12.1.2 데이터 소유권	○	○		○	○	
		12.1.3 데이터 무결성	○	○		○		
		12.1.4 데이터 보호	○	○	○	○		
		12.1.5 데이터 추적성	○	○		○		
		12.1.6 데이터 폐기	○	○	○	○	○	○

영역		분야	적용 여부					
			기존 인증제				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			116개	79개	31개	110개	64개	30개
	12.2 매체 보안	12.2.1 저장매체 관리	○			○		
		12.2.2 이동매체 관리	○			○		
	12.3 암호화	12.3.1 암호 정책 수립	○	○	○	○	○	○
		12.3.2 암호키 관리	○	○	○	○		
13. 시스템 개발 및 도입 보안	13.1 시스템 분석 및 설계	13.1.1 보안요구사항 정의	○	○		○	○	
		13.1.2 인증 및 암호화 기능	○	○	○	○	○	○
		13.1.3 보안로그 기능	○	○		○		
		13.1.4 접근권한 기능	○	○		○		
		13.1.5 시각 동기화	○	○		○	○	
	13.2 구현 및 시험	13.2.1 구현 및 시험	○	○	○	○	○	○
		13.2.2 개발과 운영환경 분리	○	○		○	○	
		13.2.3 시험 데이터 보안	○	○		○		
		13.2.4 소스 프로그램 보안	○	○		○	○	
	13.3 외주 개발 보안	13.3.1 외주 개발 보안	○	○		○		
	13.4 시스템 도입 보안	13.4.1 시스템 도입 계획	○			○		
		13.4.2 시스템 인수	○			○		
국가기관등이 이용하는 클라우드컴퓨팅서비스 보호조치 (11개)								
14. 공공기관 보안 요구사항	14.1 관리적 보호조치	14.1.1 보안서비스 수준 협약	○	○	○	○	○	○
		14.1.2 도입 전산장비 안전성	○	○	○	○	○	○
		14.1.3 보안관리 수준	○	○	○	○	○	○
		14.1.4 사고 및 장애 대응	○	○	○	○	○	○
	14.2 물리적 보호조치	14.2.1 물리적 위치 및 영역분리	○	○	○	○	○	○
		14.2.2 중요장비 이중화 및 백업체계 구축	○	○	○	○	○	○
	14.3 기술적 보호조치	14.3.1 검증필 암호화 기술 제공	○	○	○	○	○	○
		14.3.2 보안관제 제반환경 지원	○			○	○	○
		14.3.3 데이터 유출 방지					○	○
		14.3.4 시스템 격리	○	○	○	○	○	○
		14.3.5 영역분리	○	○	○	○	○	○

2 용어 정의

클라우드서비스 보안인증기준 해설을 위하여 사용되는 용어와 약어에 대한 정의와 설명은 다음과 같다.

※ 영어, 한글 순으로 정리하였으며 법령에서 정한 경우 법령에 따른 정의를 기술하고 그 외에는 해설서 내에서 용어에 대하여 정의 및 설명함

용어 및 약어	정의 및 설명
API	Application Programming Interface 소프트웨어 컴포넌트 간 기능·데이터를 주고받기 위해 정의된 인터페이스. 클라우드 환경에서는 이용자가 가상자원을 프로그래밍 방식으로 제어하거나 SaaS 기능을 외부 시스템과 연동하는 수단으로 활용됨. REST, SOAP 등 다양한 방식으로 구현.
ABAC	Attribute-Based Access Control, 속성 기반 접근 통제 RBAC에 대비하여 사용자, 자원, 환경의 속성(특징)을 조합하여 권한을 결정하는 접근통제 방식
BCP	Business Continuity Plan, 업무 연속성 계획 재난·재해 등 비상 상황에서도 기업의 핵심 업무가 중단되지 않도록 하기 위한 포괄적 전략.
CAB	Change Advisory Board, 변경 자문 위원회 조직의 IT 서비스 관리 체계 내에서 IT 환경에 예정된 변경 사항을 검토, 평가 및 우선순위를 지정하는 전문가 그룹. 변경으로 인한 위협 최소화, 비즈니스 중단 예방, 변경 사항이 비즈니스 목표와 일치하는지 확인.
CAPCHA	Completely Automated Public Turing test to tell Computers and Uhmans Apart, 컴퓨터와 인간을 구분하기 위한 완전 자동화된 공개 튜링 테스트 웹사이트에서 악의적인 프로그램의 자동 접근을 막고 텍스트, 이미지, 동작 등을 이용하여 사람인지 확인하는데 사용되는 방법.
CC 인증	Common Criteria Certification IT 제품의 보안기능 및 보증 수준을 국제 공통평가기준(ISO/IEC 15408)에 따라 평가 및 인증하는 제도.
CCE	Common Configuration Enumeration 비밀번호 길이·복잡성, 기본 계정 삭제 등 시스템 구성 및 설정상의 취약점. CVE(소프트웨어 결함)와 달리 운영 설정 규정 미준수를 점검 대상으로 함.

CI/CD 파이프라인	Continuous Integration / Continuous Delivery Pipeline 소스코드 변경 사항을 자동으로 빌드·테스트·배포하는 일련의 자동화 프로세스. CI(지속적 통합)는 코드 병합·빌드·테스트 자동화를, CD(지속적 배포)는 검증된 산출물의 스테이징·운영 환경 자동 배포를 의미함. 클라우드 환경에서는 컨테이너 이미지 생성·취약점 점검·형상관리 서버 배포까지 파이프라인에 포함됨.
Container	컨테이너 운영체제 커널을 공유하면서 프로세스·파일시스템·네트워크를 격리하는 경량 가상화 기술. Docker 등으로 구현되며, 쿠버네티스(Kubernetes) 환경에서 네임스페이스(Namespace) 단위로 이용자 간 격리를 구현함.
CSP	Cloud Service Provider, 클라우드서비스 제공자(클라우드서비스제공자) IaaS, SaaS 등의 클라우드서비스를 제공하는 자
CVE	Common Vulnerabilities and Exposure 공개적으로 알려진 컴퓨터 하드웨어 또는 소프트웨어의 결함이나 설계상의 취약점. Mitre 등에서 CVE 코드(예: CVE-2023-0000)를 부여하고, 벤더가 제공하는 보안패치와 연계하여 관리
DaaS	Desktops as a Service 「클라우드컴퓨팅법 시행령」 제3조에 따라 가상PC 환경을 인터넷을 통해 제공하는 클라우드서비스. 하이퍼바이저 기반 인프라 영역에 가상 PC, 가상화관리 솔루션, 관리 서버 등 구성 필요.
DMZ	Demilitarized Zone 외부 인터넷과 내부 네트워크 사이에 위치한 중간 네트워크 영역. 공개서버(웹서버, 배포서버 등)를 배치하여 외부 접근을 허용하되, DMZ를 통한 내부 네트워크 침투는 차단.
DR Center (재해복구센터)	Disaster Recovery Center 주센터 장애·재해 시 서비스 연속성을 유지하기 위해 별도 구축하는 백업 센터. 단순 데이터 백업이 아닌 자체 서비스 운영이 가능한 수준(클라우드 서버, 스토리지, 네트워크, 상면 구비 등)이어야 함.
DRP	Disaster Recovery Plan, 재해 복구 계획 BCP의 하위 개념으로 화재, 지진, 해킹 등으로 IT 인프라(시스템, 데이터, 네트워크 등)가 마비되었을 때 이를 복구하기 위한 기술적인 절차
Hypervisor	하이퍼바이저 물리 서버 위에서 다수의 가상머신을 생성·관리하는 소프트웨어 계층. 각 가상머신에 CPU·메모리·저장장치 등 물리 자원을 분할 제공하며, IaaS·DaaS의 핵심 구성 요소.

IaaS	Infrastructure as a Service 「클라우드컴퓨팅법 시행령」 제3조제1호에 따라 서버·저장장치·네트워크 등 인프라를 제공하는 클라우드서비스. 이용자·관리자 포털, 가상자원 관리시스템, 주센터·DR센터 등 인프라 구성 필요.
MFA	Multi Factor Authentication, 다중 요소 인증 지식(비밀번호),소유(OTP·보안토큰 등), 생체기반(지문·홍채·안면 등) 중 2가지 이상을 조합하여 사용자 신원을 확인하는 인증 방식. '강화된 인증'이라고도 함.
Multi-Tenancy	하나의 클라우드 인프라·소프트웨어 인스턴스를 다수의 이용자(테넌트)가 공유하는 아키텍처. 각 테넌트는 논리적으로 격리되어 데이터·설정·접근권한이 상호 침범되지 않아야 함.
NTP	Network Time Protocol, 네트워크 시각 동기화 네트워크를 통해 시스템 시각을 표준 타임서버와 동기화하는 프로토콜. 감사로그의 정확한 타임스탬프 기록 및 법적 증거 효력 확보를 위해 클라우드 시스템에 적용 필요.
RBAC	Role-Based Access Control, 역할 기반 접근 통제 사용자의 '직무나 역할'에 따라 권한을 부여하는 일반적인 접근통제 방식
SaaS	Software as a Service, 서비스형 소프트웨어 클라우드서비스 제공업체가 인터넷을 통해 소프트웨어를 제공하고, 이용자는 설치 없이 구독형으로 사용하는 클라우드 기반 모델
SLA	Service Level Agreement, (클라우드) 서비스 수준 협약 클라우드서비스 제공자와 이용자 간에 서비스 가용성, 장애 복구 목표시간, 보안 요구사항, 데이터 처리 방법 등 서비스 제공 조건을 명시한 계약.
SRM	Shared Responsibility Model, 책임 공유 모델 클라우드서비스제공자(CSP), 이용자(Customer)가 보안 책임을 분담하는 프레임워크. CSP는 클라우드 "자체"의 인프라(물리적 시설, 하드웨어) 보안을, 이용자는 클라우드 이용과 관련된 데이터, 애플리케이션, 접근 권한 등 보안 설정을 책임지며 IaaS, PaaS, SaaS 등 서비스 모델에 따라 책임 범위가 달라짐.
SSID	Service Set IDentifier, 서비스셋 식별자/와이파이 네트워크 이름 스마트폰이나 노트북 등 기기에서 무선 네트워크를 검색할 때 표시되는 네트워크 이름
VM	Virtual Machine, 가상머신 하이퍼바이저에 의해 물리 서버 위에 생성·운영되는 소프트웨어 기반의 가상 컴퓨터. IaaS에서 이용자에게 제공되는 핵심 컴퓨팅 자원 단위.

VPC
Virtual Private Cloud
클라우드 환경 내에서 논리적으로 격리된 가상 네트워크 공간. 이용자별 독립된 네트워크 영역을 제공하며, 보안관제 수행 시 이용기관 VPC 영역에서 접근 가능한 환경 구성 필요.

WPA2
Wifi Protected Access version 2
2004년 Wifi 얼라이언스가 발표한 무선 네트워크 보안 표준. 가정용 WPA2-PSK와 기업용 WPA2-Enterprise로 구분.

WPA3
Wifi Protected Access version 3
2018년 Wifi 얼라이언스가 발표한 무선 네트워크 보안 표준. WPA2의 PSK (Pre-Shared Key) 방식이 아닌 SAE 프로토콜 사용으로 비밀번호 무작위 대입 추측 공격에 안전한 방식. 기업용 WPA3-Enterprise는 192bit 암호화 알고리즘 지원.

가상머신
VM(Virtual Machine)
가상화 기술에 의해 논리적 시스템 자원(CPU, 메모리, 디스크, 네트워크 등)을 이용, 독립적으로 OS 운영환경이 실행되는 시스템

가상자원
Virtual Resource,
하이퍼바이저 등 가상화 인프라를 통해 생성·제공되는 가상 머신, 가상 스토리지, 가상 소프트웨어(배포 이미지 등), 가상 네트워크 등 가상화된 자산의 총칭.

감사증적
Audit Trail
시스템의 모니터링 및 감사를 위해 입력된 데이터의 변환 과정, 출력과정 등을 기록하여 추적하는 방법

검증필 암호모듈
국가정보원이 실시하는 암호모듈 검증제도(KCMVP)를 통해 안전성이 확인된 암호 모듈. VPN, 보안USB, 디스크 암호화 등 중요자료 전송·저장 제품에 탑재 필수.

공개서버
인터넷 등 외부 네트워크에서 접근 가능한 웹서버, 앱 배포 서버 등. DMZ 영역에 설치하고 침입차단시스템 등으로 보호 필요.

공급망
Supply Chain
클라우드서비스 제공에 필요한 인프라·소프트웨어·보안 서비스 등을 공급하는 업체 및 관계자들의 연결 네트워크. 하드웨어·소프트웨어 공급사, 운영위탁사 등 포함.

관리자
Administrator
클라우드 시스템에 대해 일반 사용자보다 높은 권한(root, administrator 등)을 부여받아 시스템 설정, 계정 관리, 보안 정책 변경 등을 수행하는 자. 시스템 관리자, 정보보호 관리자, DB 관리자 등으로 세분화됨.

국가기관등
(클라우드컴퓨팅법) 국가기관, 지방자치단체 및 「전자정부법」 제2조제3호에 따른 공공기관(「공공기관의 운영에 관한 법률」에 따른 공공기관, 「지방공기업법」에 따른 지방공사·지방공단 등)

다중요소 인증 MFA(Multi-Factor Authentication)
두 가지 이상의 인증요소(지식 기반, 소유 기반, 생체 기반 등)를 이용하여 식별자의 신원을 검증

등급제 「클라우드서비스 보안인증에 관한 고시(등급제)」에 따른 상·중·하등급이 있으며 현재 하등급 IaaS(64개 항목)와 하등급 SaaS(30개 항목)만 시행

멀티테넌시 Multi-Tenancy
하나의 클라우드 인프라·소프트웨어 인스턴스를 다수의 이용자(테넌트)가 공유하는 아키텍처. 각 테넌트는 논리적으로 격리되어 데이터·설정·접근권한이 상호 침범되지 않아야 함.

비상 대응 계획 Emergency Response Plan, 비상 대응 계획
사고 발생 직후 인명과 자산을 보호하기 위한 즉각적인 초기 행동 지침

사용자 User
(정보통신망법) 이용자에게 정보통신서비스를 제공하기 위해 정보시스템을 운영하는 자
클라우드서비스 제공자(CSP)의 임직원으로, 클라우드 시스템을 운영·개발·관리하는 내부 인력. 이용자(서비스를 구매하는 기관·기업·개인)와 구분됨.

소프트웨어 보안약점 Software Security Weakness
SQL 삽입, 입력값 미검증 등 소프트웨어 개발 시 발생할 수 있는 잠재적 결함. 알려진 보안취약점(CVE)과 구별되며, 시큐어코딩을 통해 사전 제거 대상.

시큐어코딩 Secure Coding
소프트웨어 개발 단계에서 발생할 수 있는 소스 코드의 보안 취약점을 예방하기 위하여 안전하게 작성하는 기법

이용자 User
(정보통신망법) 정보통신서비스 제공자가 제공하는 정보통신서비스를 이용하는 자

이용자 정보 (클라우드컴퓨팅법) 클라우드서비스 이용자가 클라우드서비스를 이용하여 클라우드서비스를 제공하는 자의 정보통신자원에 저장하는 정보로서 이용자가 소유 또는 관리하는 정보

접근기록 Access Record
클라우드 시스템에 접근한 사용자·이용자 식별정보, 접근 일시, 접근 IP, 수행 업무 등을 기록한 데이터. 서비스 통제·관리 및 보안사고 발생 시 책임추적성 확보에 활용.

접속기록 Access Log
(개인정보의 안전성 확보조치 기준) 개인정보처리시스템에 접속하는 자가 개인정보처리시스템에 접속하여 수행한 업무내역에 대하여 식별자, 접속일시, 접속지 정보, 처리한 정보주체 정보, 수행업무 등을 전자적으로 기록한 것. "접속"이란 개인정보처리시스템과 연결되어 데이터 송신 또는 수신이 가능한 상태

책임추적성 Accountability
시스템이나 서비스에서 발생한 행위를 특정 사용자나 프로세스에 귀속시킬 수 있는 성질. 개인별 계정 사용, 로그 기록, 감사 활동을 통해 확보.

클라우드시스템 클라우드서비스 제공을 위해 구성된 서버, 네트워크 장비, 정보보호시스템, 소프트웨어, 응용프로그램, 데이터베이스, 가상자원 운영 소프트웨어(하이퍼바이저 등), 가상자원, 지원서비스 등의 총칭.

클라우드컴퓨팅 Cloud Computing
(클라우드컴퓨팅법) 집적·공유된 정보통신기기, 정보통신설비, 소프트웨어 등 정보통신자원을 이용자의 요구나 수요 변화에 따라 정보통신망을 통하여 신축적으로 이용할 수 있도록 하는 정보처리체계

클라우드서비스 Cloud Computing Service
(클라우드컴퓨팅법) 클라우드컴퓨팅을 활용하여 상용으로 타인에게 정보통신자원을 제공하는 서비스, ① 서버·저장장치·네트워크 제공(IaaS), ② 소프트웨어 제공(SaaS), ③ 개발·배포·운영 환경 제공(PaaS), ④ 이를 복합 제공하는 서비스로 구분



클라우드서비스 보안인증기준 해설서

Cloud Service Security Certification Standards Manual

제2장

클라우드컴퓨팅서비스 보안인증기준 설명



Ⅰ. 관리적 보호조치

Ⅱ. 물리적 보호조치

Ⅲ. 기술적 보호조치

Ⅳ. 국가기관등이 이용하는
클라우드컴퓨팅서비스 보호조치

Ⅰ 관리적 보호조치

1. 정보보호 정책 및 조직

1.1 정보보호 정책

항목	1.1.1 정보보호 정책 수립		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○	○	
인증기준	정보보호 정책을 문서화하고, 정보보호 최고책임자의 승인 후 정책에 영향을 받는 모든 임직원 및 외부 업무 관련자에게 제공하여야 한다.							
점검항목	공통	1) 클라우드 정보보호 정책을 수립하고, 정책 시행을 위한 관련 지침, 절차, 매뉴얼 등을 문서화하고 있는가?						
	공통	2) 클라우드 정보보호 정책은 정보보호 최고책임자로부터 제·개정 시 승인을 받고 있는가?						
	공통	3) 클라우드 정보보호 정책에 영향을 받는 모든 임직원 및 외부 업무 관련자에게 정책의 내용을 이해하기 쉬운 형태로 최신본으로 전달하고 있는가?						
점검목적	정보보호 정책이 공식적으로 승인된 최신 상태로 유지되고, 관련 이해관계자에게 적시에 전달되어 정책 요구사항을 일관되게 인지·이행하도록 보장한다.							
참고	• ISMS-P 1.1.5 정책 수립 • ISO/IEC 27017 5.1 정보보안 정책							

점검항목 해설

점검항목 1)

■ 클라우드서비스 제공자(CSP)는 클라우드서비스 운영에 필요한 모든 정보보호 활동의 근거가 될 수 있는 정보보호 정책과 이를 시행하기 위한 세부적인 방법, 절차, 주기 등을 포함한 시행문서[1](지침/절차/매뉴얼 등)를 수립하여 문서화하여야 한다.

- 정책서와 시행문서에 포함된 내용은 일관성 및 연계성이 있어야 하며, 클라우드컴퓨팅 보안인증기준 및 관련 근거의 요건 충족 필요

1) 시행문서란 명칭에 관계 없이 정보보호 정책서에 귀속되는 지침 또는 절차 또는 매뉴얼 등을 모두 포함한다.

- 시행문서는 정보보호 정책에서 수립한 규정을 실제 수행하기 위한 지침서이므로, 정보보호 관련 담당자 등이 해당 지침서를 기반으로 정보보호 활동을 수행할 수 있도록 상세하게 작성

- 해당 문서에는 다음과 같은 사항을 고려하여 작성 필요

  • 목적·적용 범위·용어 정의를 명시하여 정책의 방향을 명확히 설명

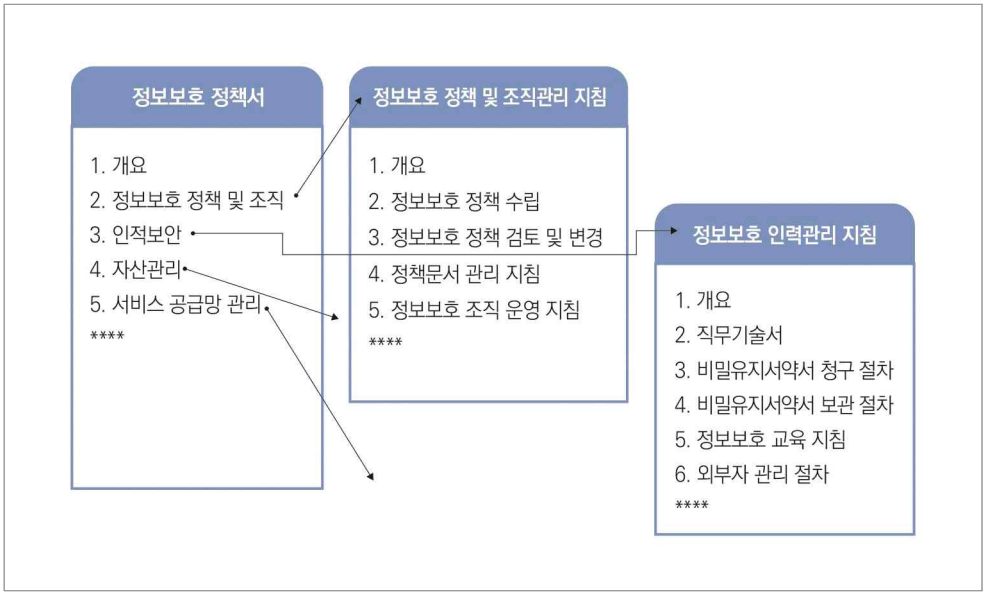
  • 정책 및 시행문서는 조직의 정보보호 목표, 위험평가 결과 등을 반영

  • 문서화된 정보로 관리되어야 하며, 버전·승인자·소유자·시행일· 검토일을 명확히 기록

  • 클라우드 특성을 고려하여 공유책임 모델(SRM: Shared Responsibility Model), 데이터 위치 및 테넌트 분리 기준 등을 반영

  • 외부 서비스 제공자 및 공급망 연동 시 보안 요구사항 정의 등

※ 정보보호 정책서 및 시행문서 구성 예시



점검항목 2)

■ 정보보호 정책서 및 시행문서는 정보보호 최고책임자로부터 제·개정 시 승인을 받아야 한다.

- 정보보호 정책서 및 시행문서에 대한 승인은 조직 내 전결규정 등에 따라 공식적으로 수행되어야 하며, 내부결재 등의 방법으로 승인을 받거나 또는 정보보호 최고책임자가 정보보호 정책문서에 직접 서명 또는 직인하는 방법도 가능

※ 정보보호 정책 승인 증거자료 예시

문 서 명 : 개발 및 도입 절차서 작성일자 : 2025-08-16
문서번호 : KISA-OP-M-DEVELOPMENT 페이지수 : 1/1

본 절차서는 클라우드서비스를 제공하기 위한 운영문서로서 검토 및 승인되었다.

구분	직위	성명	일자	서명
승인	정보보호 최고책임자	홍길동	2025. 08. 16	
검토	정보보호 담당자	김강산	2025. 08. 12	

점검항목 3)

■ 정보보호 정책서 및 시행문서는 최신으로 유지되고, 클라우드 정보보호 정책에 영향을 받는 모든 임직원 및 외부 업무 관련자가 쉽게 접근하여 활용할 수 있도록 하여야 한다.

- 정책서 및 시행문서는 제·개정사항이 발생하면 즉시 공표하고 최신본을 유지
- 임직원 및 관련된 외부자가 용이하게 참고할 수 있는 형태(사내게시판, 책자, 교육자료, 매뉴얼 등)로 제공

증거자료

- 정보보호 정책서
- 정보보호 시행문서
- 정보보호 최고책임자의 승인을 확인할 수 있는 내부 결재문서 또는 서명본
- 정책 및 지침의 배포 증적(공지사항 게시판 이용 등)

부적합 사례

- **사례 1 :** 정보보호 정책 및 지침서 개정 시 정보보호위원회, 경영진 등 권한있는 관련자의 검토 없이 임의로 개정된 경우
- **사례 2 :** 정보보호 정책 및 지침서가 최근에 개정되었으나, 해당 사항이 관련 부서 및 임직원에게 공유·전달되지 않아 일부 부서에서는 구버전의 지침서를 기준으로 업무를 수행하고 있는 경우
- **사례 3 :** 정보보호 및 개인정보보호 정책 및 지침서를 보안부서에서만 관리하고 있고 운영자 등 관련 임직원이 열람할 수 있도록 게시판, 문서 등의 방법으로 제공하지 않는 경우
- **사례 4 :** 정보보호 지침서가 작성되었으나, 정보보호 정책서에서 규정된 내용과 상충하는 내용이 포함되어 있는 등 정책서와 지침서 간의 연계성 및 일관성이 미흡한 경우

항목	1.1.2. 정보보호 정책 검토 및 변경		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○		
인증기준	정보보호 정책의 타당성 및 효과를 연 1회 이상 검토하고, 관련 근거 변경 및 내·외부 보안사고 발생 등의 중대한 사유가 발생할 경우에는 추가로 검토하고 변경하여야 한다.							
점검항목	공통	1) 클라우드컴퓨팅서비스 제공자는 클라우드 정보보호 정책 및 정책 시행문서에 대한 타당성 검토를 최소 연 1회 이상 수행하고 있는가?						
	공통	2) 중요한 변경 발생시 클라우드 정보보호정책 및 정책시행 문서의 변경 여부를 검토하여 필요 시 변경을 하고 있는가?						
	IaaS	3) 클라우드서비스 이용자에게 변경된 보안정책, 주요 보안 이슈 등을 공유하는가?						
점검목적	조직의 변화와 법·규제·위협 환경에 따라 정보보호 정책의 적합성과 효과성을 유지하기 위해 정기적 검토 및 개선을 보장한다.							
참고	• ISMS-P 2.1.1 정책의 유지관리 • ISO/IEC 27017 5.36 정보보안 정책, 규칙 및 표준 준수							

점검항목 해설

점검항목 1)

■ 정보보호 정책 및 시행문서에 대하여 최소 연 1회 이상 타당성 검토를 수행하고, 타당성 검토에 대한 이력을 다음의 사항을 포함하여 회의록, 보고서 등에 기록하고 보관하여야 한다.

- 검토 시기
- 검토 부서 및 검토자
- 검토 대상 및 검토 방법
- 검토 결과
- 정보보호 정책 및 시행문서의 제·개정이 필요한 경우 후속조치에 관한 사항 등

■ 정보보호 정책 및 시행문서에 대한 타당성 검토 시 클라우드서비스의 환경 변화 등에 따라 다음의 사항을 고려하여야 한다.

- 정보보호 및 개인정보보호 관련 법적 요구사항(클라우드컴퓨팅법, 정보통신망법, 개인정보 보호법 등)
- 클라우드컴퓨팅 보안인증기준
- 서비스 이용자의 요구사항이 반영된 계약서, SLA에 포함된 정보보호 요구사항
- 새로운 위협 또는 취약점의 발견
- 조직 사업 환경의 변화 또는 정보보호 환경의 중대한 변화

■ 정보보호 정책 및 시행문서 검토 시에는 정보보호 실무조직 인원과 이해관계자가 함께 참여하여 검토하여야 한다.

- 정보보호 최고책임자 및 개인정보 보호책임자, 정보보호 및 개인정보보호 관련 조직, IT 부서, 클라우드서비스 개발·운영 부서 등 이해관계자 식별 및 협의
- 정보보호 및 개인정보보호 관련 정책 및 시행문서 변경으로 인한 업무 영향도, 법적 준거성 등 고려

점검항목 2)

■ 정기적인 검토 이외에 다음과 같은 상황이 발생한 경우 추가적인 검토를 수행하여야 한다.

- 중대한 보안사고 발생
- 정보보호 및 개인정보보호, 클라우드컴퓨팅 관련 근거 제·개정
- 새로운 위협 또는 취약점 발견
- 서비스 이용자 등 이해관계자의 보안요구사항 변화
- 클라우드서비스 또는 정보시스템의 주요 변경(아키텍처, 구성, 접근제어 등)

※ 관련 근거(법령 및 고시)는 수시로 개정될 수 있으므로, 관련 근거 개정여부를 지속적으로 모니터링 할 필요가 있음

■ 정기적인 검토 또는 관련 근거 변경, 내·외부 보안사고 발생, 보안점검 및 내부감사 결과 반영 등에 따라 정보보호 정책 및 시행문서의 변경이 필요한 경우 이를 반영하여 개정하여야 한다.

점검항목 3)

■ 이용자에게 영향을 미칠 수 있는 정보보호 정책의 변경 및 주요 보안 이슈 발생 시 이용자에게 공지하여야 한다.

- 공지해야 할 사항 : 정보보호 정책의 변경사항, 주요 보안 이슈 등
- 공지 방법 : 클라우드 관리콘솔의 알림창, 게시판 등

증거자료

- 정보보호 정책서
- 정보보호 시행문서
- 정보보호정책 검토회의록
- 정보보호정책 제·개정 이력
- 정책 변경 및 주요 보안이슈 등에 대한 이용자 공지 내역

부적합 사례

- **사례 1 :** 법령·고시에 중대한 변경사항이 발생하였으나, 이러한 변경이 정보보호 정책 및 시행문서에 미치는 영향을 검토하지 않았거나 변경사항을 반영하여 개정하지 않은 경우
- **사례 2 :** 정보보호 정책 및 시행문서에 대해 연 1회 타당성 검토를 수행하였으나, 이에 대한 검토 증적을 남기지 않아 타당성 검토 수행 여부 및 검토 결과가 확인되지 않는 경우
- **사례 3 :** 클라우드서비스 운영과 관련하여 이용자에게 중대한 영향을 미칠 수 있는 보안이슈가 발생하였으나, 이를 이용자에게 공지하지 않은 경우
- **사례 4 :** 클라우드 아키텍처, 네트워크, 접근제어 등 주요 시스템 변경이 있었음에도 정책·절차가 이를 반영하지 않아 실제 운영과 문서가 불일치한 경우

항목	1.1.3 정보보호 정책문서 관리	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○		
인증기준	정보보호 정책 및 정책 시행문서의 이력관리 절차를 수립하고 시행하며, 최신본으로 유지하여야 한다.						
점검항목	공통	1) 클라우드 정보보호 정책 및 정책 시행문서의 승인, 제정, 개정, 배포, 보존, 폐기 등의 이력을 확인할 수 있도록 문서 관리절차를 수립·이행하고 이전 문서의 오남용 방지를 위한 별도 보관, 폐기 기준에 따라 관리하고 있는가?					
	공통	2) 클라우드 정보보호 정책 및 정책 시행문서는 최신본으로 관리하고 있는가?					
점검목적	정보보호 정책 및 관련 문서가 최신 상태로 식별·통제되어 요구사항이 일관되게 적용되고 변경 사항의 추적 가능성을 확보한다.						
참고	• ISMS-P 2.1.1 정책의 유지관리 • ISO/IEC 27017 5.37 문서화된 운영 절차						

점검항목 해설

점검항목 1)

■ 클라우드 정보보호 정책 및 정책 시행문서의 승인, 제정, 개정, 배포, 폐기 시 이력(일자, 내용, 작성자 등)을 확인할 수 있고 이전 문서의 오남용 방지를 위한 별도 보관, 폐기 기준을 포함한 문서 관리절차를 수립하고 적용하여야 한다.

- 다음의 예제와 같이 제·개정되는 문서에 개정 이력을 확인·관리할 수 있도록 정책 및 시행문서 내에 개정 이력을 포함하여 작성하거나, 별도의 관리대장으로 작성할 수 있음

문서 제·개정 이력				
번호	날짜	쪽	내용	담당자
1	2022-01-12	-	최초 작성	홍길동
2	2022-11-06	2	정보보호 최고책임자 변경	장길산
3	2024-07-01	10	정보통신망법 개정사항 반영 이용자 고지방법 변경	장길산
4	2025-12-18	8	패스워드 관리정책 변경	장길산

- 이전 버전의 문서는 오남용 방지를 위해 별도 보관·폐기 기준에 따라 관리해야 함

점검항목 2)

■ 클라우드 정보보호 정책 및 시행문서는 최신본으로 유지하여야 하며, 관련자가 최신본의 문서에

쉽게 접근하여 활용할 수 있도록 하여야 한다.

- 해당 정책 및 시행문서의 최신본 여부를 쉽게 확인할 수 있도록 정책 및 시행문서의 표지 등에 해당 문서의 버전, 시행일 등을 표기

■ 클라우드서비스 보안인증기준의 이행여부 확인이 가능하도록 운영기록(증적)을 보관·관리하여야 한다.

- 보안 업무 및 활동 과정에서 생성된 각종 양식, 대장, 로그, 결재문서 등 운영기록의 보관방법, 보호대책, 유지기간, 접근통제 등 관리절차 마련

증거자료

- 정보보호 정책서 및 시행문서의 이력 관리 내역
- 정보보호 정책서 및 시행문서 최신본 배포 증적

부적합 사례

- **사례 1 :** 정보보호 정책이 개정되었으나, 정책 시행 기준일이 명시되어 있지 않으며, 관련 정책의 작성일, 작성자 및 승인자 등이 누락되어 있는 경우
- **사례 2 :** 정보보호 정책 및 시행문서가 최근에 개정되었으나, 사내 게시판에는 구버전의 정책 및 시행문서가 공개되어 있는 경우
- **사례 3 :** 폐기 또는 별도 보관되어야 할 구버전 문서가 일반 직원에게 그대로 접근 가능하여, 최신 운영 기준과 혼선이 발생할 수 있는 경우
- **사례 4 :** ISMS, 클라우드 보안인증 등 담당자가 상이하여 각자 자신의 버전을 관리하고 있는 경우

1.2 정보보호 조직

항목	1.2.1 조직 구성	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○
인증기준	정보보호 활동을 계획, 실행, 검토하는 정보보호 전담조직을 구성하고 정보보호 최고책임자를 임명하여야 한다.						
점검항목	공통	1) 클라우드컴퓨팅서비스 제공자는 안전한 서비스 제공을 위해 별도의 실무조직 구성과 정보보호 최고책임자를 임명하고 있는가?					
	IaaS	2) 정보보호 전문성을 고려하여 실무조직 구성원을 임명하고 있는가?					
점검목적	정보보호 활동이 조직 내에서 명확한 책임과 역할 체계를 기반으로 계획·이행·모니터링되어 지속적 개선이 가능하도록 보장한다.						
참고	• 정보통신망법 제45조의3(정보보호 최고책임자의 지정 등) • ISMS-P 1.1.3 조직 구성						

점검항목 해설

점검항목 1)

■ 최고경영자는 조직 내에서 정보보호 관리 활동을 효과적으로 추진하기 위하여 이를 총괄·관리할 수 있는 정보보호 최고책임자(CISO)를 인사발령 등의 공식적인 지정절차를 거쳐 지정하여야 한다.

- 정보보호 최고책임자는 정보보호와 관련된 예산, 인력 등 자원을 할당할 수 있는 임원급으로 지정
- 정보보호 최고책임자는 인사발령 등을 통하여 공식적으로 임명하고, 이를 과학기술정보통신부장관에게 신고
- 정보보호 최고책임자는 정보통신망법에 따른 자격요건을 충족하여야 하며, 정보보호 최고책임자 겸직 제한 요건에 해당될 경우 법에서 허용하는 정보보호 관련 업무 외 다른 업무의 겸직 금지

※ 정보보호 최고책임자 지정 및 신고, 신고 예외 등 상세한 사항은 정보통신망법 제45조의3 및 동법 시행령 제36조의7, 제36조의8을 참고

- 정보보호 최고책임자 지정 시 조직의 정보보호 요구 수준, 클라우드서비스 운영 특성 및 책임공유모델(SRM)을 고려하여 역할과 책임을 명확히 정의
- 클라우드서비스 제공자가 개인정보처리자에 해당될 경우 개인정보 보호책임자를 법적 요건에 따른 자격요건을 충족하는 자로 지정(개인정보 보호법 제31조 및 동법 시행령 제32조 참고)

■ 최고경영자는 조직의 규모 및 클라우드서비스의 중요도에 따라 필요인력, 예산 등을 분석하여 정보보호 실무조직을 구성하여야 한다.

- 조직의 규모에 따라 정보보호 조직은 전담 또는 겸임조직으로 구성할 수 있으며 겸임조직으로 구성하더라도 정보보호 조직에 대한 공식적인 선언 또는 지정이 필요함
- 정보보호 관련 담당자(실무 담당자)가 해당 업무를 충실히 수행할 수 있도록 제반 사항을 지원

점검항목 2)

■ 정보보호를 위한 실무조직을 구성하는 경우 구성원의 전문적 지식 보유 여부, 실무경력, 직무 관련 교육 이수 이력 등을 고려하여 전문성이 확보된 인력으로 구성하여야 한다.

- 전문성에 대한 기준은 내부 지침, 직무기술서 등을 통해 정의하고, 해당 기준에 따른 조건을 검토하여 인력 구성
- 클라우드서비스 운영과 관련된 업무를 수행하는 인력은 클라우드 환경의 책임공유모델(SRM)에 대한 이해를 기반으로 정보보호 역량 필요

증거자료

- 정보보호 조직 구성도
- 정보보호 최고책임자 임명장 또는 승인문서
- 정보보호 직무기술서

부적합 사례

- **사례 1 :** 정보통신망법에 따른 정보보호 최고책임자 신고 의무 대상자임에도 불구하고 정보보호 최고책임자를 과학기술정보통신부장관에게 신고하지 않은 경우
- **사례 2 :** 정보보호와 관련된 실질적인 권한 및 지위를 보유하고 있지 않은 인원을 정보보호 최고책임자로 지정하고 있어, 정보보호에 관한 업무를 총괄하여 책임질 수 있다고 보기 어려운 경우
- **사례 3 :** 정보보호 정책 및 직무기술서에 정보보호 관련 담당자의 자격요건을 명시하고 있으나, 해당 요건을 충족하지 못한 인원이 정보보호 관련 담당자로 지정되어 있는 경우

항목	1.2.2 역할 및 책임 부여		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○	○	○		
인증기준	정보자산과 보안에 관련된 모든 임직원 및 외부 업무 관련자의 정보보호 역할과 책임을 명확하게 정의하여야 한다. 또한, 서비스 이용자의 정보보호 역할과 책임도 서비스 수준 협약 등을 통해 명확하게 정의하여야 한다.							
점검항목	공통	1) 정보보호 최고책임자와 정보보호 관련 담당자의 역할 및 책임을 정의하고 있는가?						
	공통	2) 클라우드컴퓨팅서비스 수준 협약(SLA) 또는 계약서에 이용자의 정보보호 역할과 책임이 반영되어 있는가?						
	IaaS	3) 정보보호 최고책임자와 정보보호 관련 담당자의 활동을 평가할 수 있는 체계를 수립하고 있는가?						
점검목적	정보보호와 관련된 모든 이해관계자의 역할과 책임을 명확히 하여, 요구사항의 일관된 이행과 책임성을 확보한다.							
참고	• 정보통신망법 제45조의3(정보보호 최고책임자의 지정 등) • ISMS-P 1.1.2 최고책임자의 지정 • ISO/IEC 27017 CLD.5.38 클라우드 컴퓨팅 환경에서의 공동 역할 및 책임, CLD.5.39 클라우드서비스 파트너의 역할 및 책임에 관한 협약							

점검항목 해설

점검항목 1)

■ 정보보호 정책서 또는 시행문서(정보보호 조직 구성지침 등)에서 규정하고 있는 정보보호 최고책임자 등 정보자산 및 정보보호와 관련된 모든 임직원의 역할 및 책임을 직무기술서 등을 활용하여 구체적으로 정의하여야 한다.

- 정보보호 최고책임자는 법적 요구사항을 반영하여 역할 및 책임 정의

※ 정보통신망법에서 규정된 정보보호 최고책임자의 총괄 업무

1. 정보보호 계획의 수립·시행 및 개선
2. 정보보호 실태와 관행의 정기적인 감사 및 개선
3. 정보보호 위험의 식별 평가 및 정보보호 대책 마련
4. 정보보호 교육과 모의 훈련 계획의 수립 및 시행
5. 정보통신망법 또는 관계 법령에 따라 정보보호를 위하여 필요한 조치의 이행

※ 개인정보 보호법에 따른 개인정보 보호책임자의 업무 등 겸직 가능

- 정보보호 최고책임자는 정보보호 정책 승인 및 주요 보안 의사결정을 수행할 권한을 보유하고 정보보호

목표 달성을 위한 자원을 할당

- 정보보호 최고책임자는 정보보안 사고 발생 시 대응 체계를 총괄, 관련 부서 및 외부 관계기관 간의 협조를 지휘, 위험평가 결과에 따라 보안 통제 수준을 조정하거나 개선 조치를 결정

■ 정보보호 관련 담당자로 외부 인원이 포함되는 경우 외부 인원의 역할 및 책임도 구체적으로 정의하여야 한다.

점검항목 2)

■ 클라우드서비스 수준 협약(SLA) 또는 계약서에 이용자에게 부과되는 정보보호 역할과 책임을 명시하여야 한다.

- 이용자에게 부과되는 정보보호 역할과 책임은 이용자가 이해할 수 있도록 상세하고 명확하게 기술

※ 이용자에게 부과되는 역할 및 책임 예시

제공자의 의무	이용자의 의무
제○○조 (제공자의 의무) ① 제공자는 본 약관이 정하는 바에 따라 지속적이고 안정적인 서비스를 제공하는데 최선을 다합니다. ② 제공자는 항상 이용자의 개인정보를 포함한 이용자 정보에 대하여 관리적, 기술적 안전조치를 강구하여 정보보안에 최선을 다합니다. ③ 제공자는 공정하고 건전한 운영을 통하여 전자상거래 질서유지에 최선을 다하고 지속적인 연구개발을 통하여 양질의 서비스를 제공함으로써 고객만족을 극대화하여 인터넷 사업 발전에 기여합니다. ④ 제공자는 이용자로부터 제기되는 불편사항 및 문제에 대해 정당하다고 판단될 경우 우선적으로 그 문제를 즉시 처리합니다. 단, 신속한 처리가 곤란할 경우, 이용자에게 그 사유와 처리일정을 즉시 통보합니다. ⑤ 제공자는 소비자 보호단체 및 이용자의 소비자 보호업무의 추진에 필요한 자료 등의 요구에 적극 협력합니다.	제○○조 (이용자의 의무) ① 아이디와 비밀번호에 관한 모든 관리의 책임은 이용자에게 있습니다. ② 이용자는 아이디와 비밀번호를 제 3 자가 알 수 있도록 해서는 안 됩니다. ③ 이용자는 다음 행위를 하여서는 안됩니다. 1. 신청 또는 변경 시 허위내용의 등록 2. 타인의 정보도용 3. 제공자가 게시한 정보의 변경 4. 제공자가 정한 정보 이외의 정보(컴퓨터 프로그램 등) 등의 송신 또는 게시 5. 제공자와 기타 제3자의 저작권 등 지적재산권에 대한 침해 6. 제공자 및 기타 제3자의 명예를 손상시키거나 업무를 방해하는 행위 7. 외설 또는 폭력적인 메시지, 화상, 음성, 기타 공서양속에 반하는 정보를 서비스에 공개 또는 게시하는 행위 8. 기타 불법적이거나 부당한 행위

점검항목 3)

■ 정보보호 최고책임자 및 정보보호 관련 담당자의 역할과 책임을 평가할 수 있는 지표를 개발하여 주기적으로 평가할 수 있는 체계를 수립하여야 한다.

- 평가 주기는 내부적으로 결정(연도별 또는 반기별 또는 분기별 등)
- 평가체계는 투명한 평가가 이루어질 수 있도록 가급적 정량화

- 조직의 운영환경 등을 고려하여 직무기술서에 정의된 역할의 수행 여부를 판단할 수 있는 지표 산정 등

증거자료

- 정보보호 조직 구성도
- 정보보호 직무기술서
- 클라우드서비스 수준 협약(SLA)
- 클라우드서비스 이용 계약서
- 정보보호 활동 평가 지표

부적합 사례

- **사례 1 :** 정보보호 정책 및 직무기술서에 정보보호 최고책임자 및 관련 담당자의 역할과 책임을 정의하고 있으나, 실제 운영현황과 일치하지 않는 경우
- **사례 2 :** 정보보호 최고책임자가 지정되어 있으나, 관련 근거에서 요구하는 역할 및 책임이 내부 지침이나 직무기술서 등에 구체적으로 명시되어 있지 않은 경우
- **사례 3 :** 정보보호 관련 담당자의 활동을 주기적으로 평가할 수 있는 목표, 기준, 지표 등의 체계가 마련되어 있지 않은 경우
- **사례 4 :** 클라우드서비스 이용계약서 및 SLA에 이용자의 정보보호 관련 역할 및 의무가 구체적으로 명시되어 있지 않은 경우

2. 인적보안

2.1 내부인력 보안

항목	2.1.1 고용계약	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○		
인증기준	고용 계약서에 정보보호 정책 및 관련 법률을 준수하도록 하는 조항 또는 조건을 포함시키고, 새로 채용하거나 합류한 근무 인력이 클라우드컴퓨팅서비스의 설비, 자원, 자산에 접근이 허용되기 이전에 서명을 받아야 한다.						
점검항목	공통	1) 고용 계약서에 정보보호 정책 및 관련 법률을 준수하도록 하는 조항 또는 조건이 포함되어 있는가?					
	공통	2) 새로 채용하거나 합류한 근무 인력이 고용 계약서에 서명 후 클라우드컴퓨팅서비스의 설비, 자원, 자산에 접근이 이루어지고 있는가?					
점검목적	직원들에게 정보보안 책임을 명확히 전달하고, 보안 위반 시 조치 근거를 마련하며, 조직의 중요 정보 자산을 보호하는 데 필요한 기본 조건을 설정한다.						
참고	• ISMS-P 2.2.3 보안 서약 • ISO/IEC 27017 6.2 고용 조건,						

점검항목 해설

점검항목 1)

■ 고용 계약서에 정보보호 정책 및 관련 법률을 준수하도록 하는 조항 또는 조건을 포함하여야 한다.

- 고용 계약서 내에 정보보호 정책 및 법률 준수에 대한 상세 내용을 포함하기 어려운 경우 별도 정보보호 서약서 등을 추가 작성 가능

※ 고용 계약서 내 보안의무 관련 조항 예시

> **제9조**(보안의무)
> "노동자"는 "사용자"의 업무 수행상 얻은 기밀에 대해서 계약기간 중은 물론 계약 종료 후에라도 일절 누설하여서는 안 되며 상기 사항의 위반으로 인한 민 · 형사상의 책임을 진다.

점검항목 2)

■ 신규 고용인력 및 합류한 근무 인력이 클라우드서비스의 설비, 자원, 자산에 접근이 허용되기 전에 고용 계약서가 작성 또는 갱신되어 있어야 한다.

- 정보보호 관련 요건이 포함된 고용 계약서 또는 별도 정보보호 서약서를 작성하기 전에는 클라우드서비스의 설비, 자원 자산에 대한 접근 제한

증거자료

- 고용 계약서
- 정보보호 서약서 또는 비밀유지 서약서

부적합 사례

- **사례 1 :** 클라우드서비스의 설비, 자원, 자산에 접근이 가능한 인력과 고용 계약서가 작성되었으나, 고용 계약서 내에 정보보호 정책 및 관련 법률의 준수, 비밀유지 의무 등의 내용이 포함되어 있지 않은 경우
- **사례 2 :** 최근 고용된 인력들 중 한 명이 회사가 수립한 정보보호 서약 절차에 따라 5월 10일에 그 서약을 완료했으나, 그 서약일 이전인 4월 20일에 클라우드 운영 시스템에 접속한 경우
- **사례 3 :** 3월 1일부로 클라우드서비스 업무 부서로 발령된 인력이 4월 10일이 되었으나 아직 고용계약서를 작성하거나 갱신하지 않은 경우

항목	2.1.2 주요 직무자 지정 및 감독		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○	○	○	○	○
인증기준	클라우드컴퓨팅서비스의 시스템 운영 및 개발, 정보보호 등에 관련된 임직원의 경우 주요 직무자로 지정하여 관리하고, 직무 지정 범위는 최소화하여야 한다.							
점검항목	공통	1) 클라우드컴퓨팅서비스를 제공하기 위한 중요 정보자산(정보, 시스템 등)을 취급하는 직무를 정의하고 해당 직무를 수행하는 주요 직무자를 지정하고 있는가?						
	IaaS	2) 중요정보를 취급하는 주요 직무자는 최소한으로 지정하고 주기적으로 주요 직무자 현황을 관리하고 있는가?						
	SaaS	3) 주요직무자는 최소의 인원으로 지정되고 있는가?						
점검목적	최소한의 사용자가 승인된 범위의 소프트웨어 구성 요소 및 서비스에 대하여 접근할 수 있음을 보장한다.							
참고	• ISMS-P 2.2.1 주요 직무자 지정 및 관리 • ISO/IEC 27017 5.2 정보보안 역할 및 책임							

점검항목 해설

점검항목 1)

■ 클라우드서비스를 제공하기 위한 중요 정보자산(정보, 시스템 등)을 취급하는 직무를 내부 지침 등을 통해 명확히 정의하여야 한다.

※ 주요 직무 기준 예시

- 정보보호 최고책임자
- 중요정보(개인정보, 인사정보, 영업비밀, 산업기밀, 재무정보 등) 취급자
- 주요 정보시스템(서버, 가상화 시스템, DB, 응용 프로그램 등) 운영 및 개발자
- 사용자 및 이용자 클라우드 포탈 담당자
- (개인) 정보보호 업무 기획 및 정보보호 책임자/관리자/담당자(정보보호 관련 정책·지침 관리, 침해사고 대응, 보안관제, 정보보호시스템 운영 업무 등)
- 네트워크 관리자
- 암호키 관리자 등

■ 주요 직무 기준에 해당하는 업무를 수행하는 임직원을 주요 직무자로 지정하여야 한다.

- 주요 직무를 정의 및 식별할 수 있도록 관리 (예: 직무 기술서)
- 지정된 주요 직무자를 식별할 수 있도록 관리 (예: 주요 직무자 목록)
- 주요 직무자 현황을 파악하여 주요 직무자로 공식 지정

- 개인정보를 취급하는 인원에 대해서는 개인정보취급자로 지정

※ 주요 직무자 목록 예시

No	부서/팀	성명	직무	개인정보 취급	주요시스템 접근권한	비고
1	개발팀	홍길동	DBA	○	○	
2	인프라팀	이순신	정보보호 업무	X	○	
3	개발팀	장길산	형상관리 업무	X	○	소스코드 관리
4	운영1팀	계백	개인정보처리업무	○	○	
5	운영2팀	강감찬	암호키 관리업무	X	○	

점검항목 2)

■ 주요 직무자의 경우 업무 범위 및 목적에 벗어나는 정보처리 권한을 부여하지 않도록 관련 직무자를 최소한으로 지정하여야 한다.

- 주요 직무자 권한 신청 및 부여에 대한 승인 절차 마련
- 업무상 반드시 필요한 경우에 한하여 주요 직무자로 지정
- 외부인력은 가급적 주요 직무자 지정에서 제외하고 불가피한 경우 관리 방안을 수립하여 적용
- 주요 직무자 대한 관리 및 통제방안 수립·이행(교육, 모니터링 등)

■ 주요 직무자의 현황을 주기적으로 관리하여 직무자 별 업무 성격에 따라 적정한 권한이 부여되었는지 여부를 검토하여야 한다.

- 주기적으로 주요 직무자 지정 현황 및 적정성을 검토
- 불필요하게 주요 직무자로 지정된 경우 주요 직무에 해당하는 권한을 회수하여 주요 직무자를 최소화
- 적정성 검토 결과를 반영하여 주요 직무자 목록 현행화

■ 참고로 인증기준‘10.2.1 사용자 등록 및 권한 부여’에서는 클라우드컴퓨팅시스템 각각에 대해 사용자 등록 시 직무별, 역할별 접근권한 분류체계를 수립하고 업무상 필요한 최소한의 권한 부여를 요구하고 있다.

- 이에 비해, 인증기준 ‘2.1.2 주요 직무자 지정 및 감독’에서는 중요 정보자산(정보, 시스템, 시설 등)을 취급하는 모든 직무를 식별하고 주요 직무자에 대해 최소화 지정 및 주기적인 현황 검토를 수행하는 등 전체적으로 통합 관리하는 측면을 요구

■ 조직도, 자산관리대장, 직무기술서, 시스템 등록된 사용자 현황, 업무분장표 등을 통해 인증범위 내 주요 직무자 식별 및 주요 직무자의 최소한 지정, 주기적 검토 여부, 각 증적들간의 상호 정합성 등을 판단할 수 있다.

점검항목 3)

■ 주요 직무자의 경우 업무 범위 및 목적에 벗어나는 정보처리 권한을 부여하지 않도록 관련 직무자를 최소한으로 지정하여야 한다.

- 주요 직무자 권한 신청 및 부여에 대한 승인 절차 마련
- 업무상 반드시 필요한 경우에 한하여 주요 직무자로 지정
- 외부인력은 가급적 주요 직무자 지정에서 제외하고 불가피한 경우 관리 방안을 수립하여 적용
- 주요 직무자 대한 관리 및 통제방안 수립·이행(교육, 모니터링 등)

증거자료

- 주요 직무 기준
- 직무 기술서
- 주요 직무자 목록
- 개인정보취급자 목록

부적합 사례

- **사례 1 :** 주요 직무자 목록(개인정보취급자 명단, 비밀정보관리자 명단 등)을 작성하고 있으나, 정보보호 시스템 관리자가 주요 직무자 목록에서 누락된 경우
- **사례 2 :** 업무 변경 등에 따라 주요 직무에 해당하는 권한이 회수된 인원까지 주요 직무자로 지정되어 있거나, 최근에 신규로 주요 직무에 해당하는 권한을 부여받은 임직원이 주요 직무자로 지정되지 않는 등 주요 직무자 목록이 현행화되지 않은 경우
- **사례 3 :** 부서 단위로 주요 직무에 해당하는 권한을 부여함에 따라 업무상 불필요한 인원까지 과도하게 주요 직무자로 지정된 경우

항목	2.1.3 직무 분리		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○		
인증기준	권한 오남용 등 내부 임직원의 고의적인 행위로 발생할 수 있는 잠재적인 위협을 줄이기 위하여 직무 분리 기준을 수립하고 적용하여야 한다.							
점검항목	공통	1) 직무의 권한 오남용을 예방하기 위하여 정보보호 관련 주요 직무 분리 기준을 수립하고 직무별 역할과 책임을 명확하게 기술하고 있는가?						
	공통	2) 직무 분리가 어려운 경우 직무자 간 상호 검토, 상위관리자 정기 모니터링 및 변경사항 승인, 책임추적성 확보 방안 등의 보완통제를 마련하고 있는가?						
점검목적	의도적 또는 실수로 인한 오용, 사기, 오류의 위험을 줄이고, 어떤 개인도 시스템이나 데이터에 대한 과도한 통제권을 갖지 않도록 한다.							
참고	• ISMS-P 2.2.2 직무 분리 • ISO/IEC 27017 5.3 직무 분리							

점검항목 해설

점검항목 1)

■ 직무별 권한과 책임을 분산시켜 직무 간 상호견제를 할 수 있도록 직무 분리 기준을 수립하여야 한다.

- 특정 인원이 너무 많은 권한을 가지거나 서로 충돌할 수 있는 업무를 맡지 않도록 정보보호 정책 또는 지침 등에 직무 분리 기준을 명시

※ 직무 분리 기준 예시

- 개발과 운영 직무 분리
- 정보시스템(서버, DB, 네트워크 등)간 운영직무 분리
- 정보보호 관리와 정보시스템 운영직무 분리
- 정보보호 관리와 정보시스템 개발직무 분리
- 권한을 포함한 계정 신청과 승인 및 생성 직무 분리
- 변경 요청과 변경 승인 직무 분리 등

점검항목 2)

■ 조직 규모가 작거나 인적 자원 부족 등의 사유로 인해 불가피하게 직무 분리가 어려운 경우, 직무자 간의 상호 검토, 상위관리자의 주기적인 직무수행 모니터링 및 변경사항 검토·승인, 직무자의

책임추적성 확보 등의 보완통제를 마련하여야 한다.

- 직무자 간의 상호 검토, 상위관리자의 주기적인 직무수행 모니터링 및 변경사항 검토·승인 등을 통해 권한의 오·남용 등이 발생하지 않도록 관리
- 개인별 계정 사용, 로그기록 및 감사·모니터링을 통하여 직무자 행위에 대한 책임추적성 확보 등

증거자료

- 직무 분리 기준
- 직무기술서
- 주요 직무자 현황
- 직무 미분리 시 보완통제 현황

부적합 사례

- **사례 1 :** 조직 및 인원의 규모 상 담당자별 직무 분리가 충분히 가능한 조직임에도 업무 편의성만을 사유로 내부 지침으로 정한 직무 분리 기준을 준수하고 있지 않은 경우
- **사례 2 :** 직무 분리가 어려운 불가피한 사유로 인해 책임자의 승인을 받은 후 개발과 운영 직무를 병행하고 있으나, 직무자 간 상호 검토, 상위관리자의 주기적인 직무수행 모니터링 및 변경사항 검토·승인, 직무자의 책임추적성 확보 등의 보완통제 절차가 마련되어 있지 않은 경우

항목	2.1.4 비밀유지서약서		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○		
인증기준	정보보호와 개인정보보호 등을 위해 필요한 사항을 비밀유지서약서에 정의하고 주기적으로 갱신하여야 한다.							
점검항목	공통	1) 직원 채용, 직무 변경, 고용 해지 시 정보보호 책임이 명시된 정보보호서약서 및 비밀유지서약서를 받고 있는가?						
	공통	2) 임시직원 혹은 외주용역과 같은 외부인력에게 정보자산에 대한 접근권한을 부여할 경우, 정보보호에 대한 책임을 계약서에 명시하고 이에 대한 정보보호서약서를 받고 있는가?						
	공통	3) 정보보호서약서 및 비밀유지서약서는 법적 분쟁 발생 시 증거자료로 사용할 수 있도록 안전하게 보존하고 용이하게 찾아볼 수 있도록 관리하고 있는가?						
점검목적	조직의 중요한 정보가 무단으로 공개되는 것을 방지하고, 정보 유출 시 법적 조치를 취할 수 있는 근거를 확보한다.							
참고	• ISMS-P 2.2.3 보안 서약 • ISO/IEC 27017 6.6 비밀 또는 비공개 협약							

점검항목 해설

점검항목 1)

■ 신규로 채용된 인력은 조직의 중요정보 취급 및 관리 시 정보보호의 필요성과 책임에 대해 명시된 정보보호서약서에 서명하고 제출하여야 한다.

■ 정보보호서약서의 제출 의무에 대해 신규 인력 채용 절차 중 기본적인 사항으로 인식하고 관리부서를 지정하여 정보보호서약서를 관리하여야 한다.

- 정보보호 서약서 징구·관리 절차 수립 필요

■ 직무상 알게 된 조직의 중요정보의 누출 방지를 위하여 퇴직 절차 내에 비밀유지서약서를 징구하고 누출 발생 시 그에 따르는 법적 책임이 있음을 상기시켜야 한다.

■ 직무변경과 같이 인력의 고용조건에 변화가 발생한 경우, 이전에 습득한 비밀정보를 누출하지 않고 새로운 직무 수행과 관련하여 정보보호에 관한 책임을 준수하도록 정보보호서약서를 제출하여야 한다.

※ 보안(정보보호) 서약서 예시

보안(정보보호) 서약서

회사의 전 임직원 및 자회사, 협력회사, 임시직에 종사하는 사원들은 지켜야 할 보안사항을 숙지했음을 입증하는 서약서에 서명해야 합니다. 임직원들은 근무기간 뿐 아니라 근무기간 후(동 업종, 경쟁업체 2년 내 취업금지)에도 동일하게 적용됨을 인식하고 서명하기 전 숙독하여 주시기 바랍니다.

1. 나는 주식회사 ○○○○(이하 회사라 함)에 관한 정보와 회사가 비밀유지 대상으로 지정한 정보를 업무에 한해 이용한다..
2. 나는 회사로부터 제공받은 각종 서류, 사진, 자료, 전산장비 등 정보를 기록매체에 대해 주의 깊게 사용, 보관함으로서 무단변조, 복사, 훼손, 분실 등으로부터 안전하게 관리한다.
3. 나는 상대가 누구이건 간에 알 필요가 없는 자에게 회사 혹은 제3자 소유 정보를 누설하지 않는다.
4. 나는 허가받지 않은 정보나 시설에 접근하지 않는다.
5. 나는 나의 업무나 회사와 관련된 업무를 수행하는 경우에만 사내 데이터 처리시설을 사용할 것이며 정보자산의 외부 발신시 회사의 통제절차를 준수한다.
6. 나는 회사의 전산장비에 사적 정보나 회사가 아닌 타 기업 정보 및 회사와 관련되지 않은 데이터를 보관하지 않는다.
7. 나는 나에게 할당된 사원증, 사용자 ID 및 패스워드가 중요한 보안사항임을 인식하여 오직 나만이 사용할 것이며 타인에게 대여 또는 누설하지 않는다.
8. 나는 회사의 보안규정 및 정책을 준수한다.

나는 상기사항을 숙지하여 이를 성실히 준수할 것을 동의하며, 서약서의 보안사항을 위배하였을 경우 부정경쟁방지 및 영업비밀보호에 관한 법류 등 관련 법령에 의한 민, 형사상의 책임 이외에도 회사의 사규나 관련 규정에 따른 징계조치 등 어떠한 처벌도 감수할 것이며 회사에 끼친 손해에 대해 지체없이 변상 복구시킬 것을 서약합니다.

년 월 일

소 속 :
성 명 : (인)

(주)○○○○ 귀중

점검항목 2)

■ 임시직원 혹은 외주용역업체 직원과 같은 외부인력에게 정보자산에 대한 접근권한을 부여할 경우 정보보호 책임, 조직 내 정보보호 규정 준수 의무, 정보보호 의무에 미준수로 인한 사건·사고 발생 시 손해배상 책임 등의 내용을 정보보호서약서에 명시하고 서명을 받아야 한다.

- 임시직원, 외부인력 등에 대한 정보보호서약서 징구·관리 절차 수립 필요

- 인증평가 대상 내의 임직원 및 임시직원, 관계 협력사, 외주 용역업체 직원 등 관련자들에 대해서 정보보호서약서가 징구·관리되어야 함

※ 상황별 정보보호서약서 또는 비밀유지서약서 징구 예시

대상	상황
내부 인력	입사, 퇴사
	고용 조건의 변경 및 변경사항 발생
	전보 및 직무 변경
	프로젝트 및 TF 참여
외부 인력	사업 시작
	사업 종료

■ 계약서에 정보보호 책임을 명시하는 부분에 대해서는 '2.2.1. 외부인력 계약', '4.1.2. 공급망 계약'에서 계약서를 검토하고 명시한다.

점검항목 3)

■ 정보보호서약서 및 비밀유지서약서는 법적 분쟁 발생 시 법률적 책임에 대한 증거자료로 사용할 수 있기 때문에 필요 시 용이하게 찾아볼 수 있는 형태로 안전하게 보관하여야 한다.

■ 정보보호서약서 및 비밀유지서약서에 개인정보가 포함될 경우 비인가자에게 유·노출되지 않도록 물리적으로 안전한 장소에 보관하여야 한다.

증거자료

- 정보보호서약서 및 비밀유지서약서(임직원 및 외부인력)
- 외주 용역 계약서
- 정보보호서약서 징구 및 관리 절차(보관 방법 포함)

부적합 사례

- **사례 1 :** 임직원에 대해서는 정보보호서약서를 받고 있었으나, 클라우드서비스 관련 정보시스템에 접속이 가능한 외주 인력에 대해서는 정보보호서약서를 받지 않은 경우
- **사례 2 :** 제출된 정보보호서약서를 모아 놓은 문서철이 비인가자가 접근 가능한 상태로 사무실 책상에 방치되어 있는 등 관리가 미흡한 경우
- **사례 3 :** 개인정보취급자에 대하여 정보보호서약서를 받고 있으나, 정보보호서약서 내에 비밀유지에 대한 내용만 있고 개인정보 보호법 준수 등 개인정보보호에 관한 책임 및 의무에 관한 사항이 포함되어 있지 않은 경우

항목	2.1.5 퇴직 및 직무변경		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○					
인증기준	임직원의 퇴직 또는 직무 변경에 관한 책임을 명시적으로 정의하고 수행하여야 한다. 또한 이에 대한 접근권한도 제거하여야 한다.							
점검항목	공통	1) 부서 및 직무변경, 휴직, 퇴직 등으로 인한 인사변경 내용이 인사부서, 정보보호부서, 정보시스템 운영부서 간에 공유되고 있는가?						
	공통	2) 조직 내 인력(정규직 임직원, 임시직원, 외주용역업체 직원 등)의 직무변경 혹은 퇴직 시 정보자산 반납, 접근권한 조정·회수, 결과 확인 등 수립된 절차에 따라 지체 없이 이행하고 있는가?						
점검목적	직원의 퇴사 또는 부서 이동, 외부 인력의 계약이 끝날 때 접근 권한 및 회사의 자산이 제대로 회수되도록 보장한다.							
참고	• ISMS-P 2.1.5 퇴직 및 직무변경 관리 • ISO/IEC 27017 6.5 고용 종료 또는 직무 변경 후의 책임							

점검항목 해설

점검항목 1)

■ 부서 및 직무변경, 휴직, 퇴직 등 인사변경 발생 시 정보자산 반납, 접근권한의 변경·회수 조치가 신속하게 이루어질 수 있도록 인사부서는 변경내용을 정보보호부서, 정보 시스템 운영부서 등에 공유하여야 한다.

- 관련 조직 및 시스템 간에 인사 변경 내용이 신속하게 공유될 수 있도록 절차 수립·이행

※ 인사 변경 내용에 대한 신속한 공유 절차 예시

- 인사시스템과 정보처리· 정보보호시스템을 연동하여 실시간 또는 일단위로 계정정보 동기화
- 통합 계정 등록·관리시스템에 협력업체 인원을 포함하여 개별 시스템과 계정 동기화
- 퇴직 프로세스에 퇴직자 정보를 관련 부서에 공유하는 절차 포함 등

■ 이용자에게 담당자 퇴직 및 직무변경 시 알려야 하는 정보(예: 고객 서비스 담당자 변경사항 등)를 신속히 통지하여야 한다.

점검항목 2)

■ 조직 내 인력(정규직 임직원, 임시직원, 외주용역업체 직원 등)의 직무변경 혹은 퇴직 발생 시

정보자산 반납, 접근권한의 조정·회수 등을 수립된 절차에 따라 시행하고 결과를 확인하여야 한다.

- 미사용 또는 불필요 계정(퇴직, 휴직, 파견, 장기 휴가, 프로젝트 종료 등) 권한 정지, 회수 처리 이행여부 점검
- 관련 기록을 보존하고 퇴직 절차 준수 여부에 대하여 정기적으로 검토 등

■ 직무변경자 혹은 퇴직자와 불가피하게 정보시스템 및 정보보호시스템 계정을 공유하여 사용한 경우 해당 계정의 비밀번호를 즉시 변경하여야 한다.

증거자료

- 퇴직 및 직무변경 절차서
- 퇴직자 보안점점 체크리스트 및 점검 내역
- 퇴직 시 자산 반납 관리대장
- 퇴직 시 정보보호서약서

부적합 사례

- **사례 1 :** 최근에 퇴직한 클라우드서비스 운영자에 대하여 자산반납, 권한 회수 등의 퇴직절차 이행 기록이 확인되지 않은 경우
- **사례 2 :** 임직원 퇴직 시 정보시스템의 접근권한은 지체 없이 회수되었지만, 출입통제 시스템 및 VPN 등 일부 정보보호시스템의 접근 권한이 회수되지 않은 경우
- **사례 3 :** 최근 클라우드 고객서비스 담당자의 퇴직으로 인해 담당자 연락처가 변경되었으나, 이를 이용자에게 신속하게 통지하지 않은 경우
- **사례 4 :** 임직원 퇴직 시에는 인사시스템 연동을 통해 관련 정보시스템의 계정 및 접근권한이 지체없이 회수되고 있었지만, 인사시스템에 등록되지 않은 임시직원, 외주용역업체 직원의 계정 및 접근권한은 지체없이 회수되고 있지 않은 경우

2.2 외부인력 보안

항목	2.2.1 외부인력 계약	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○			○		
인증기준	외부인력(외부유지보수직원, 외부용역자 포함)에 의한 정보자산 접근 등과 관련된 보안요구사항을 계약에 반영하여야 한다.						
점검항목	공통	1) 정보처리 업무를 외부인력에게 위탁하는 경우 보안요구사항을 정의하여 계약 시 반영하고 있는가?					
점검목적	외부 업체와 협력할 때 정보보안에 관한 명확한 요구사항을 정하고 이에 동의하도록 한다.						
참고	• ISMS-P 2.3.2 외부자 계약 시 보안 • ISO/IEC 27017 5.20 공급자와 협약 내 정보보안 명시, CLD.5.39 클라우드서비스 파트너의 역할 및 책임에 관한 협약						

점검항목 해설

점검항목 1)

■ 조직의 업무 중 서비스 제공을 위한 시스템 통합(System Integration, SI), 운영(System Maintenance, SM), 유지보수, 고객상담, 보안관제 등의 업무를 외부에 위탁하는 경우, 외부인력의 업무 형태에 따라 다음과 같은 보안요구사항을 정의하여 계약 시 반영하여야 한다.

- 정보보호 관련 법률 준수 (개인정보 처리 관련 등)
- 정보보호서약서 제출 (비밀유지, 정보보호 책임 등)
- 위탁 업무 수행 직원 대상 주기적인 정보보호 교육 수행
- 업무수행 관련 취득한 중요정보 유출 방지 대책
- 외부인력 내부 네트워크(업무망) 연결 시 인터넷접속 제한
- 외부인력 사무실 공간에 대한 물리적 보호조치 (장비 및 매체 반출입, 출입통제 등)
- 외부인력 PC 등 단말 보안 (백신 설치, 안전한 패스워드 설정 및 주기적 변경, 화면보호기 설정 등)
- 조직 중요정보 시스템 접근 허용 시 과도한 권한이 부여되지 않도록 접근권한 부여 및 해지 절차
- 주기적 보안점검 수행
- 무선 네트워크 구축 및 사용 제한 (필요 시 위험분석을 통한 대책 마련 후 책임자 승인)
- 재위탁 하도급 계약 시 본 계약 수준의 보안요구사항 정의
- 보안요구사항 위반 시 처벌, 손해배상 책임
- 보안사고발생에 따른 보고 의무 등

※ 외부자 업무형태에 따라 세부항목의 보안요구사항을 계약서에 반영하지 못하는 경우 타당한 사유 필요

증거자료

- 위탁 계약서
- 정보보호 협약서
- 위탁업제 선정 관련 RFP, 외주용역 평가표

부적합 사례

- **사례 1 :** 클라우드서비스 운영, 개발하는 외주용역업체에 대한 위탁계약서 내에 해당 위탁 업무와 관련된 정보보호 관련 요건이 포함되어 있지 않거나, 비밀유지에 관한 일반 사항만 포함되어 있는 경우
- **사례 2 :** 개인정보 처리업무를 위탁하는 외부업체와의 위탁계약서상에 개인정보 보호법 등 법령에서 요구하는 일부 항목(재위탁 제한, 관리·감독에 관한 사항 등)이 포함되어 있지 않은 경우

항목	2.2.2 외부인력 보안 이행 관리	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○			○		
인증기준	계약서에 명시한 보안요구사항 준수 여부를 주기적으로 점검하고 위반사항이나 침해사고 발생 시 적절한 조치를 수행하여야 한다.						
점검항목	공통	1) 외부인력이 계약서에 명시한 보안요구사항을 준수하고 있는지 주기적으로 점검 또는 감사를 수행하고 문제점 발견 시 개선할 수 있는 보호대책을 수립·이행하고 있는가?					
점검목적	• 내부 인력이 아닌 외부인력에 대한 보안 요구사항의 이행을 통해 클라우드 보안수준을 유지한다.						
참고	• ISMS-P 2.3.3 외부자 보안 이행 관리 • ISO/IEC 27017 5.22 공급자 서비스 모니터링, 검토 및 변경 관리						

점검항목 해설

점검항목 1)

■ 외부인력 관리 직무를 맡은 담당자는 외부인력과 계약 시 정의한 보안요구사항을 준수하고 있는지 주기적으로 점검 또는 감사를 수행하여야 한다.

- 외부자와 계약 시 정의한 보안 요구사항을 준수하고 있는지 주기적으로 점검 또는 감사 수행
- 외부자에 대한 점검 또는 감사는 업무 시작 전, 업무 진행되는 과정, 종료 시점에 진행하되 필요한 경우 수시로 진행
- 외부자의 정보보호 및 개인정보보호 역량, 자체 시스템 보유 여부, 처리하는 정보의 수량 및 민감도 등을 고려하여 점검 주기 및 방법 결정

■ 외부인력이 자체적으로 정보보호책임자를 지정하여 보안점검을 수행한 경우 그 결과를 주기적으로 보고받고 문제점 발생 시 유사한 문제가 재발하지 않도록 추가적인 보호대책을 수립하고 이행하여야 한다.

- 외부자의 보안요구사항의 지속적인 유지 여부 점검
- 점검결과 및 이행조치 현황 등을 기록 및 관리
- 정보시스템 및 업무에 변경사항 발생 시 보안요구사항 이행여부 점검
- 내부지침 개정 등에 따라 보안요구사항 변경 필요 시 계약서 등 변경

■ 외부자에 대한 점검 또는 감사 시 발견된 문제점에 대하여 개선계획을 수립·이행하여야 한다.

- 점검 및 감사 결과에 대하여 공유하고 발견된 문제점에 대한 개선방법 및 재발 방지대책을 수립하여 이행
- 개선 조치 완료 여부에 대한 이행점검 수행

증거자료

- 위탁 계약서
- 외부자 보안점검 체크리스트
- 외부자 보안점검 결과
- 외부자 교육 내역(결과, 명단, 교재 등)

부적합 사례

- **사례 1 :** 회사 내에 상주하여 IT 개발 및 운영 업무를 수행하는 외주업체에 대해서는 정기적으로 보안점검을 수행하고 있지 않은 경우
- **사례 2 :** 외부자가 자체적으로 보안점검을 수행한 후 그 결과를 통지하도록 하고 있으나, 외부자가 보안점검을 충실히 수행하고 있는지 여부를 확인하는 절차가 존재하지 않아 보안점검 결과의 신뢰성이 매우 떨어지는 경우
- **사례 3 :** 외부자 보안점검 시 다수의 문제점들이 발견되었으나, 이에 대한 개선조치 여부를 확인하지 않은 경우

항목	2.2.3 계약 만료 시 보안	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○			○		
인증기준	외부인력과의 계약 만료 시 자산 반납, 접근권한의 회수, 중요정보 파기, 업무 수행 시 알게 된 정보에 대한 비밀유지서약 등을 확인하여야 한다.						
점검항목	공통	1) 위탁사가 위탁 업무 수행과정에서 담당자 퇴직 등의 변경사항이 발생할 경우 위탁사 관련부서에 보고하고 공식적인 절차에 따라 정보자산 반납, 접근계정 삭제 등의 조치를 하고 있는가?					
	공통	2) 외부인력과의 계약 만료, 업무 종료 시 공식적인 절차에 따라 정보자산의 반납, 정보 시스템 접근계정 삭제, 중요정보 파기, 물리적 출입권한 삭제, 업무 수행 시 알게 된 정보의 비밀유지서약서 작성 등을 확인하고 있는가?					
점검목적	지속적인 모니터링과 평가를 통해 공급업체 관계에서 발생할 수 있는 보안 위험을 지속적으로 관리하고, 필요시 적절한 개선 조치 여부를 확인한다.						
참고	• ISMS-P 2.3.4 외부자 계약 변경 및 만료 시 보안 • ISO/IEC 27017 5.11 자산 반환						

점검항목 해설

점검항목 1)

■ 위탁 업무 수행과정에서 외부인력의 관련 업무 담당자가 변경될 수 있으며 변경사항에 대한 보고 및 적절한 보호조치가 지체없이 이루어질 수 있도록 관리하여야 한다.

- 담당조직이 외부자 계약만료, 업무 종료, 담당자 변경이 발생했음을 신속하게 인지할 수 있도록 정보 공유

점검항목 2)

■ 외부인력과의 계약 만료, 업무 종료에 따른 공식적인 정책 및 절차가 수립되어야 하며, 정책 및 절차를 통해 정보자산 반납 및 업무 중 사용하였던 모든 접근계정 삭제 및 비밀유지서약서 작성이 보장되어야 한다.

- 외부인력 등에 제공한 자료, 최종 산출물 등의 제반자료는 전량 회수하고 외부업체에 복사본 등의 별도 보관 금지

※ 외부인력과의 계약만료, 변경 또는 업무 종료 시 체크리스트 예시

번호	확인 사항	담당자 확인 결과
1	관련 부서에 변경 사항 통지 여부 (인력 변경 시)	
2	지급된 정보자산 반납 여부	
3	시스템 접근계정 삭제	
4	제공된 데이터 및 문서의 반납 또는 파기·삭제	
5	단말기 내 저장매체 데이터 삭제	
6	출입카드 반납	
7	서약서 작성	
8	담당부서 책임자 확인	

■ 외부자 계약 만료 시 위탁 업무와 관련하여 외부자가 중요정보 및 개인정보를 보유하고 있는지 확인하고 이를 회수·파기할 수 있도록 절차를 수립·이행하여야 한다.

- 위탁 업무 과정에서 취득한 개인정보 등 중요정보를 회수·파기하기 위하여 외부자의 사무실에 직접 방문하여 파기 여부를 확인하거나 또는 외부자가 자체적으로 파기한 후 파기 확약서 작성·제출
- 정보시스템과 담당자 PC뿐 아니라, 메일 송수신함 등 해당 정보가 저장되어 있는 모든 장치 및 매체에 대한 삭제 조치 필요
- 파기 시에는 해당 정보가 복구·재생되지 않도록 안전한 방법으로 파기

증거자료

- 외부자 계약 만료 시 점검항목 및 결과
- 정보 및 개인정보 파기 확약서
- 외부자 계약 만료 시 비밀유지서약서

부적합 사례

- **사례 1 :** 일부 정보시스템에서 계약 만료된 외부자의 계정 및 권한이 삭제되지 않고 존재하는 경우
- **사례 2 :** 위탁업체와 계약 종료 이후 보유하고 있는 위탁업무 과정에서 취급한 정보(개인정보 등)를 파기하였는지 여부를 확인·점검하지 않은 경우

2.3 정보보호 교육

항목	2.3.1 교육 프로그램 수립	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○					
인증기준	모든 임직원 및 외부 업무 관련자를 포함하여 연간 정보보호 교육 프로그램을 수립하여야 한다.						
점검항목	공통	1) 내부의 모든 직원과 외부인력(외주용역)을 위한 정보보호 교육, 훈련, 인식 프로그램이 수립되어 있는가?					
점검목적	직원들이 보안 위협을 인식하고 적절히 대응할 수 있는 능력을 갖추도록 하며, 조직 전체의 보안 문화를 강화하고 인적 오류로 인한 보안 사고 위험을 줄인다.						
참고	• ISMS-P 2.2.4 인식제고 및 교육 훈련 • ISO/IEC 27017 6.3 정보보호 인식, 교육 및 훈련						

점검항목 해설

점검항목 1)

■ 정보보호 교육의 시기, 기간, 대상, 내용, 방법 등의 내용이 포함된 연간 정보보호 교육 계획을 수립하고 정보보호 최고책임자 등의 승인을 받아야 한다.

- 교육 유형 : 정보보호 인식제고 교육, 주요직무자/개인정보취급자/수탁자 교육, 전문 교육 등
- 교육 방법 : 온라인 동영상 교육, 온라인 실시간 교육, 집합교육 등
- 교육 대상 : 임직원 및 관련 외부자 포함
- 교육 시기 : 반기 1회 또는 연 1회 등
- 교육 승인 : 교육 계획에 대한 검토 및 책임자 승인, 예산 배정 등

※ 외부자의 경우, 직접 교육을 수행하거나 또는 외부자가 자체적으로 교육을 수행한 후 그 결과를 제출하도록 하는 것도 가능함

■ 교육의 대상, 내용, 기간 등에 따라 효과적으로 교육을 수행할 수 있는 방법(예 : 집합교육, 온라인 교육, 전달 교육 등)을 선택하여야 한다.

- 교육 대상자의 수준 및 업무특성과 환경 고려

■ 정보보호 인식제고를 위하여 보안의 날 지정, 포스터 또는 뉴스레터 등을 제작할 수 있다.

■ 정보보호 및 클라우드서비스와 관련하여 직무별 전문성 제고를 위한 별도의 교육을 받을 수 있도록 하여야 한다.

- 정보보호 관련 위탁 교육, 외부 전문가 초빙, 외부 컨퍼런스, 세미나, 워크샵 참석, 온라인 강의 등

증거자료

- 연간 정보보호 교육계획서

부적합 사례

- **사례 1 :** 연간 정보보호 교육 계획에 교육 주기와 대상은 명시하고 있으나, 시행 일정, 내용 및 방법 등의 내용이 포함되어 있지 않은 경우
- **사례 2 :** 연간 정보보호 교육 계획을 수립하였으나, 전임직원에 대한 인식제고 교육 내용만 포함하고 있고 정보보호 최고책임자, 정보보호 담당자 등 직무별 전문성을 높이기 위한 교육 및 훈련 내용은 수립되어 있지 않은 경우
- **사례 3 :** 내부 임직원에 대한 교육계획은 수립되어 있으나, 클라우드서비스 운영과 관련된 외부인력에 대한 교육계획은 수립되어 있지 않은 경우

항목	2.3.2 교육 시행		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○	○	○	○	○
인증기준	모든 임직원 및 외부 업무 관련자를 대상으로 연 1회 이상 정보보호 교육을 시행하고 정보보호 정책 및 절차의 중대한 변경, 내·외부 보안사고 발생, 관련 근거 변경 등의 사유가 발생하면 추가 교육을 실시하여야 한다.							
점검항목	공통	1) 내부의 모든 직원과 외부인력(외주용역)을 대상으로 연 1회 이상 기본 정보보호 교육을 수행하고 있는가?						
	공통	2) 정보보호 정책 및 절차의 중대한 변경, 조직 내·외부 보안사고 발생, 정보보호 및 클라우드 관련 법률 변경 등이 발생 시 이에 대한 추가 교육을 수행하고 있는가?						
점검목적	직원들이 보안 위협을 인식하고 적절히 대응할 수 있는 능력을 갖추도록 하며, 조직 전체의 보안 문화를 강화하고 인적 오류로 인한 보안 사고 위험을 줄인다.							
참고	• ISMS-P 2.2.4 인식제고 및 교육훈련 • ISO/IEC 27017 6.3 정보보호 인식, 교육 및 훈련							

점검항목 해설

점검항목 1)

■ 연간 정보보호 교육계획에 따라 내부의 모든 직원 및 외부인력(외주용역)을 대상으로 연 1회 이상 정보보호 교육을 수행하여야 한다.

- 클라우드서비스를 운영하는 모든 정규직 임직원, 임시직원, 외부인력 등을 대상으로 연 1회 이상 기본 정보보호 교육 시행
- 자체적으로 교육을 수행하기 어려운 여건인 경우 외부의 전문교육기관을 통해 교육 이수 가능

■ 개인정보 보호책임자 및 개인정보취급자는 법적 요구사항에 따라 연 1회 이상 개인정보보호 교육을 별도로 이수하여야 한다.

- 기본 정보보호 교육에 개인정보보호 내용이 포함된 경우 별도 추가 교육 이수 불필요

※ 개인정보 포털(www.privacy.go.kr)의 교육 과정 및 교육자료 참고 가능

■ 인증범위 내의 모든 인원에 대해서 정보보호 교육을 실시하여야 하며, 출장이나 휴가 등으로 정보보호 교육에 참여하지 못한 인원에 대한 교육 방법을 마련하여 시행하여야 한다.

- 교육 수행 시 불참자 식별 및 관리 필요
- 불참자 대상 추가교육, 전파교육 등 교육방안 마련

점검항목 2)

■ 정보보호 정책 및 절차의 중대한 변경, 내·외부 보안사고 발생, 관련 근거 변경 등 다음과 같은 사유가 발생하면 추가적인 교육을 실시하여야 한다.

- 정보보호(개인정보 포함) 및 클라우드 관련 법률 변경
- 조직의 정보보호 관련 정책 및 절차 변경
- 조직 내·외부 보안사고 발생
- 업무환경의 중대한 변화 발생

※ 중요하지 않은 사안일 경우 게시판 공지, 이메일 안내 등으로 대체 가능

증거자료

- 연간 정보보호 교육계획서
- 교육 참석자 목록
- 교육 이수증
- 교육 결과보고서
- 교육 수행 관련 자료(교육 자료, 교육 사진 등)

부적합 사례

- **사례 1 :** 내부 임직원에 대해서는 정보보호 교육이 수행되었으나, 인증범위 내 정보자산 및 설비에 접근하는 외부인력(외주직원)에 대해서는 정보보호 교육이 수행되지 않은 경우
- **사례 2 :** 모든 임직원을 대상으로 정보보호 집합교육을 실시하면서 불참자가 일부 발생하였으나, 해당 불참자에 대한 교육방안을 마련하고 있지 않은 경우
- **사례 3 :** 개인정보취급자에 대한 교육을 전사 임직원 대상 정보보호 인식제고 교육으로 대체하였으나, 해당 정보보호 인식제고 교육 내용에 개인정보보호 관련 내용이 포함되어 있지 않은 경우

항목	2.3.3 평가 및 개선	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○					
인증기준	정보보호 교육 시행에 대한 기록을 남기고 결과를 평가하고 개선하여야 한다.						
점검항목	공통	1) 정보보호 교육, 훈련, 인식 프로그램의 수행 결과를 평가하고 있는가?					
	공통	2) 평가 결과를 분석하여 새로운 정보보호 요구사항을 도출하고 프로그램의 개선에 반영하고 있는가?					
점검목적	직원들이 보안 위협을 인식하고 적절히 대응할 수 있는 능력을 갖추도록 하며, 조직 전체의 보안 문화를 강화하고 인적 오류로 인한 보안 사고 위험을 줄인다.						
참고	• ISMS-P 2.2.4 인식제고 및 교육훈련 • ISO/IEC 27017 6.3 정보보안 인식, 교육 및 훈련						

점검항목 해설

점검항목 1)

■ 교육 시행 후, 교육 공지, 교육자료, 출석부 등과 같은 기록을 남기고 미리 마련된 평가기준에 따라 설문 또는 테스트 등을 통해 교육 내용의 적절성과 효과성을 평가하여야 한다.

- 직무 특성 및 수준을 고려하여 적절한 교육 내용, 방법, 주기 등에 반영
- 교육 미참여자 최소화를 위한 방안 개선
- 교육내용과 교육방법이 각 직무별 보안기준 준수역량 제고에 적합한지 확인 등

점검항목 2)

■ 교육평가 결과 내용에서 도출된 문제점에 대해 개선 대책을 마련하고 차기 교육 계획 수립 시 반영하여야 한다.

- 직무 관련 특화 교육 실시 등

증거자료

- 연간 정보보호 교육계획서(직무별 차별화된 교육 내용 포함)
- 교육 참석자 목록
- 교육 이수증

- 교육 결과보고서
- 교육 자료

부적합 사례

- **사례 1 :** 당해 연도 정보보호 및 개인정보보호 교육을 실시하였으나, 교육시행 및 평가에 관한 기록(교육 자료, 출석부, 평가 설문지, 결과보고서 등) 일부를 남기지 않고 있는 경우
- **사례 2 :** 교육 결과의 평가를 위해 정보보호 교육 수행 후 설문지를 받고 있으나, 소수의 인원만 설문지를 제출하여 평가 결과의 신뢰성이 매우 떨어지는 경우

3. 자산관리

3.1 자산 식별 및 분류

항목	3.1.1 자산 식별	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○	○	
인증기준	클라우드컴퓨팅서비스에 사용된 정보자산(정보 시스템, 정보보호시스템, 정보 등)에 대한 자산분류기준을 수립하고 식별된 자산의 목록을 작성하여 관리하여야 한다.						
점검항목	공통	1) 정보자산(정보 시스템, 소프트웨어 등)의 분류기준을 수립하고 클라우드컴퓨팅서비스를 제공하기 위한 모든 정보자산을 식별하고 있는가?					
	공통	2) 식별된 정보자산을 별도 목록으로 관리하고 있는가?					
	공통	3) 정기적으로 정보자산 현황을 조사하고 정보자산목록을 최신으로 유지하고 있는가?					
점검목적	클라우드서비스에 활용되는 정보자산을 체계적으로 식별·통제하여 자산 보호 조치의 일관성과 추적 가능성을 확보한다.						
참고	• ISMS-P 1.2.1 자산 식별, 1.3.3 운영현황 관리, 2.1.3 정보자산 관리 • ISO/IEC 27017 5.9 정보 및 관련 자산 목록						

점검항목 해설

점검항목 1)

■ 클라우드서비스 제공자는 서비스의 특성과 보안 영향도를 고려하여 정보자산 분류기준을 수립하고, 이에 따라 정보자산을 식별하여야 한다.

- 정보자산 분류기준은 정보자산의 유형(물리·논리·가상·소프트웨어), 중요도, 민감도 및 리스크 수준을 기반으로 정의하며, 가상자원(VM, PoD, Container 이미지 등), 클라우드 인프라, 관리성 서비스 자산을 반드시 포함
- 인증범위 내 모든 자산에 대하여 전수 조사를 실시하고 식별된 정보자산은 책임공유모델(SRM)에 따라 CSP와 이용자 간 관리책임을 구분
- 신규 도입, 구성 변경, 서비스 확장 또는 기술 구조 변화(Kubernetes, 컨테이너 기반 운영 등)를 반영하여 자산 현황 및 분류 기준을 주기적으로 재검토하고 최신 상태로 유지

※ 정보자산 분류 예시

분류	설명
서버	윈도우서버, 리눅스서버, 유닉스서버 등 클라이언트의 요구를 처리하는 시스템
네트워크 장비	라우터, 백본스위치, L4스위치, L3스위치, LB 등 서버와 클라이언트간 통신을 가능하게 하는 장비
정보보호시스템	침입차단시스템, 침입방지시스템, 웹방화벽 등 정보의 훼손, 변조, 유출 등을 방지하기 위하여 구축된 시스템
저장장치	데이터베이스, 스토리지, 백업저장매체, 보조저장매체 등 정보를 저장하는 장치
응용프로그램	운영체제, 웹서버프로그램, WAS프로그램, DBMS 등 특정 기능을 수행하기 위해 서버에 설치하는 소프트웨어
단말기	PC, 노트북, 태블릿 등 데이터를 입력하거나 표시하는 데 쓰이는 전자 하드웨어 기기
정보	고객정보, 주문내역 등 문서적 정보와 전자적 정보 모두를 포함
가상 인프라	하이퍼바이저, 클라우드 플랫폼 등 가상환경을 제공하기 위한 자산
가상자원	가상 머신(CSP 소유의 자산), 가상 스토리지, 가상 소프트웨어(예: 배포 이미지 등) 등 가상 인프라를 통해 가상화된 자산

점검항목 2)

■ 식별된 정보자산은 쉽게 확인할 수 있도록 목록화하여 관리하여야 한다.

- 정보자산 목록은 문서로 관리하거나 자산관리시스템을 활용하는 등 다양한 방법으로 관리 가능
- 정보자산 목록은 개발·테스트·운영 등 용도별로 구분하고, 재해복구 센터는 전환 시 책임자 등 주요 특성 정보를 포함

점검항목 3)

■ 신규 도입·변경·폐기되는 정보자산 현황을 확인할 수 있도록 정기적으로 정보자산 현황을 조사하여 정보자산 목록을 최신으로 유지하여야 한다.

- 클라우드서비스에 사용된 정보자산(시설, 장비, 소프트웨어 등)의 변경을 지속적으로 모니터링하여 허가받지 않은 변경을 탐지하고 최신 변경 이력을 유지
- 클라우드 컴퓨팅 서비스 운용에 필요한 물리 자산 목록을 유지하고 회수, 폐기 등의 자산 변화 상황을 반영

※ 인증평가를 위한 자산 식별 절차

- 클라우드서비스 제공자는 자체 문서 형식 또는 시스템을 이용하여 인증범위 내 전체 정보자산을 분류기준에 따라 식별, 목록화, 최신화 등 관리
- 클라우드서비스 제공자는 인증평가 전에 서비스 제공을 위해 필요한 모든 정보자산을 식별하여 정보자산관리대장을 작성하고, 인증평가팀은 정보자산관리대장을 이용하여 CCE, CVE, 소스코드진단,

모의해킹 등을 위한 자산을 최종 확정

- 확정된 정보자산에 대해서 CCE, CVE, 소프트웨어 보안약점 진단, 모의해킹 등 수행

증거자료

- 정보자산 분류 기준을 포함하고 있는 내부 규정(정보보호 정책서, 정보자산 관리지침 등)
- 정보자산 목록(정보자산관리대장)

부적합 사례

- **사례 1 :** 클라우드서비스와 관련한 정보자산을 식별하여 정보자산 목록으로 작성하였으나 주기적으로 정보자산 현황을 조사하지 않아 취약점 점검 과정에서 발견된 현재 정보자산 현황과 정보자산 목록이 일치하지 않음이 확인된 경우
- **사례 2 :** 내부 규정에 정보자산 식별 및 분류에 관한 기준을 마련하였으나, 정보자산 목록 내 정보자산 분류가 규정과 상이한 경우
- **사례 3 :** 운영부서에서 서버의 운영체제 및 응용프로그램 대한 업그레이드를 수행하였으나 이를 정보자산 관리부서에 통보하지 않아 정보자산 현황에 해당 서버의 운영체제 정보가 현행화되지 않았음이 확인된 경우
- **사례 4 :** 물리적인 정보자산에 대하여 식별을 완료하였으나 클라우드 환경 인프라인 하이퍼바이저, 도커(docker), 서비스용 컨테이너 골든 이미지 등을 정보자산으로 식별하지 않은 경우

항목	3.1.2 자산별 책임 할당	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○			○	○	
인증기준	식별된 자산마다 책임자 및 관리자를 지정하여 책임소재를 명확히 하여야 한다.						
점검항목	공통	1) 식별된 정보자산에 대한 책임자 및 관리자(또는 담당자)를 지정하고 있는가?					
점검목적	각 자산의 관리 책임을 명확히 하여 정보자산 보호 조치의 이행과 책임성을 확보한다.						
참고	• ISMS-P 2.1.3 정보자산 관리 • ISO/IEC 27017 5.9 정보 및 자산 목록						

점검항목 해설

점검항목 1)

■ 정보자산 관리(도입, 변경, 폐기, 반·출입 등)를 책임을 질 수 있는 책임자와 정보자산을 실제 관리·운영하는 관리자(또는 담당자)를 지정하여 책임소재를 명확하게 하여야 한다.

- 정보자산 별 책임자 및 관리자(또는 담당자)를 지정하고 정보자산 목록에 기재
- 자산별 책임자는 자산의 보호 수준 결정, 변경 승인, 보안 조치 이행 여부 확인 등 의사결정, 운영 담당자는 보안 통제 적용 및 기술적 관리 수행
- 퇴직, 전보 등 인사이동이 발생하거나 정보자산이 도입, 변경, 폐기되는 경우 정보자산 별 책임자 및 담당자 정보 검토 및 재지정하고 자산목록과 관련 시스템에 반영

증거자료

- 정보자산 분류 기준을 포함하고 있는 내부 규정(정보보호 정책서, 정보자산 관리지침 등)
- 정보자산 목록(책임자/관리자 지정 현황 포함)

부적합 사례

- **사례 1 :** 인사이동이 발생하여 정보자산의 관리책임자와 담당자가 변경되었으나, 이를 정보자산 목록에 반영하지 않은 경우
- **사례 2 :** 최근 신규로 도입된 서버 또는 가상자산을 정보자산 목록에 등록하였으나, 해당 자산의 관리책임자와 운영 담당자 정보자산 목록에 명시되지 않아 자산관리 책임이 불명확한 경우

항목	3.1.3 보안등급 및 취급		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	기밀성, 무결성, 가용성, 법적요구사항 등을 고려하여 자산의 보안등급을 부여하고, 보안등급별 취급 절차에 따라 관리하여야 한다.							
점검항목	공통	1) 기밀성, 무결성, 가용성, 법적요구사항 등을 고려하여 정보자산의 중요도를 평가하기 위한 기준을 수립하고 있는가?						
	공통	2) 정보자산별로 중요도를 평가하고 각 자산별 특성에 적합한 보안등급을 부여하고 보안등급을 쉽게 확인할 수 있도록 하고 있는가?						
	공통	3) 정보자산의 보안등급에 따른 취급절차(생성, 저장, 이용, 파기 등)를 정의하고 이행하고 있는가?						
점검목적	정보자산의 중요도에 기반한 적절한 보호조치를 적용하여 기밀성·무결성·가용성 및 법적 요구사항을 효과적으로 보장한다.							
참고	• ISO/IEC 27017 5.12 정보 분류, 5.13 정보 표시							

점검항목 해설

점검항목 1)

■ 정보자산의 유출, 장애 및 침해 발생 시 조직의 업무에 미치는 영향을 고려하여 식별된 정보자산의 중요도를 평가할 수 있는 기준을 수립하여야 한다.

■ 일반적으로 기밀성, 무결성, 가용성, 법적요구사항 등을 고려하여 중요도 평가기준을 마련할 수 있다. 이외에도 서비스 영향, 재무적 손실, 고객 상실, 대외 이미지 등도 추가적으로 고려할 수 있다.

- 정보자산의 중요도 평가 기준 수립
- 정보자산 중요도 평가 시 타 자산과의 연관성 고려

※ 정보자산 중요도를 평가하기 위한 주요 고려사항

- 기밀성 : 정보자산이 접근권한이 없는 자에게 노출되었을 때의 위험성을 파악
- 무결성 : 하드웨어 변경, 소프트웨어 변조, 데이터 값 수정 등 정보자산의 상태 또는 내용이 임의로 변경되었을 때의 위험성을 파악
- 가용성 : 정보자산이 필요 시 사용이 불가능하거나, 접근이 되지 않을 때 서비스에 미치는 영향을 파악
- 법적요구사항 : 해당 자산의 운영과 관련한 법규가 있는지 파악하고, 관련 근거를 준수하지 않았을 때의 위험성 파악

점검항목 2)

■ 정보자산 중요도 평가기준에 따라 정보자산별로 중요도를 평가하여야 한다. 또한 정보자산별 특성에 따라 보안등급을 부여하고 다음과 같이 임직원이 보안등급을 쉽게 식별할 수 있도록 하여야 한다.

- 중요도 평가 시기: 자산 최초 도입, 역할 및 용도 변경 등
- (전자)문서 : 기밀(비밀), 대외비, 비공개, 일반 등 등급화하여 표시
- 서버 등 하드웨어 자산 : 자산번호, 바코드, 태그 표시 등을 통한 보안등급 확인

※ IDC를 임대하여 클라우드서비스를 제공하는 IaaS의 경우 불필요하게 타인에게 보안등급 등이 노출되지 않도록 서버 등 정보자산에 보안등급을 부착하지 않고 자산번호, 바코드 등을 통해 내부자들만 보안등급을 인식할 수 있도록 조치하는 것이 바람직

점검항목 3)

■ 정보자산의 보안등급에 따라 취급절차(생성, 저장, 이용, 파기 등)를 정의하고 이에 따른 접근통제 등 적절한 보안통제를 이행하여야 한다.

※ 정보자산 보안등급에 따른 보안통제 예시

- 정보자산 분류 및 중요도 평가기준에 따른 보안등급 평가
- 자산 담당자 지정 및 담당자 외의 시스템 접근 제한 등 차별 적용
- 데이터 저장·처리·전송 시 인증 및 권한관리, 암호화, 접근통제, 개인정보 마스킹, 접근기록 생성·보관·검토 등 보안등급에 따라 차별된 보안통제 적용
- 정보자산 파기 시 저장매체 내의 중요 데이터를 복구 불가능하도록 삭제 등 차등 조치

증거자료

- 정보자산 중요도 평가 기준 및 취급절차가 포함된 내부 규정(정보보호정책서, 정보자산 관리지침)
- 정보자산 목록(정보자산 보안등급 포함)

부적합 사례

- **사례 1 :** 서버 접속용 전용 PC의 경우 타 PC에 비하여 높은 보안통제를 적용하고 있으나, 중요도 평가 시 일반 업무용 PC와 동일하게 평가하는 등 모든 인증범위 내 PC를 동일한 보안등급으로 평가한 경우
- **사례 2 :** 관련 절차에 정보자산의 보안 등급에 따른 차등적인 보안정책 적용을 규정하고 있으나 중요도가 높은 1등급 서버에 대하여 3등급 서버와 동일한 수준의 보안정책을 적용하고 있는 경우
- **사례 3 :** 클라우드 환경에서 컨테이너 및 이미지 기반 운영을 하고 있으나, 물리 서버 기준으로만 자산 중요도를 평가하여 PoD, Container, VM 등에 대한 보호 수준이 정책에 반영되지 않은 경우

3.2 자산 변경관리

항목	3.2.1 변경관리	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○		
인증기준	클라우드컴퓨팅서비스에 사용된 자산(시설, 장비, 소프트웨어 등)의 변경이 필요한 경우 보안 영향평가를 통해 변경사항을 관리하여야 한다. 또한 이용자에게 큰 영향을 주는 변경에 대해서는 사전에 공지를 하여야 한다.						
점검항목	공통	1) 클라우드 시스템 관련 자산(시설, 장비, 소프트웨어 등) 변경에 관한 절차를 수립·이행하고 있는가?					
	공통	2) 클라우드컴퓨팅서비스 관련 자산 변경 중 이용자에게 큰 영향을 주는 변경에 대해서는 사전에 공지하고 있는가?					
	IaaS	3) 클라우드 시스템 관련 자산 변경을 수행하기 전 성능 및 보안에 미치는 영향을 분석하고 있는가?					
점검목적	자산 변경 시 보안 영향 및 서비스 제공에 대한 위험을 통제하여, 안정성과 신뢰성을 유지하고 이용자에게 적절히 고지한다.						
참고	• ISMS-P 2.9.1 변경관리 • ISO/IEC 27017 8.32 변경 관리						

점검항목 해설

점검항목 1)

■ 클라우드서비스 제공을 위한 시설 및 정보자산의 변경이 필요한 경우 변경 요청, 책임자 검토·승인, 변경 확인, 변경이력 관리 등의 공식적인 절차를 수립하고 이행하여야 한다.

- 변경 필요에 따른 요청, 변경 전 영향분석, 승인, 이행, 변경결과 검토, 이력 기록 등의 내용을 포함한 내부 절차 마련

■ 정보자산의 변경의 범위에는 다음의 사항을 포함하여야 한다.

- 전산실 증설, 무정전 전원 장치(UPS) 교체 등 시설의 변경
- 시스템 CPU/메모리/저장장치 증설, 서버 이중화 등 정보시스템 도입·변경
- 네트워크 전용선 추가, VPN신규 구성 등 네트워크 구성 변경
- 운영체제 업그레이드, 상용 소프트웨어 설치, 운영 중인 응용프로그램 기능 개선, 소프트웨어 업데이트 등 소프트웨어의 변경
- 기타 클라우드서비스 제공과 관련한 변경 등

점검항목 2)

■ 클라우드서비스 관련 시설 및 정보자산 변경 시 이용자에게 큰 영향을 주는 변경에 대해서는 사전에 다음의 내용을 이용자에게 공지하여야 한다.

- 변경 내용(자산변경, 작업 등) 및 일시
- 서비스 종료 또는 중단, 성능 저하 등 변경으로 인한 이용자에게 미치는 영향
- 긴급연락처 등

점검항목 3)

■ 클라우드서비스 관련 시설 및 정보자산 변경이 필요한 경우 변경에 따른 보안, 성능, 업무 등에 미치는 영향을 분석하여 변경에 따른 영향을 최소화 할 수 있도록 변경을 이행하고 변경 실패에 따른 복구방안을 사전에 고려하여야 한다.

- 변경의 규모를 고려하여 영향 분석 대상 기준을 자체적으로 수립 가능
- 변경에 따른 잠재적 요인들이 시스템 안정성에 미치는 영향 분석

증거자료

- 자산 변경절차 및 영향분석에 관한 사항이 포함된 내부 규정(정보보호정책서, 정보자산 관리지침)
- 자산 변경에 따른 영향분석 보고서
- 자산 변경에 따른 변경계획서, 변경완료보고서
- 자산 변경에 따른 이용자 공지 사례

부적합 사례

- **사례 1 :** 자산 변경절차가 마련되어 있어 변경 전 영향분석 및 변경 실패 시 복구방안을 마련하여야 하나 담당자가 복구방안을 마련하지 않고 네트워크 장비 교체 작업을 수행하던 중 장애가 발생하여 서비스 복구가 지연된 경우
- **사례 2 :** 네트워크 장비 증설에 따른 클라우드서비스 일시 중단의 위험이 있었으나 이용자에게 이를 공지하지 않고 증설 작업을 진행한 경우
- **사례 3 :** 운영 담당자가 변경 승인 없이 서버 설정(방화벽 정책, 시스템 파라미터 등)을 직접 수정하여 일시적 서비스 오동작이 발생하였으나, 변경 이력 및 검토 기록이 없어 원인 파악이 지연된 경우

항목	3.2.2 변경 탐지 및 모니터링	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○			○		
인증기준	클라우드컴퓨팅서비스에 사용된 자산(시설, 장비, 소프트웨어 등)의 변경을 지속적으로 모니터링 하여 허가 받지 않은 변경을 탐지하고 최신의 변경 이력을 유지하여야 한다.						
점검항목	공통	1) 클라우드컴퓨팅서비스에 사용된 자산(시설, 장비, 소프트웨어 등)의 변경을 지속적으로 모니터링 하여 허가받지 않은 변경을 탐지하고 최신의 변경 이력을 유지하고 있는가?					
점검목적	자산 변경 사항을 식별·추적하여 무단 변경을 방지하고, 보안 및 서비스 안정성을 지속적으로 확보한다.						
참고	• ISMS-P 2.11.3 이상행위 분석 및 모니터링 • ISO/IEC 27017 8.16 모니터링 활동						

점검항목 해설

점검항목 1)

■ 클라우드서비스에 사용된 자산(시설, 장비, 소프트웨어 등)에 대해서 최신 변경이력을 유지하여야 한다.

- 변경 전 또는 변경 후 변경 사실을 정보자산 관리 책임자(또는 담당자)에 통보하는 절차 마련
- 정보자산 관리 책임자는 주기적으로 정보자산 변경 여부를 조사 수행

■ 중요시스템에 대해서는 보안 모니터링 도구 등을 사용하여 허가받지 않은 변경을 탐지하여야 한다.

- 반입된 기자재 현황, SW설치목록 등을 통해 미승인 변경 사례 점검
- 허가받지 않은 변경을 탐지할 경우 대응할 수 있는 절차 마련

증거자료

- 정보자산 목록
- 정보자산 변경 이력 사례(변경계획서, 변경완료보고서 등)
- 미승인 변경 탐지 방안

부적합 사례

- **사례 1 :** 클라우드서비스 관련 자산 변경 시 변경 수행 부서가 정보자산 관리 부서에게 이를 통보하는 절차가 없고 정보자산 관리부서가 자산 변경 여부를 정기적으로 점검하는 절차도 마련되어 있지 않은 경우
- **사례 2 :** 클라우드서비스 관련 서버를 증설하고 해당 부서가 이를 정보자산 담당부서에 통지하였으나, 이를 정보자산 목록에 반영하고 있지 않은 경우
- **사례 3 :** 내부 규정에 따라 정기적으로 자산 변경 여부를 점검하여야 하나 이를 수행하지 않아 클라우드서비스 관련 서버에 하이퍼바이저 프로그램이 신규 버전으로 업데이트 된 사실을 파악하지 못하고 있는 경우
- **사례 4 :** 운영자가 승인 없이 컨테이너 이미지 버전을 직접 교체하였으나 변경 탐지 방법 및 절차 등이 없어 식별·관리 할 수 없을 경우

항목	3.2.3 변경 후 작업 검증	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○			○		
인증기준	클라우드컴퓨팅서비스에 사용된 자산(시설, 장비, 소프트웨어 등)의 변경 후에는 보안성 및 호환성 등에 대한 작업 검증을 수행하여야 한다.						
점검항목	공통	1) 클라우드 시스템 관련 자산 변경 후 보안성, 호환성에 대한 작업검증을 수행하고 있는가?					
점검목적	변경 이후 자산의 보안성·호환성·성능이 저하되지 않도록 검증하여 서비스 안정성과 신뢰성을 확보한다.						
참고	• ISO/IEC 27017 8.32 변경 관리						

점검항목 해설

점검항목 1)

■ 클라우드서비스 관련 정보자산 변경 후 서비스 영향도, 정상 동작 여부확인 및 보안성, 호환성, 서비스 영향 등에 대한 작업 검증을 수행하여야 한다.

- 보안성 검토 : 정보자산 변경에 따른 보안정책 설정·변경 시 이상 유무 확인
- 호환성 검토 : 정보자산 변경에 따른 타 정보자산과의 상호 호환성 이상 유무 확인
- 서비스 영향 검토 : 정보자산 변경에 따른 서비스 성능 저하 여부 확인

증거자료

- 자산 변경에 따른 영향분석 보고서
- 자산 변경에 따른 변경계획서, 변경완료보고서

부적합 사례

- **사례 1 :** 클라우드서비스 관련 네트워크 구성을 변경하였으나, 서비스의 빠른 재개를 목적으로 충분한 호환성 검증 작업을 수행하지 않아 장애가 발생한 경우
- **사례 2 :** 내부 규정에 자산변경에 따른 보안성, 호환성 등의 작업 검증 수행에 관한 내용이 마련되어 있지 않고 자산 변경 시 변경작업 결과보고서를 작성하였으나 결과보고서에 보안성, 호환성 등의 작업 검증을 수행했다는 내용을 확인할 수 없는 경우
- **사례 3 :** 실제 운영 트래픽 환경에서의 특성 차이를 고려하지 않고, 개발·테스트 환경에서만 검증된 변경 사항을 운영환경에 적용하여, 서비스 중단의 위험이 발생할 가능성이 있는 경우

3.3 위험관리

항목	3.3.1 위험관리 계획 수립	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○			○		
인증기준	관리적, 기술적, 물리적, 법적 분야 등 정보보호 전 영역에 대한 위험 식별 및 평가가 가능하도록 위험관리 방법과 계획을 사전에 수립하여야 한다.						
점검항목	공통	1) 관리적, 물리적, 기술적, 법적 분야 등 다양한 측면에서 발생할 수 있는 위험을 식별하고 평가할 수 있는 방법을 정의하여 문서화하고 있는가?					
	공통	2) 매년 위험관리를 수행하기 위하여 전문 인력 구성, 기간, 대상, 방법, 예산 등을 구체화한 위험관리계획을 수립·이행하고 있는가?					
점검목적	정보보호 전 영역의 위험을 체계적으로 식별·평가하여 적절한 통제 및 개선 활동이 가능하도록 위험관리 체계를 확보한다.						
참고	• ISMS-P 1.2.3 위험 평가 • ISO/IEC 27017 5.7 위협 인텔리전스						

점검항목 해설

점검항목 1)

■ 관리적, 기술적, 물리적, 법적 분야 등 클라우드서비스 인증범위 전 영역에 대한 위험 식별 및 평가가 가능하도록 각 영역별 특성을 반영한 위험관리 방법과 수행 절차 등을 마련하고 지침으로 규정하여야 한다.

※ 클라우드서비스 위험관리 시 고려사항(예시)

- 위험평가를 수행할 정보자산의 식별 및 분류, 가치 측정, 서비스 흐름 및 구성요소 파악
- 가상환경(가상화·컨테이너·API·멀티테넌시 등)을 포함한 정보자산, 서비스에 대한 보안 위협과 취약성 식별
- 부정사용 또는 공격의 가능성 추정
- 위험 이벤트와 관련된 잠재적 손실 평가(예: 서비스 중단, 규제 위반, 데이터 침해, 고객 신뢰도 하락 등)
- 위험 처리 및 자산 보호를 위한 적절한 보안 대책과 통제 구현

점검항목 2)

■ 위험관리 방법 및 절차에 따라 매년 위험관리계획을 수립하고 이행하여야 하며, 위험관리계획에는 다음과 같은 내용을 포함하여야 한다.

- 위험관리 수행인력 : 위험관리 방법, 조직의 업무 및 시스템에 대한 전문성을 갖춘 인력과 관련 부서 실무책임자가 참여 (위험관리 전문가, 정보보호관리자, 클라우드서비스 운영자, 현업부서 실무 책임자 등), 필요시 외부 전문가를 활용하여 서비스 운영과 독립적인 검토 수행
- 위험평가 기간 : 자산의 규모 등을 고려하여 2주~1개월 등 적절하게 선정. 단, 기간을 길게 선정하는 경우 위험평가 기간 동안 자산의 변동 등이 있을 수 있으므로 이를 고려하여 선정
- 위험관리 대상 : 클라우드서비스를 제공하기 위한 정보자산을 누락 없이 포함

※ 클라우드서비스 제공을 위해 공동으로 이용하는 자산, 임직원 등이 이용하는 단말기에 공통으로 적용되는 보안통제 솔루션 등에 대해서 클라우드서비스 제공자가 별도 식별, 위험평가 등을 수행하고 있다면 클라우드 인증에서는 제외 가능

- 위험관리 방법 : 자산, 서비스, 기업의 특성을 고려하여 기업이 자유롭게 선택
- 위험관리 예산 : 외부 전문가를 통해 수행 시 컨설팅 비용 등 필요 예산을 확보

증거자료

- 위험식별 및 평가에 관한 내용을 포함하고 있는 내부 규정(위험관리지침)
- 위험관리(평가) 계획서

부적합 사례

- **사례 1 :** 매년 위험평가계획을 수립하여 위험관리를 수행하고 있으나, 위험관리에 대한 내부 규정이나 절차가 명확히 마련되어 있지 않은 경우
- **사례 2 :** 금년도 위험관리계획을 수립하였으나, 전년도 말에 신규로 추가된 클라우드서비스 관련 네트워크장비가 위험평가대상으로 식별되지 않아 누락되어 있는 경우
- **사례 3 :** 클라우드 환경 고유 위험요소(가상화, API 노출 등)를 고려하지 않고 기존 정보시스템 위험관리 방식만 적용하여 위험평가를 수행한 경우

항목	3.3.2 취약점 점검		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○	○	
인증기준	취약점 점검 정책에 따라 주기적으로 기술적 취약점(예 : 유·무선 네트워크, 운영체제 및 인프라, 응용프로그램 취약점 등)을 점검하고 보완하여야 한다.							
점검항목	공통	1) 클라우드컴퓨팅서비스 취약점 점검 절차를 수립하여 연 1회 이상 점검을 수행하고 있는가?						
	IaaS	2) 인터넷 및 클라우드서비스 관리 네트워크에서 침투테스트를 실시하고 있는가?						
	공통	3) 발견된 취약점에 대한 조치를 수행하고 그 결과를 책임자에게 보고하는가?						
점검목적	기술적 취약점을 주기적으로 식별·보완하여 시스템의 보안 수준을 지속적으로 유지·강화한다.							
참고	• ISMS-P 2.11.2 취약점 점검 및 조치 • ISO/IEC 27017 8.8 기술적 취약점 관리							

점검항목 해설

점검항목 1)

■ 다음과 같은 내용을 포함하는 클라우드서비스 취약점 점검 절차를 수립하여야 한다.

- 취약점 점검 대상 (예 : 서버, 네트워크장비, 정보보호시스템, 데이터베이스, 응용프로그램, 가상인프라. 가상자원 등)
- 신규 시스템 도입 및 중요 시스템 변경 등을 고려한 취약점 점검 주기
- 취약점 점검 담당자, 책임자 지정 및 결과 보고 체계
- 취약점 점검 절차 및 방법 등

※ 취약점 점검 유형 예시

종류	설명
CCE취약점	• 사용자에게 허용된 권한 이상의 동작을 허용하거나, 범위 이상의 정보 열람·변조·유출 등을 가능하게 하는 시스템 설정 상의 취약점 ※ 공개된 클라우드 취약점 점검 가이드 등을 활용하여 점검
CVE취약점	• 컴퓨터 하드웨어 또는 소프트웨어 결함이나 체계, 설계상의 취약점
소프트웨어 보안약점 진단	• IaaS, DaaS, SaaS 웹포털 및 기능(App) 등 소프트웨어 보안약점 진단(시큐어코딩) ※「행정기관 및 공공기관 정보시스템 구축·운영 지침」(행정안전부고시)에 따른 보안약점 진단기준을 적용

■ 다음과 같은 내용을 포함하여 취약점 점검을 실시하여야 한다.

- 라우터, 스위치 등 네트워크 장비 구성, 설정 취약점
- 서버 OS, WEB/WAS, DBMS, 어플리케이션 등에 대한 보안 설정 취약점 및 알려진 취약점
- 방화벽 등 정보보호시스템 취약점
- 웹 및 모바일 서비스(모바일 앱 등) 취약점
- 사용자 단말기(PC), 스마트 기기 취약점
- 가상 인프라 및 가상 자원 취약점 등
- 소스코드 보안약점 및 형상서버 등
- 인터페이스 및 API 취약점

■ 취약점 점검 시 이력관리가 될 수 있도록 '점검자', '점검일시', '점검대상', '점검방법', '점검내용 및 결과', '발견사항', '조치사항' 등이 포함된 보고서를 작성하여야 한다.

■ 클라우드서비스에 대한 취약점 점검을 주기적(연 1회 이상)으로 수행하여야 한다.

- 외부 전문업체 또는 전문가를 활용하여 취약성 점검을 수행하는 것도 가능

점검항목 2)

■ 인터넷 및 클라우드서비스 관리 네트워크에서 침투테스트를 실시하여야 한다.

- 대상 대상 : 클라우드서비스 관련 인프라 및 응용 프로그램
- 대상 시점 : 중요한 인프라 변경 시 또는 응용 프로그램 업데이트 시 등

■ 시스템 변경이 없더라도 최소 연 1회 이상 정기적으로 침투테스트를 실시하여야 한다.

■ 침투테스트 시 이력관리가 될 수 있도록 '점검자', '점검일시', '점검대상', '점검방법', '점검내용 및 결과', '발견사항', '조치사항' 등이 포함된 보고서를 작성하여야 한다.

점검항목 3)

■ 취약점 점검 결과 발견된 취약점에 대한 대응방안 및 조치결과를 문서화하여야 하며 조치결과 보고서를 작성하여 책임자에게 보고하여야 한다.

- 불가피하게 조치를 할 수 없는 취약점의 경우 그 사유를 명확하게 확인하고 책임자에게 보고
- 조치 불가능한 취약점에 대해 보고 후에도 대체 보안기능(기능사용 제한, 주기적인 모니터링 등)을 적용하여 해당 취약점으로 인한 위험관리 수행

증거자료

- 취약점 점검 계획서
- 취약점 점검 결과보고서
- 취약점 점검 조치 계획보고서
- 취약점 점검 조치 완료보고서(미조치 항목 사유 포함)

부적합 사례

- **사례 1 :** 클라우드서비스에 대하여 취약점 점검을 정기적으로 수행하고 있지 않은 경우
- **사례 2 :** 클라우드서비스에 대하여 취약점 점검을 수행하였으나 하이퍼바이저, 로드밸런서 등 가상인프라에 대한 취약점 점검을 누락한 경우
- **사례 3 :** 클라우드서비스에 대하여 취약점 점검을 수행하고 취약점을 발견하여 담당 부서에 조치를 통보하였으나 해당 취약점이 조치되었는지 여부를 확인하지 않은 경우
- **사례 4 :** 클라우드서비스에 대하여 취약점 점검을 수행하여 취약점을 발견하였으나 명확하지 않은 사유로 일부 취약점을 조치 불가 판정하고 조치 불가 사유를 책임자에게도 승인받지 않은 경우
- **사례 5 :** 운영환경에 대한 점검만 수행하고, CI/CD 파이프라인, 컨테이너 이미지 저장소, 개발 환경에 대한 취약점 점검이 수행되지 않은 경우

항목	3.3.3 위험분석 및 평가		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	위험관리 방법 및 계획에 따라 정보보호 전 영역에 대한 위험 식별 및 평가를 연 1회 이상 수행하고 그 결과에 따라 수용 가능한 위험수준을 설정하여 관리하여야 한다.							
점검항목	공통	1) 클라우드서비스 제공과 관련된 전 영역에 대한 위험분석 및 평가를 연 1회 이상 수행하고 있는가?						
	공통	2) 클라우드서비스에 악영향을 미친다고 판단될 시 수시로 위험평가를 수행하고 있는가?						
점검목적	정기적인 위험 식별·평가 및 위험수준 설정을 통해 정보보호 위험을 통제 가능한 수준으로 유지하고 지속적으로 관리한다.							
참고	• ISMS-P 1.2.3 위험 평가 • ISO/IEC 27017 5.7 위협 인텔리전스							

점검항목 해설

점검항목 1)

■ 클라우드서비스 제공과 관련된 전 영역을 대상으로 위험 식별과 평가를 연 1회 이상 정기적으로 수행하여야 하며 기 적용된 정보보호대책의 실효성 검토도 함께 이루어져야 한다.

■ 위험 식별 시 다음의 사항을 고려해야 한다.

- 클라우드 관리 및 운영 방식, 가상화 및 컨테이너 환경 특성
- 네트워크, 시스템, 플랫폼, 애플리케이션 등 구성 요소 변경
- 사용자 접근 및 권한 관리 구조
- 공급망 및 서비스 의존성(API 연동 등)
- 보안 위협 동향, 취약점 정보 및 공개된 공격사례
- 책임공유모델(SRM)에 따른 CSP/고객 영역별 역할 및 위험 분담

점검항목 2)

■ 클라우드서비스에 악영향을 미치는 취약점 발견되었거나 서비스를 구성하는 주요 정보자산이 변경된 경우 수시 위험평가를 수행하여야 한다.

- 서버, 네트워크 장비, 가상화 인프라, 컨테이너 등 핵심 시스템 변경 시
- 신규 취약점 공개(CVE, CWE, 보안공지 등) 또는 공급망 관련 보안 이슈 발생 시

- 운영 정책 또는 접근제어 방식의 변경 등 보안 영향이 있는 환경 변화 시
- 외부 서비스 연동(API, SaaS 등)에 대한 계약 변경 또는 SLA 영향 발생 시

증거자료

- 위험평가 계획서
- 위험평가 결과보고서

부적합 사례

- **사례 1 :** 클라우드서비스에 대하여 전년도에 위험평가를 실시하였으나 금년도에 변경된 정보자산이 없다는 이유로 위험평가를 실시하지 않은 경우
- **사례 2 :** 클라우드서비스를 구성하는 주요 기반시설이 변경되어 규정에 따라 수시 위험평가를 수행해야 함에도 불구하고 이에 따른 수시 위험평가를 실시하지 않은 경우
- **사례 3 :** 취약점 점검 및 보안 이벤트 증가 등 신규 위험 요인이 발생했음에도, 정기 평가 시점까지 기다려 수시 위험평가를 수행하지 않은 경우

항목	3.3.4 위험처리		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	법규 및 계약관련 요구사항과 위험수용 수준을 고려하여 위험평가 결과에 따라 통제할 수 있는 방법을 선택하여 처리하여야 한다.							
점검항목	공통	1) 위험평가의 결과에 따라 통제할 수 있는 방법을 선택하여 처리하여야 하며, 내외부의 환경 변화에 따른 클라우드서비스 위험을 지속적으로 모니터링을 할 수 있는 프로세스를 수립 및 이행하고 있는가?						
점검목적	위험평가 결과와 법적·계약적 요구사항을 반영하여 적절한 통제조치를 선택·이행함으로써 위험을 허용 가능한 수준으로 유지한다.							
참고	• ISMS-P 1.2.4 보호대책 선정, 1.3.1 보호대책 구현							

점검항목 해설

점검항목 1)

■ 모든 위험에 대하여 자원(인력, 예산 등), 내/외부 요구사항, 위험수준, 책임공유모델(SRM)을 고려하여 위험처리 방법을 정해야 한다.

- 위험 처리방법을 결정할 때에는 법적, 계약관련 요구사항을 함께 고려
- 위험을 완화하거나 수용하는 판단하는 기준인 허용 가능한 위험수준(DoA : Degree of Assurance)은 경영진 또는 정보보호책임자의 승인 하에 결정
- 위험을 완화하기 위한 계획은 중요도에 따라 우선순위 설정
- 또한, 계획은 정보보호책임자(CISO 등)의 승인받아 계획을 수행하는 직원에게 정확히 전달
- 서비스 제공자 책임 영역과 고객 책임 영역에 대한 위험처리 방안을 구분

※ 발견된 위험을 처리하는 방법(예시)

- 위험 완화(감소) : 위험에 대한 적절한 통제를 수행하여 위험의 발생가능성 또는 위험으로 인한 예상 피해를 완화시킴
- 위험 수용 : 비용대비 효과를 고려하여 위험을 그대로 수용
- 위험 전이(전가) : 보험 등을 통해 위험의 책임을 제3자와 공유함
- 위험 회피 : 위험이 존재하는 절차, 사업을 포기함

■ 위험 모니터링 및 처리에 대한 프로세스 및 계획을 수립 및 이행하여야 한다.

- 정보자산의 신규 도입, 변경 등에 따른 새로운 위협과 취약성, 위험에 대하여 정기적으로 검토 필요

- 신규 취약점 발견에 따른 서비스 영향도를 수시로 점검
- 주요 시스템에 대하여 최소 월 1회 또는 상시 모니터링 실시
- 이상 징후의 유형은 시스템 로그의 검토, 보안 이벤트 모니터링, 위협 인텔리전스 기반 탐지 방식 등을 활용하여 수립

증거자료

- (위험평가 결과에 따른) 위험처리 계획서 (정보보호 책임자 승인 포함)
- 위험처리 이행 점검 보고서
- 신규 위험 대응 보고서

부적합 사례

- **사례 1 :** 클라우드서비스에 대한 위험평가를 수행하였으나 DB에 이용자 계좌번호 암호화 미흡사항을 법적 요구사항 검토 없이 위험수용으로 판단한 경우
- **사례 2 :** 클라우드서비스에 대한 위험평가를 수행하였으나, 위험평가 결과에 따른 허용 가능한 위험 수준을 정보보호책임자에게 승인받지 않고 담당자가 임의로 결정한 경우
- **사례 3 :** 신규 취약점에 대한 모니터링 방안이 마련되어 있지 않아 log4j 등의 신규 기술 취약점에 대한 위험평가가 장기간 이루어지지 않은 경우
- **사례 4 :** 공동책임모델(SRM)이 명확하지 않아 식별된 위험평가 결과에 대한 대응을 수행하지 않은 경우

4. 서비스 공급망 관리

4.1 공급망 관리 정책

항목	4.1.1 공급망 관리 정책 수립	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○	○	
인증기준	클라우드컴퓨팅서비스에 대한 접근과 서비스 연속성을 저해하는 위험을 식별하고 최소화하기 위해 공급망과 관련한 보안 요구사항을 정의하는 관리정책을 수립하여야 한다.						
점검항목	공통	1) 클라우드컴퓨팅서비스에 대한 접근과 서비스 연속성을 저해하는 위험을 식별하고 있는가?					
	공통	2) 식별된 위험을 최소화하기 위한 보안 요구사항을 포함하는 공급망 관리정책을 수립하고 있는가?					
점검목적	공급자 및 제3자가 조직의 정보보호 요구사항을 충족하도록 보장하고, 공급망에서 발생할 수 있는 보안 리스크를 최소화 한다.						
참고	• ISMS-P 2.3.1 외부자 현황 관리 • ISO/IEC 27017 5.19 공급자 관계 정보보호						

점검항목 해설

점검항목 1)

■ 클라우드서비스 제공자는 클라우드서비스에 대한 접근과 서비스 연속성을 저해할 수 있는 공급망 상의 이해관계자(공급자 등) 및 위험을 식별하여야 한다.

- 공급망 상의 이해관계자와 맺은 계약(위수탁계약, 제품공급 제약 등) 관계에 따른 위험 식별
- 공급망 및 공급자에 의해 야기될 수 있는 관련 시설, 서비스 및 데이터의 분실, 도난, 유출, 위조, 변조, 훼손 등의 발생 가능성 검토
- 처리되는 데이터의 종류, 네트워크 환경, 오피스 환경 등과 공급망 및 공급자와 관련한 위험 식별

※ 공급망 및 공급자 정의

- 공급망(Supplier chain) : 제품이나 서비스가 최종 사용자에게 전달되기까지 거치는 조직, 사람, 활동, 정보, 자원의 네트워크를 의미. 정보보호 관점에서는 ICT(정보통신기술) 공급망을 통해 하드웨어, 소프트웨어, 클라우드서비스 등이 전달되는 과정에서 발생할 수 있는 보안 위험을 관리하는 체계를 의미
- 공급자(Supplier) : 계약 또는 기타 방법으로 조직에 제품이나 서비스(특히 ICT 서비스)를 제공하는 외부 기관이나 개인을 의미. 예 : 클라우드서비스 제공자(CSP), 소프트웨어 개발사, 하드웨어 제조사, 외부 데이터 처리 업체 등

■ 클라우드서비스 제공을 필요한 공급망과 공급자 현황을 식별하고, 현행화해야 한다.

- 서비스 제공에 필요한 시설, 설비, 정보자산, 네트워크, 소프트웨어, 매니지드 서비스 등 공급자 현황을 식별하고 지속적으로 현행화 필요

점검항목 2)

■ 식별된 위험을 최소화하기 위한 보안요구사항을 포함한 공급망 관리대책을 수립하여야 한다.

- 공급망 상의 이해관계자와 맺은 계약의 범위에서 발생 가능한 위험을 최소화하기 위한 보안대책
- 데이터의 유출, 위조, 변조, 훼손 위험을 최소화하기 위한 기술적인 보안대책
- 시설 및 설비, 서비스, 네트워크 등의 장애로 인한 위험을 최소화하기 위한 보안대책
- 외부 위탁으로 인한 위험을 최소화하기 위한 보안대책 등

증거자료

- 공급망 및 공급자 관리지침(위탁업체 관리지침)
- 공급자 현황 목록

부적합 사례

- **사례 1 :** 클라우드서비스를 제공과 관련한 공급자에 대하여 보안사항 요구사항, 계약서에 보안사항 반영 등을 명시하는 절차가 마련되어 있지 않은 경우
- **사례 2 :** 클라우드서비스를 제공하고 있으나 서비스 제공에 필요한 공급자 현황이 정확하게 파악되어 있지 않은 경우

항목	4.1.2 공급망 계약	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○		
인증기준	클라우드컴퓨팅서비스 범위 및 보안 요구사항을 포함하는 공급망 계약을 체결하고 다자간 협약시 책임을 개별 계약서에 각각 명시해야 하며, 해당 서비스에 관련된 모든 이해관계자에게 적용하여야 한다.						
점검항목	공통	1) 클라우드컴퓨팅서비스 범위 및 보안 요구사항을 공급망 계약에 포함하고 다자간 협약 시 각각의 역할과 책임을 명시하고 있는가?					
점검목적	공급자 및 제3자가 조직의 정보보호 요구사항을 충족하도록 보장하고, 공급망에서 발생할 수 있는 보안 리스크를 최소화한다,						
참고	• ISMS-P 2.3.2 외부자 계약시 보안 • ISO/IEC 27017 5.20 공급자 협약 내 정보보안 명시, CLD.5.39 클라우드서비스 파트너의 역할 및 책임에 관한 협약						

점검항목 해설

점검항목 1)

■ 공급망 계약 체결 시 서비스의 범위 및 수립된 보안요구사항을 계약서에 반영하여야 한다.

- 공급자가 제공하는 서비스의 범위
- 공급자와 수요자의 역할과 책임
- 공급자가 준수해야 하는 보안요구사항
- 문제 발생 시 대책 및 법적 책임 등

■ 식별된 위험을 해결하기 위한 사항이 계약에 반영되어야 한다.

■ 다자간 협약을 맺는 경우 각각의 역할 및 책임을 명시하여야 한다.

- 협약에 포함된 당사자들의 역할 및 책임을 개별 계약서마다 명시

※ 인프라사업자(IaaS 인증업체)와 계약 시 포함되는 내용 예시

- 클라우드서비스 인프라 지원 및 관리 책임
- 서비스 복원 및 복구에 대한 책임
- 복원 및 복구 지원을 위한 서비스(소산 및 DR 등) 제공
- 네트워크 모니터링 서비스 및 필요 시 보안관제 서비스 제공
- 클라우드서비스 보호를 위한 정보보호시스템 제공

※ 클라우드서비스파트너(예: SW 개발·유지보수, 클라우드 관리 등)와 계약 시 포함되는 내용 예시

- 기능적, 기술적 보안 요구사항의 반영 여부
- 개발 보안 가이드 준수 여부(시큐어 코딩 등)
- 테스트 시 보안 요구사항 준수 여부
- 개발 완료된 시스템에 대한 취약점 점검 등 수행 여부
- 개발인력 대상 SW개발 보안교육 여부

■ 이용자의 보안요구사항은 계약서, 서비스수준협약서(SLA) 등에 반영을 검토하여야 한다.

- 계약서, 협약서 등에 명시된 요구사항은 클라우드서비스 제공자의 정보보호대책에 구현
  - 이용자의 클라우드서비스에 대한 업무 연속성 유지, 안전성 유지 등의 원활한 운영에 대한 클라우드서비스 제공자의 책임 명시
  - 클라우드서비스와 관련한 이용자 데이터의 물리적 위치 명시
- SaaS 제공자를 포함하여 이용자가 보안요구사항의 준수여부에 대한 증거를 요구하는 경우 관련 자료를 제공

증거자료

■ 공급망(공급자) 표준 계약서 또는 서비스수준협약서(SLA)

부적합 사례

■ **사례 1 :** 공급망 계약을 체결하였으나 계약서나 협약서에 보안요구사항을 반영하지 않은 경우

■ **사례 2 :** 공급망 계약이 3자 간 필요한 경우이나 계약서는 2자 계약 서명이 된 경우

4.2 공급망 변경관리

항목	4.2.1 공급망 변경 관리	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○		
인증기준	정보보호 정책, 절차 및 통제에 대한 수정 및 개선이 필요하다고 판단될 경우 서비스 공급망 상에 발생할 수 있는 위험에 대한 검토를 통해 안전성을 확보 후 계약서 내용 변경 방안을 제시하여야 한다.						
점검항목	공통	1) 공급망 변경과 관련하여 계약서 등을 공급망 상의 이해관계자들에게 제시하고 있는가?					
	공통	2) 안전성 확보를 위해 필요시 클라우드 공급망에 대한 보안위험을 재평가하고 있는가?					
점검목적	지속적인 모니터링과 평가를 통해 공급업체 관계에서 발생할 수 있는 보안 위험을 지속적으로 관리하고, 필요시 적절한 개선 조치를 취하기 위한 것						
참고	• ISO/IEC 27017 5.22 공급자 서비스 모니터링, 검토 및 변경 관리						

점검항목 해설

점검항목 1)

■ 사고 발생 시 계약 해지, 재계약 통제 등 제재 사항을 포함하는 공급망 변경 가능에 대해 계약서에 명시하고 이를 공급망 상 이해관계자들에게 제시하여야 한다.

※ 계약해지 및 재계약 통제 등 제재 사항 적용 사유 예시

- 제공자가 정당한 사유 없이 서비스를 시작하지 아니한 경우
- 제공자가 서비스 계약에 따른 계약 조건을 이행하지 아니한 경우
- 제공자가 서비스수준협약서에 협의된 목표 수준에 미달되어 개선될 가능성이 없는 경우
- 제공자가 제공하는 서비스가 제안서 및 수행계획과 다르거나 뚜렷하게 차이가 있는 경우 등

점검항목 2)

■ 공급망 변경 시 안전성 확보를 위해 필요 시 공급망에 대한 보안위험을 재평가하여야 한다.

- 제공자의 임직원이 접근 가능한 정보 및 정보처리 시설 식별, 접근 형태 분석
- 접근 가능한 자산의 중요도 및 보호대책
- 정보자산에 대한 접근방법, 권한 승인 절차
- 변경 관리 절차 및 보고 체계
- 제공자의 임직원 적격성 및 교육 훈련 보장

증거자료

- 제재 사항에 관한 내용이 포함된 공급자와의 표준 계약서 또는 협약서
- 계약변경관리 절차
- 공급망 위험 검토 결과

부적합 사례

- **사례 1 :** 공급망 변경에 따른 재계약과 관련한 사항이 내부 규정에 마련되어 있지 않은 경우
- **사례 2 :** 정보보호정책이 변경되어 공급망 상의 보안정책에 변동이 생겼으나, 이에 대하여 공급자에게 계약 변경 등을 요구하지 않은 경우

항목	4.2.2 공급망 모니터링 검토		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○	○	
인증기준	클라우드컴퓨팅서비스 공급망 상에서 발생하는 기록 및 보고서는 정기적으로 모니터링 및 검토하여야 한다.							
점검항목	공통	1) 서비스 수준 협약의 요구사항에 대한 준수 여부를 모니터링 가능한 체계를 수립하고 주기적으로 검토하고 있는가?						
점검목적	지속적인 모니터링과 평가를 통해 공급업체 관계에서 발생할 수 있는 보안 위험을 지속적으로 관리하고, 필요시 적절한 개선 조치를 취한다.							
참고	• ISO/IEC 27017 5.22 공급자 서비스 모니터링, 검토 및 변경 관리							

점검항목 해설

점검항목 1)

■ 공급망 상에서 합의된 보안요구사항의 준수 여부를 확인하기 위한 절차를 마련하고 이에 따라 공급망을 정기적으로 모니터링 및 검토하여야 한다.

- 공급망 서비스 목록 작성 (서비스 내용 및 처리하는 정보 유형, 개인정보 또는 민감정보 처리 유무 등)
- 서비스 수준 협약 내의 보안요구사항
- 민감한 데이터 처리 합의
- 정기 운영보고서 검토 또는 실사, 모니터링 수행 등

증거자료

- 공급망 서비스 목록
- 공급망 관련 정기 운영보고서
- 공급망 관련 점검결과

부적합 사례

- **사례 1 :** 공급자에게 매월 운영보고서를 받고 있으나 보안요구사항 준수여부 등 검토를 하지 않은 경우
- **사례 2 :** 공급자 현황 검토를 정기적으로 수행하고 있으나 계약기간이 6개월 미만인 단기 공급자의 경우 현황 검토에 누락된 경우

5. 침해사고 관리

5.1 침해사고 대응 절차 및 체계

항목	5.1.1 침해사고 대응 절차 수립	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○
인증기준	침해사고에 대한 효율적이고 효과적인 대응을 위해 신고절차, 유출 금지 대상, 사고 처리 절차 등을 담은 침해사고 대응절차를 마련하여야 한다. 침해사고 대응절차는 이용자와 제공자의 책임과 절차가 포함되어야 한다.						
점검항목	공통	1) 침해사고의 정의 및 범위, 긴급연락체계 구축, 침해사고 발생 시 보고 및 대응절차, 침해사고 대응조직의 구성 등을 포함한 침해사고 대응절차를 수립하고 있는가?					
점검목적	보안 사고 발생 시 신속하고 효과적으로 대응하여 피해를 최소화하고, 빠른 복구를 달성한다.						
참고	• ISMS-P 2.11.1 사고 예방 및 대응체계 구축 • ISO/IEC 27017 5.24 정보보안 사고 관리 계획 및 대비						

점검항목 해설

점검항목 1)

■ 클라우드서비스를 제공하면서 발생할 수 있는 침해사고를 예방하고 침해사고 발생 시 효율적으로 대처하기 위하여 다음의 내용을 포함하는 침해사고 대응절차를 수립하여야 한다.

- 침해사고의 정의 및 범위 (유형 및 중요도 포함)

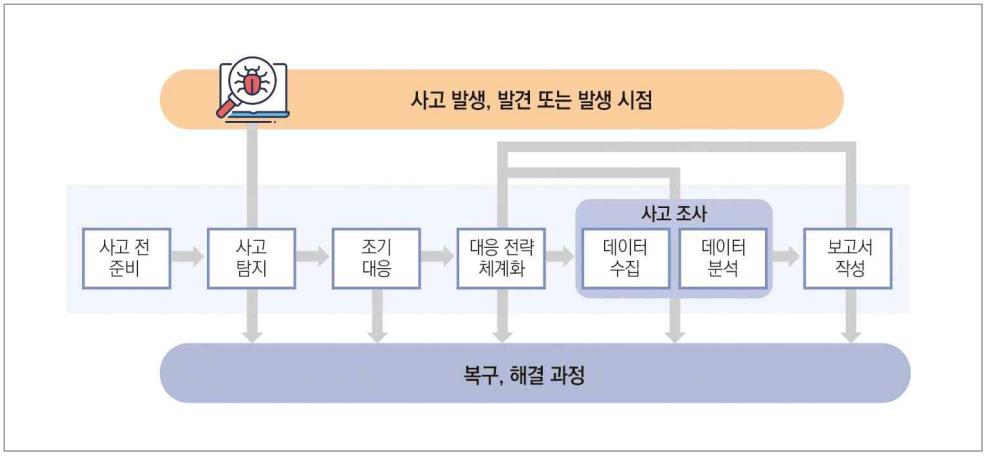
※ 침해사고 정의(정보통신망법 제2조제7호)

> - 다음의 방법으로 정보통신망 또는 이와 관련된 정보시스템을 공격하는 행위로 인하여 발생한 사태
> 가. 해킹, 컴퓨터바이러스, 논리폭탄, 메일폭탄, 서비스거부 또는 고출력 전자기파 등의 방법
> 나. 정보통신망의 정상적인 보호·인증 절차를 우회하여 정보통신망에 접근할 수 있도록 하는 프로그램이나 기술적 장치 등을 정보통신망 또는 이와 관련된 정보시스템에 설치하는 방법

- 비상연락체계 (내부직원 및 외부 협력사, 관계기관 포함)
- 침해사고 탐지 방안
- 침해사고 대응조직 구성 및 구성원의 역할과 책임
- 침해사고 발생 시 기록, 보고, 사고전파 절차
- 침해사고 원인 분석 및 피해 상황 파악
- 침해사고 신고 및 통지 절차 (관계기관, 이용자 등)

- 서비스 복구 및 침해사고 재발방지
- 침해사고 대응 훈련
- 기타 침해사고 예방, 대응, 복구를 위해 필요한 사항 등

※ 침해사고 대응 절차 예시



분류	설명
사고 전 준비	사고가 발생하기 전 침해사고 대응팀과 조직적인 대응을 준비
사고 탐지	정보보호시스템 및 네트워크 장비에 의한 이상 징후 탐지 관리자에 의한 침해사고의 식별
초기 대응	초기 조사 수행, 사고 정황에 대한 기본적인 세부사항 기록 사고대응팀 신고 및 소집 침해사고 관련 부서에 통지
대응 전략 체계화	최적의 전략을 결정하고 관리자 승인을 획득 초기 조사 결과를 참고하여 사고 조사 과정에 수사기관 공조 여부를 판단
사고 조사	데이터 수집 및 분석을 통하여 수행. 언제, 누가, 어떻게 사고가 일어났는지, 피해 확산 및 사고 재발을 어떻게 방지할 것인지를 결정
보고서 작성	의사 결정자가 쉽게 이해할 수 있는 형태로 사고에 대한 정확한 보고서 작성
재발 방지	차기 유사 공격을 식별 및 예방하기 위한 보안정책의 수립, 절차 변경, 사건의 기록, 장기 보안정책 수립, 기술 수정 계획수립 등을 결정

증거자료

- 정보보호 정책서
- 침해사고 대응지침

부적합 사례

- **사례 1 :** 침해사고 대응지침을 마련하였으나 지침 내에 침해사고 발생 시 보고절차가 마련되어 있지 않은 경우
- **사례 2 :** 침해사고 대응지침을 마련하였으나 지침 내에 서비스 제공자, 이용자의 역할과 책임이 명시되지 않고 사고 신고 및 통보를 위한 비상연락망이 없는 경우

항목	5.1.2 침해사고 대응 체계 구축	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○	○	
인증기준	침해사고 정보를 수집·분석·대응할 수 있는 보안관제 시스템 및 조직을 구성·운영하고, 침해사고 유형 및 중요도에 따라 보고 및 협력체계를 구축하여야 한다.						
점검항목	공통	1) 침해사고를 모니터링 하여 신속하게 대응할 수 있도록 모니터링 및 대응 방법, 절차, 대응조직 및 인력, 보고 및 승인 방법 등을 포함한 중앙 집중적인 대응체계를 수립하고 있는가?					
	IaaS	2) 침해사고 유형, 중요도, 긴급성 등에 따라 분류하고 이에 따른 보고체계를 정의하고 있는가?					
	공통	3) 외부 관제시스템 업체 등 외부 기관을 통해 침해사고 대응체계를 구축·운영하는 경우 보안사고 대응 절차의 세부사항을 계약서에 반영하고 있는가?					
	공통	4) 침해사고의 모니터링, 대응 및 처리와 관련된 정부 부처, 외부전문가, 전문 업체, 전문기관(KISA) 등과의 협조체계를 수립하고 있는가?					
점검목적	보안 사고 발생 시 혼란을 최소화하고, 신속하고 일관된 방식으로 대응하여 피해를 줄이고 비즈니스 운영을 빠르게 정상화한다.						
관련표준	• ISMS-P 2.11.1 사고 예방 및 대응체계 구축 • ISO/IEC 27017 5.24 정보보안 사고 관리 계획 및 대비						

점검항목 해설

점검항목 1)

■ 침해사고를 모니터링하고 신속하게 대응할 수 있도록 중앙 집중적인 대응체계를 수립하여야 한다.

- 모니터링 및 대응 방법, 절차
- 대응 조직 및 인력
- 침해사고 보고 및 승인 절차 등

■ 자체적으로 보안관제 시스템을 구축하거나 외부 전문 업체와의 계약을 통해 보안관제 시스템을 구축할 수 있다.

- 외부의 전문 업체를 활용하여 보안관제 시스템을 구축하는 경우 별도의 조직 구성 불필요

점검항목 2)

■ 침해사고 유형을 식별하여 중요도를 분류하고 이에 따른 보고체계를 정의하여야 한다.

※ 침해사고 유형 및 중요도 (예시)

침해사고 유형				중요도	보고체계
비인가자의 정보시스템 접근 시도	악성 프로그램 유포	정보 유출	서비스 거부 공격		
-	악성 프로그램 감염 확인	-	공격시도 있으나 서비스 영향 미비	하	보안팀장
접근 시도 발견	악성프로그램 지속 유포	정보 유출 시도 발견	공격시도 있으며 서비스 일부 제한	중	정보보호책임자 (비상대응팀 소집)
접근 성공	-	정보유출 확인	공격시도 있으며 서비스 중단	상	경영진

점검항목 3)

■ 외부 보안관제 업체와 계약을 맺는 경우 수립된 침해사고 대응절차의 내용을 계약서에 반영하여야 한다.

- 침해사고 대응절차를 계약서, 협약서(SLA), 제안요청서(RFP) 등에 반영
- 침해사고 대응절차 내에 보안관제 업체와 서비스 제공자 간의 역할 정의
- 모니터링, 이벤트 등 수집 및 분석, 상황전파, 보안 이슈 및 업계동향 보고, 침해사고 원인 파악 및 피해 분석, 복구 방안 강구 등에 대한 범위 및 역할 정의

점검항목 4)

■ 침해사고의 모니터링, 대응 및 처리와 관련된 외부전문가, 전문 업체, 전문기관(한국인터넷진흥원 등)과의 연락 및 협조체계를 수립하여야 한다.

- 비상연락망 등 외부 전문기관과 연락체계를 구축하고 담당자, 연락처 등의 정보를 최신으로 유지
- 자체 긴급연락망 등을 수립
- 침해사고 발생 시 관련 책임자 및 유관기관에 즉시 연락할 수 있도록 자체 긴급연락망(핫라인)을 수립하고, 사고 발생 시 즉각 통지

증거자료

- 침해사고 대응 관련 지침(침해사고 대응조직, 비상연락망, 침해사고 유형 및 중요도 포함)
- (외부 관제 용역 시)외부관제 용역 계약서
- 일별/주간별/월별 보안관제 보고서 샘플

부적합 사례

- **사례 1 :** 클라우드서비스 침해사고에 대비한 침해사고 대응지침을 마련하였으나, 대응조직과 인력 등의 내용이 명확하게 정의되어 있지 않은 경우
- **사례 2 :** 클라우드서비스의 보안관제를 전문보안관제업체에게 위탁하고 있으나 위탁계약서 및 협약서에 침해사고 대응에 관한 역할 및 책임에 관한 사항이 명시되어 있지 않은 경우
- **사례 3 :** 침해사고 대응지침 내 비상연락망을 작성하였으나 최근 계약한 수탁사 연락처가 누락되어 있고, 다른 수탁사의 연락처도 현행화되어 있지 않은 경우

항목	5.1.3 침해사고 대응 훈련 및 점검		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○	○	
인증기준	침해사고 대응과 관련된 역할 및 책임이 있는 담당자를 훈련시켜야 하고, 주기적으로 침해사고 대응 능력을 점검하여야 한다.							
점검항목	공통	1) 침해사고 대응 절차에 관한 연 1회 이상 모의훈련 계획을 수립하고 이에 따라 주기적으로 훈련을 실시하고 있는가?						
	공통	2) 침해사고 대응 모의훈련 결과를 이용자가 요청할 경우 이를 문서화하여 제공하고 있는가?						
점검목적	침해사고 대응 조직이 역할과 절차를 이해하고 실제 사고 발생 시 역할과 절차에 따른 대응을 할수 있도록 한다.							
관련표준	• ISMS-P 2.11.4 사고 대응 훈련 및 개선							

점검항목 해설

점검항목 1)

■ 정보보호 담당자는 침해사고 발생 시 신속하게 대응하기 위해 정기적으로(연 1회 이상) 침해사고 모의훈련 계획을 수립하고 이를 시행하여야 한다.

- 침해사고 대응 관련 인력이 모두 포함될 수 있도록 모의훈련 계획을 수립
- 모의훈련 계획은 침해사고 대응과 관련된 담당자의 훈련이 될 수 있도록 문서화하여 책임자의 승인을 받은 후 시행
- 모의훈련 완료 후 결과보고서를 작성하여 보고
- 모의훈련 결과 대응체계의 변경이 필요한 경우 반영 (절차, 문서, 조직, 시스템 등)
- 다양한 모의훈련 시나리오를 수립하여 상황별 신속 대응 능력 향상

※ 침해사고 대응 훈련의 유형 (예시)

· 도상 훈련 : 문서 기반의 시나리오를 토대로 침해사고 대응조직이 토론하며 대응 체계를 점검하는 훈련

· 모의 훈련 : 실제 침해사고가 시스템 또는 네트워크에 발생하는 모의 상황을 발생시켜 그 상황을 침해사고 대응 조직이 수립된 대응 체계에 따라 조치하는지를 점검하는 훈련

점검항목 2)

■ 클라우드서비스 이용자가 모의훈련에 대한 결과를 요청할 경우 모의훈련 결과를 문서화하여 제공하여야 한다.

- 클라우드서비스 이용자가 요청할 경우 모의훈련 결과를 문서로 제공받을 수 있다는 이용자의 권리를 계약서 또는 협약서(SLA) 등에 포함

증거자료

- 침해사고 모의훈련 계획서
- 침해사고 모의훈련 결과보고서
- 침해사고 모의훈련 결과서 이용자 제공 내역

부적합 사례

- **사례 1 :** 클라우드서비스에 대한 침해사고 모의훈련을 실시하였으나, 최근 3년간 동일한 시나리오로 훈련을 실시하고, 훈련 후 개선사항도 없음으로 되어 있는 등 훈련의 효과성이 떨어지는 경우
- **사례 2 :** 침해사고 대응지침에는 모의훈련 결과를 책임자에게 보고하도록 되어 있으나, 관련 증적을 확인할 수 없는 경우
- **사례 3 :** 침해사고 모의훈련 결과 시스템 및 침해사고 대응절차 개선사항이 확인되었으나, 개선계획 수립 및 이행 등 후속조치가 이뤄지지 않아 훈련의 효과성이 떨어지는 경우

5.2 침해사고 대응

항목	5.2.1 침해사고 보고		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○	○	○	○	○
인증기준	침해사고 발생 시 침해사고 대응 절차에 따라 법적 통지 및 신고 의무를 준수하여야 한다. 또한 클라우드컴퓨팅서비스 이용자에게 발생 내용, 원인, 조치 현황 등을 신속하게 알려야 한다.							
점검항목	공통	1) 침해사고의 징후 또는 침해사고 발생을 인지한 경우 정의된 침해사고 보고절차에 따라 신속하게 보고가 이루어지고 있는가?						
	공통	2) 침해사고보고서에는 사고 날짜, 사고 내용 등 필요 내용을 모두 포함하고 있는가?						
	공통	3) 침해사고 발생 시 관련 법률 및 규정에 따라 신고, 통지하는 절차를 따르고 있는가?						
점검목적	침해사고 대응 조직이 이용자 통지 또는 기관 신고 등의 역할과 절차를 이해하고 실제 사고 발생 시 그 역할과 절차를 신속하게 수행하도록 한다.							
참고	• 클라우드컴퓨팅법 제25조(침해사고 등의 통지 등) • 정보통신망법 제48조의3(침해사고의 신고 등) • ISO/IEC 27017 6.8 정보보안 이벤트 보고							

점검항목 해설

점검항목 1)

■ 침해사고 징후 또는 침해사고를 인지한 경우 보고절차에 따라 신속하게 보고하여야 한다.

- 사전에 규정한 절차에 따라 침해사고 유형, 중요도 및 보고체계에 따른 신속한 보고 진행

점검항목 2)

■ 침해사고 발생 시 다음 내용을 포함한 침해사고보고서를 작성하여야 한다.

- 침해사고 발생일시
- 보고자와 보고일시
- 사고 내용 (발견사항, 피해 내용 등)
- 사고대응 경과 내용
- 사고대응까지의 소요시간 등

점검항목 3)

■ 아래와 같은 침해사고 발생 시 법령에 따른 의무에 따라 신속하게 통지 및 신고하여야 한다.

- 개인정보 보호법에 따른 개인정보 유출 등 신고
- 정보통신망법에 따른 침해사고 신고
- 클라우드컴퓨팅법에 따른 클라우드서비스 관련 시스템 상의 침해사고 및 이용자 정보 유출, 서비스 중단 등 발생 시 신고

※ 침해사고 발생 시 통지 및 신고 예시

구분		클라우드컴퓨팅법	정보통신망법
근거		클라우드컴퓨팅법 제25조(침해사고 등의 통지 등)	정보통신망법 제48조의3(침해사고의 신고 등)
주체		클라우드서비스 제공자	정보통신서비스 제공자 집적정보통신시설 사업자
신고	대상	-	과학기술정보통신부장관 또는 한국인터넷진흥원((☎ 118, 보호나라 www.boho.or.kr)
	기준		침해사고 발생
	내용		침해사고 발생 일시, 원인 및 피해내용, 침해사고에 대한 조치사항 등 대응 현황, 침해사고 대응업무 담당 부서 및 연락처
	방법		서면, 전자우편, 전화, 인터넷 홈페이지 입력 등
	시기		침해사고 발생 인지 후 24시간 이내
통지	대상	이용자(SaaS 사업자, 기업·개인, 공공기관 등)	-
	기준	침해사고 발생	-
	내용	1. 발생내용 2. 발생 원인 3. 클라우드서비스 제공자의 피해 확산 방지 조치 현황 4. 이용자의 피해 예방 또는 확산 방지 방법 5. 담당부서 및 연락처	-
	방법	- 전화, 휴대전화, 우편, 전자우편, 문자메시지, 클라우드서비스 접속화면 게시 또는 이와 유사한 방법 - 클라우드서비스 접속화면을 통하여 알리는 경우 15일 이상 게시	-
	시기	지체 없이	

※ 이용자 정보 유출 발생 시 통지 및 신고 예시

• 이용자 정보 : 이용자의 개인정보를 포함하여 클라우드서비스에서 생산, 저장, 관리되는 이용자의 정보

구분		클라우드컴퓨팅법		개인정보 보호법
근거		클라우드컴퓨팅법 제25조(침해사고 등의 통지 등)		개인정보 보호법 제34조(개인정보 유출 등의 통지·신고)
주체		클라우드서비스 제공자		개인정보처리자
신고	대상			개인정보보호위원회(brss.pipc.go.kr, 해외사업자는 brss@korea.kr) 또는 , 한국인터넷진흥원 (☎ 118, privacyclean@kisa.or.kr, www.privacy.go.kr))
	기준			① 1천명 이상 개인정보 유출 ② 민감정보 또는 고유식별정보 유출 ③ 외부로부터 불법적인 접근으로 개인정보 유출
	내용			1. 유출 등이 된 개인정보 항목 2. 유출 등이 된 시점과 그 경위 3. 유출 등으로 인하여 발생할 수 있는 피해를 최소화하기 위하여 정보주체가 할 수 있는 방법 등에 관한 정보 4. 개인정보처리자의 대응조치 및 피해 구제절차 5. 정보주체에게 피해가 발생한 경우 신고 등을 접수할 수 있는 담당부서 및 연락처
	방법			서면 등의 방법
	시기			72시간 이내
통지	대상	이용자(SaaS 사업자, 기업·개인, 공공기관 등)		정보주체
	기준	이용자 정보 유출 발생		개인정보 유출 발생
	내용	이용자	1. 발생내용 2. 발생 원인 3. 피해 확산 방지 조치 현황 4. 이용자의 피해 예방 또는 확산 방지 방법 5. 담당부서 및 연락처	1. 유출 등이 된 개인정보 항목 2. 유출 등이 된 시점과 그 경위 3. 유출 등으로 인하여 발생할 수 있는 피해를 최소화하기 위하여 정보주체가 할 수 있는 방법 등에 관한 정보 4. 개인정보처리자의 대응조치 및 피해 구제절차 5. 정보주체에게 피해가 발생한 경우 신고 등을 접수할 수 있는 담당부서 및 연락처
		과기정통부 장관	1. 유출된 이용자 정보의 개요(파악된 경우) 2. 유출된 시점과 그 경위 3. 클라우드서비스 제공자의 피해확산 방지 조치 현황	
	방법	전화, 휴대전화, 우편, 전자우편, 문자메시지, 클라우드서비스 접속화면 15일 이상 게시		서면 등의 방법, 연락처 확인 불가 등 정당한 사유가 있는 경우 홈페이지에 30일 이상 게시
	시기	지체 없이		72시간 이내

※ 서비스 중단 시 통지 예시

구분		클라우드컴퓨팅법
근거		클라우드컴퓨팅법 제25조(침해사고 등의 통지 등), 클라우드법 시행령 제16조, 제17조
주체		클라우드서비스 제공자
통지	대상	이용자(SaaS 사업자, 기업·개인, 공공기관 등)
	기준	① 서비스 중단시간 10분 이상 ② 24시간 이내 2회 이상 중단기간 15분 이상 ※ 단, 당사자 간 계약으로 기간을 정하였을 경우에는 그 기간 이상 중단 시
	내용	1. 발생내용 2. 발생 원인 3. 피해 확산 방지 조치 현황 4. 이용자의 피해 예방 또는 확산 방지 방법 5. 담당부서 및 연락처
	방법	전화, 휴대전화, 우편, 전자우편, 문자메시지, 또는 클라우드서비스 접속화면에 15일 이상 게시
	시기	즉시 또는 지체 없이

증거자료

- 침해사고 대응지침
- 침해사고 보고서
- 침해사고 신고 내역
- 침해사고 이용자 통지내역

부적합 사례

- **사례 1 :** 클라우드서비스 이용자 정보가 유출되었고, 유출된 이용자 정보에 운전면허번호 10여건이 포함되어 있었으나 이용자 통지만 수행하고 관계기관 신고를 누락한 경우
- **사례 2 :** 클라우드서비스에 침해사고가 발생하여 이용자 정보가 유출되었으나, 관계기관에만 신고하고 이용자 통지를 수행하지 않은 경우

항목	5.2.2 침해사고 처리 및 복구		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○	○	
인증기준	침해사고 발생 시 침해사고 대응 절차에 따라 처리와 복구를 신속하게 수행하여야 한다.							
점검항목	공통	1) 침해사고가 발생한 경우 절차에 따라 처리 및 복구를 수행하고 그 기록을 남기고 있는가?						
	IaaS	2) 침해사고 대응에 대한 이용자의 요청이 발생되는 경우 침해사고 대응 지원을 할 수 있는 체계를 마련하고 있는가?						
점검목적	비상 상황이나 재해 발생 시에도 중요한 정보와 시스템의 기밀성, 무결성, 가용성을 유지하고, 비즈니스 운영의 빠른 복구를 지원한다.							
관련표준	• ISMS-P 2.11.5 사고 대응 및 복구 • ISO/IEC 27017 5.26 정보보안 사고 대응							

점검항목 해설

점검항목 1)

■ 침해사고 처리와 복구 절차에 따라 침해사고 발생 원인을 파악하고 해당 원인을 제거하는 등 기술적, 관리적 대응 조치를 수행하여야 한다.

■ 침해사고 처리를 완료 후 다음의 내용을 포함한 침해사고 대응결과보고서를 작성하여야 한다.

- 처리 및 복구 일시
- 담당자
- 처리 및 복구 방법
- 처리 및 복구 수행 경과 내용
  (예 : 시작부터 종료까지 시간 순으로 작성)

점검항목 2)

■ 클라우드서비스 이용자의 침해사고 대응 요청이 있는 경우 자문, 기술지원 등 침해사고 대응 지원을 제공하여야 한다.

- 침해사고 탐지 지원
- 침해사고 발생 시 원인분석, 피해확산방지, 고객 및 언론대응, 관계기관 신고 등의 사고대응 지원
- 침해사고 조치 후 서비스 복구 및 재발방지 대책 마련 지원 등

증거자료

- 침해사고 대응지침
- 침해사고 대응 결과보고서

부적합 사례

- **사례 1 :** 침해사고가 발생하여 조치하였으나 침해사고 대응결과보고서를 작성하지 않은 경우
- **사례 2 :** 클라우드서비스 이용자의 침해사고 대응 지원체계가 마련되어 있지 않은 경우

5.3 사후관리

항목	5.3.1 침해사고 분석 및 공유		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○		
인증기준	침해사고가 처리 및 종결된 후 발생 원인을 분석하고 그 결과를 이용자에게 알려야 한다. 또한 유사한 침해사고에 대한 신속한 처리를 위해 침해사고 관련 정보 및 발견된 취약점을 관련 조직 및 임직원과 공유하여야 한다.							
점검항목	공통	1) 침해사고가 종결된 후 사고의 원인을 분석하고 그 결과를 이용자에게 고지하고 있는가?						
	공통	2) 침해사고 정보와 발견된 취약점을 관련 조직 및 인력과 공유하고 있는가?						
점검목적	침해사고 처리, 종결 및 사후 원인분석 등의 제반 정보를 이용자에게 공유한다. 해당 정보는 내부 공유하여 추후 유사한 사고 발생 시 신속한 처리가 가능하도록 한다.							
관련표준	• ISMS-P 사고 대응 및 복구 • ISO/IEC 27017 5.26 정보보안 사고 대응							

점검항목 해설

점검항목 1)

■ 침해사고가 처리되고 종결된 후 침해사고의 원인을 분석하고 필요 시 분석결과를 클라우드서비스 이용자에게 고지하여야 한다.

- 침해사고 원인 분석 시 자체 인력 또는 외부전문가, 관계기관 등과 협력
- 클라우드서비스 이용자에게 고지할 보고서 작성
- 전화, 휴대전화, 우편, 문자메시지, 전자 우편 또는 홈페이지 고지 등을 통해 클라우드서비스 이용자에게 고지

점검항목 2)

■ 침해사고 정보와 발견된 취약점을 관련 조직 및 인력과 공유하여야 한다.

- 침해사고 정보와 발견된 취약점 및 원인, 조치방안 등을 관련 인력(내부, 필요시 외부 전문가 및 관계기관 인력)과 공유

증거자료

■ 침해사고 대응절차

- 침해사고 분석 결과 이용자 고지 내역

부적합 사례

- **사례 1 :** 침해사고가 발생하여 이를 조치하였으나, 사고 원인과 분석결과를 클라우드서비스 이용자에게 고지하지 않은 경우
- **사례 2 :** 침해사고가 발생하여 이를 조치하였으나, 사고 원인과 분석결과 및 후속조치에 대해 담당부서에서만 인지하고 관련 부서에게 공유하지 않은 경우

항목	5.3.2 재발 방지		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○	○	
인증기준	침해사고 관련 정보를 활용하여 유사한 침해사고가 반복되지 않도록 침해사고 재발방지 대책을 수립하고, 필요한 경우 침해사고 대응 체계도 변경하여야 한다.							
점검항목	공통	1) 침해사고 분석을 통해 얻어진 정보를 활용하여 유사 사고가 재발하지 않도록 대책을 수립하고 필요한 경우 침해사고 대응절차 등을 변경하고 있는가?						
점검목적	이전 발생한 보안 사고의 교훈을 활용하여 향후 유사 사고가 발생하지 않도록 하거나, 발생하더라도 피해를 최소화한다.							
관련표준	• ISMS-P 2.11.5 사고 대응 및 복구 • ISO/IEC 27017 5.27 정보보안 사고로부터 학습							

점검항목 해설

점검항목 1)

■ 침해사고 분석을 통해 얻은 정보를 활용하여 유사 사고가 반복되지 않도록 재발방지 대책을 수립하여야 한다.

- 침해사고 처리 완료 후 발생 원인에 대한 재발방지 대책 수립
- 수립된 재발방지 대책을 관련 임직원에게 공유 및 교육 실시
- 유사 사고가 발생하지 않도록 발견된 취약점 제거

■ 분석된 결과에 따라 필요한 경우 침해사고 대응 절차, 정보보호 정책 등의 사고대응체계 변경을 수행하여야 한다.

- 정보보호 정책 및 절차, 침해사고 대응 절차 변경 시 임직원에게 변경 내용에 대해 교육
- 지속적인 임직원의 정보보호 인식 개선 활동 필요

증거자료

- 침해사고 재발방지 대책
- 재발방지 대책에 따른 이행내역(지침 제·개정, 임직원 교육 등)

부적합 사례

- **사례 1 :** 클라우드서비스에 사용되는 정보시스템이 log4j 취약점에 의해 침해사고가 발생하였으나, 해당 서버만 조치하고 다른 서버의 log4j 취약점은 보안조치를 수행하지 않았으며, 조치계획도 마련되어 있지 않은 경우

6. 서비스 연속성 관리

6.1 장애대응

항목	6.1.1 장애 대응절차 수립	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○	○	
인증기준	관련 법률에서 규정한 클라우드컴퓨팅서비스의 중단으로부터 업무 연속성을 보장하기 위해 백업, 복구 등을 포함하는 장애 대응 절차를 마련하여야 한다.						
점검항목	공통	1) 클라우드 시스템 장애를 즉시 인지하고 대응하기 위한 절차를 수립~~·이행~~하고 있는가?					
점검목적	비상 상황이나 재해 발생 시에도 중요한 정보와 시스템의 기밀성, 무결성, 가용성을 유지하고, 비즈니스 운영의 빠른 복구를 지원한다.						
참고	• ISMS-P 2.9.2 성능 및 장애관리 • ISO/IEC 27017 5.29 업무 중단시 정보보안, 5.30 업무 연속성을 위한 ICT 준비, 8.6 용량 관리						

점검항목 해설

점검항목 1)

■ 클라우드서비스 장애 발생 시 즉각 대응할 수 있는 장애 대응절차를 수립하여야 한다.

- 장애 대응절차에는 장애보고, 장애탐지 및 복구, 재발방지, 백업 및 복구 관련 절차 포함
  - 백업 대상, 백업담당자 지정, 백업 주기 및 보존기한, 백업 매체 관리, 복구 테스트, 복구 절차 등
- 장애 대응 매뉴얼 및 절차는 매년 정기적으로 점검하고 업데이트 수행

■ 장애 대응절차는 발생 가능한 장애의 유형과 장애의 심각도에 따라 대응할 수 있도록 상세한 절차가 포함되도록 작성한다.

- 장애 유형 및 심각도 정의
- 장애 유형 및 심각도별 보고절차 (재발방지 대책 포함)
- 장애 유형별 탐지 방법 수립 : NMS 등 관리시스템 활용
- 장애 대응 및 복구에 관한 책임과 역할 정의
- 장애 유형별 대응 및 복구절차
- 장애 기록 및 분석
- 데이터 백업 및 복구 절차
- 장애에 따른 이용자 통지 및 관계 기관 통보 절차

- 비상연락체계(유지보수업체, 정보시스템 제조사) 등

※ 장애 유형 예시

관점	유형 예시
프로세스 관점	장애, 문제, 알려진 오류
발생 원인 관점	인적 장애, 자연 장애 시스템 장애, 기반 구조 장애, 기술적 장애, 운영 장애
위협 요소 관점	조직 내부인의 장애, 조직 외부인의 장애, 불규칙적 장애, 규칙적 장애
발생 위치 관점	Data, Process, System, Network 사람, 환경, 기타 유형 무형 자산

※ 장애 분류 및 대응방안 예시

<table>
<tr><th>통제</th><th colspan="3">재해 및 장애</th><th>재해 및 장애의 요인</th><th>장애 대응방안</th></tr>
<tr><td rowspan="2">통제
불가능
요인</td><td colspan="3">자연 재해</td><td>화재(전산실, 사무실), 지진 및
지반침하, 수재, 태풍 등</td><td>재해복구센터 구축을 통한
기기 및 프로그램의 이중화
데이터 백업 및 소산</td></tr>
<tr><td colspan="3">인적 재해</td><td>파업, 폭동, 테러 등</td><td rowspan="2">백업 또는 대체요원 확보</td></tr>
<tr><td rowspan="3">통제
가능
요인</td><td colspan="2">인적 장애</td><td rowspan="2">운영
장애</td><td>시스템운영실수, 단말기 및
저장매체의 파괴 및 절취, 외부
공격자의 침입, 컴퓨터 바이러스의
피해, 자료누출 등</td></tr>
<tr><td rowspan="2">기술
적
장애</td><td>시스
템
장애</td><td>운영체제 결함, 응용프로그램의 결함,
통신프로토콜의 결함,
통신소프트웨어의 결함, 하드웨어의
손상 등</td><td rowspan="2">전산기기 이중화 및 프로그램
변경 통제 강화
재해복구센터 구축을 통한
기기 및 프로그램의 이중화
통신망 이중화
전력공급 중단에 대비한
무정전 전원 장치(UPS) 및
발전 설비 구축</td></tr>
<tr><td colspan="2">기반구조
장애</td><td>정전사고, 단수, 설비 장애(항온항습,
공기정화시설, 통신시설, 발전기,
공조기 등), 건물의 손상 등</td></tr>
</table>

증거자료

- 장애 대응 매뉴얼 및 절차
- 비상연락망
- 정보보호 정책서
- 서비스연속성관리지침

부적합 사례

- **사례 1 :** 클라우드서비스 장애 발생 시 비상연락망에 따라 장애 대응 담당자에게 연락하도록 하고 있으나 장애 대응 담당자 연락처에 보직 이동자나 퇴사자 정보가 남아 있는 등 현행화 되지 않은 경우
- **사례 2 :** 장애 대응절차를 수립하고 있으나 장애유형 및 심각도, 장애 대응 및 복구에 관한 책임과 역할 정의, 보고 절차, 장애 유형별 조치 절차, 장애 탐지 방법, 장애 발생 시 이용자 통지 절차 등이 장애 대응절차에서 누락되어 있는 경우
- **사례 3 :** 장애 대응절차를 장애처리 흐름에 따라 도식화하고 있으나 장애 발생 시 법적 요구사항에 따른 이용자 통지 프로세스가 명시되지 않은 경우
- **사례 4 :** 클라우드서비스 운영을 위탁하여 수행하고 있으나 장애 대응절차에서 장애 발생 시 수탁사가 운영하는 클라우드 시스템에 대한 장애 대응절차를 명시하지 않은 경우
- **사례 5 :** 장애 대응절차를 수립하고 있으나 네트워크 구성 및 외주업체 변경 등의 내·외부 환경변화가 적절히 반영되어 있지 않은 경우

항목	6.1.2 장애 보고	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○
인증기준	클라우드컴퓨팅서비스 중단이나 피해가 발생 시 장애 대응절차에 따라 법적 통지 및 신고 의무를 준수하여야 한다. 또한 클라우드컴퓨팅서비스 이용자에게도 발생 내용, 원인, 조치 현황 등을 신속하게 알려야 한다.						
점검항목	공통	1) 장애 대응절차에 클라우드서비스 중단이나 피해 발생 시 법적 통지 및 신고 의무에 따른 장애보고절차가 마련되어 있는가?					
점검목적	관련 법률 및 규제 요구사항을 준수하고, 규정 위반으로 인한 법적 제재, 벌금, 평판 손상 등의 위험을 줄인다.						
참고	• ISO/IEC 27017 6.8 정보보안 이벤트 보고						

점검항목 해설

점검항목 1)

■ 클라우드서비스 중단이나 피해발생 시 법적 통지 및 신고 의무를 준수할 수 있도록 관련 사항을 포함하여 장애 대응절차를 수립하여야 한다.

※ 장애대응 절차에서 장애 발생 시 이용자에게 통지해야 하는 사항에 대한 참고

- 클라우드컴퓨팅법 시행령 제16조(통지가 필요한 클라우드서비스의 중단 기간)
  1. 클라우드서비스의 중단 기간이 연속해서 10분 이상인 경우
  2. 클라우드서비스의 중단 사고가 발생한 때부터 24시간 이내에 클라우드서비스가 2회 이상 중단된 경우로서 그 중단된 기간을 합하여 15분 이상인 경우
- 클라우드컴퓨팅법 시행령 제17조(통지의 내용 및 방법)
  1. 발생내용
  2. 발생원인
  3. 클라우드서비스 제공자의 피해 확산 방지 조치 현황
  4. 클라우드서비스 이용자의 피해 예방 또는 확산 방지 방법
  5. 담당부서 및 연락처

* (예외사항) 천재지변이나 그 밖의 불가피한 사유로 상기 통지방법으로 통지가 곤란한 경우에는 「신문 등의 진흥에 관한 법률」 제2조제1호가목에 따른 전국을 보급지역으로 하는 둘 이상의 일반 일간신문에 1회 이상 공고하는 것으로 갈음할 수 있음 (이 경우, 그 사유와 공고 내용을 지체 없이 문서(전자문서를 포함)로 과학기술정보통신부에 통보하여야 함)

증거자료

- 장애대응 매뉴얼 및 절차
- 신고 및 통보 내역 (서식/항목)
- 장애관리 현황(대장)
- 정보보호 정책서
- 서비스연속성관리지침

부적합 사례

- **사례 1 :** 내부 정책·지침에는 장애 발생 시 경영진 및 이해관계 부서에게 보고하도록 정하고 있으나, 장애 발생 시 담당 부서에서 자체적으로 대응 조치 후 경영진 및 이해관계 부서에 보고하지 않은 경우
- **사례 2 :** 클라우드서비스의 장애 대응절차에서 장애 발생 시 법적 요구사항에 따른 이용자 통지 절차를 수립하지 않는 경우
- **사례 3 :** 클라우드서비스의 장애 대응절차에서 장애 발생 시 이용자 통지 절차를 수립하고 있으나 법적 요구사항에 따른 클라우드서비스의 중단 기간이 명시되어 있지 않은 경우
- **사례 4 :** 클라우드서비스의 장애 대응절차 중 장애에 따른 이용자 통지절차를 수립하고 있으나 장애 발생 시 이용자 통지 항목과 이용자 통지방법을 명시하지 않은 경우

항목	6.1.3 장애 처리 및 복구		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○	○	
인증기준	클라우드컴퓨팅서비스 중단이나 피해가 발생할 경우, 서비스 수준 협약(SLA)에 명시된 시간 내에 장애 대응절차에 따라 해당 서비스의 장애를 처리하고 복구시켜야 한다.							
점검항목	공통	1) 장애 발생 시 절차에 따라 조치하고 장애 조치보고서 등을 통해 기록·관리하고 있는가?						
	IaaS	2) 장애 발생 시 서비스 수준 협약에 명시된 시간 내에 장애 대응절차에 따라 조치하고 있는가?						
점검목적	서비스 중단과 같은 상황에서도 목표한 서비스 가용성이 확보되도록 실질적 대응 체계를 마련한다.							
참고	• ISMS-P 2.9.3 백업 및 복구관리, 2.12.1 재해·재난 대비 안전조치 • ISO/IEC 27017 5.29 업무 중단 시 정보보안, 8.13 정보 백업							

점검항목 해설

점검항목 1)

■ 장애 발생 시 장애대응절차 및 서비스 수준 협약(SLA)에 따라 해당 서비스의 장애를 조치하여야 한다.

■ 장애 처리 완료 후 다음의 내용이 포함된 장애조치 보고서를 작성하고 이력을 관리하여야 한다.

- 장애일시
- 장애 유형 및 심각도 (예 : 상, 중, 하)
- 담당자, 책임자명 (유지보수업체 포함)
- 장애 내용 (장애로 인한 피해 또는 영향 포함)
- 장애 원인
- 조치 내용
- 복구내용
- 재발방지대책 등

점검항목 2)

■ IaaS의 경우 클라우드서비스 중단이나 피해가 발생할 경우 서비스 수준 협약(SLA)에 명시된 시간 내에 장애를 처리하고 복구할 수 있도록 대응절차를 수립·이행하여야 한다.

증거자료

- 장애대응 매뉴얼 및 절차
- 장애조치 보고서
- 서비스 수준협약 (SLA)
- 정보보호 정책서
- 서비스연속성관리지침

부적합 사례

- **사례 1 :** 비상사태 발생 시 클라우드서비스의 연속성 확보 및 피해 최소화를 위하여 백업센터를 구축하여 운영하고 있으나, 백업센터를 활용한 재해 복구 절차 등이 수립되어 있지 않아 재해 복구가 효과적으로 진행되기 어려운 경우
- **사례 2 :** 클라우드서비스 운영과 관련된 일부 중요 클라우드 시스템에 대한 복구 목표시간이 정의되어 있지 않으며, 이에 대한 적절한 복구 대책을 마련하고 있지 않은 경우
- **사례 3 :** 장애 대응절차와 장애 유형별 조치방법 간 일관성이 없거나 예상복구시간 산정에 대한 근거가 부족하여 신속·정확하고 체계적인 대응이 어려운 경우
- **사례 4 :** 최근 발생한 장애 대응 보고 문건들을 확인한 결과, 서비스 수준 협약(SLA)에서 이용자에게 약정한 서비스 중단 시간을 초과하였거나 그 협약을 통해 약정한 이용자 보상이 이루어지지 않은 경우

항목	6.1.4 재발 방지	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○	○	
인증기준	장애 관련 정보를 활용하여 유사한 서비스 중단이 반복되지 않도록 장애 재발방지 대책을 수립하고, 필요한 경우 장애대응 절차도 변경하여야 한다.						
점검항목	공통	1) 심각도가 높은 장애의 경우 원인분석을 통한 재발방지대책을 수립·이행하고 있는가?					
점검목적	실제 사건 발생 후에도 계획이 제대로 작동했는지 평가하고, 재발 방지를 위한 개선을 수행한다.						
참고	• ISMS-P 2.11.5 사고 대응 및 복구 • ISO/IEC 27017 5.27 정보보안 사고로부터 학습						

점검항목 해설

점검항목 1)

■ 심각도가 높은 장애는 복구를 완료한 이후 유사한 장애가 반복적으로 발생하지 않도록 재발방지대책을 수립·이행하여야 한다.

- 재발방지대책은 장애의 원인을 분석하여 원인을 제거하거나 회피수단을 강구하여 적용
- 재발방지대책이 수립되면 해당 내용을 장애가 발생한 서비스를 운영하는 이해관계자 등에게 교육, 통지 등 수행
- 재발방지대책이 장애 조치보고서에 포함된 경우 장애 조치보고서로 증적 대체 가능
- 장애를 조치하는 동안 적용된 절차가 부적절할 경우 장애 대응절차 변경
- 기존 절차에 포함되어 있지 않거나, 현실적인 내용과 다른 경우 장애분석을 통해 개선된 사항을 반영하여 지침/절차를 변경

증거자료

- 장애 조치보고서
- 재발방지 대책
- 장애 대응절차
- 정보보호 정책서
- 서비스연속성관리지침

부적합 사례

- **사례 1 :** 장애 대응절차에 따라 장애 대응 중 부적절한 절차를 발견하였으나 장애 처리 후 개선하지 않은 경우
- **사례 2 :** 장애 처리 후 장애에 대한 조치내역과 재발방지대책을 경영진에게 보고하였으나 장애가 발생한 서비스를 운영하는 이해관계자 등에게 통지하지 않은 경우
- **사례 3 :** 장애 대응 관련 지침, 매뉴얼 등에 장애 처리 후 해당 장애에 대한 재발방지대책을 명시하고 있지 않은 경우

6.2 서비스 가용성

항목	6.2.1 성능 및 용량 관리	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○

인증기준	클라우드컴퓨팅서비스의 가용성을 보장하기 위해 성능 및 용량에 대한 요구사항을 정의하고, 지속적으로 관리할 수 있는 모니터링 방법 또는 절차를 수립하여야 한다.	
점검항목	공통	1) 클라우드 시스템의 성능 및 용량을 지속적으로 모니터링하기 위한 절차를 수립·이행하고 있는가?
	공통	2) 클라우드시스템 성능 및 용량 요구사항(임계치)을 초과하는 경우 조치절차를 수립·이행하고 있는가?
점검목적	정보 처리 시설, 인적 자원, 사무실 및 기타 시설의 필요한 용량을 보장한다.	
참고	• ISMS-P 2.9.2 성능 및 장애관리 • ISO/IEC 27017 8.6 용량 관리	

점검항목 해설

점검항목 1)

■ 고객서비스 및 내부 업무의 연속성을 보장하기 위해 주요 클라우드 시스템의 성능 및 용량을 모니터링 하여야 한다.

- 성능 및 용량 관리가 필요한 대상을 식별
- 식별된 관리대상의 네트워크 대역폭, HW 요구사항(CPU, MEM, HDD, NIC 등) 등의 임계치 정의
- 모니터링 방법 수립 및 설정된 임계치에 따라 모니터링 결과 기록 및 보고
- 성능 및 용량 관리를 담당하는 담당자, 책임자 등의 지정

■ SaaS의 경우 서비스연속성 관리지침에 클라우드서비스의 운영환경에 대한 성능 및 용량 등에 대한 요구사항을 정의하여야 한다.

- 정의된 요구사항에 따라 설정된 임계치에 대한 모니터링을 수행하여야 함

점검항목 2)

■ 정의된 임계치 초과 시 조치절차를 수립·이행하여야 한다.

- 클라우드 시스템의 성능 및 용량을 지속적으로 모니터링
- 임계치 초과 시 조치절차 또는 방안을 수립 및 이행

※ 조치절차 수립 시 참고사항

- 조치절차는 가용성 보장절차에 포함하여 수립하거나 별도로 수립 가능
- IaaS의 경우 시스템, 메모리, 저장장치, 회선 등 증설, 이중화 등
- SaaS의 경우 가상자원의 증설, 네트워크 대역폭 증설

증거자료

- 성능·용량 분석 보고서
- 모니터링 절차서
- 모니터링 대상 및 임계치 현황
- 임계치 초과 시 조치계획
- 정보보호 정책서
- 서비스연속성관리지침

부적합 사례

- **사례 1 :** 클라우드서비스를 운영하는 클라우드 시스템의 성능 및 용량 모니터링 절차를 수립하였으나 성능 및 용량 요구사항(임계치) 초과 시 관련 검토 및 후속조치방안 수립·이행이 이루어지고 있지 않은 경우
- **사례 2 :** 클라우드서비스를 운영하는 클라우드 시스템의 성능 및 용량 모니터링 절차를 수립하였으나 정보시스템의 성능 및 용량 모니터링을 수행하지 않는 경우
- **사례 3 :** 클라우드서비스를 운영하는 클라우드 시스템의 성능 및 용량 모니터링 절차를 수립하고 모니터링을 수행하고 있으나 모니터링 결과를 기록하지 않고 있는 경우

항목	6.2.2 이중화 및 백업		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○		
인증기준	정보처리설비(예 : 클라우드컴퓨팅서비스를 제공하는 물리적인 서버, 스토리지, 네트워크 장비, 통신 케이블, 접속 회선 등)의 장애로 서비스가 중단되지 않도록 정보 처리설비를 이중화하고, 장애 발생 시 신속하게 복구를 수행하도록 백업 체계도 마련하여야 한다.							
점검항목	공통	1) 백업 대상, 주기, 방법, 절차 등이 포함된 백업 및 복구절차를 수립·이행하고 있는가?						
	공통	2) 네트워크 차단, 전력 중단 등 외부의 서비스 장애에 대응하기 위한 중요 장비를 이중화하고 있는가?						
	SaaS	3) 중요정보가 저장된 백업매체의 경우 재난에 대처할 수 있도록 백업매체를 물리적으로 떨어진 장소에 소산하고 있는가?						
점검목적	데이터나 시스템 손실로부터 복구를 가능하게 한다.							
참고	• ISMS-P 2.9.3 백업 및 복구관리, 2.12.1 재해·재난 대비 안전조치 • ISO/IEC 27017 8.13 정보 백업, 8.14 정보처리 시설의 이중화)							

점검항목 해설

점검항목 1)

■ IT 재해, 장애, 침해사고 등 발생 시 적시에 복구하기 위해 백업 및 복구절차를 수립하고 백업담당자 및 책임자를 지정하여야 한다.

- 백업대상(서버 이미지, DB 데이터, 보안로그 등) 선정
- 백업대상별 백업 주기 및 보존기한 정의
- 백업 담당자 및 책임자 지정
- 백업방법 및 절차 : 백업시스템 활용, 매뉴얼 방식 등(백업매체 관리 포함)
- 중요 데이터는 강화된 백업 전략(3-2-1 백업 전략* 등) 적용 권고
  * 원본 외 최소 2개 복사본, 서로 다른 2개 저장매체, 최소 1개는 별도 물리적 위치에 저장
- 복구 담당자 및 책임자 명시
- 백업 대비 복구 우선순위 선정
- 백업이력관리 (백업 관리 대장)
- 백업 소산에 대한 물리적·지역적 사항 고려
- 백업 사이트 구축 및 운영 정책

■ 백업 대상은 대상 정보 및 클라우드 시스템의 중요도를 고려하여 선정하여야 하며 정해진 절차에

따라 백업관리를 수행하여야 한다.

■ 주기적으로 백업이력 등을 검토하고 복구 테스트를 통해 정확성과 무결성을 점검한다.

- 복구 테스트는 분기 1회 이상 권고

■ 복구절차는 복구 테스트 과정을 통하여 적시에 복구가 가능한 절차를 포함하여야 한다.

■ 이용자 데이터 보호 관련 정보 보관 및 복원을 위한 백업 체계를 마련하여야 한다.

- 백업 사이트 구축 및 운영 정책
- 백업 사이트에 대한 위험 관리 정책 등

점검항목 2)

■ 클라우드서비스의 정보처리설비의 중요도 및 복구 우선순위 등에 따라 장애 발생 시 신속하게 복구가 가능하도록 이중화 운영 체계를 마련하여야 한다.

- 네트워크 회선, 네트워크 장비, 전력선 등 이중화
- 이중화 대상이 되는 주요 정보처리시스템 또는 설비 식별 및 이중화 구축
- 중요정보를 저장하고 있는 스토리지
- 중요 클라우드서비스 관련 시스템(단 DR 센터에서 운영하는 정보처리설비는 이중화 필수 요건은 아님)
- SaaS의 주요 정보처리설비는 자체 이중화 구축 또는 IaaS의 이중화 서비스를 이용(계약서에 반영 필요)

점검항목 3)

■ 주요정보가 저장된 백업 매체는 소산 백업을 수행하여야 한다.

- 인프라 사업자의 DR 서비스 활용 가능
- 필요한 경우 소산 보관이 필요한 데이터를 선정하여 소산 백업 수행
- 백업관리대장 작성 및 관리

증거자료

- DR 서비스 계약서
- 시스템 구성도 (이중화)
- 서비스 복구 조직 및 절차
- 백업 관리대장, 백업 절차서

- 정보보호 정책서
- 서비스연속성관리지침

부적합 사례

- **사례 1 :** 백업 대상, 주기, 방법, 절차 등이 포함된 백업 및 복구 절차가 수립되어 있지 않은 경우
- **사례 2 :** 클라우드서비스 관련 백업정책이 수립되어 있으나 백업 담당자 및 책임자, 백업매체 관리 절차, 백업 복구절차가 누락되어 있는 경우
- **사례 3 :** 내부 정책·지침에 따라 별도로 백업하여 관리하도록 명시된 일부 시스템(정보보호시스템 정책 및 로그 등)에 대한 백업이 이행되고 있지 않은 경우
- **사례 4 :** 내부 정책·지침에는 주기적으로 백업매체에 대한 복구 테스트를 수행하도록 정하고 있으나 복구테스트를 장기간 실시하지 않은 경우
- **사례 5 :** 백업정책에서 정보처리설비의 장애로 서비스가 중단되지 않도록 소산하도록 하고 있으나 실제 소산백업을 수행하고 있지 않은 경우

항목	6.2.3 서비스 가용성 점검		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	서비스 가용성에 대한 영향 평가를 주기적으로 점검하여야 한다.							
점검항목	공통	1) 서비스 장애로부터 서비스 연속성을 확보하기 위해 주기적으로 영향 평가를 통해 점검하고 있는가?						
	공통	2) 서비스 장애로부터 서비스 연속성을 확보하기 위한 보안대책이 마련되어 있는가?						
점검목적	사이버 공격, 시스템 장애, 자연재해 등의 상황에서도 핵심 ICT 서비스를 지속적으로 제공하고, 비즈니스 운영을 신속하게 복구할 수 있는 능력을 확보한다.							
참고	• ISMS-P 2.12.2 재해 복구 시험 및 개선 • ISO/IEC 27017 5.30 업무 연속성을 위한 ICT 준비							

점검항목 해설

점검항목 1)

■ 서비스 연속성을 확보하기 위해 주기적으로 비즈니스 영향평가를 검토하고 재해복구 모의훈련 등을 통해 서비스 연속성을 검증, 미흡한 부분은 보완하여야 한다.

- 핵심 서비스 및 자산 식별
- 성능 및 용량 관리 (시스템 성능, 용량 및 리소스 가용성 등)
- 복구 우선순위 및 복구 목표 시간 등 목표 설정 (RTO, RPO 등)
- 복구 전략 수립 및 보완
- 연 1회 이상 주기적 검토 수행

■ 클라우드서비스의 재난 상황 발생 시 신속하게 대응하기 위해 재해 복구 절차 및 훈련 계획을 수립하고, 매년 시행하여야 한다.

- 다양한 재난상황(예: 화재, 지진, 수해 등)을 가정하고, 관련 대응 인력이 모두 포함된 재해복구 모의훈련 계획 수립
- 화재 경보기, 가스 경보기, UPS, 자가발전기 등 재난 상황 대비를 위한 설비의 운영 및 정상 작동 점검 결과
- 시설보호계획, 업무연속성 계획 수립 및 이행 여부
- 재난 대비 및 재해 복구 관련 전문기술자 확보 유무
- 통신 중단, 전원 공급망 장애, 화재 등 재해 상황에 대한 재해 복구 모의 훈련 수행 후 결과보고서 작성 및 보고

※ 타 제도에 의해 클라우드서비스 범위를 포함한 재난 대비 모의훈련을 수행한 경우, 해당 증적으로 재해 복구 상황에 대한 모의훈련 점검 증적 대체 가능

점검항목 2)

■ 서비스 연속성 확보를 보장할 수 있도록 물리적으로 떨어진 곳에 별도 리전 또는 DR서비스를 제공하여야 한다.

■ 별도 제공 리전 또는 DR센터로 서비스 전환, 주센터와 DR센터 간 지리적 거리, 복구시간, 이중화 여부 등을 포함한 자산목록, 네트워크/시스템 구성도, 정책 및 시행문서, DR 소개 자료, DR 이용자 매뉴얼 등을 준비 및 재해 복구를 시연하여야 한다.

〈재해복구센터 구축 조건 예시 〉

필수설비	선택사항
· 클라우드서비스용 서버, 스토리지 · 네트워크 상면 · 주센터와 물리적 분리	· 소프트웨어, 어플리케이션 · 주센터와 지리적 거리(이격 거리) · DR서비스 복구시간 · DR 센터 내 이중화 구성 여부

〈리전 또는 DR센터 체크리스트 예시〉

구분	체크리스트	적합여부
서비스 설명	• 다음 항목의 자료가 준비되었는가?	
	- 데이터 백업을 이용한 리전 전환 가능 여부	적합□ 부적합□
	- 리전 또는 DR 소개 자료 ※ 주센터와 DR센터 간 지리적 거리, 복구시간, 이중화 여부 등 포함	적합□ 부적합□
	- DR 서비스의 정상적인 작동 유무 검증 시연 ※ 장애상황에 따른 DR전환 시나리오 준비 및 시연	적합□ 부적합□
	- 리전 또는 DR 관련 정책 및 지침	적합□ 부적합□
	- (DR관련) 인증평가 대상 자산 목록과 구성도	적합□ 부적합□
	- 고객용 (DR)서비스 설명 컨텐츠 및 이용 매뉴얼	적합□ 부적합□
	- DR서비스제공을 위한 상용솔루션 사용 여부 (DR서비스 제공을 위한 데이터백업, 서비스 전환 등을 위한 상용솔루션 등)	적합□ 부적합□
물리적 구축	• 클라우드서비스용 서버, 스토리지, 네트워크, 상면 등을 구비하고 있는가?	적합□ 부적합□
	• 접근통제가 적절하게 이루어지고 있는가? ※ 8.1. 물리적보호구역 및 8.2. 정보처리시설 및 장비보호에 대한 사항을 점검	적합□ 부적합□

증거자료

- DR 서비스 계약서
- 서비스 연속성 계획
- 비즈니스 영향 평가
- 자산 목록
- 네트워크/시스템 구성도
- DR 소개 자료 및 이용자 매뉴얼
- 정보보호 정책서
- 서비스연속성관리지침

부적합 사례

- **사례 1 :** 클라우드서비스의 연속성 확보를 위한 주기적인 영향 평가를 수행하지 않는 경우
- **사례 2 :** 클라우드서비스의 연속성 확보를 위한 영향 평가에 핵심 서비스는 포함되어 있으나 서비스를 운영하는 서버에 대한 영향 평가가 누락되어 있는 경우
- **사례 3 :** 영향평가를 통해 복구 목표시간 및 복구 목표시점을 정의하고 있으나 수립된 복구 목표시점보다 백업 간격이 더 긴 경우
- **사례 4 :** 재해복구 모의훈련을 수행하고 있으나 중요도가 낮은 서비스를 대상으로 매년 동일한 시나리오로 모의훈련을 진행하는 경우

7. 준거성

7.1 법 및 정책 준수

항목	7.1.1 법적요구사항 준수	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○

인증기준	정보보호 관련 법적 요구사항을 식별하고 준수하여야 한다.	
점검항목	공통	1) 정보보호 관련 법적 요구사항을 식별하고 준수하고 있는가?
점검목적	정보보안과 관련된 법적, 규제적, 계약적 요구사항의 준수를 보장한다.	
참고	• ISMS-P 1.4.1 법적 요구사항 준수 검토 • ISO/IEC 27017 5.31 법적, 규제적, 계약 요구사항, 5.32 지식 재산권, 5.34 프라이버시 및 개인정보 보호	

점검항목 해설

점검항목 1)

■ 클라우드서비스 운영 시 준수해야 할 법적·규제적·계약적 요구사항을 식별하고 준수를 보장하여야 한다.

- 클라우드서비스 운영 시 준수하여야 하는 정보보호 관련 법적·규제적·계약적 요구사항 식별 및 문서화

※ 준수법 예시: 클라우드컴퓨팅법, 정보통신망법, 개인정보 보호법, 위치정보법, 신용정보법, 전자금융거래법, 전자정부법, 가상자산이용자보호법 등

※ 클라우드서비스의 유형 등에 따라 준수해야 할 정보보호 관련 법적 요구사항이 상이할 수 있으며, 세부적인 사항은 관련 법·시행령·지침·고시, 해설서, 가이드라인 등 참고

※ 개인정보보호 관련 각종 가이드, 지침, 해설서, 안내서 등은 개인정보 포털(www.privacy.go.kr) 자료실 참고

■ 요구사항 변경 여부를 연 1회 이상 정기적으로 검토 및 반영하고 그 준수 여부를 입증할 수 있는 증거를 유지해야 한다.

- 법적 요구사항의 준수 여부를 정기적으로 점검할 수 있는 절차 수립(검토 주기, 대상, 담당자, 방법 등) 및 이행
- 요구사항의 제·개정 현황을 모니터링하여 변경사항이 발생한 경우 조직 및 서비스에 미치는 영향 분석
- 필요시 내부 정책·지침·체크리스트 등에 반영하여 최신성 유지

※ 관련 근거 파악·관리 예시

NO	분류	항목	준수 여부	현황	관련법률
1	침해사고	침해사고 발생 시 관계기관 및 이용자에게 통지하는가?	Y	침해사고 발생 시 관계기관 신고절차 및 이용자 통보 절차를 수립·운영하고 있음	클라우드컴퓨팅 발전 및 이용자 보호에 관한법률 제25조
2	개인정보 수집	서비스 제공을 위한 최소한의 정보만 수집하는가?	Y	서비스 제공을 위한 최소한의 정보만 수집하고 있음	개인정보 보호법 제16조
3	개인정보 수집	민감정보 수집 시 정보주체로부터 별도 동의를 받거나 관련 법령을 근거로 수집하고 있는가?	Y	민감정보 수집 시 정보주체로부터 별도 동의를 받아 수집하고 있음	개인정보 보호법 제23조
4	개인정보 이용	개인정보를 제공 받는 경우 제공받은 목적 외의 용도로 이용하지 않는가?	Y	개인정보를 제공 목적 외의 용도로 이용하고 있지 않음	개인정보 보호법 제19조
5	개인정보 파기	개인정보의 보유기간 경과, 처리 목적 달성 시 지체 없이 파기하고 있는가?	Y	클라우드서비스 회원탈퇴 시 5일 이내에 회원 DB에서 삭제하고 있음(단, 전자상거래법에 따른 거래기록은 5년간 분리 보관)	개인정보 보호법 제21조
6	개인정보 처리방침	개인정보 처리방침을 법적 필수 사항을 모두 포함하여 정보주체가 쉽게 확인할 수 있도록 공개하는가?	Y	클라우드 포털사이트 첫화면 하단에 개인정보 처리방침을 법적 필수사항을 모두 포함하여 공개하고 있음	개인정보 보호법 제30조

증거자료

- 식별된 법적 요구사항 목록
- 법적 요구사항 점검 체크리스트
- 법적 요구사항 준수여부 점검 결과

부적합 사례

- **사례 1 :** 정보통신망법, 개인정보 보호법 등 조직에서 준수하여야 할 법률이 개정되었으나, 법률 개정사항을 파악하고 있지 못한 경우
- **사례 2 :** 클라우드서비스에서 개인정보의 처리를 수반하고 있어 개인정보 보호법의 준수가 필요하지만, 클라우드컴퓨팅법 및 정보통신망법만 준수가 필요한 법률로 식별하고 개인정보 보호법을 준수 대상 법률에서 누락한 경우
- **사례 3 :** 법적 요구사항 준수 여부를 주기적으로 점검하기 위한 절차가 수립·이행되고 있지 않은 경우
- **사례 4 :** 법적 요구사항 변경사항을 12개월간 검토하지 않음. '법적 요구사항 준수 프로세스' 문서가 존재하나, 최근 검토 이력이 평가일 기준 12개월 전이 마지막으로 클라우드컴퓨팅법, 정보통신망법 등 관련 법령의 개정사항 반영 여부를 확인할 수 없는 경우

항목	7.1.2 정보보호 정책 준수		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	정보보호 정책 및 서비스 수준 협약에 포함된 보안 요구사항을 식별하고 준수하며 이용자가 요구하는 경우 관련 증거를 제공하여야 한다.							
점검항목	공통	1) 클라우드 정보보호 정책 및 서비스 수준 협약에 포함된 보안 요구사항을 식별하고 준수하고 있는가?						
	공통	2) 이용자 요청 시 보안 요구사항 준수여부에 대한 증거를 제공하고 있는가?						
점검목적	정보보호 활동이 조직의 정보보호 정책과 주제별 정책, 규칙, 표준에 따라 설계되고 작동하도록 보장한다.							
참고	• ISO/IEC 27017 5.36 정보보안 정책, 규칙 및 표준 준수							

점검항목 해설

점검항목 1)

■ 클라우드서비스 정보보호 정책 및 서비스 수준 협약(SLA)에 포함된 보안요구사항을 식별하고 준수하여야 한다.

- 클라우드 보안 요구사항의 준수여부를 내부 보안감사 및 모니터링 등의 활동을 통해 검토

■ 보안요구사항은 관련 법률, 정책, 계약서 및 SLA 등의 내용을 검토한 후 식별하고 체크리스트 형태로 작성하여 준수여부 및 개선방안을 검토한다.

※ 보안요구사항 준수여부 관련 체크리스트 예시

No	구분	관련 조항 그룹	No	점검 항목	평가	수행 현황	개선방안 및 보호대책	이행 계획
1.1	개인정보의 안전성 확보조치 기준	접근 권한의 관리	1.1.1	개인정보처리시스템에 대한 접근 권한을 개인정보취급자에게만 업무 수행에 필요한 최소한의 범위로 차등 부여하고 있는가?				
			1.1.2	개인정보취급자 또는 개인정보취급자의 업무가 변경되었을 경우 지체 없이 개인정보처리시스템의 접근 권한을 변경 또는 말소하고 있는가?				
			1.1.3	개인정보처리시스템의 접근 권한 부여, 변경 또는 말소에 대한 내역을 기록하고, 그 기록을 최소 3년간 보관하고 있는가?				
			1.1.4	개인정보처리시스템에 접근할 수 있는 계정을 발급하는 경우 정당한 사유가 없는 한 개인정보취급자 별로 계정을 발급하고 다른				

No	구분	관련 조항 그룹	No	점검 항목	평가	수행 현황	개선방안 및 보호대책	이행 계획
				개인정보취급자와 공유되지 않도록 하고 있는가?				
			1.1.5	개인정보취급자 또는 정보주체의 인증수단을 안전하게 적용하고 관리하고 있는가?				
			1.1.6	개인정보취급자 또는 정보주체가 일정 횟수 이상 인증에 실패한 경우 개인정보처리시스템에 대한 접근을 제한하는 등 필요한 조치를 하고 있는가?				
1.2		접근통제	1.2.1	정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 개인정보처리시스템에 대한 비인가 접근제한, 개인정보 유출 시도 탐지·대응을 위한 안전조치를 적용하고 있는가?				
			1.2.2	개인정보취급자가 정보통신망을 통해 외부에서 개인정보처리시스템에 접속하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단을 적용하고 있는가?				
			1.2.3	처리하는 개인정보가 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 공개되거나 유출되지 않도록 개인정보처리시스템, 개인정보취급자의 컴퓨터 및 모바일 기기 등에 조치를 하고 있는가?				
			1.2.4	개인정보취급자가 일정시간 이상 업무처리를 하지 않는 경우에는 자동으로 접속이 차단되도록 하고 있는가?				
			1.2.5	개인정보처리시스템에서 개인정보를 다운로드 또는 파기할 수 있거나 개인정보처리시스템에 대한 접근 권한을 설정할 수 있는 개인정보취급자의 컴퓨터 등에 대한 인터넷망 차단 조치를 하고 있는가?				
1.3	클라우드 서비스 SLA	이용자 장애 통지	1.3.1	사전 예고 없이 SLA에서 정한 기준(10분) 이상 연속해서 서비스 중단이 발생한 경우, 해당 사실을 이용자에게 지체 없이 알리고 있는가?				

점검항목 2)

■ 이용자가 보안요구사항 준수여부에 대한 증거 요청 시 제공하여야 한다.

- 이용자 요청시 보안 요구사항 준수 증거를 계약서 또는 SLA에 명시된 기한내에 제공
- 보안요구사항 준수여부 증거는 인증서, 감사보고서, 로그 기록, 정책 문서 등을 포함
- 이용자에게 증거 제공을 위한 프로세스를 문서화하고 이를 이용자에게 고지

증거자료

- 정보보호 정책서
- 계약서, 서비스 준수 협약서
- 식별된 보안요구사항 준수 여부 검토 결과

부적합 사례

- **사례 1 :** 클라우드서비스 정보보호 정책 및 서비스 수준 협약(SLA)에 포함된 보안요구사항이 별도로 식별·관리되고 있지 않은 경우
- **사례 2 :** 클라우드서비스 관련 보안요구사항에 대해 체크리스트를 작성하여 정기적으로 점검하고 있으나, 해당 체크리스트에 최근에 개정된 정보보호 정책 관련 내용이 반영되어 있지 않은 경우

7.2 보안감사

항목	7.2.1 독립적 보안감사	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○		

인증기준	법적 요구사항 및 정보보호 정책 준수 여부를 보증하기 위해 독립적 보안감사 계획을 수립하여 시행하고 개선 조치를 취하여야 한다.	
점검항목	공통	1) 클라우드 보안 요구사항의 준수여부를 보증하기 위해 독립적 감사 계획을 수립하여 시행하고 있는가?
	공통	2) 감사결과를 정보보호 최고책임자에게 보고하고 발견된 사항에 대해 개선조치를 취하고 있는가?
점검목적	정보보안 관리에 대한 조직의 접근법의 지속적인 적절성과 타당성, 효과를 보장한다.	
참고	• ISMS-P 1.4.2 관리체계 점검 • ISO/IEC 27017 5.35 독립적인 정보보안 검토	

점검항목 해설

점검항목 1)

■ 다음의 항목을 포함한 독립적인 보안감사 계획을 수립하고 연 1회 이상 수행하여야 한다.

- 보안감사 점검 인원
  - 보안감사는 객관성·전문성·독립성 확보를 위해 외부인력 수행이 바람직하나 내부인력 활용 시 클라우드서비스 업무와 독립적인 업무를 담당하는 자로서 보안감사 역량을 보유한 자를 선임
- 보안감사 점검 인원의 자격요건 정의
  - 점검의 객관성, 전문성 등을 확보할 수 있도록 자격요건을 정의
- 보안감사 범위
  - 클라우드컴퓨팅 및 정보보호 관련 법률 준수
  - 클라우드서비스 보안운영 명세서 내의 점검항목
  - 규정(정책, 지침 등 명칭 무관)의 준수사항을 포함한 규정 대비 이행 여부 점검

■ ISMS 인증항목을 기준으로 감사를 수행할 경우 클라우드서비스 보안인증에 관한 고시 등에서 요구하는 항목이 누락되지 않도록 적절한 감사항목을 정의하여야 한다.

점검항목 2)

■ 보안감사 결과보고서를 작성하여 정보보호 최고책임자에게 보고하여야 한다.

- 보안감사 완료 후 결과보고서를 작성하여 정보보호 최고책임자 및 개인정보보호책임자 등 경영진에게 보고

■ 보안감사 결과 보완이 필요한 사항이 발견된 경우에는 해당 사항에 대한 조치계획을 수립하여 정보보호최고책임자에게 보고 및 이행하여야 한다.

- 조치 완료여부에 대하여도 확인 수행

증거자료

- 보안감사 계획서
- 보안감사 결과보고서
- 보안감사 이행조치결과서

부적합 사례

- **사례 1 :** ISMS 인증기준을 기반으로 보안감사를 수행함에 따라, 클라우드컴퓨팅법 및 클라우드 보안인증 관련 보안요건이 점검항목에서 일부 누락된 경우
- **사례 2 :** 보안감사 인력에 점검 대상으로 식별된 전산팀 직원이 포함되어 전산팀 관리 영역에 대한 점검에 관여하고 있어, 보안감사의 독립성이 훼손된 경우
- **사례 3 :** 보안감사 수행 이후 발견된 문제점에 대해 조치계획을 수립하였으나, 조치 완료 여부를 확인하지 않아 보안감사 지적사항 중 특별한 사유 없이 미조치된 경우가 다수 존재하는 경우

항목	7.2.2 감사기록 및 모니터링		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○	○	
인증기준	보안감사 증적(로그)은 식별할 수 있는 형태로 기록 및 모니터링 되어야 되고 비인가된 접근 및 변조로부터 보호되어야 한다.							
점검항목	공통	1) 보안감사 증적(로그)을 식별하고 로그유형 및 보존기간의 법적요건을 고려하여 기록(보관), 검토하고 있는가?						
	공통	2) 로그기록을 별도 저장장치를 통해 백업하고 비인가된 접근 및 변조로부터 보호하고 있는가?						
점검목적	이벤트를 기록하는 로그가 작성되고 저장되며 보호되는지 여부를 확인한다.							
참고	• ISMS-P 2.9.5 로그 및 접속기록 접검 • ISO/IEC 27017 5.33 기록 보호, 8.15 로깅, 8.16 모니터링 활동							

점검항목 해설

점검항목 1)

■ 법적 요건을 고려하여 보관하여야 할 보안감사 증적(로그)을 식별하고 유형 및 기간을 정하여야 한다.

- 시스템 설계 시 보안감사 기록유형을 정의 (예: 사용자 접속 기록, 인증 성공/실패 로그, 권한 등록/변경/삭제 등)
- 시스템 설계 시 보안감사 증적으로 생성되어야 하는 로그항목을 선정 (예: 사용자 접속 기록의 경우 접속일시, ID, 접속지 IP, 처리한 정보주체 정보, 수행업무 등 (예: 이용자/사용자 식별 및 인증, 관리자의 관리행위, DB 접근 등)
- 생성된 보안감사 증적은 법률에 따라 보관 (최소 1년 이상 등)

※ 항목별 감사 로그 보관기한 관리 서식 예시

구분	로그 항목	보관 기간	법적 근거	비고
클라우드컴퓨팅법				
정보통신망법				
개인정보보호법				
전자금융거래법				
~법				

- 보안로그의 위·변조에 대비한 무결성 보장 적용, 도난, 분실 등을 방지하기 위한 대책 마련

■ 응용프로그램 내의 보안감사(접근기록 등) 증적 외에도 윈도우시스템, 리눅스/유닉스시스템, 데이터베이스, WEB/WAS, 네트워크 장비, 보안시스템 등에 대한 로그도 생성, 보관, 모니터링되어야 한다.

※ 특히, 클라우드 관리콘솔에 접속하여 수행한 업무내역(클라우드 설정 변경 등)에 대해서도 로그를 생성, 보관 및 모니터링 수행

※ 보안감사 로그 예시

구분	설명
보안 관련 감사로그	- 사용자 접속기록(사용자 식별정보 : ID, 접속일시, 접속지 : 단말기 IP, 처리한 정보주체 정보, 수행업무 : 정보 생성, 수정, 삭제, 검색 출력 등) - 인증 성공/실패 로그 - 파일 접근 및 설정 변경 - 계정 및 권한 등록/변경/삭제 - 정보시스템 시작 및 중지, 특수 권한으로의 접근 기록 - 주요 업무관련 행위에 대한 로그 등
시스템 이벤트 로그	- 운영체제 구성요소에 의해 발생되는 로그(시스템 시작, 종료, 상태, 에러코드 등)
보안시스템 로그	- 관리자 행위 로그 - 보안시스템 정책(룰셋 등) 등록/변경/삭제 로그 - 이벤트 로그 등
개인정보처리시스템 접속기록	- 개인정보취급자의 접속기록(식별자 : 개인정보취급자 ID 등, 접속일시, 접속지 정보 : 단말기 IP주소 등, 처리한 정보주체 정보, 수행업무 : 생성, 입력, 수정, 삭제, 검색 출력, 다운로드 등)

■ 보관되고 있는 보안감사 증적을 모니터링할 수 있는 수단을 마련하여야 한다.

- 보안감사 증적을 이벤트별 조회, 사용자별 조회, 키워드를 적용한 조회, 날짜별 조회 등 다양한 조회 기능 적용
- 비정상적인 사건(연속된 인증실패, 저장 및 전송데이터 훼손, 대량의 데이터 다운로드 등)이 발생한 경우 알람 기능 적용
- 보안관제 시스템, 통합보안관리 시스템 등을 이용한 자동화된 모니터링 적용 등

■ 보안감사 증적 중 개인정보처리시스템에 대한 접속기록은 월 1회 이상 또는 개인정보처리자가 내부관리계획에서 정한 주기에 따라 점검하여야 하며, 기타 시스템의 감사로그는 이용자의 요구사항 또는 클라우드서비스 제공자의 정책 및 지침에 따라 정기적으로 검토되어야 한다.

- 개인정보취급자의 개인정보처리시스템에 대한 접속기록 및 개인정보의 다운로드 상황을 확인하고 점검하는 주기·방법·사후조치 절차 등이 내부 관리계획에 따라 이행되는지 확인

■ 로그 검토기준에 따라 검토 한 후 이상징후 여부 등 그 결과를 관련 책임자에게 보고하여야 한다.

■ 이용자가 감사 로그를 요청할 경우 제공하여야 한다.

점검항목 2)

■ 보안감사 증적은 별도 저장장치에 백업하여야 하며, 비인가된 접근 및 변조로부터 보호되어야 한다.

- 시스템 설계 시 보안감사 증적에 대하여 비인가된 접근차단, 변조방지 기능 적용
- 보안감사 증적의 백업데이터(백업매체)에 대한 비인가된 접근 및 변조에 대한 관리적 보안대책 적용

증거자료

- 보안감사 로그 유형, 보존기간 등 현황
- 로그 백업 대장
- 로그기록 백업매체 관리 증적
- 로그기록 검토/보고 증적

부적합 사례

- **사례 1 :** 로그 기록 대상, 방법, 보존기간, 검토 주기, 담당자 등에 대한 세부 기준 및 절차가 수립되어 있지 않은 경우
- **사례 2 :** 클라우드서비스 관련 보안감사 로그 및 개인정보처리시스템의 접속기록을 오브젝트 스토리지에 보관하고 있으나, 보관기간을 1년 미만으로 설정하고 있는 경우
- **사례 3 :** 중요 서버에 대한 로그 기록을 별도로 백업하거나 적절히 보호하지 않아 사용자의 명령 실행 기록 및 접속 이력 등을 임의로 삭제할 수 있는 경우
- **사례 4 :** 개인정보 내부 관리계획에는 1,000명 이상의 정보주체에 대한 개인정보를 다운로드한 경우에는 사유를 확인하도록 기준이 책정되어 있는 상태에서 1,000명 이상의 개인정보 다운로드가 발생하였으나 그 사유를 확인하지 않고 있는 경우

Ⅱ 물리적 보호조치

8. 물리적 보안

8.1 물리적 보호구역

항목	8.1.1 물리적 보호구역 지정		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○	○	
인증기준	중요 정보 및 정보처리시설을 보호하기 위한 물리적 보안 구역(예 : 주요 정보처리 설비 및 시스템 구역, 사무실, 외부인 접견실 등)을 지정하고, 각 보안 구역에 대한 보안 대책을 마련하여야 한다.							
점검항목	공통	1) 주요 설비 및 시스템을 보호하기 위하여 물리적 보호구역을 다음과 같이 정의하고 구역별 보호대책을 수립·이행하고 있는가? - 접견구역 : 외부인 접견 구역 - 제한구역 : 사무실 지역 등 - 통제구역 : 클라우드서비스 운용 설비 및 시스템 구역 등						
점검목적	중요 정보와 정보처리시설을 보호하기 위하여 보안 구역을 정의하고 구역별 적절한 물리적 통제를 적용하여 무단 접근과 보안 위협을 예방한다.							
참고	• ISMS-P 2.4.1 보호구역 지정 • ISO/IEC 27017 7.1 물리적 보안 경계							

점검항목 해설

점검항목 1)

■ 중요정보 저장시설, 서비스의 주요 장비가 운영되는 시설 등 서비스의 주요 물리적인 시설을 안전하게 보호하기 위해 중요도에 따라 분류하여 지정하고, 물리적인 접근통제 대책을 수립하여 적용하여야 한다. 이때 보안구역 기준은 문서화되고 정기적으로 검토 및 갱신되어야 한다.

※ 예) 중요도에 따라 접견구역, 제한구역, 통제구역으로 분류

- 접견구역 : 외부인이 별다른 통제 없이 출입이 가능한 구역
- 제한구역 : 비인가된 접근을 방지하기 위하여 별도의 출입통제 장치 및 감시시스템이 설치된 장소로 출입 시 직원카드와 같은 출입증이 필요한 장소

• 통제구역 : 제한구역의 통제항목을 모두 포함하고 출입자격이 최소인원으로 유지되며 출입을 위하여 추가적인 절차가 필요한 곳

접견구역	제한구역	통제구역
· 외부인이 통제없이 출입 가능	· 내부직원은 출입이 허용되나 외부인은 출입이 통제 · 출입통제 장치 등으로 인가된 인원만 출입 가능 · 사무실 복도 등에 CCTV 등 보안장치 설치 및 모니터링	· 외부인은 물론 내부직원이라도 필요한 최소한의 인원만 출입 가능 · 제한구역보다 더 엄격한 출입통제 적용 · CCTV 등 보안장치 설치 및 모니터링 · 출입을 위해 추가적인 신청, 검토, 승인 등의 절차 필요 · 비인가자 출입 시 인가자에 의한 인솔 등 필요
· 접견장소 등	· 각 부서별 사무실 등	· 전산실 · 통신장비실 · 관제실 · 운영실 · 공조실 · 발전실 등

■ 내부직원, 외부직원(유지보수 등), 제3자의 출입에 대한 출입절차를 수립하여 적용하여야 한다.

■ 통제구역은 반드시 인가된 인원만 출입을 허용하여야 하며, 인가자를 최소한으로 제한하여야 한다.

■ 통제구역임을 표시하고 비인가된 접근시도 여부를 주기적으로 검토하여야 한다.

■ 클라우드컴퓨팅시스템은 일반 정보시스템과 분리 운영되어야 하며, 별도 케이지 등을 설치하여 출입 및 출입기록을 관리하여야 한다.

- 데이터센터 시설 내 클라우드 컴퓨팅 서비스 제공을 위한 시스템의 물리적 위치를 파악하고 물리적 보호구역에 대한 보안대책을 마련
- 데이터센터 시설 내 화재, 전력 이상 등 인재 및 자연재해 등에 대비하여 필요한 설비를 구축하고 현황을 관리

■ 각 보호구역의 중요도 및 특성을 반영하여 작업 절차를 수립하고 필요 설비를 갖추어야 한다.

증거자료

- 정보보호 정책서
- 물리적보안지침
- 보호구역 지정 현황

- 보호구역 물리적 보안대책
- 시스템 구성도(물리적 구성 확인 가능)

부적합 사례

- **사례 1 :** 주요 설비 및 시스템을 보호하기 위한 물리적 공간(전산실, 관제실, 공조실, 발전실, 전원실, 부서별 사무실, 로비 등)에 대해 보호구역을 정의하지 않는 경우
- **사례 2 :** 내부 정책·지침에서 통제구역, 제한구역, 접견구역으로 물리적 보호구역을 정의하도록 하고 있으나 보호구역에 대한 보호대책을 명시하지 않는 경우
- **사례 3 :** 클라우드 시스템과 일반 정보시스템을 분리하지 않고 혼용하여 운영하는 경우
- **사례 4 :** 내부 정책·지침에서 보안구역 표시 방법을 명시하지 않고 있거나 통제구역을 제한구역으로 표시하고 있는 경우

항목	8.1.2 물리적 출입통제		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○	○	
인증기준	물리적 보안 구역에 인가된 자만이 접근할 수 있도록 출입을 통제하는 시설(예 : 경비원, 출입 통제 시스템 등)을 갖추어야 하고, 출입 및 접근 이력을 주기적으로 검토하여야 한다.							
점검항목	공통	1) 물리적 보호 구역에 인가된 자만이 접근할 수 있도록 출입을 통제하는 시설(예 : 출입 통제 시스템 등)을 갖추고 있는가?						
	공통	2) 주기적으로 통제구역의 출입명단 및 출입카드 발급 현황을 검토 및 승인하고 더 이상 출입하지 않는 직원은 출입명단에서 삭제하고 있는가?						
점검목적	물리적 보안 구역에 대한 접근을 통제하고 출입 이력을 검토하여 무단 접근을 방지하고 자산의 기밀성·무결성·가용성을 보호한다.							
참고	• ISMS-P 2.4.2 출입통제 • ISO/IEC 27017 7.2 물리적 출입							

점검항목 해설

점검항목 1)

■ 물리적 보호 구역에 인가된 자만이 접근할 수 있도록 출입을 통제하는 설비(예 : 출입 통제 시스템, 생체 인식 장치 등)을 설치·운영하여야 하며, 접근 권한은 정보자산의 중요도 및 위험 수준에 따라 결정되어야 한다.

- 출입 통제 시스템은 지식 기반(비밀번호), 소유 기반(출입카드 등), 생체 기반(지문, 홍체, 정맥 등), 행위 기반(패턴 등) 중 자산의 중요도 및 통제 목적 등을 고려하여 선택 하되 다중 인증(MFA)을 권고가능
- 비밀번호 방식의 지식 기반 출입 통제 시스템을 사용할 경우 출입 및 접근 이력관리를 위해 출입관리대장 등을 작성 (CCTV 등을 통한 출입 유무에 대한 모니터링 수행 병행)하여 무결성과 책임 추적성을 확보할 수 있어야 함

점검항목 2)

■ 통제구역 인가자의 명단 및 출입카드 발급 현황을 주기적(예: 분기 1회 이상)으로 검토하여야 한다.

■ 출입이 인가된 인력 중 퇴사, 역할의 변경, 전보 등으로 인가 대상에서 제외되는 경우 즉시 출입 권한을 회수하고 출입 통제 시스템에 반영하여야 한다.

■ 주기적으로 통제구역의 출입명단(장비 반출입 포함) 및 출입카드 발급 현황을 검토 및 승인하고 더 이상 출입하지 않는 직원은 출입명단에서 삭제하여야 한다.

■ 물리적 보안 구역에 출입 및 접근한 이력을 내부 정책·지침에 따라 보관 및 주기적으로 검토하고 이상 징후가 있을 경우 즉시 조사 및 대응하여야 한다.

증거자료

- 보호구역 지정 현황
- 보호구역 물리적 보안대책
- 보호구역 인가자 목록
- 출입관리대장
- 출입카드 발급현황
- 출입자 이력 검토 증적
- 정보보호 정책서
- 물리적보안지침

부적합 사례

- **사례 1 :** 내부 정책·지침에서 보호구역별 보호대책을 명시하고 있으나 통제구역, 제한구역에 지침에서 명시한 보호대책(출입통제시스템 등)을 적용하지 않는 경우
- **사례 2 :** 통제구역의 출입통제를 위해 설치한 출입통제시스템에 클라우드서비스 운영을 담당하지 않는 임직원 및 외부자에 대한 출입등록이 되어 있는 경우
- **사례 3 :** 통제구역 접근기록(CCTV, 출입기록 등)을 보관하고 있으나, 모니터링 하고 정기적으로 분석하는 절차가 없어 이상 접근(근무 시간 외 출입 등)을 탐지하지 못하는 경우
- **사례 4 :** 출입통제시스템에 등록되어 있는 임직원 및 외부자 중 퇴사자, 휴직자, 직무 변경자, 계약 만료된 외부자가 존재하는 경우

항목	8.1.3 물리적 보호구역 내 작업		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	유지보수 등 주요 정보처리 설비 및 시스템이 위치한 보호구역 내에서의 작업 절차를 수립하고 작업에 대한 기록을 주기적으로 검토하여야 한다.							
점검항목	공통	1) 클라우드 시스템 도입, 유지보수 등으로 보호구역 내 작업이 필요한 경우 작업신청 및 수행 관련 절차를 수립하고 작업기록을 주기적으로 검토하고 있는가?						
	공통	2) 클라우드 시스템이 위치한 통제구역 내 모바일기기(노트북, 스마트기기 등) 사용 방지 및 불법적인 활동을 모니터링(예: CCTV) 하기 위한 대책이 마련되어 있는가?						
점검목적	보호구역 내 작업을 절차에 따라 통제하고 기록을 검토함으로써 무단 활동을 방지하고 정보처리설비의 보안성과 무결성을 유지한다.							
참고	• ISMS-P 2.4.5 보호구역 내 작업 • ISO/IEC 27017 7.6 보안 구역에서의 작업							

점검항목 해설

점검항목 1)

■ 통제구역에서 정보시스템 도입·변경·폐기, 유지보수(정기점검 포함) 등의 작업을 수행할 경우 보안위험 발생 가능성을 고려한 정형화된 작업 절차를 수립하고, 이를 적절히 승인·관리하여야 한다.

- 작업이 수행하기 전에 작업신청서를 통한 신청 및 신청에 대한 검토·승인
  - 작업신청서에는 작업자(내부인력 or 외부인력 등), 작업일시, 작업목적, 작업수행에 필요한 기기(노트북, USB, 네트워크, 모바일 기기 등)에 대한 안전성 확보 등이 포함되어야 함
- 작업수행을 위한 보호구역 출입절차 마련

■ 작업 완료 후 결과를 포함하여 작업 이력을 기록하고 주기적으로 검토함으로써 작업의 적정성과 보안성 확보 여부를 확인하여야 한다.

- 작업기록에는 작업일자, 작업시간, 작업목적, 작업내용, 작업업체 및 담당자명, 검토자, 승인자 등 포함
- 출입기록 및 작업기록의 위험도에 따른 주기적 검토(예: 분기 1회 이상)

점검항목 2)

■ 통제구역 내에서 작업을 수행하는 경우 모바일기기(노트북, 스마트폰, 태블릿 PC, 이동 매체)에 대한 사용은 원칙적으로 금지하여야 한다.

■ 해당 작업에 불가피하게 모바일 기기를 사용해야 하는 경우 반드시 사전에 검토 및 책임자 승인을 받고 사용하여야 한다.

- 작업 수행을 위한 모바일기기 반출입 및 안전성 확보 절차(백신 설치 등 필수 소프트웨어 설치) 마련
- 작업 완료 후 관련 이력 및 매체 반출입 기록 관리

증거자료

- 보호구역 내 작업 절차
- 작업 신청서
- 출입관리대장(출입카드 발급현황 등)
- 작업 기록서
- 통제구역 CCTV 배치도
- 모바일기기 반출입관리대장 (백신 등)
- 통제구역에 대한 출입기록 및 작업기록 검토 내역
- 정보보호 정책서
- 물리적보안지침

부적합 사례

- **사례 1 :** 작업 신청을 수행하지 않고 통제구역(전산실 등)에서 정보시스템 도입 및 폐기, 유지보수 작업을 수행하는 경우
- **사례 2 :** 통제구역 작업 시 작업기록에 작업일자, 작업시간, 작업목적, 작업내용, 작업업체 및 담당자명, 검토자, 승인자를 기록하지 않는 경우
- **사례 3 :** 통제구역에 대한 작업기록을 주기적으로 검토하여 검토 내용을 책임자에게 승인받지 않는 경우
- **사례 4 :** 작업 중 사용된 USB, 노트북 등 반입 가능한 모바일 기기에 대한 보안성 검토 또는 반출 기록이 존재하지 않은 경우

항목	8.1.4 사무실 및 설비 공간 보호		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	사무실 및 설비 공간에 대한 물리적인 보호방안을 수립하고 적용하여야 한다.							
점검항목	공통	1) 팩스, 복사기, 프린터, 공용 PC, 파일서버, 문서고 등 공용으로 사용하는 사무장비 및 시설에 대한 보호대책을 수립·이행하고 있는가?						
	공통	2) 공용업무 환경 보안에 대한 관리자를 지정하고 준수여부를 주기적으로 검토하고 있는가?						
점검목적	사무실 및 설비 공간에 적절한 물리적 보호조치를 적용하여 자산의 기밀성·무결성·가용성을 확보한다.							
참고	• ISMS-P 2.4.3 정보시스템 보호 • ISO/IEC 27017 7.3 사무실, 공간 및 시설 보안							

점검항목 해설

점검항목 1)

■ 공용으로 사용하는 사무기기 및 공용 업무 공간에 대한 정보 유출, 비인가 접근 및 오남용 방지를 위한 물리적·기술적 보호대책을 수립하고 이행하여야 한다.

- 공용사무기기 : 팩스, 복사기, 프린터, 복합기, 공용 PC
  - 공용사무기기 주변 및 공용사무실(회의실, 프로젝트룸 등)에는 주요문서 등이 방치되지 않도록 조치
  - 공용PC의 경우 화면보호기 설정, 재시작 시 암호설정, 공용 패스워드의 주기적인 변경, 주요정보 저장 금지 등을 적용
- 파일서버 : 공용으로 사용되는 파일서버의 경우 부서별, 업무별, 사용자별로 접근권한을 부여하여야 하며, 주요파일은 가급적 공용으로 사용하는 파일서버에 저장하지 않도록 조치
- 문서고 : 문서고에 대한 접근권한을 부서별 혹은 업무별로 부여하여 출입가능인원을 최소화하고 CCTV 혹은 출입통제시스템을 설치하여 출입이력을 관리
- 기타 공용 업무환경에 대한 보안대책 수립

점검항목 2)

■ 공용으로 사용하는 사무기기, 공용사무실 등에 대한 관리를 위해 관리담당자를 지정하고 수립된 보호대책이 준수되고 있는지 주기적으로 점검하여야 한다.

증거자료

- 공용 사무기기 현황 및 보호대책
- 공용업무환경 보안 관리자 지정
- 공용업무환경 점검 내역
- 정보보호 정책서
- 물리적보안지침

부적합 사례

- **사례 1 :** 내부 정책·지침에서 공용으로 사용하는 복합기, 공유 PC, 파일서버, 문서고 등의 사무장비 및 시설에 대한 보호대책이 수립되지 않는 경우
- **사례 2 :** 복합기, 공용PC 등 공용사무기기에 중요정보나 개인정보가 저장되어 있는 경우
- **사례 3 :** 공용업무 환경 보안을 담당하는 관리자를 지정하지 않는 경우
- **사례 4 :** 공용업무 환경 보안 담당자가 공용업무 환경 보안 준수 여부를 주기적으로 검토하지 않는 경우
- **사례 5 :** 공용PC에 무단 설치된 소프트웨어가 있거나, OS 패치 및 백신 업데이트 등 보안 관리가 되고 있지 않은 경우

항목	8.1.5 모바일 기기 반출입	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○			○		
인증기준	노트북 등 모바일 기기 미승인 반출·입을 통한 중요정보 유출, 내부망 악성코드 감염 등의 보안사고 예방을 위하여 보호구역 내 임직원 및 외부인력 모바일 기기 반출·입 통제절차를 수립하고 기록·관리하여야 한다.						
점검항목	공통	1) 노트북, 패드 등 모바일 기기 반출·입 시 반출·입 통제 및 보안사고 예방 절차를 수립하고 있는가?					
	공통	2) 모바일 기기 반출·입 절차에 따라 반출·입 대장을 작성하고 관리자는 주기적으로 모바일 기기 반출·입 이력을 점검하고 있는가?					
점검목적	보호구역 내 모바일 기기의 반출·입을 통제하여 중요정보 유출 및 악성코드 감염 등 보안사고를 예방하고 구역의 보안성을 유지한다.						
참고	• ISMS-P 2.4.6 반출입 기기 통제 • ISO/IEC 27017 7.9 외부 자산 보안						

점검항목 해설

점검항목 1)

■ 보호구역별로 모바일기기(노트북, 태블릿 컴퓨터 등)의 반출·입에 대한 통제절차를 수립하여 적용하여야 한다.

- 보호구역 출입 전 반출·입 및 보안성 점검 절차(보호구역 출입통제 책임자의 사전 승인 등)
- 반·출입 관리대장 등에 기록 및 출입 전 모바일 기기 보안 점검 절차 포함
- 모바일 기기 반출·입내역 주기적 점검 절차
- 보안사고 예방절차 등 포함 (백신 설치 감사, 모바일 기기의 카메라 차단 등)
- 외부의 모바일 기기는 원칙적으로 반입을 금지하고 필요한 경우 내부에서 관리되고 있는 모바일 기기를 사용하도록 절차 수립
- USB 사용이 필요한 경우 보안USB 사용
- 개인 소유 기기 반입은 원칙적으로 금지 등 예방 절차 포함

점검항목 2)

■ 보호구역 내로 모바일기기를 반출·입하는 경우 반출·입에 대한 이력을 기록하여 내부정책·지침에 따라 보관(예: 최소 6개월 이상) 유지하여야 하며, 담당자는 주기적으로 기록을 검토하여야 한다.

■ 기록(반출·입 관리대장 등)에는 반출·입 일시, 사용자, 기기식별정보(모델, MAC, 시리얼 번호 등), 사유, 반출·입 구역, 보안점검 결과, 관리자 확인 서명 등

증거자료

- 모바일기기 반출·입 통제 절차 (백신 설치, 카메라 보안 씰 등 포함)
- 모바일기기 반출·입 신청서 및 승인 문서
- 모바일기기 반출·입 이력 검토 내역
- 정보보호 정책서
- 물리적보안지침

부적합 사례

- **사례 1 :** 통제구역 내 작업시 책임자의 승인을 받았으나, 백신설치, 저장매체 통제 적용 등 보안성이 확보 되지 않은 개인 기기를 사용하여 작업한 경우
- **사례 2 :** 내부 지침에 따라 전산장비 반출·입이 있는 경우 관리대장 내 반출입 내용을 기재하고 관리책임자의 서명을 받도록 되어있으나, 반출입 기록에 세부내용(일시, 사용자, 기기정보 등), 관리책임자의 서명 등이 누락되어 있는 경우
- **사례 3 :** 통제구역에서의 모바일기기 반출·입 이력을 주기적으로 검토하지 않는 경우

8.2 정보처리 시설 및 장비보호

항목	8.2.1 정보처리시설의 배치		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	물리적 및 환경적 위험으로부터 잠재적 손상을 최소화하고 비인가된 접근 가능성을 최소화하기 위하여, 정보처리시설 내 장비의 위치를 파악하고 배치하여야 한다.							
점검항목	공통	1) 클라우드시스템의 특성을 고려하여 배치 장소를 분리하고 있는가?						
	공통	2) 클라우드시스템의 실제 물리적 위치를 손쉽게 확인할 수 있는 방안(배치도, 자산목록 등)을 마련하고 있는가?						
점검목적	장비의 적절한 위치 선정과 배치를 통해 물리적·환경적 위험과 비인가 접근 가능성을 최소화하여 정보처리시설의 안정성과 보안성을 확보한다.							
참고	• ISO/IEC 27017 7.8 장비 배치 및 보호							

점검항목 해설

점검항목 1)

■ 서버, 네트워크 장비, 정보보호시스템, 백업장치 등 정보시스템은 중요도 및 특성(유형, 가용성 등)에 따라 분리하여 배치하고, 잠금 가능한 전산랙(Rack), 보안 케이지 등을 이용하여 시스템을 외부로부터 보호하여야 한다.

- 침수, 화재, 전력 이상, 진동 등 물리·환경적 위협을 고려하여 적절한 위치에 배치
- 정보시스템의 수량이 많지 않을 경우 하나의 전산랙에 배치하되 특성별 분리 배치 가능

■ 개인정보 또는 기밀정보 등 중요정보를 저장하고 있는 서버나 중요 네트워크 장비(백본 등)의 경우 전산랙에 잠금장치를 설치하는 등 인가된 자에 한해 접근이 가능하도록 관리하여야 한다.

점검항목 2)

■ 정보시스템은 관리자가 즉시 위치를 확인할 수 있도록 물리적 배치도(시설 단면도, 배치도 등) 또는 목록을 마련하여 최신본으로 관리하여야 한다.

- 시스템 정보자산목록에 물리적 위치를 표시
- 목록에서 물리적 배치를 확인 가능하도록 최신현황 유지

■ 장비 이동, 신규 설치, 철거 등 위치 변경 시 변경관리 절차에 따라 검토·승인 후 반영되어야 하며, 위치정보는 권한이 있는 담당자만 열람할 수 있도록 관리하여야 한다.

증거자료

- 정보자산 배치도
- 정보자산 목록
- 정보보호 정책서
- 물리적보안지침

부적합 사례

- **사례 1 :** 클라우드서비스를 운영하는 서버, 네트워크 장비, 정보보호시스템, 백업장치 등의 정보시스템을 도입 순서대로 랙에 설치하여 특성별 분리되지 않은 경우
- **사례 2 :** 클라우드서비스를 운영하는 서버, 네트워크 장비, 정보보호시스템, 백업장치 등의 정보시스템을 전산랙(Rack)에 보관하지 않고 전산실 내 임의의 장소에 설치하여 사용하는 경우
- **사례 3 :** 클라우드서비스를 운영하는 어떤 정보시스템이 어떤 전산랙(Rack)에서 운영되고 있는지 파악하지 못하는 경우
- **사례 4 :** 클라우드서비스를 운영하는 정보시스템이 보관되고 있는 배치도가 현행화 되지 않는 경우

항목	8.2.2 보호설비		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	각 보안 구역의 중요도 및 특성에 따라 화재, 누수, 전력 이상 등 자연재해나 인재에 대비하여 화재 감지기, 소화 설비, 누수 감지기, 항온 항습기, 무정전 전원 장치(UPS), 이중 전원선 등의 설비를 갖추어야 한다.							
점검항목	공통	1) 각 보호구역의 중요도 및 특성에 따라 화재, 전력 이상 등 인재 및 자연재해 등에 대비하여 필요한 설비를 갖추고 운영절차를 수립·관리하고 있는가?						
	공통	2) 보호구역 내 주요 시스템 및 인력을 화재로부터 보호하기 위하여 필요한 설비를 설치하고 지속적으로 운영·관리하고 있는가?						
	공통	3) 보호구역 내 주요 시스템을 수해로부터 보호할 수 있도록 누수를 탐지할 수 있는 설비를 설치하고 지속적으로 운영·관리하고 있는가?						
	공통	4) 보호구역 내 주요 정보시스템이 안정적인 환경에서 동작할 수 있도록 적절한 온도와 습도를 유지시키는 항온항습 또는 에어컨을 설치하여 운영·관리하고 있는가?						
	공통	5) 보호구역 내 주요 시스템이 전력을 안정적으로 공급받을 수 있도록 시설을 설치하고 지속적으로 운영·관리하고 있는가?						
	공통	6) 화재 등의 재해 발생 시 임직원이 대피절차에 따라 안전하게 대피할 수 있도록 비상벨, 비상등, 비상통로 안내표지 등을 설치하고 있는가?						
	공통	7) 주요 정보시스템을 외부 집적정보통신시설(IDC)에 위탁운영하는 경우, 물리적보호에 필요한 요구사항을 계약서에 반영하고 운영상태를 주기적으로 검토하고 있는가?						
점검목적	보안 구역의 중요도와 특성에 맞는 보호 설비를 구축하여 화재·누수·전력 이상 등 물리적·환경적 사고로부터 정보자산과 서비스의 안정성을 확보한다.							
참고	• 정보통신망 이용촉진 및 정보보호 등에 관한 법률 제46조(집적된 정보통신시설의 보호) • 정보통신망 이용촉진 및 정보보호 등에 관한 법률 시행령 제38조(보험가입) • 집적정보 통신시설 보호지침(고시) 제4조(각종 대난에 대비한 보호조치) • 소방시설 설치 및 관리에 관한 법률 제12조(특정소방대상물에 설치하는 소방시설의 관리 등) • 소방시설 설치 및 관리에 관한 법률 시행령 제11조(특정소방대상물에 설치·관리해야 하는 소방시설) [별표 4] 1. 소화설비 바. 5) • ISMS-P 2.2.4 보호설비 운영 • ISO/IEC 27017 7.5 물리적·환경적 위협으로부터 보호, 7.11 지원 설비							

점검항목 해설

점검항목 1)

■ 보호구역의 중요도와 특성을 고려하여 화재, 침수, 전력 이상, 지진, 진동, 고온·저온 등 인재 및 자연재해에 대비한 운영절차를 마련하고, 비상 대응계획(ERP, Emergency response Plan)),

재해복구계획(DRP, Disaster Recovery Plan) 및 업무연속성계획(BCP, Business Continuity Plan)과 연계하여야 한다

점검항목 2)

■ 화재 감지기, 자동소화설비는 관련 소방 규정 기준에 따라 충분히 설치하고 설비 가동시 시스템 및 데이터 손상이 최소화되어야 한다.

- 보호구역 면적에 대비하여 화재 감지기 및 소화설비 설치
- 소화설비 장치 사용법 안내서 배치
- 소화설비에 대한 주기적인 점검 수행

> 「**소방시설 설치 및 관리에 관한 법률 시행령**」
> **제11조**(특성소방대상물에 설치·관리해야 하는 소방시설) [별표 4] 특정소방대상물의 관계인이 특정소방대상물에 설치·관리해야 하는 소방시설의 종류(제11조 관련)
> 1. 소화설비
> 바. 물분무등소화설비를 설치해야 하는 특정소방대상물은 다음의 어느 하나에 해당하는 것으로 한다.
> 5) 특정소방대상물에 설치된 전기실·발전실·변전실·축전지실·통신기기실 또는 전산실, 그 밖에 이와 비슷한 것으로 바닥면적이 300㎡ 이상인 것

점검항목 3)

■ 바닥·벽면 침수 및 배관 누수 위험을 고려하여 방수벽·배수구 설치, 누수 감지 센서 설치, 주기적인 점검 수행, 침수 시 즉시 데이터 보호 및 전원 차단 절차를 마련하여야 한다.

- 누수감지기 설치
- 누수감지 설비에 대한 주기적인 점검

점검항목 4)

■ 보호구역 운영 환경은 장비 제조사 권고 기준 또는 자체 기준 범위 내에서 온·습도를 유지하고, 항온항습(필요 시 냉각수·공조 시스템 포함) 시 모니터링 및 알림 체계를 마련하여야 한다.

- 항온항습에 대한 기준 수립
- 항온항습기 또는 에어컨 등 온습도 유지를 위한 시설 설치
- 항온항습 설비에 대한 주기적인 점검 수행

> 「**집적정보 통신시설 보호지침**」
> **제4조**(각종 재난에 대비한 보호조치)
> ② 사업자는 각종 전원장비를 보호하기 위하여 다음 각 호에 해당하는 조치를 하여야 한다.
> 2. 전산실에서 온습도 측정이 가능하도록 항온항습기를 설치할 것

점검항목 5)

■ 보호구역 내 정보시스템을 위한 안전한 전원공급 설비를 구비하여야 한다.

- 무정전 전원 장치(UPS), 비상발전기, 전원선 이중화, 전압유지기, 접지시설 등은 설비 중요도 및 가용성 요구수준에 따라 구축하고 정기 시험 가동 및 기록을 유지
- 전원공급 설비에 대한 주기적인 점검 수행

「**집적정보 통신시설 보호지침**」

제4조(각종 재난에 대비한 보호조치)

① 사업자는 집적정보통신시설에 안정적으로 전원을 공급하고 지진, 수해 및 화재 등으로 인한 전원공급이 중단되는 경우에 대비하기 위하여 다음 각 호에 해당하는 조치를 하여야 한다.

1. 전력관련시설(축전지설비, 자가발전설비, 수변전설비)의 상황파악 및 통제를 위한 전력감시실 또는 중앙감시실을 설치할 것
2. 전력공급의 중단을 방지하기 위하여 UPS(무정전 전원 장치)와 축전지설비를 보유하고, 장시간 외부에서의 전원공급이 중단될 경우에 대비하여 자체 전력공급을 위한 자가발전설비를 구비할 것
3. 수전, 변전 및 배전기능을 갖춘 수변전실을 두어야 하며 배전반에 단락, 지락, 과전류 및 누전을 방지하기 위하여 필요한 장비를 설치할 것

「**소방시설 설치 및 관리에 관한 법률 시행령**」

제11조(특성소방대상물에 설치·관리해야 하는 소방시설) [별표 4] 특정소방대상물의 관계인이 특정소방대상물에 설치·관리해야 하는 소방시설의 종류(제11조 관련)

2. 경보설비

자. 누전경보기는 계약전류용량이 100암페어를 초과하는 특정소방대상물에 설치해야 한다.

점검항목 6)

■ 화재 등의 재해 발생 시 임직원의 안전을 위하여 대피 및 응급대응 절차를 마련하고 비상벨, 비상등, 비상통로 안내표지 등 설치, 안전 담당자 지정 및 정기훈련을 하여야 한다.

「**집적정보 통신시설 보호지침**」

제4조(각종 재난에 대비한 보호조치)

① 사업자는 집적정보통신시설에 안정적으로 전원을 공급하고 지진, 수해 및 화재 등으로 인한 전원공급이 중단되는 경우에 대비하기 위하여 다음 각 호에 해당하는 조치를 하여야 한다.

4. 주요시설에는 기존 조명설비의 작동이 멈추는 경우에 대비하여 비상조명을 설치할 것

「**소방시설 설치 및 관리에 관한 법률 시행령**」

제11조(특성소방대상물에 설치·관리해야 하는 소방시설) [별표 4] 특정소방대상물의 관계인이 특정소방대상물에 설치·관리해야 하는 소방시설의 종류(제11조 관련)

3. 피난구조설비

다. 유도등을 설치해야 하는 특정소방대상물은 다음 어느 하나에 해당하는 것으로 한다.

1) 피난구유도등, 통로유도등 및 유도표지는 특정소방대상물에 설치한다.

점검항목 7)

■ 주요 정보시스템을 외부 집적정보통신시설(IDC)에 위탁운영하는 경우 화재, 수재, 전력이상, 온도, 습도, 환기 등의 환경적 위협 및 파손, 도난 등 물리적 위협으로부터 보호되도록 보안요구사항을 계약서에 반영하고 운영상태를 주기적으로 검토하여야 한다.

증거자료

- 보호설비 운영 절차 및 기준
- 정보자산 목록
- 위탁운영업체의 물리적 보호설비에 대한 정기 운영점검결과
- 물리적 보호설비 주기적 검토 내역
- 정보보호 정책서
- 물리적보안지침

부적합 사례

- **사례 1 :** 내부 정책·지침에서 클라우드서비스를 운영하는 정보시스템이 운영되고 있는 전산실에 대한 자연재해나 인재에 대비한 보호설비를 갖추어 운영하는 절차를 수립하지 않는 경우
- **사례 2 :** 내부 정책·지침에서 수립되어 전산실에서 운영하기로 한 항온항습기, 화재감지기, 소화설비, 누수감지기, UPS, 비상발전기, 전압유지기, CCTV, 출입통제시스템, 외부침입감지 및 경보, 전력선 이중화 등이 전산실에서 운영되지 않고 있는 경우
- **사례 3 :** 전산실에 설치된 누수감지기 등 보호설비에 대한 주기적 점검을 수행하고 있으나 일부 보호설비가 정상적으로 작동하지 않는 경우
- **사례 4 :** 전산실에 무정전 전원 장치(UPS)를 설치하고 있으나 용량 부족으로 인하여 장애 발생 가능성이 높은 경우
- **사례 5 :** 이중전원선을 통해 클라우드시스템이 전력을 안정적으로 공급 받을 수 있도록 하고 있으나, 변전소와 전력 우선공급계약을 맺지 않고 있는 경우
- **사례 6 :** 비상발전기용 유류의 안전한 공급을 위해 2곳 이상의 주유소와 유류 우선공급 계약을 맺지 않고 있는 경우
- **사례 7 :** 전산실의 화재 등의 재해 발생 시 대피할 수 있는 대피절차를 수립하지 않는 경우
- **사례 8 :** 전산실에 비상 상황 시 대피를 도울 수 있는 비상벨, 비상등, 비상로 안내표지가 설치·운영되지 않는 경우
- **사례 9 :** 클라우드시스템을 외부 IDC에 위탁하여 운영하는 경우 화재, 수재, 전력이상, 온도, 습도, 환기 등 환경적 위협 및 파손, 도난 등 물리적 위협으로부터 보호될 수 있는 보안요구사항을 계약서에 반영하지 않고 계약하는 경우

항목	8.2.3 케이블 보호	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○			○		
인증기준	데이터를 송수신하는 통신케이블이나 전력을 공급하는 전력 케이블은 손상이나 도청으로부터 보호하여야 한다.						
점검항목	공통	1) 전력 및 통신케이블이 외부로부터의 물리적 손상이나 전기적 영향(예 : 간섭)으로부터 보호되고 있는가?					
점검목적	통신 및 전력 케이블을 보호하여 손상·도청 등으로 인한 서비스 장애와 정보 유출 위험을 최소화한다.						
참고	• ISO/IEC 27017 7.12 배선 보안						

점검항목 해설

점검항목 1)

■ 전력 및 통신케이블 등이 외부의 영향 없이 안정적으로 전력 및 데이터 전송이 이루어질 수 있도록 보호대책을 적용해야 한다.

- 전력케이블과 통신케이블은 물리적으로 구분하여 배선
- 전력케이블과 통신케이블에 대한 식별
- 전력케이블과 통신케이블 사이의 전자기적 간섭을 방지하기 위한 차폐 또는 거리* 유지

  * 국립전파연구원 접지설비·구내통신설비·선로설비 등 통신공동구등에 대한 기술기준 참고
- 케이블을 지지하고 보호할 수 있는 설비 설치 (예 : 케이블 트레이)
- 도청이나 손상이 일어나지 않도록 케이블을 보이지 않게 매설할 것
- 약전실, 강전실, 배전반 등에 대한 접근통제 등

증거자료

- 전력 및 통신케이블 보호대책
- 정보보호 정책서
- 물리적보안지침

부적합 사례

- **사례 1 :** 클라우드서비스를 운영하는 정보시스템의 전력 및 통신케이블이 혼입되어 관리되는 경우
- **사례 2 :** 클라우드서비스를 운영하는 정보시스템의 전력 및 통신케이블이 어떤 정보시스템으로 연결되는지 확인되지 않는 경우
- **사례 3 :** 전력 및 통신케이블에 케이블 트레이 미설치 등 손상 가능성이 우려되는 경우
- **사례 4 :** 정보시스템에 연결된 케이블이 외부로 노출되도록 설치되어 있는 경우

항목	8.2.4 시설 및 장비 유지보수		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	정보처리시설은 가용성과 무결성을 지속적으로 보장할 수 있도록 유지보수 하여야 한다.							
점검항목	공통	1) 시설 및 장비의 가용성 및 무결성 보장하기 위해 지속적으로 유지보수를 하고 있는가?						
점검목적	정보처리시설의 안정적 운영을 위해 적절한 유지보수를 수행하여 가용성과 무결성을 지속적으로 확보한다.							
참고	• 집적정보 통신시설 보호지침 제4조(각종 재난에 대비한 보호조치), 제5조(관리인원의 선발 및 배치) • ISO/IEC 27017 7.13 장비 유지보수							

점검항목 해설

점검항목 1)

■ 주요 시설 및 장비에 대해서는 가용성과 무결성을 확보할 수 있도록 정기점검 및 유지보수 계획을 수립하고 시행하여야 한다.

- 유지보수 전문기관과 유지보수 계약을 맺고, 유지보수 인력의 출입에 대한 보안대책을 수립하여 적용
- 정보처리시설에 대하여 정기적인 점검 수행(월 1회 이상 권고)
- 점검 및 조치결과는 문서화하여 책임자에게 보고

「**집적정보 통신시설 보호지침**」

제4조(각종 재난에 대비한 보호조치)

⑤ 사업자는 지진, 수해, 화재 등 각종 재난으로부터 주요시설 설비의 안전운영을 위하여 주요시설 설비 안전운영매뉴얼을 수립하여 관련 직원을 대상으로 교육하고 주기적으로 관리감독하여야 한다.

⑥ 사업자는 주요시설 설비의 변경이 발생한 때에는 관련분야 전문가로부터 변경사항에 대한 안전성 검토를 받아야 한다.

제5조(각종 재난에 대비한 보호조치)

② 사업자는 주요시설의 유지·관리를 수행하는 관련분야 2년이상의 경험이 있는 전문인력을 두어야 한다.

④ 사업자는 집적정보통신시설의 보호를 위하여 다음 각 호에 해당하는 업무를 수행하는 관리책임자를 두어야 한다.

2. 집적정보통신시설에 대한 물리적·기술적, 인적·제도적 안전성 점검·지도
5. 기타 집적정보통신시설의 보호를 위하여 사업자가 지시하는 관리·감독 업무

증거자료

■ 보호구역 내 시설 및 장비 정기점검 내역

- 정보보호 정책서
- 물리적보안지침

부적합 사례

- **사례 1 :** 클라우드서비스 운영을 위한 시설 및 장비에 대한 정기점검 계획을 수립하고 있으나 수립된 계획에 따라 정기점검을 수행하지 않는 경우
- **사례 2 :** 내부 정책·지침에서 명시한 주기에 따라 정보처리시설에 대한 정기적인 점검을 수행하지 않는 경우

항목	8.2.5 장비 반출입		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	장비의 미승인 반출·입을 통한 중요 정보 유출, 악성코드 감염 등의 침해사고 예방을 위하여, 보안 구역 내 직원 및 외부 업무 관련자에 의한 장비 반출·입 절차를 수립하고, 기록 및 관리하여야 한다.							
점검항목	공통	1) 보호구역 내 중요한 장비, 문서, 매체 등에 대한 반출입 관련 정책 및 절차를 수립·이행하고 있는가?						
점검목적	보안 구역 내 장비의 반출·입을 통제하고 기록을 관리하여 중요정보 유출 및 악성코드 감염 등 보안사고를 예방한다.							
참고	• ISMS-P 2.4.6 반출입 기기 통제 • ISO/IEC 27017 7.9 외부 자산 보안							

점검항목 해설

점검항목 1)

■ 보호구역 내 장비, 설비, 저장매체 등의 반출·입 통제 정책 및 절차를 수립하고 이행하여야 한다.

- 보안성 검토, 사전 승인, 출입 통제, 작업 후 검증, 이력 기록 및 사후 분석을 포함하는 반출·입 절차 마련
- 반출·입 절차에는 전산장비(서버, 네트워크 장비 등), 설비(항온항습기, UPS 등), 문서(기밀문서, 대외비 등), 저장매체(외장형 HDD, CD, USB 메모리 등), 휴대용 기기(휴대폰, 카메라 등) 포함
- 반출입 과정에서 기밀 정보 유출, 악성코드 감염, 비인가 장비 반입·사용 방지 필요

■ 관리대장을 구비하거나 전산화를 통하여 장비의 반출·입 내역을 기록으로 보관하고 유지하여야 한다.

- 기록에는 일시, 품명 및 수량, 반·출입 담당자, 반출·입 장소, 반출·입 사유, 관리부서 확인 및 서명 등과 내용을 포함

증거자료

- 보호구역 내 장비 등 반출입 절차
- 반출입 신청서
- 반출입 관리 대장
- 정보시스템의 안전지출 및 긴급파기 계획
- 정보보호 정책서

■ 물리적보안지침

부적합 사례

- **사례 1 :** 전산실에 대한 장비 반출·입 통제 절차에서 장비(서버, 네트워크 장비, 항온항습기, UPS 등), 저장매체(외장형 HDD, CD, USB 메모리 등), 문서(조직의 기밀문서, 대외비 문서 등), 촬영기기(카메라 등)의 반출·입 통제 절차가 누락 되어 있는 경우
- **사례 2 :** 내부 정책·지침에서 전산실에 대한 장비 반출·입 통제 절차를 수립하고 있으나 수립된 절차에 따라 장비 반출·입 통제를 수행하지 않는 경우
- **사례 3 :** 반출입 관리대장에 일시, 품명 및 수량, 반출·입 담당자, 반출·입 장소, 반출·입 사유, 관리부서 확인 및 서명 등의 내용이 누락 되어 있는 경우

항목	8.2.6 장비 폐기 및 재사용		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	정보처리시설 내의 저장 매체를 포함하여 모든 장비를 파악하고, 민감한 데이터가 저장된 장비를 폐기하는 경우 복구 불가능하도록 하여야 한다. 또한 재사용하는 경우에도 복구 불가능 상태에서 재사용하여야 한다.							
점검항목	공통	1) 저장매체의 장비폐기에 대한 절차를 수립·이행해야 하며 저장매체 폐기 및 재사용 시 정보가 복구되지 않도록 처리하고 있는가?						
	공통	2) 자체적으로 저장매체를 폐기할 경우 관리대장을 통해 폐기이력을 남기고 폐기확인증적을 함께 보관하고 있는가?						
	공통	3) 외부업체를 통해 저장매체를 폐기할 경우 폐기 절차를 계약서에 명시하고 완전한 폐기에 대한 확인을 하고 있는가?						
점검목적	정보처리시설 내 장비와 저장매체를 식별·관리하고, 민감정보가 저장된 장비를 폐기·재사용할 때 복구 불가능한 상태를 보장하여 정보 유출을 방지한다.							
참고	• ISMS-P 2.9.7 정보자산의 재사용 및 폐기 • ISO/IEC 27017 7.14 장비의 안전한 폐기 또는 재사용, 8.10 정보 삭제 • NIST SP 800-88r2 Guidelines for Media Sanitization							

점검항목 해설

점검항목 1)

■ 저장매체(서버 디스크, 백업 장치, 이동식 매체 등) 폐기 및 재사용 시 기밀 정보가 복구되지 않도록 내부 정책·지침 등에 따른 보안 절차를 적용하여야 한다.

- 폐기 기준 수립
- 폐기 방법(물리적, 전자적으로 완전 파괴)
- 폐기 담당자 명시 등

■ 저장매체 폐기 또는 재사용 절차는 사전 승인, 보안 삭제 또는 물리적 파기, 이력 문서화, 책임자 검토 및 승인, 필요 시 증적 확보를 포함해야 한다.

■ 저장매체 재사용시에는 오버라이팅, 로우레벨 포맷 등을 통하여 원본 복구 불가능한 상태에서 재사용하여야 한다.

점검항목 2)

■ 자체적으로 폐기하는 경우 폐기이력을 기록으로 유지하여야 하며, 폐기에 대한 책임자의 확인을 득하여야 한다.

- 폐기일자
- 폐기 담당자, 확인자(책임자) 서명
- 폐기방법
- 폐기확인증적(동영상, 사진 등) 등

점검항목 3)

■ 외부업체를 통해 저장매체를 폐기할 경우 내부 폐기절차와 상응하는 내용을 계약서에 반영하여야 한다.

■ 외부업체가 폐기절차를 준수하는지 감독하여야 하며, 폐기에 대한 증적(예: 사진, 동영상 등)을 보관·유지하여야 한다.

증거자료

- 저장매체 폐기 절차
- 저장매체 데이터 삭제 관련 증적
- 저장매체 재사용 시 보관 관련 증적
- 저장매체 폐기 관리대장
- 폐기 확인 증적
- (외부업체를 통해 저장매체 폐기 시) 계약서
- 정보보호 정책서
- 물리적보안지침

부적합 사례

- **사례 1 :** 수립된 저장매체의 폐기 절차에 따라 저장매체를 폐기하지 않는 경우
- **사례 2 :** 자체적으로 저장매체를 폐기하고 있으나 폐기일자, 폐기 담당자, 확인자, 폐기 방법, 폐기확인증적(사진 등)이 포함된 폐기이력을 남기지 않는 경우
- **사례 3 :** 외부업체를 통해 저장매체를 폐기하였으나 내부 폐기 절차와 상응하는 내용을 계약서에 반영하지 않는 경우
- **사례 4 :** 저장매체가 폐기되기 전에 보관 기간 동안 별도 보안구역에 격리하지 않고 일반 사무실 등에 방치되어 도난 또는 손상, 임의 복구 위험이 있었던 경우

Ⅲ 기술적 보호조치

9. 가상화 보안

9.1 가상화 인프라

항목	9.1.1 가상자원 관리	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○	○	
인증기준	가상자원(가상 머신, 가상 스토리지, 가상 소프트웨어 등)의 생성, 변경, 회수 등에 대한 관리방안을 수립하여야 한다.						
점검항목	공통	1) 가상자원(가상 머신, 가상 스토리지, 가상 소프트웨어 등)의 생성, 변경, 회수 등에 대한 관리방안을 수립 및 이행하고 있는가?					
	공통	2) 가상자원(가상 머신, 가상 스토리지, 가상 소프트웨어 등)의 생성, 변경, 회수 등에 대한 승인, 책임추적성 확보 방안 및 주기적 점검을 이행하고 있는가?					
점검목적	클라우드 컴퓨팅의 공유 가상 환경을 사용할 때 정보 보안 위험을 완화한다.						
참고	• ISO/IEC 27017 8.9 구성 관리						

점검항목 해설

점검항목 1)

■ 가상자원의 생성, 변경, 회수 등에 대한 관리방안을 수립하고 운영하여야 한다.

- 가상자원 생성/변경/회수 등에 대한 절차 및 방법

구분	고려사항
가상자원 생성	가상자원 접근통제 가상 소프트웨어 이미지 등록 절차 가상 소프트웨어 이미지 등록, 배포 담당자 가상 소프트웨어 이미지, 스냅샷 저장 장소 가상 소프트웨어 이미지, 스냅샷의 공유 금지 가상 소프트웨어 이미지, 스냅샷의 안전성 (바이러스 검사, 보안 업데이트, 패치 등) 가상 소프트웨어 이미지의 불필요 서비스 제거, 최소 권한 적용
가상 자원 배포	무결성 검증 방법
가상자원 변경	다른 가상자원에 대한 영향 등 고려
가상자원 회수	가상자원 회수 절차 및 방법 비정상적인 회수 대책 가상자원 회수 기록 관리 등

■ DaaS의 경우 이용자의 DaaS 애플리케이션 사용 종료 등에 따라 가상PC에 저장된 이용자의 데이터를 복구할 수 없도록 삭제하여야 한다.

- 가상PC 내 자료저장 방지를 위해, 가상 머신 클린 이미지 제공, 가상 머신 내 홈폴더 초기화 등의 저장방지 기술 적용 필요
- 초기화를 위한 방식은 Pooled 방식과 Dedicated 방식 모두 허용

※ Pooled 방식 : 가상PC VM 자체(OS 설정값 등) 초기화

※ Dedicated 방식 : 가상PC의 OS 상태는 유지되나, 홈폴더 초기화 등을 통해 가상PC에 저장되는 데이터만 삭제

점검항목 2)

■ 가상자원의 생성·변경·회수 시 승인절차가 마련되어야 한다.

■ 가상자원의 생성·변경·회수에 대하여 주기적으로 점검을 수행하고 점검 이력을 남겨야 한다.

- 예) 점검사항으로는 가상자원의 생성·변경·회수에 대한 책임자의 승인 여부, 담당자의 실행 여부, 업무 수행 이슈가 발생한 경우 사후조치를 수행하였는지 여부, 승인된 범위를 벗어난 생성·변경·회수 등이 발생했는지 등 점검

증거자료

- 가상자원 관리 절차 및 방법
- 가상자원 점검내역

- 이용자 가상자원 완전 삭제 관련 증적
- 정보보호 정책서
- 가상화 보안 관리지침

부적합 사례

- **사례 1 :** 클라우드서비스 운영을 위한 가상자원의 생성, 변경, 회수 등에 대한 관리절차를 수립하고 있으나 스냅샷/이미지 파일의 안전한 저장소, 스냅샷/이미지 파일의 안정성 검증 방법 등에 대한 내용이 누락되어 있는 경우
- **사례 2 :** 클라우드서비스 제공자(IaaS 서비스 제공자)의 경우 서비스를 제공하는 가상자원에 대한 주기적인 보안 업데이트, 패치 관리 방법 및 최신 버전 제공 방안이 관리절차에서 누락되어 있는 경우
- **사례 3 :** 내부 정책·지침서 클라우드서비스 운영을 위한 가상자원의 생성, 변경, 회수 등의 관리 절차를 수립하고 있으나, 수립된 관리절차에 따르지 않고 가상자원의 생성, 변경, 회수 등의 작업을 수행하는 경우
- **사례 4 :** Pooled 또는 Dedicated 방식의 DaaS 서비스를 이용하는 이용자가 가상 PC 사용 종료 시 가상 PC에 이용자 관련 데이터가 삭제되지 않고 남아 있는 경우

항목	9.1.2 가상자원 회수		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○	○	
인증기준	이용자와의 계약 종료 시 가상자원 회수 절차에 따라 백업을 포함한 모든 클라우드 시스템에서 삭제하여야 한다.							
점검항목	공통	1) 이용자의 가상자원의 처분에 대한 내용을 클라우드서비스 수준 협약(SLA) 및 계약서에 반영하고 있는가?						
	공통	2) 이용자의 가상자원 회수 시 모든 가상자원은 클라우드 환경에서 완전 삭제 되는가?						
점검목적	민감한 정보의 불필요한 노출을 방지하고 정보 삭제에 관한 법적, 법규적, 규제적 및 계약적 요구사항을 준수한다.							
참고	• ISO/IEC 27017 8.10 정보 삭제							

점검항목 해설

점검항목 1)

■ 클라우드서비스 계약서 및 수준협약(SLA)에 서비스 이용 계약 종료에 따른 모든 가상자원(백업된 가상자원 포함)의 완전삭제에 관한 내용이 포함되어 있어야 한다.

점검항목 2)

■ 계약 종료에 따른 가상자원 회수절차를 수립·이행하여야 한다.

- 계약 종료에 따른 이용자의 모든 가상자원(백업된 가상자원 포함) 및 이용자의 데이터(백업 데이터 포함)가 삭제될 수 있도록 하는 절차를 마련
- 계약 종료 시 해당 절차에 따라 가상자원 회수, 완전 삭제 등 수행
- 계약 종료 및 이용자의 가상자원 삭제 후 이용자 요청에 따른 가상자원 삭제여부를 확인하는 절차(예: 삭제여부 문의에 대한 답변 메일, 삭제 확인서 발행 등) 마련

증거자료

- 계약서 및 SLA
- 이용자 가상자원 회수 절차
- 이용자 가상자원 완전 삭제 기법 설명 증적

- 정보보호 정책서
- 가상화 보안 관리지침

부적합 사례

- **사례 1 :** 내부 정책·지침서에 클라우드서비스 운영을 위한 가상자원의 생성, 변경, 회수 등의 관리 절차를 수립하고 있으나, 이용자와의 계약 종료 시 가상자원의 회수 절차를 포함하지 않고 있는 경우
- **사례 2 :** 이용자의 가상환경 회수 시 이용자의 가상자원, 이용자 접속로그, 백업 등 모든 가상자원을 클라우드 환경에서 완전 삭제할 수 있는 방안이 정의되지 않는 경우
- **사례 3 :** 이용자의 가상자원의 회수 시 이용자의 가상환경 운영 중 생성된 이용자 접속로그와 이용자의 백업을 삭제하지 않는 경우
- **사례 4 :** 이용자의 계약 종료 및 가상자원 삭제 후 해당 이용자가 가상자원 삭제여부를 확인 요청하는 경우 그에 대한 확인절차가 없거나 이루어지지 않은 경우

항목	9.1.3 가상자원 모니터링	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○			○	○	
인증기준	가상자원에 대한 무결성 보장하기 위한 보호조치 및 가상자원의 변경(수정, 이동, 삭제, 복사)에 대해 모니터링 하여야 한다. 또한, 가상자원에 손상이 발생한 경우 이를 이용자에게 알려주어야 한다.						
점검항목	공통	1) 가상자원에 대한 무결성을 보장하기 위한 보호조치 및 모니터링을 수행하고 가상자원 손상 시 이용자에게 통지하기 위한 절차가 마련되어 있는가?					
점검목적	관련 로그와 모니터링 정보에 대한 액세스를 제공하여 투명성을 보장하고 이용자 보안 관리를 지원한다.						
참고	• ISMS-P 2.11.3 이상행위 분석 및 모니터링 • ISO/IEC 27017 8.16 모니터링 활동, CLD.8.36 클라우드서비스 무단 사용 탐지 및 방지						

점검항목 해설

점검항목 1)

■ 가상자원의 무결성을 보장하기 위한 보호대책을 수립하고 이행하여야 한다.

- 가상자원(스냅샷이나 이미지 등)의 비인가된 변경을 방지하고, 무단변경을 탐지하기 위해 해시, 체크섬 등을 이용한 무결성 변경 방지
- 동일 하이퍼바이저에서 동작하는 각각의 가상 머신이 사용하는 메모리 공유 금지

■ 가상자원의 생성, 이동, 삭제, 복사 등 변경에 대하여 모니터링 체계를 갖추고 이행하여야 한다.

- 가상자원의 생성, 이동, 삭제, 복사 등은 책임자의 승인하에 이루어져야 하며, 인가된 관리자가 작업 수행
- 가상자원의 생성, 이동, 삭제, 복사 등의 작업에 대하여 승인된 작업만 이루어지는지 모니터링 수행

■ 가상서버의 생성, 변경, 삭제, 상태(동작여부) 등의 현황을 전자적 방법(예: 포털) 등을 통해 이용자에게 알려주어야 한다.

■ 가상자원에 손상이 발생하는 경우 이용자에게 통지하기 위한 절차를 수립하고 이행하여야 한다.

- 가상자원에 손상이 발생하는 경우 지체없이 해당 이용자에게 손상에 대한 통지 수행
- 손상에 대한 책임이 있는 책임자의 연락처, 손상의 범위, 손상으로 인한 피해 등의 내용 통보

증거자료

■ 가상자원 무결성 보장 방안 (보호조치 및 모니터링)

- 가상자원 모니터링 결과
- 손상 발견 시 이용자 통지 절차, 통지 내역
- 정보보호 정책서
- 가상화 보안 관리지침

부적합 사례

- **사례 1 :** 가상환경의 변경(수정, 이동, 삭제, 복사)에 대한 모니터링을 수행하지 않는 경우
- **사례 2 :** 이용자의 가상환경 손상 시 이용자에게 통지하는 절차에 따라 이용자에게 통지하지 않는 경우
- **사례 3 :** 이용자의 가상환경 손상을 확인할 수 있는 로그가 저장되지 않는 경우

항목	9.1.4 하이퍼바이저 보안		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○	○	
인증기준	가상자원을 관리하는 하이퍼바이저의 기능 및 인터페이스에 대한 접근 통제 방안을 마련하여야 한다. 또한 하이퍼바이저에 대한 소프트웨어 업데이트 및 보안패치를 최신으로 유지하여야 한다.							
점검항목	공통	1) 하이퍼바이저를 보호하기 위한 보호조치 및 시스템 관리 인터페이스에 대한 접근을 통제하고 있는가?						
	공통	2) 하이퍼바이저 운영자의 권한 오남용을 방지하기 위해 지속적으로 탐지하고 통제하기 위한 방안을 마련하고 있는가?						
	공통	3) 바이러스, 웜, 트로이목마 등의 악성코드로부터 하이퍼바이저를 보호하기 위한 방안을 마련하고 있는가?						
점검목적	클라우드 환경에서 하이퍼바이저(Hypervisor), 가상 머신(VM), 컨테이너 등 가상화 계층을 안전하게 관리한다.							
관련표준	• NIST SP 800-53 R5 AC-4 Access Enforcement, AC-6 Least Privilege, SC-7 Boundry Protection, SC-39 Process Isolation, SI-2 Flaw remediation, CM-3 Configuration Change Control							

점검항목 해설

점검항목 1)

■ 가상자원 관리를 위하여 하이퍼바이저에 대한 보호조치를 수립하여 적용하여야 한다.

- 하이퍼바이저에 대한 최신 업데이트 적용
- 하이퍼바이저 관리기능에 대한 접근통제
  - 2-Factor 인증 적용, 원격관리의 경우 접근 IP 제한, 전용 관리단말 지정 등
  - 원격관리의 경우 통신 구간에 대한 보호대책 적용(암호통신 등)
  - 접속 및 작업 로그 생성 및 보관
- 비인가된 소프트웨어 설치 금지
- 주기적인 하이퍼바이저 로그 분석
- 서로 다른 이용자가 동일한 하이퍼바이저를 이용하는 멀티 태넌시(Multi-tenancy) 환경에서 이용자들의 가상머신(Virtual machine)을 서로 격리

■ 클라우드시스템 관리 인터페이스에 대한 접근을 제한하여야 한다.

- 방화벽을 사용한 제한된 콘솔 접근
- 다중 요소 인증, IP 주소 필터링 등을 통한 접근제어
- 하이퍼바이저 접근을 위한 관리망을 별도로 구성
- 하이퍼바이저 원격 접속 관리 비활성화 또는 원격 접근이 필요 시에는 암호화된 통신 수단을 사용

점검항목 2)

■ 관리자(운영자)에게 관리권한을 제공하는 경우 최소한의 관리기능만 사용할 수 있도록 하여야 한다.

■ 관리행위에 대한 로그를 남기고 로그에 대한 주기적인 검토를 통해 위반 사항을 탐지할 수 있는 방안을 수립하여 적용하여야 한다.

점검항목 3)

■ 하이퍼바이저가 설치된 시스템에는 악성코드 탐지를 위한 백신 프로그램을 설치하여야 하며, 백신 프로그램은 최신의 버전을 유지할 수 있도록 하여야 한다.

■ 악성코드 감염 시에 대한 대응방안(격리 등)을 수립하여야 한다.

증거자료

- 하이퍼바이저 접근통제 및 보호대책 방안
- 하이퍼바이저 접근 기록 검토 증적
- 정보보호 정책서
- 가상화 보안 관리지침

부적합 사례

- **사례 1 :** 하이퍼바이저를 운영하는 업무를 수행하지 않는 인력에 대해 하이퍼바이저에 대한 접근권한을 부여하는 경우
- **사례 2 :** 하이퍼바이저에 대한 접속이력 로그를 저장하지 않으며, 주기적인 로그 분석을 수행하지 않은 경우
- **사례 3 :** 하이퍼바이저에 허가 받지 않은 소프트웨어가 설치된 경우
- **사례 4 :** 하이퍼바이저에 대한 접근을 접근통제솔루션을 통해 통제하고 있으나 접근통제솔루션에 업무 필요성이 없는 사용자가 하이퍼바이저에 접근할 수 있도록 접근권한을 부여하고 있는 경우
- **사례 5 :** 하이퍼바이저에 설치된 백신 프로그램에서 악성코드 감염 발생 시 대응하기 위한 대응방안이 마련되어 있지 않는 경우
- **사례 6 :** 하이퍼바이저에 대한 주기적인 또는 최신 업데이트가 적용되지 않은 경우
- **사례 7 :** 멀티 테넌트 환경에서 서로 다른 이용자의 가상머신 격리가 이루어지지 않은 경우

항목	9.1.5 공개서버 보안	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○
인증기준	가상자원을 제공하기 위한 웹사이트와 가상소프트웨어(앱, 응용프로그램)를 배포하기 위한 공개서버에 대한 물리적, 기술적 보호대책을 수립하여야 한다.						
점검항목	공통	1) 웹서버 등 공개 서버를 운영하는 경우 이에 대한 보호대책을 마련하고 있는가?					
	공통	2) 공개서버는 내부 네트워크와 분리된 DMZ(Demilitarized Zone) 영역에 설치하고 침입차단시스템 등 보안시스템을 통해 보호하고 있는가?					
	공통	3) 공개서버의 취약점 점검을 주기적으로 수행하고 발견된 취약점을 조치하고 있는가?					
점검목적	조직의 네트워크와 사용자를 악성 또는 부적절한 콘텐츠로부터 보호하기 위해 웹사이트 및 기타 인터넷 기반 리소스에 대한 접근을 제어한다.						
참고	• ISMS-P 2.10.3 공개서버 보안 • ISO/IEC 27017 8.23 웹 필터링						

점검항목 해설

점검항목 1)

■ 공개 서버(웹서버, 배포 서버 등)를 운영하는 경우 아래 보호 대책을 참고하여 적용하여야 한다.

- 공개 서버의 경우 서비스별 전용으로 서버를 운영
- 웹서버를 통한 개인정보 송·수신 시 TLS V1.2 이상 적용
- IPTABLES, PodSecurityPolicy, Container Network Interface 등을 이용한 접근통제 및 식별 및 인증을 통한 권한 설정
- 백신 설치 및 OS 최신 패치
- 불필요한 서비스 제거 및 포트 차단
- 불필요한 소프트웨어·스크립트·실행파일 등 설치 금지 등
- 불필요한 페이지(테스트 페이지) 및 에러처리 미흡에 따른 시스템 정보 노출 방지

점검항목 2)

■ 공개 서버(웹서버, 배포 서버 등)는 DMZ 영역에 설치하고 공개 서버가 침해당하더라도 공개 서버를 통한 내부 네트워크 침입이 불가능하도록 접근통제 정책을 적용하여야 한다.

- DMZ의 공개 서버가 내부 네트워크에 위치한 DB, WAS(Web Application Server) 등의 정보시스템과 접속이 필요한 경우, 엄격한 접근통제 정책 적용

- 침입차단시스템의 정책은 서비스를 위한 최소 서비스만 허용하도록 설정 관리

점검항목 3)

■ 공개서버의 취약점 점검은 인증기준 “3.3.2. 취약점 점검” 통제항목의 취약점 점검절차에 따라 수행하여야 한다.

- OS, 어플리케이션, 웹서비스 등에 대한 취약점 점검 수행
- 웹서버의 경우 OWASP TOP 10등 웹 응용프로그램 취약점 점검
- 발견된 취약점은 신속하게 조치

증거자료

- 네트워크 및 시스템 구성도
- 보안시스템 운영 현황
- 취약점 점검 및 조치 현황
- 정보보호 정책서
- 가상화 보안 관리지침

부적합 사례

- **사례 1 :** 가상자원을 제공하거나 가상소프트웨어(앱, 응용프로그램)를 배포하기 위한 공개서버에 대한 물리적, 기술적 보호대책이 수립되어 있지 않는 경우
- **사례 2 :** 공개서버에 대한 접속이력 로그를 저장하지 않는 경우
- **사례 3 :** 공개서버에 대한 접속이력의 적정성을 공개서버에 대한 접근통제 절차에서 정의한 주기에 따라 점검하지 않는 경우
- **사례 4 :** 공개서버에 대한 접근을 접근통제솔루션을 통해 통제하고 있으나 접근통제솔루션에 업무 필요성이 없는 사용자가 공개서버에 접근할 수 있도록 접근권한을 부여하고 있는 경우

항목	9.1.6 상호 운용성 및 이식성		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○					
인증기준	클라우드컴퓨팅서비스 제공자는 표준화된 가상화 포맷, 이식성이 높은 가상화 플랫폼, 공개 API 등을 이용하여 클라우드컴퓨팅서비스 간의 상호 운용성 및 이식성을 높여야 한다.							
점검항목	공통	1) 상용 운용성 및 이식성을 높이기 위한 조치(표준화된 가상화 포맷, 이식성이 높은 가상화 플랫폼, 공개 API) 들을 취하고 있는가?						
점검목적	이용자가 클라우드서비스를 다른 시스템이나 클라우드와 연동할 수 있도록 보장한다.							
참고	• 클라우드컴퓨팅법 제22조(상호 운용성의 확보)							

점검항목 해설

점검항목 1)

■ 클라우드서비스 제공자는 표준화된 가상화 플랫폼, API 등을 지원하여 클라우드서비스 간의 이식성 및 상호 운용성을 지원해야 한다.

- 가상화 플랫폼은 표준화된 플랫폼을 적용하고 가상 이미지도 호환 가능한 표준 포맷 사용
  - OVF(Open Virtualization Format), OVA(Open Virtualization Application/Appliance) 등
- 공개된 API 사용 및 마이그레이션 응용프로그램 도입
  - 공개된 API는 공격의 정보로 사용될 수 있으므로 이에 대한 클라우드서비스를 설계하는 단계에서부터 보안대책을 수립한 후 적용

증거자료

- 클라우드 상호 운영/이식성 제공 방안(가상화 포맷, 플랫폼, API 등)
- 정보보호 정책서
- 가상화 보안 관리지침

부적합 사례

- **사례 1 :** 클라우드서비스 운영 시 이용자에게 표준화된 가상화 포맷, 가상화 플랫폼, 표준화된 API를 제공하지 않는 경우

9.2 가상 환경

항목	9.2.1 악성코드 통제	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○	○	
인증기준	바이러스, 웜, 트로이목마 등의 악성코드로부터 이용자의 가상 환경(가상 PC, 가상서버, 가상 소프트웨어 등)을 보호하기 위한 악성코드 탐지, 차단 등의 보안기술을 지원하여야 한다. 또한 이상징후 발견 시 이용자 통지하고 사용 중지 및 격리 조치를 수행하여야 한다.						
점검항목	공통	1) 바이러스, 웜, 트로이목마 등의 악성코드로부터 가상 환경을 보호하기 위한 기술을 도입 또는 지원하고 있는가?					
	공통	2) 이상 징후 발견 시 이용자에게 통지하고 사용 중지 및 격리 조치를 수행하고 있는가?					
점검목적	정보 및 기타 관련 자산이 악성 코드로부터 보호되도록 보장한다.						
참고	• ISMS-P 2.10.9 악성코드 통제 • ISO/IEC 27017 8.7 악성코드 대응						

점검항목 해설

점검항목 1)

■ 바이러스, 웜, 트로이목마 등의 악성코드로부터 클라우드서비스 제공 환경을 보호하기 위한 보안기술을 지원하여야 한다.

- 보안시스템(백신, 이메일 보안, 웹쉘탐지, 웹방화벽 등) 설치 및 최신업데이트
- 운영체제의 보안 업데이트
- 서비스되는 SW(WAS, DB 등) 최신 보안패치 등
- 최신 악성코드 예방·탐지 활동을 지속적으로 수행

점검항목 2)

■ 클라우드서비스 제공 환경에서 이상 징후가 발견되는 경우 이용자에게 통지하고 사용 중지 및 격리 조치를 수행하여야 한다.

- 바이러스, 웜, 트로이목마 등 악성코드가 발견된 시스템은 즉시 사용을 중단하고, 타 시스템과 격리(네트워크 분리)
- 다른 시스템에 악성코드가 전파되었는지 점검 수행
- 가능한 경우 감염경로를 파악하고 보안대책을 수립하여 조치
- 서비스에 영향을 미치는 경우 이용자에게 통지

증거자료

- 정보자산 목록 (백신, 웹쉘탐지, 웹방화벽 등 설치된 악성코드 통제 보안시스템 목록)
- 이상 징후 발견 시 통지 및 조치 절차
- 정보보호 정책서
- 가상화 보안 관리지침

부적합 사례

- **사례 1 :** 클라우드서비스 제공 환경 등에 대한 악성코드 대응방안 및 통지절차를 마련하지 않는 경우
- **사례 2 :** 클라우드서비스 제공 환경이 악성 코드에 감염되었음을 발견하였으나 피해확산 방지 조치를 취하지 않는 경우
- **사례 3 :** 클라우드서비스 제공 환경에 설치한 백신프로그램에 최신 버전 엔진을 적용하지 않는 경우

항목	9.2.2 인터페이스 및 API 보안		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○				
인증기준	가상 환경(가상 PC, 가상서버, 가상 소프트웨어 등) 접근을 위한 인터페이스 및 API에 대한 보안취약점을 주기적으로 분석하고, 이에 대한 보호 방안을 마련하여야 한다.							
점검항목	공통	1) 가상 환경(가상 PC, 가상서버, 가상 소프트웨어 등) 접근을 위한 인터페이스 및 API에 대한 보호 방안을 마련하고 있는가?						
점검목적	클라우드 관리 경로(콘솔, API, 가상화 계층)를 보호한다.							
관련표준	• ISMS-P 2.8.1 보안 요구사항 정의 • ISO/IEC 27017 8.26 응용프로그램 보안 요구사항, 8.27 안전한 시스템 아키텍처 및 엔지니어링 원칙							

점검항목 해설

점검항목 1)

■ 전송, 권한 및 인증, 소프트웨어 개발, 메시지 보호 측면에서의 인터페이스 및 API 취약점 분석, API 간 연관성 분석을 주기적으로 수행하고 보완하여야 한다.

- 서비스 제공자가 사용 또는 제공하는 API 목록 관리
- 사용 또는 제공하는 인터페이스 및 API에 대한 정기적 취약점* 점검

  * 타인 데이터 접근, 권한을 넘는 접근, 데이터 과다 노출, 과도한 리소스 사용, 잘못된 설정 등

■ SaaS의 경우 클라우드서비스 환경에서 상위 서비스(IaaS, PaaS 등)로 통신하는 인터페이스 및 API 뿐만 아니라 SaaS 이용자가 클라우드서비스 환경으로 접근할 수 있는 인터페이스 및 API를 식별하고 보호방안을 마련하여야 한다.

- 상위 서비스(IaaS, PaaS 등) 사업자가 제공하는 안전한 인터페이스 및 API를 사용
- 상위 서비스(IaaS, PaaS 등) 사업자가 제공하는 인터페이스 및 API가 아닌 경우 해당 인터페이스 및 API가 안전한지 여부를 확인하고 사용
- 식별된 인터페이스를 통한 중요 데이터 통신 시 암호화 등을 통하여 보호

증거자료

- 가상 환경 인터페이스(API) 취약점 점검 및 조치 현황
- 정보보호 정책서
- 가상화 보안 관리지침

부적합 사례

- **사례 1 :** 가상 환경(가상 PC, 가상서버, 가상 소프트웨어 등)에 접근 가능한 인터페이스 및 API 취약점 분석, API 연관성 분석을 주기적으로 수행하는 절차를 수립하지 않는 경우
- **사례 2 :** 가상 환경(가상 PC, 가상서버, 가상 소프트웨어 등)에 접근 가능한 인터페이스 및 API 취약점 분석, API 연관성 분석을 연 1회 이상 수행하지 않는 경우

항목	9.2.3 데이터 이전	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○				
인증기준	이용자가 기존 정보시스템 환경에서 클라우드컴퓨팅서비스의 가상 환경으로 전환 시 안전하게 데이터를 이전하도록 암호화 등의 기술적인 조치방안을 제공하여야 한다.						
점검항목	공통	1) 기존 정보시스템 환경에서 가상 환경으로 데이터 이전 시, 안전하게 이전하고 있는가?					
점검목적	조직 내부에서 그리고 외부 이해관계자와 주고받는 정보의 보안을 유지하도록 보장한다.						
참고	• ISMS-P 2.10.5 정보전송 보안 • ISO/IEC 27017 5.14 정보 전송						

점검항목 해설

점검항목 1)

■ 가상 환경으로 이용자의 데이터를 이전하는 경우 다음과 같은 기술적 방안을 마련하여야 한다.

- 안전한 암호화 통신채널(예: 전용회선, VPN 등) 적용

■ 수동으로 이용자 데이터를 이전하는 경우 이동매체의 안전한 전달, 이동매체에 데이터 저장 시 암호화, 이동 간의 데이터 무결성 확보 등의 보안대책을 수립하여야 한다.

증거자료

- 전송구간 암호화 솔루션 운영 현황(예: VPN 등)
- 데이터 이전 시 보안대책
- 정보보호 정책서
- 가상화 보안관 리지침

부적합 사례

- **사례 1 :** 이용자 데이터 이전 시 이전 절차 및 기술적인 조치방안이 수립되지 않는 경우
- **사례 2 :** 이용자 데이터 이전 시 암호화 되지 않은 채널을 이용하여 이용자 데이터를 이전하는 경우
- **사례 3 :** 이용자 데이터를 수동으로 이전하는 경우 이용자 데이터를 저장하는 저장매체에 대한 암호화를 수행하지 않는 경우
- **사례 4 :** 이용자 데이터를 수동으로 이전하는 경우 이용자 데이터를 저장하는 저장매체에 대한 접근 가능 인력이 식별되지 않는 경우

항목	9.2.4 가상 소프트웨어 보안		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○		
인증기준	클라우드컴퓨팅서비스 제공자는 출처, 유통경로 및 제작자가 명확한 소프트웨어로 구성된 가상 환경을 제공하여야 한다.							
점검항목	공통	1) 가상 환경 내에 출처, 유통경로 및 제작자가 명확하지 않은 가상 소프트웨어의 설치를 방지하고 있는가?						
	IaaS	2) 허가 받지 않은 소프트웨어 설치가 탐지된 경우 이용자에 알리기 위한 연락체계가 수립하고 있는가?						
점검목적	운영 시스템의 무결성을 보장하고 기술적 취약점의 악용을 방지한다.							
참고	• ISO/IEC 27017 8.19 운영 시스템에서의 소프트웨어 설치							

점검항목 해설

점검항목 1)

■ 출처, 유통경로 및 제작자가 명확한 소프트웨어를 이용하여 가상 환경을 제공해야 한다.

- 최초 이미지 배포 시 승인된 소프트웨어만 설치 및 배포
- 출처가 불명확한 소프트웨어, 검증되지 않은 프리웨어 소프트웨어, 오픈소스 소프트웨어 등은 설치 금지
- 라이선스가 없거나 판매 또는 기술지원 종료(EOL/EOS)되었거나 임박한 소프트웨어 등은 설치 금지

■ 설치된 소프트웨어는 소프트웨어 제작사가 제공하는 보안패치 및 업데이트를 적용하여야 한다.

점검항목 2)

■ 클라우드서비스 제공자가 제공한 이미지 내에 허가받지 않은 소프트웨어 설치가 탐지된 경우 이용자에게 신속하게 알려야 한다.

증거자료

- 정보자산목록 (가상 환경 관련 소프트웨어)
- 소프트웨어 패치관리대장
- 정보보호 정책서
- 가상화 보안 관리지침

부적합 사례

- **사례 1 :** 이용자의 가상 서버, 가상PC에 출처, 유통경로 및 제작자가 명확하지 않은 가상 소프트웨어의 설치 여부를 확인하고 설치 확인 시 이용자에게 알리는 절차를 수립하고 있지 않는 경우
- **사례 2 :** 이용자의 가상 서버, 가상PC에 출처, 유통경로 및 제작자가 명확하지 않은 가상 소프트웨어의 설치 여부를 주기적으로 점검하지 않는 경우
- **사례 3 :** 이용자의 가상 서버, 가상PC에 설치된 가상 소프트웨어에 대해 주기적인 보안 패치 및 업데이트를 실시하지 않는 경우

10. 접근통제

10.1 접근통제 정책

항목	10.1.1 접근통제 정책 수립	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○	○	
인증기준	비인가자의 접근을 통제할 수 있도록 접근통제 영역 및 범위, 접근통제 규칙, 방법 등을 포함하여 접근통제 정책을 수립하여야 한다.						
점검항목	공통	1) 접근 통제영역을 정의하고 접근 통제영역별로 접근통제 정책을 수립하고 있는가? (접근통제 영역별 통제 규칙, 방법, 절차, 예외사항에 대한 안전한 관리절차 등)					
점검목적	접근통제 정책을 수립하여 비인가자의 접근을 예방하고 정보자산의 기밀성·무결성·가용성을 보호한다.						
참고	• ISMS-P 2.6.1 네트워크 접근, 2.6.2 정보시스템 접근, 2.6.3 응용프로그램 접근, 2.6.4 데이터베이스 접근 • ISO/IEC 27017 5.15 접근 통제						

점검항목 해설

점검항목 1)

■ 클라우드서비스 운영 서버, 개발 서버, 정보보호시스템, 이용자 데이터 등 중요 정보자산에 대한 접근통제 정책을 수립·이행하여야 한다.

- 자산 유형별 접근통제 대상에 따라 접근권한과 책임, 승인 절차 명시
- 주요 서버 또는 중요 데이터에 접근하는 경우 2-factor 인증 고려
- 시스템별 계정을 명확히 식별하고 안전한 접근수단 적용
- 원격 접속시 전용선, 암호화 통신 또는 VPN 적용, 클라우드 콘솔 사용시 암호화 통신(https), 접근 IP 제한, 다중 인증 등을 적용
- 클라우드서비스 보안 설정 기준(인증, 암호화, 세션 관리, 접근통제, 장기미사용 잠금 등)
- 서비스의 중요도에 따른 영역 간 접근통제 적용

■ 관리서버의 경우 보다 강력한 인증을 고려하여야 한다.

■ 업무상 불가피하게 접근통제 정책을 벗어난 접근이 필요한 경우 접근시간, 접근위치 제한 등 추가적인 보완대책을 마련한 후 접근을 허용하여야 한다.

- 접근통제 정책 예외 시 책임자 승인 필요
- 접근통제 정책 예외 시 책임자 승인, 허가기간 등의 이력 보관

■ 클라우드서비스 운영 서버에 접근 가능한 관리용 단말을 지정하고 무선을 통한 접근은 차단하여야 한다.

- 관리시스템 접근 가능한 단말을 관리용 단말로 지정하고 목록 관리
- 접속 가능한 단말의 IP주소, MAC 주소 등으로 제한

■ DaaS의 경우 가상PC에 접근하는 접속 단말(내부망 PC 등)에 대해 IP 및 MAC 제한을 수행하여야 한다(IP/MAC 모두 통제 필요).

- 가상화 관리 솔루션의 기능을 활용하여 접속 단말 통제 가능

증거자료

- 접근통제 정책 및 방안
- 관리자 단말기 현황
- 정보보호 정책서
- 접근통제관리지침

부적합 사례

- **사례 1 :** 클라우드서비스를 운영하는 클라우드 시스템(VM, 하이퍼바이저, DBMS, 네트워크, Application, 응용프로그램, 네트워크, 정보보호시스템 등)에 대한 접근통제 절차를 수립하지 않는 경우
- **사례 2 :** 클라우드서비스를 운영하는 클라우드 시스템에 대한 접근통제 절차를 수립하였으나 수립된 접근통제 절차에 따라 접근통제를 수행하지 않는 경우
- **사례 3 :** 업무용 모바일 기기에 대한 허용 기준, 사용 범위, 승인 절차, 인증 방법 등에 대한 정책이 수립되어 있지 않은 경우
- **사례 4 :** 클라우드 시스템에 접근 가능한 관리용 단말을 지정하지 않고 있는 경우
- **사례 5 :** 클라우드 REST API/CLI 등을 통한 우회 접근에 대한 통제 및 로그관리 정책이 수립되지 않은 경우

항목	10.1.2 접근기록 관리		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○	○	○	○	○
인증기준	접근기록 대상을 정의하고 서비스 통제, 관리, 사고 발생 책임추적성 등을 보장할 수 있는 형태로 기록되고 유지하여야 한다.							
점검항목	공통	1) 클라우드 시스템의 사용자/관리자 접속 내역을 기록하고, 접근의 타당성을 정기적으로 검토하고 있는가?						
점검목적	접근기록을 적절히 식별·관리하여 서비스 통제, 보안 모니터링, 사고 발생 시 책임추적성을 확보한다.							
참고	• ISMS-P 2.9.4 로그 및 접속기록 관리 • ISO/IEC 27017 8.15 로깅							

점검항목 해설

점검항목 1)

■ 접근기록을 생성하여 보관해야 하는 대상시스템을 정의하고 목록화하여 관리하여야 한다. 대상시스템은 서비스 및 업무 중요도를 고려하여 접근기록의 보존이 필요한 대상을 정의하여야 한다.

- 접근기록 생성 대상 시스템*은 운영 서버, 관리 서버, DBMS, 응용 서비스, API/콘솔 접근, 가상화 관리 솔루션, 클라우드 관리 포털 등 중요도 기반으로 정의

  * 해당 시스템에 로그인 한 접속로그와 접속 후 수행한 업무 로그를 생성하는 시스템을 포함

- 접근기록은 DB 접근로그(응용서비스 또는 이용자), DBMS 접근로그(사용자), 운영체제 접근로그(사용자가 시스템관리를 위해 SSH 등을 이용한 접근) 등 주요 시스템 및 응용프로그램에 로그인 한 접속로그와 접속하여 수행한 행위에 대한 로그를 의미
- 접근기록을 남기거나 생성해야 하는 시스템을 식별하고 해당 시스템에서 생성되는 접근기록을 별도로 보관·유지
- 운영체제, DBMS 등 상용 프로그램에서 생성되는 접근기록(로그인 기록 등)은 프로그램별로 상이하므로 정확한 생성 위치를 파악 및 식별
- 로그인 이후 수행한 행위에 대한 주요 로그(예: 개인정보 다운로드 등)를 모두 포함

■ 보안사고의 사후 조사 지원 등 책임추적성 확보를 위해 클라우드 시스템의 접근기록은 법률 및 이용자의 정책에 따라 일정기간 동안 보관하여야 한다.

- 개인정보 보호법에 따른 개인정보처리시스템의 경우 개인정보취급자의 접속기록은 최소 1년 이상 유지·관리하여야 함. 다만, 5만명 이상의 정보주체에 관한 개인정보를 처리하거나, 고유식별정보 또는

민감정보를 처리하는 개인정보처리시스템의 경우에는 2년 이상 보관·관리하여야 함

■ 접근권한 부여, 수정, 삭제 등과 관련된 기록은 법률 및 이용자의 정책을 준수하여야 한다.

※ 접근권한 기록 보관 기간 예시

관련 법률	대상	보관 기간
개인정보 보호법	개인정보처리시스템의 접근권한 기록	최소 3년간 보관

■ 접근기록은 사고 발생 시 책임추적성을 보장할 수 있도록 다음의 사항을 포함하여 생성되고 보존되어야 한다.

- 접근 주체 정보(계정 등)
- 접근시간
- 접근 IP 또는 MAC 정보
- 수행업무(접근데이터 정보, 접근 후 활동 정보 등)
- 처리한 정보주체 정보

■ 기록된 접근기록은 통제항목 '7.2.2. 감사기록 및 모니터링'의 점검항목과 함께 검토되어야 하며 접근기록은 위험기반 접근 방식에 따라 주기적으로 점검(예: 월 1회 이상) 하여야 한다.

증거자료

- 접근기록 생성 대상 목록
- 접근기록 검토 내역 (보안로그)
- 정보보호 정책서
- 접근통제관리지침

부적합 사례

- **사례 1 :** 저장하고 있는 로그에 대한 검토 주기, 대상, 방법, 검토 수행자 및 확인자 등을 포함한 로그 검토 절차가 수립되어 있지 않는 경우
- **사례 2 :** 클라우드 시스템에 대한 로그 기록을 별도로 백업하거나 적절히 보호하지 않아 사용자의 명령 실행 기록 및 접속 이력 등을 임의로 삭제할 수 있는 경우
- **사례 3 :** 개인정보처리시스템에 접속한 기록을 확인한 결과 접속자의 계정, 접속 일시, 접속자 IP주소 정보는 남기고 있으나, 처리한 정보주체 정보 및 수행업무(조회, 변경, 삭제, 다운로드 등)와 관련된 정보를 남기고 있지 않는 경우
- **사례 4 :** 로그 서버의 용량의 충분하지 않아서 개인정보처리시스템 접속기록이 3개월밖에 남아 있지 않는 경우
- **사례 5 :** 개인정보 다운로드에 대해 내부관리계획에서 정한 개인정보 다운로드 기준에 의해 검토(적정성 및 사유 확인 등)를 하지 않고 있는 경우

10.2 접근권한 관리

항목	10.2.1 사용자 등록 및 권한부여		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○	○	
인증기준	클라우드 시스템 및 중요정보에 대한 접근을 통제하기 위하여 공식적인 사용자 등록 및 해지 절차를 수립하고 업무 필요성에 따라 사용자 접근권한을 최소한으로 부여하여야 한다.							
점검항목	공통	1) 클라우드 시스템 내 사용자 계정에 대한 등록·변경·삭제에 관한 공식적인 검토·승인 절차가 있는가?						
	공통	2) 클라우드 시스템의 사용자 계정 생성 및 변경 시 직무별, 역할별 접근권한 분류 체계를 수립하고 있으며, 업무상 필요한 최소한의 권한만을 부여하고 있는가?						
점검목적	접근기록을 명확히 정의·관리하여 서비스 통제와 보안 모니터링을 가능하게 하고, 사고 발생 시 책임추적성을 확보한다.							
참고	• ISMS-P 2.5.1 사용자 계정 관리 • ISO/IEC 27017 5.16 계정관리, 5.18 접근 권한							

점검항목 해설

점검항목 1)

■ 사용자 계정을 등록·변경·삭제(비활성화)하는 경우 공식적으로 검토·승인하는 절차를 수립하여야 한다.

- 계정 발급 시 업무 필요성 및 최소 권한 부여 등 해당 계정 발급의 적정성 검토 절차
- 관리자 또는 특수권한 사용자(개인정보취급자 등)에 대한 계정 발급 및 변경에 대한 적정성 검토 절차
- 발급된 계정의 접근범위 및 권한 등에 대한 사항 검토 절차
- 전보, 퇴직 등 인사이동 발생 시 계정 삭제 등의 절차
- 책임자의 승인 절차
- 임시 계정 발급 (접근위치, 사용기간 등 관리) 절차
- 접근권한 부여·변경·말소 기록에 대한 보관

※ 접근권한 부여·변경·말소 기록 보관 기한 예시

적용 시스템	계정 유형	보관 기간	비고
응용 서버	개인정보처리자	최소 3년간 보관	개인정보보호법

점검항목 2)

■ 직무별, 역할별, 서비스 유형별 등 클라우드 시스템 접근권한을 정의한 분류 체계를 수립하고

관리하여야 한다.

- 불필요하거나 과도하게 중요 정보 또는 개인정보에 접근하지 못하도록 권한 세분화

※ 접근권한 분류 체계 예시

구분	서비스 그룹	담당	조회	수정	삭제	다운로드	권한부여
최고 관리자	A 서비스	홍○○	○	○	○	○	○
	B 서비스	홍○○	○	○	○	○	○
부 관리자	A 서비스	이○○	○	○	○	○	○
	B 서비스	강○○	○	○	○	○	○
사용자	A 서비스	유○○	○	○	○	○	
	A 서비스	김○○	○				
	B 서비스	박○○	○	○	○	○	
	B 서비스	정○○	○				

■ 접근권한은 업무 수행에 필요한 최소한으로 할당하여야 하며, 담당자 직무에 따라 차등 부여하여야 한다.

- 클라우드 시스템 운영·개발·보안 등 기능별 직무별 접근 권한 및 계정 분리

※ 권한 최소 부여 및 현황 관리 예시

- 업무상 불필요한 직무자(계정)에게 권한 부여 여부 (업무 변경, 부서 변경, 퇴직자 등)
- 수행 직무, 역할별 권한 차등 부여
- 마지막 접속 후 장기간(예, 3개월 이상) 미접속된 계정
- 시스템 슈퍼관리자 권한 등을 팀 내 전체 인원에게 부여하는 경우 적절한 사유 등을 주기적으로 검토, 현황 관리 (업무 수행을 위한 필요성과 업무 수행을 위한 최소한의 권한만 부여하도록 관리)

증거자료

- 사용자 계정 등록, 변경, 삭제 승인 절차 및 승인 내역
- 접근권한 분류체계
- 접근권한 부여·변경·말소 기록
- 정보보호 정책서
- 접근통제관리지침

부적합 사례

- **사례 1 :** 클라우드서비스를 운영하는 클라우드 시스템(VM, 하이퍼바이저, DBMS, 네트워크, Application, 응용프로그램, 네트워크, 정보보호시스템 등)의 계정을 생성, 변경, 삭제하기 위한 사용자 등록 및 해지 절차를 수립하고 있지 않는 경우
- **사례 2 :** 클라우드서비스를 운영하는 클라우드 시스템의 계정을 생성, 변경, 삭제 시 사용자 등록 및 해지 절차를 이행하지 않고 담당자가 임의로 계정을 생성, 변경, 삭제 하는 경우
- **사례 3 :** 사용자 및 개인정보취급자에 대한 계정 및 권한에 대한 사용자 등록, 해지 및 승인절차 없이 구두 요청, 이메일 등으로 처리하여 이에 대한 승인 및 처리 이력이 확인되지 않는 경우
- **사례 4 :** 클라우드서비스를 운영하는 클라우드 시스템의 계정에 대한 접근권한 분류체계(슈퍼관리자, 일반관리자, 일반사용자, 모니터링 등) 기준을 수립하지 않는 경우
- **사례 5 :** 퇴직자, 휴직자 또는 업무가 변경된 사용자에 대한 계정 삭제 또는 비활성화가 즉시 수행되지 않아 장기간 활성화된 상태로 유지된 경우

항목	10.2.2 관리자 및 특수 권한관리		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○	○	
인증기준	클라우드 시스템 및 중요정보 관리, 특수 목적을 위해 부여한 계정 및 권한을 식별하고 별도 통제하여야 한다.							
점검항목	공통	1) 관리자 및 특수 권한은 최소한의 인원에게만 부여하고, 권한 부여 시 책임자 승인 절차를 수립하고 있는가?						
	공통	2) 관리자 권한 및 특수 권한을 식별하여 별도 목록으로 관리하고 있는가?						
	공통	3) 외부자에게 부여하는 계정은 한시적으로 부여하고, 사용이 끝난 후에는 즉시 삭제 또는 정지하고 있는가?						
점검목적	특수 목적 및 중요정보 관리를 위한 계정·권한을 식별·통제하여 오남용을 방지하고 보안성을 강화한다.							
참고	• ISMS-P 2.5.5 특수 계정 및 권한 관리 • ISO/IEC 27017 8.2 특권 접근 권한							

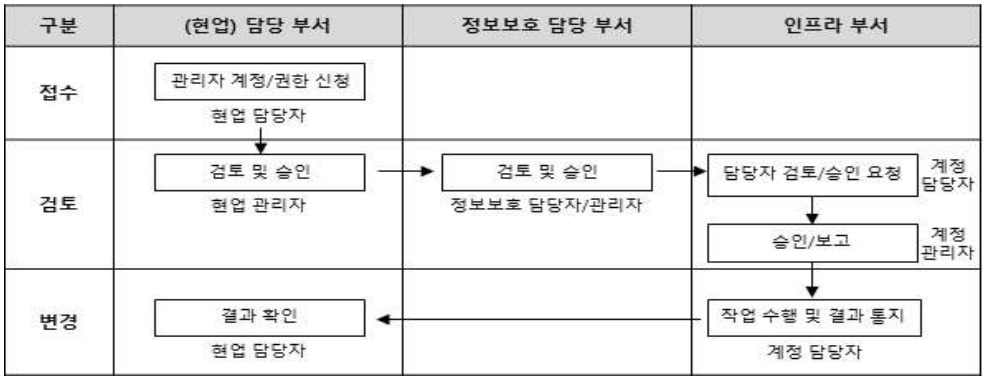
점검항목 해설

점검항목 1)

■ 클라우드 시스템의 관리자(root, administrator 등) 및 특수권한(계정 및 접근 설정 권한 등)을 갖는 계정을 할당하는 경우 책임자로부터 승인을 받은 후 계정을 할당하여야 한다.

- 관리자 및 특수권한 계정을 부여하는 경우 공식적인 절차에 따라 신청 및 승인이 이루어질 수 있도록 절차를 수립하여 이행
- 관리자 및 특수권한을 부여하는 경우 일반적인 사용자 계정·권한 발급 절차보다 엄격한 기준 적용(임원 또는 정보보호 최고책임자 승인 등)

※ 관리자 계정/권한 절차 예시



점검항목 2)

■ 할당된 관리자 권한 및 특수권한을 목록화하여 주기적으로 검토하고 필요한 최소 수준으로 유지 및 관리하여야 한다.

- 특수권한은 반드시 필요한 경우에만 할당
- 주기적(예: 3개월)으로 권한을 재검토 하고 장기 미사용(예: 3개월)시 자동 잠금 등 필요조치 수행
- 특수권한의 최소화 및 모니터링을 위해 특수권한을 부여받은 계정 식별 및 현황 관리

※ 관리자 및 특수권한 예시

- 시스템(서버, 데이터베이스, 네트워크 등)의 관리자
- 정보보호시스템의 관리자
- 응용프로그램 배치 및 구동을 위한 사용되는 계정
- 응용프로그램의 관리자 (권한 부여, 수정, 삭제 등 권한 보유)
- 응용프로그램의 이용자 (수정, 삭제, 다운로드 등 가능한 자와 조회만 가능한 자 분류)

※ 관리자 계정 목록 예시

No	시스템 명	아이디	사용자	부서	용도	비고
1	A 서버(hostname1)	sample1	홍길동	A팀	운영	
2	B 서버(hostname2)	sample2	김철수	B팀	개발	
이하 생략						

점검항목 3)

■ 클라우드 시스템 유지보수 등을 위해 외부자에게 계정 및 접근권한을 부여하는 경우 사용기간, 접근위치 등을 제한하여 발급하고, 관련 업무 활동이 종료된 이후 해당 계정을 즉시 삭제하거나 사용을 정지시켜야 한다.

- 내·외부자의 권한을 구분하여 별도 그룹으로 관리

증거자료

- 사용자 계정 등록, 변경, 삭제 승인 내역
- 접근권한 부여 기록
- 특수권한자 목록
- 외부자에게 부여된 계정 목록
- 정보보호 정책서
- 접근통제관리지침

부적합 사례

- **사례 1 :** 클라우드서비스 운영을 위한 클라우드 시스템에서 관리자 및 외주업체 담당자에 부여한 특수계정 목록을 별도 식별하고 있지 않는 경우
- **사례 2 :** 클라우드서비스 운영을 위한 클라우드 시스템의 관리자 계정을 업무 필요성이 없는 임직원 및 외주업체 담당자에게 부여하고 있는 경우
- **사례 3 :** 특수 계정에 대한 사용 목적 및 업무 종료일 등 관리 기준이 명확히 정의되지 않은 경우

항목	10.2.3 접근권한 검토	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○	○	
인증기준	클라우드 시스템 및 중요정보에 대한 접근을 관리하기 위하여 접근권한 부여, 이용(장기간 미사용), 변경(퇴직 및 휴직, 직무변경, 부서변경)의 적정성 여부를 정기적으로 점검하여야 한다.						
점검항목	공통	1) 클라우드 시스템에 대한 접근권한 검토 기준, 검토주체, 검토방법, 주기 등을 정하여 정기적 검토를 이행하고 있는가?					
	IaaS	2) 접근권한의 검토 결과 접근권한 오남용 등의 이상 징후가 발견된 경우 그에 따른 조치절차를 수립·이행하고 있는가?					
점검목적	접근권한의 주기적 적정성 점검을 통해 클라우드 시스템 및 중요정보에 대한 불필요한·과도한 접근을 방지하고 보안성을 유지한다.						
참고	• ISMS-P 2.5.6 접근권한 검토 • ISO/IEC 27017 5.18 접근 권한						

점검항목 해설

점검항목 1)

■ 할당된 계정 및 접근권한이 직무 및 최소권한 원칙에 따라 적절한지 주기적으로 검토~~를 수행~~하고 결과를 관리하여야 한다.

- 클라우드서비스의 환경변화 또는 관련 직원의 인사변경(퇴직, 휴직, 전보 등) 등 반영 여부
- 장기간 미사용(3개월 권고) 계정의 존재 여부
- 외부자에게 할당된 계정의 관리 상태
- 계정 및 권한 할당 시 승인 등의 절차 준수 여부
- 직무의 변경 등이 발생한 경우 계정 또는 접근권한의 회수 및 재할당
- 계정 등록대장과 실 시스템 계정 일치 여부
- 직무 변경 등에 따른 접근권한 승인 내역
- 임시 계정 권한 회수 여부

■ 검토 기준별로 검토주체, 방법, 주기(최소 분기 1회 이상 권고) 등을 정하여 이행하여야 한다.

점검항목 2)

■ 접근권한 검토 결과 의심스러운 상황이 발견된 경우 원인분석 및 관련 위험 평가, 보완대책 마련,

보고 등 절차를 수립, 이행하여야 한다.

- 과다한 권한부여, 오남용, 계정 및 권한 할당 시 승인절차 미 준수 등 의심스러운 상황
- 검토 후 변경 적용된 권한에 대해서는 이용자/사용자 등 관련자에게 통지
- 이상 징후 발생 시 그 성격에 따라 선 조치 후 보고 실시
- 권한 변경 관리대장(직무 변경, 입·퇴사자)을 기준으로 이상 징후 확인

증거자료

- 접근권한 검토 이력 (접근권한 점검대장)
- 이상 징후 발견 시 조치 절차
- 정보보호 정책서
- 접근통제관리지침

부적합 사례

- **사례 1 :** 클라우드서비스 운영을 위한 클라우드시스템의 접근권한 검토 기준을 수립하였으나 검토 주기, 검토 담당자 및 책임자 등 접근권한 검토 절차에 포함되어야 할 내용이 누락되어 있는 경우
- **사례 2 :** 클라우드서비스 운영을 위한 클라우드 시스템의 접근권한에 대해 내부에서 수립한 주기에 따른 접근권한 검토를 수행하지 않는 경우
- **사례 3 :** 클라우드서비스 운영을 위한 클라우드 시스템의 접근권한에 대해 내부에서 수립한 주기에 따라 접근권한 검토를 수행하고 있으나 장기미사용 계정, 업무를 수행하지 않는 담당자 계정이 존재하는 경우
- **사례 4 :** 내부 정책·지침에 장기 미사용자 계정에 대한 잠금(비활성화) 또는 삭제 조치하도록 되어 있으나, 장기 미 사용자의 계정이 활성화되어 있는 경우(접근권한 검토가 충실히 수행되지 않아 해당 계정이 식별되지 않은 경우)
- **사례 5 :** 접근권한 검토 시 접근권한의 과다 부여 및 오·남용 의심사례가 발견되었으나, 이에 대한 상세조사, 내부보고 등의 후속조치가 수행되지 않은 경우
- **사례 6 :** 클라우드 인프라 자동화 도구에서 사용되는 API 기반 계정에 대한 접근권한 검토가 수행되지 않아 관련 계정으로 인한 위험이 존재하는 경우

10.3 사용자 식별 및 인증

항목	10.3.1 사용자 식별	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○	○	
인증기준	클라우드 시스템에서 사용자를 유일하게 구분할 수 있는 식별자를 할당하고 추측 가능한 식별자 사용을 제한하여야 한다. 동일한 식별자를 공유하여 사용하는 경우 그 사유와 타당성을 검토하고 책임자의 승인을 받아야 한다.						
점검항목	공통	1) 클라우드 시스템에서 사용자를 유일하게 구분할 수 있는 식별자를 할당하고, 추측 가능한 식별자의 사용을 제한하고 있는가?					
	공통	2) 동일한 식별자를 공유하여 사용하는 경우 그 사유와 타당성을 검토하고 책임자의 승인을 받고 있는가?					
점검목적	사용자 식별자를 고유하고 추측 불가능한 방식으로 관리하여 책임추적성을 확보하고 부적절한 식별자 공유로 인한 보안 위험을 방지한다.						
참고	• ISMS-P 2.5.2 사용자 식별 • ISO/IEC 27017 5.16 계정 관리						

점검항목 해설

점검항목 1)

■ 클라우드 시스템은 사용자를 유일하게 구분할 수 있는 식별자(아이디)를 할당하여 모든 사용자의 책임추적성을 보장하여야 한다.

- 시스템 설계 시에 유일한 식별자 발급에 대한 부분을 고려
- 관리자 및 특수권한 계정은 추측 가능한 식별자(root, administrator 등) 사용은 제한
- 시스템 설치 후 제조사 또는 판매사의 기본계정 및 시험계정 등은 제거·비활성화·안전한 인증수단 적용 후 사용 또는 추측이 어려운 계정으로 변경과 같은 통제 방안 마련
- 기본 계정 사용 시 별도의 통제방안 마련
- API 기반 접근 사용자·자동화 계정도 동일하게 유일한 식별·로그 기반 추적이 가능해야 함

점검항목 2)

■ 클라우드 시스템 관련 업무상 불가피하게 계정을 공유하여 사용할 경우, 사유와 타당성을 검토하여 책임자의 승인을 받아야 하며 책임추적성을 보장할 추가적인 통제방안을 적용하여야 한다.

- 공유 계정 사용 시 사용자의 식별을 위한 추가 인증 및 접근 통제방안 마련
- 공유 계정 사용 시 사용기간 최소화 필요

증거자료

- 시스템 관리자 계정 관리대장
- 공용 계정 관리대장
- 공용 계정 발급 승인 내역
- 정보보호 정책서
- 접근통제관리지침

부적합 사례

- **사례 1 :** 클라우드서비스 운영을 위한 클라우드 시스템(VM, 하이퍼바이저, DBMS, 네트워크, Application, 응용프로그램, 네트워크, 정보보호시스템 등)의 계정을 공용으로 사용하기 위해 필요한 절차를 수립하지 않는 경우
- **사례 2 :** 클라우드서비스 운영을 위한 클라우드 시스템의 계정을 공용계정으로 사용하고 있으나, 공용계정 사용에 대한 타당성 검토를 수행하고 책임추적성을 확보할 수 있는 보완통제 방안(접속로그의 주기적 점토, 담당자 간 상호 직무검토 등)을 마련하여 책임자의 승인을 받지 않는 경우
- **사례 3 :** 클라우드서비스 운영을 위한 클라우드 시스템의 계정 현황을 확인한 결과, 제조사에서 제공하는 기본 관리자 계정을 변경하지 않고 사용하고 있는 경우
- **사례 4 :** 개발자가 개인정보처리시스템 계정을 공용으로 사용하고 있으나, 타당성 검토 또는 책임자의 승인 등이 없이 사용하고 있는 경우
- **사례 5 :** 클라우드 시스템 유지보수업체 직원의 계정을 별도로 부여하지 않고 기존 등록되어 있는 계정을 공용으로 사용하고 있는 경우
- **사례 6 :** 자동화 시스템(Terraform, Jenkins, GitLab, Ansible 등)에 동일한 계정 사용 (DevOps)

항목	10.3.2 사용자 인증		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○	○	○	○	○
인증기준	클라우드 시스템에 대한 접근은 사용자 인증, 로그인 횟수 제한, 불법 로그인 시도 경고 등 안전한 사용자 인증절차에 의해 통제하여야 한다.							
점검항목	공통	1) 클라우드 시스템에 대한 접근은 사용자 인증, 로그인 횟수 제한, 불법 로그인 시도 경고 등 안전한 사용자 인증절차에 의해 통제하고 있는가?						
	공통	2) 싱글사인온 등의 인증 방법을 사용하는 경우, 이에 대한 별도의 보호대책을 수립하고 있는가?						
점검목적	안전한 사용자 인증절차를 적용하여 비인가 접근을 방지하고 클라우드 시스템의 기밀성·무결성·가용성을 보호한다.							
참고	• ISMS-P 2.5.3 사용자 인증 • ISO/IEC 27017 8.5 안전한 인증							

점검항목 해설

점검항목 1)

■ 클라우드 시스템에 대한 접근은 사용자 인증, 로그인 횟수 제한, 불법 로그인 시도 경고 등 안전한 사용자 인증절차에 의해 통제하여야 한다.

- 시스템 설계 및 운영 시에 사용자 인증에 대한 통제방안 고려
- 비밀번호 및 인증정보 강도 기준(길이, 복잡도, 변경주기, 재사용 제한 등) 설정 및 관리
- 공개 인터넷망을 통해 접속하는 포탈의 경우 아이디, 패스워드 기반 이외에 강화된 인증수단(OTP, 인증서, 보안토큰 등) 적용 고려
- 특수권한 계정, 원격접속, 외부업체 접속 등 위험도가 높은 접근은 MFA 적용 권고
- 일정 횟수 이상 로그인 실패 시 계정 잠금 또는 CAPTCHA 적용
- 법적 요구사항에 따른 강화된 인증방식 사용이 필요한 경우 준수

점검항목 2)

■ 싱글사인온 등 다양한 클라우드 시스템에 대한 사용자 인증을 용이하게 하는 시스템을 운영하는 경우 병목 및 침투(인증 도용 등) 시 피해 확대 가능성이 있으므로 별도의 보안대책(주요 시스템 재인증, 강화된 인증 적용 등)을 마련하여야 한다.

- SSO 기반 접근 시 서비스의 중요도 또는 민감도에 따라 정보 접근 전 추가 인증 (재인증 또는 MFA) 권고

- 세션 하이재킹, 토큰 도용 방지를 위한 토큰 암호화, 유효기간 제한, IP/단말 기반 검증 적용
- 클라우드 간 계정 연동(AD, LDAP, SAML, OAuth 등) 시 권한 승계 범위 최소화
- SSO 인증 로그(성공/실패, 사용자, IP, 위치 기반)를 별도 모니터링 및 이상 탐지

증거자료

- 사용자 인증 화면
- 로그인 횟수 제한 설정 또는 제한된 화면
- 불법 로그인 시도 경고 화면
- 강화된 인증 수단 제공 화면
- 정보보호 정책서
- 접근통제관리지침

부적합 사례

- **사례 1 :** 클라우드서비스 운영을 위한 클라우드 시스템(VM, 하이퍼바이저, DBMS, 네트워크, Application, 응용프로그램, 네트워크, 정보보호시스템 등)에 접근하기 위한 사용자 인증 절차를 수립하지 않는 경우
- **사례 2 :** 클라우드서비스 운영을 위한 클라우드 시스템 로그인 실패 시 해당 ID가 존재하지 않거나 비밀번호가 틀림을 자세히 표시해 주고 있는 경우
- **사례 3 :** 관리자 포털(관리시스템)에서 타당한 사유 없이 세션 타임아웃이 설정되어 있지 않는 경우
- **사례 4 :** 관리자 포털(관리시스템), 이용자 포털(관리시스템)에서 내부 절차에 따른 로그인 횟수 제한을 적용하지 않는 경우
- **사례 5 :** 관리자 포털(관리시스템)에서 동일 계정에 의한 동시 접속을 허용하고 있는 경우
- **사례 6 :** 인증 세션 유지 시간이 지나치게 길어 (예: 24시간 세션 유지 등) 최초 로그인 이후 재인증 없이 관리 콘솔에서 장시간 작업 가능한 경우

항목	10.3.3 강화된 인증 수단 제공	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○
인증기준	이용자가 클라우드컴퓨팅서비스에 대해 다중 요소 인증 등 강화된 인증 수단을 요청하는 경우 이를 제공하기 위한 방안을 마련하여야 한다.						
점검항목	공통	1) 이용자 요구 시 인증(PKI)기반, OTP, 지문 등 다중 인증 수단을 제공할 수 있는가?					
점검목적	이용자 요구에 따라 강화된 인증수단을 제공할 수 있는 체계를 마련하여 계정 보안성과 서비스 신뢰성을 향상한다.						
참고	• NIST SP 800-53 R5 IA-2 Identification and Authentication(Organizational Users)						

점검항목 해설

점검항목 1)

■ 이용자 요구 시 인증서(PKI) 기반, OTP, 지문 등 다중 인증 수단을 제공할 수 있도록 방안을 마련하여야 한다.

- 추가 인증수단 예시 : OTP, 휴대폰 문자 인증, 인증서, 이메일 인증코드
- 추가 통제방안 예시 : IP(국가) 제한, MAC 제한, 브라우저 제한

※ 불특정 다수가 이용하는 클라우드 특성상 강화된 인증 수단을 기본적으로 제공하되 이용자 요구에 따라 사용 여부를 선택 가능

■ 정보통신망을 통해 외부에서 클라우드서비스 관리시스템에 접속하려는 경우 가상사설망(VPN : Virtual Private Network) 등 안전한 접속 및 추가 인증수단을 적용하여야 한다.

증거자료

- 추가 인증수단 적용 화면(OTP, 이메일 인증 등)
- 정보보호 정책서
- 접근통제관리지침

부적합 사례

- **사례 1 :** 관리자 포털(관리시스템), 이용자 포털(관리시스템)에서 인터넷을 통한 사용자 로그인을 적용하고 있으나, ID, 비밀번호 외의 강화된 인증수단을 적용하고 있지 않은 경우
- **사례 2 :** 관리자 포털 또는 이용자 포털 접속시 최초 ID, 비밀번호 기반 인증 후 다시 한번 ID, 비밀번호 기반으로 로그인 하는 경우

항목	10.3.4 패스워드 관리	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○
인증기준	법적 요구사항, 외부 위협요인 등을 고려하여 패스워드 복잡도 기준, 초기 패스워드 변경, 변경 주기 등 사용자 및 이용자 패스워드 관리 절차를 수립·이행하고 패스워드 관리 책임이 사용자 및 이용자에게 있음을 주지시켜야 한다. 특히 관리자 패스워드는 별도 보호대책을 수립하여 관리하고, 이용자 패스워드 관리절차는 공지하여야 한다.						
점검항목	공통	1) 클라우드 시스템 또는 서비스에 대해 보안성 기준을 만족하는 안전한 사용자 및 이용자 패스워드 관리 절차를 수립·이행하고 있는가?					
	공통	2) 클라우드 시스템 관리자 패스워드는 별도 목록(문서 또는 파일)으로 유지·관리하고, 비밀등급에 준하는 보호대책을 적용하고 있는가?					
	공통	3) 이용자 계정 및 패스워드 관리절차 관련 내용을 홈페이지 또는 메일 등을 통하여 이용자가 쉽게 확인하고 이해할 수 있도록 공지하고 있는가?					
점검목적	법적 요구사항과 위협 환경을 고려한 패스워드 관리 기준을 적용하여 사용자·이용자 계정의 보안을 강화하고, 특히 관리자 계정의 보호 수준을 높여 전체 시스템의 안전성을 확보한다.						
참고	• ISMS-P 2.5.4 비밀번호 관리 • ISO/IEC 27017 5.17 인증 정보						

점검항목 해설

점검항목 1)

■ 사용자 및 이용자 패스워드 관리를 위한 관리절차를 수립하여 적용하여야 한다.

- 시스템 설계 시 패스워드 관리절차의 요구사항 적용
- 패스워드를 별도 문서 또는 파일로 보관하는 경우 비밀등급으로 분류하여 비인가자의 접근통제 방안 수립
- 패스워드 저장 기능(브라우저 자동 저장 등) 사용 제한 방안 수립

※ 패스워드 관리절차 예시

- 문자(영문 대소문자), 숫자, 특수문자를 조합하는 패스워드 생성규칙 수립
- 초기/임시 패스워드를 발급할 경우 클라우드서비스 최초 로그인 시 강제 변경 기능 제공
- 패스워드는 이용자 정책에 따라 주기적으로 변경 (분기 1회 이상 권고, 동일 패스워드 재사용 금지)
- 연속된 자판 배열, 생일, 전화번호 등 추측하기 쉬운 개인 신상정보를 활용한 패스워드 사용 제한
- 패스워드 처리(입력, 변경) 시 마스킹 처리
- 클라우드 시스템 침해사고가 발생 또는 패스워드의 노출 징후가 의심될 경우 즉시 패스워드 변경
- 패스워드만 입력하는 자동 로그인은 금지
- 패스워드 분실, 도용 우려 시 본인확인 등을 통한 안전한 재발급 절차 마련 등

점검항목 2)

■ 관리자 패스워드는 일반 사용자 패스워드와 별도 관리하여야 한다.

예) 서버 시스템에 접속 가능한 일반 사용자 계정과 root 계정이 있는 경우 root 계정의 패스워드를 별도 안전하게 관리 (관리자 부재 또는 패스워드를 잊어버린 경우 확인 목적 등)

- 관리자 패스워드를 기록한 문서 또는 저장매체는 비밀에 준하여 관리
- 내화금고 등 잠금장치로 비인가자의 접근 통제

점검항목 3)

■ 이용자에게 이용자 패스워드 관리에 대한 절차를 공지하여야 한다.

- 패스워드 생성 규칙 안내 (패스워드 복잡도, 길이 등)
- 연속 숫자, 생일, 전화번호 등 추측하기 쉬운 개인 신상정보를 이용한 패스워드 생성 제한
- 주기적인 패스워드 변경 유도
- 이용자 패스워드 분실·도난 시 안전한 재발급 절차(본인인증 등)
- 연속적인 로그인 실패 시에 대한 안내
- 장기 미사용, 이용만료 등에 대한 안내
- 패스워드 관리에 대한 책임 안내 등

■ 공지 방법은 홈페이지 공지사항, 알림 메시지, 전자 우편 등을 이용하여 공지할 수 있다.

증거자료

- 패스워드 관리 절차
- 패스워드 복잡도 설정, 변경 주기 등 설정 화면
- 시스템 관리자 패스워드 관리대장
- 이용자 계정 및 패스워드 관리 방법 및 절차 공지
- 정보보호 정책서
- 접근통제관리지침

부적합 사례

- **사례 1 :** 클라우드서비스 운영을 위한 클라우드 시스템(VM, 하이퍼바이저, DBMS, 네트워크, Application, 응용프로그램, 네트워크, 정보보호시스템 등)의 패스워드 관리절차를 수립하지 않는 경우
- **사례 2 :** 내부 정책·지침에서 클라우드서비스 운영을 위한 클라우드 시스템의 패스워드 생성규칙의 기준을 정하고 있으나, 일부 클라우드 시스템에서 내부 정책·지침과 상이한 비밀번호를 사용하고 있는 경우
- **사례 3 :** 내부 정책·지침에 패스워드 변경주기가 규정되어 있음에도 불구하고 패스워드를 변경하지 않고 그대로 사용하고 있는 경우
- **사례 4 :** 운영자 또는 관리자 계정의 비밀번호가 브라우저 자동 저장 기능 등을 통해 노출될 가능성이 있는 경우

11. 네트워크 보안

11.1 네트워크 보안

항목	11.1.1 네트워크 보안정책 수립	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○	○	
인증기준	클라우드컴퓨팅서비스와 관련된 내·외부 네트워크에 대해 보안정책과 절차를 수립하여야 한다.						
점검항목	공통	1) 내·외부 네트워크를 통한 클라우드 시스템의 접근을 통제하는 보안정책이 수립되어 있는가?					
점검목적	네트워크와 네트워크 내 정보의 보안을 보장한다.						
참고	• ISMS-P 2.6.1 네트워크 접근 • ISO/IEC 27017 8.20 네트워크 보안						

점검항목 해설

점검항목 1)

■ 네트워크와 네트워크 내부 정보의 보안을 보장하여야 한다.

- 네트워크 분리를 위해 VLAN, VPC, Network Policy 등 기술적 통제를 구현
- 서로 다른 신뢰 수준의 환경(개발/테스트/운영)을 논리적 또는 물리적으로 분리
- 네트워크 트래픽 모니터링 및 이상 징후 탐지
- 네트워크 분리, 암호화 통신, 접근통제, 모니터링 등을 포함하는 네트워크 보안 정책을 수립하고 분기 1회 이상 검토
- 정책은 네트워크 분리, 암호화 통신, 접근통제, 모니터링을 포함
- 클라우드 환경에서 기술적 통제(VPC, Security Group, Network Policy 등)를 구현

■ 내부망을 통해 클라우드 시스템에 접속하는 경우 지정된 단말을 통해서만 접근할 수 있도록 통제하여야 한다.

- 스마트패드, 스마트폰 등 스마트기기를 통한 클라우드 시스템 원격운영 금지
- 무선 네트워크 사용에 대한 제한 사항
- 네트워크 관리용 단말의 접근통제 절차(IP나 MAC 통제 방법, 단말의 수 등)
- 네트워크 관리용 단말의 운영절차(백신 설치, 최신 보안패치, 불필요한 프로그램 제거, 식별 및 인증 수행 등)
- IP 할당 절차 등
- 계정별 사용현황 현행화 및 정기 검토

- 네트워크 사용 단말기 목록 관리

■ 외부 네트워크를 통한 시스템 원격운영은 원칙적으로 금지하여야 한다.

- 단 긴급 장애대응 등과 같이 부득이한 경우 보안대책 마련
  - 최고책임자의 승인
  - 접속 단말 및 사용자 인증 (IP/MAC인증, 2-factor 인증 등)
  - 한시적 접근권한 부여
  - 원격으로 접근하는 채널에 대한 보호 대책(VPN 사용, SSH 사용 등)
  - 접속 단말 보안
  - 원격 운영 현황 모니터링
  - 원격 접속에 대한 로깅 및 주기적 분석
  - 원격운영 관련 보안인식 교육 등
  - 접속 위치 제한 : 접근가능 위치 제한, 접속자 특정 IP주소 할당
  - 외부에서 시스템 접속 시 관리자 전용 페이지 접근 제한

증거자료

- 정보자산목록 (IP정보 포함)
- 네트워크 구성도 (IP정보 포함)
- 방화벽 정책
- Network Policy
- 단말기 접근 통제 방안
- 클라우드 접속 단말기 지정 현황
- 시스템 원격 접속 현황 및 방법
- 정보보호 정책서
- 네트워크보안지침

부적합 사례

- **사례 1 :** 내부 서버팜이 구성되어 있으나, 네트워크 접근제어 설정 미흡으로 내부망에서 서버팜으로의 접근이 과도하게 허용되어 있는 경우
- **사례 2 :** 외부자(외부 개발자, 방문자 등)에게 제공되는 네트워크를 별도의 통제 없이 내부 업무 네트워크와 분리하지 않은 경우
- **사례 3 :** 내부 정책·지침과는 달리 MAC주소 인증, 필수 보안 소프트웨어 설치 등의 보호대책을 적용하지 않은 상태로 네트워크 케이블 연결만으로 사내 네트워크에 접근 및 이용할 수 있는 경우
- **사례 4 :** 내부 정책·지침에는 클라우드 시스템에 대한 원격 접근은 원칙적으로 금지하고 불가피한 경우 IP 기반의 접근통제를 통하여 승인된 사용자만 접근할 수 있도록 명시하고 있으나, 클라우드 시스템에 대한 접근 통제 IP주소가 설정되어 있지 않아 모든 PC에서 원격 접속이 가능한 경우
- **사례 5 :** 네트워크 보안 정책 문서 미수립, 방화벽 보안 룰셋을 운영 중이나, '네트워크 보안 정책' 문서가 존재하지 않음. 담당자 개인 판단으로 방화벽 규칙을 설정하고 있으며, 정책 승인 및 검토 프로세스가 없는 경우

항목	11.1.2 네트워크 모니터링 및 통제		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○	○	
인증기준	DDoS, 비인가 접속 등으로 인한 서비스 중단 및 중요정보 유출 등을 막기 위해 네트워크를 모니터링하고 통제하여야 한다.							
점검항목	공통	1) 접근통제 정책에 따라 인가된 사용자만이 내부 네트워크(서비스망, 관리망)에 접근할 수 있도록 네트워크 식별자(IP) 할당 등을 통제하고 있는가?						
	공통	2) 내부 네트워크를 구성하는 주요자산 목록, 구성도, IP 현황을 최신으로 유지하고 안전하게 관리하고 있는가?						
	공통	3) 내부 네트워크 IP 주소는 사설 IP로 할당하고 국제권고표준을 따르고 있는가?						
	공통	4) DDoS, 비인가 접속 등으로 인한 서비스 중단 및 중요 정보 유출 등을 예방하기 위해 네트워크를 모니터링하고 있는가?						
점검목적	비정상적인 행위를 탐지하고 정보보안 사고의 발생을 신속하게 식별한다.							
참고	• ISO/IEC 27017 8.16 모니터링 활동, 8.20 네트워크 보안							

점검항목 해설

점검항목 1)

■ 클라우드서비스 운영에 포함된 자산에 IP를 부여하는 경우 승인절차에 따라 IP를 할당하여야 하며, 승인되지 않은 IP의 경우 접속을 차단하여야 한다.

- 인가된 사용자만 네트워크에 접근할 수 있도록 허용
- 네트워크 장치에 불필요한 서비스 및 포트 등 제거 또는 차단

점검항목 2)

■ 내부 네트워크를 구성하는 주요 자산목록, 구성도, IP 현황 등을 최신으로 유지하고, 외부에 유출되지 않도록 대외비 이상으로 안전하게 관리하여야 한다.

- 최소한의 인력만 문서에 접근 가능하도록 통제
- 전자문서 형태로 관리할 경우 암호 설정 등
- 정기적인 접근권한 타당성 검토
- 네트워크 접근이 가능한 모든 IP 식별

점검항목 3)

■ 관리망의 주소체계는 외부로 라우팅되지 않는 표준에서 정한 사설 IP주소 체계를 사용하고, 내부 주소체계가 외부에 유출되지 않도록 하여야 한다.

- 네트워크별 IP주소 부여 기준 마련 예시

※ 사설 IP주소(RFC 1918)

- 10.0.0.0 ~ 10.255.255.255
- 172.16.0.0 ~ 172.31.255.255
- 192.168.0.0 ~ 192.168.255.255

※ IPv4 Link-Local IP(RFC 3927)

- 169.254.0.0 ~ 169.254.255.255

점검항목 4)

■ DDoS, 비인가 접속 등의 서비스 중단 및 중요정보 유출 등을 예방하기 위해 네트워크 모니터링 방안을 수립하고 이행하여야 한다.

※ 네트워크 관리 및 모니터링 등은 외부 위탁 가능하며, 외부 위탁되는 경우 계약서 또는 SLA 확인 필요

- 접속기록 및 이벤트 로그 정기 모니터링
- 의심 활동 탐지 시 자동화된 경보 및 대응 절차 수립
- 모니터링 로그는 최소 6개월 이상 보관

증거자료

- 정보자산목록 (IP정보 포함)
- 네트워크 구성도
- 네트워크 모니터링 시스템
- 네트워크 모니터링 위탁 시 계약서, SLA 등
- 정보보호 정책서
- 네트워크보안지침

부적합 사례

- **사례 1 :** 외부로부터 클라우드서비스 네트워크에 대한 침해 시도를 인지할 수 있도록 하는 상시 또는 정기적 모니터링 체계 및 절차를 마련하고 있지 않는 경우
- **사례 2 :** 네트워크 모니터링 절차에 네트워크 모니터링 시 탐지된 이상 트래픽에 대한 조치 절차가 누락되어 있는 경우
- **사례 3 :** 내부망에 위치한 데이터베이스 서버 등 일부 중요 서버의 IP주소가 내부 정책·지침과 달리 공인 IP로 설정되어 있고, 네트워크 접근 차단이 적용되어 있지 않은 경우
- **사례 4 :** 방화벽 정책에 IP를 대역으로 과도하게 허용하고, 알 수 없는 IP에 대해 접근을 허용하거나, 사용하지 않는 port를 허용하고 있는 경우
- **사례 5 :** 네트워크 보안 통제 적용 여부를 1년 이상 미검토, '네트워크 보안 통제 절차'에서는 반기별로 보안 통제를 검토하도록 하고 있으나, 실제 방화벽 규칙에 통제가 적용되었는지 정기적인 검토 이력이 없고 최근 검토 기록은 3년전이 마지막이며, 신규 추가된 가상 네트워크 3개는 검토 대상에서 누락된 경우

<table>
<tr><th rowspan="3">항목</th><th rowspan="3" colspan="2">11.1.3 네트워크 정보보호시스템 운영</th><th colspan="4">기존</th><th colspan="2">등급제(하)</th></tr>
<tr><th>IaaS</th><th>SaaS
표준</th><th>SaaS
간편</th><th>DaaS</th><th>하등급</th><th>하등급
SaaS</th></tr>
<tr><td>○</td><td>○</td><td></td><td>○</td><td>○</td><td></td></tr>
<tr><td>인증기준</td><td colspan="8">클라우드컴퓨팅서비스와 관련된 내·외부 네트워크를 보호하기 위하여 정보보호시스템(방화벽, IPS, IDS, VPN 등)을 운영하여야 한다.</td></tr>
<tr><td rowspan="3">점검항목</td><td>공통</td><td colspan="7">1) 내·외부 네트워크를 보호하기 위하여 정보보호시스템(방화벽, IPS, IDS, VPN 등)가 운영되고 있는가?</td></tr>
<tr><td>공통</td><td colspan="7">2) 정보보호시스템 관리자 등 접근이 허용된 인원을 최소화하고 비인가자 접근을 엄격하게 통제하고 있는가? (직접운영 시)</td></tr>
<tr><td>공통</td><td colspan="7">3) 정보보호시스템별 정책(룰셋 등) 신규 등록, 변경, 삭제 등 절차를 수립하고 정책의 타당성 검토를 주기적으로 수행하고 있는가? (직접운영 시)</td></tr>
<tr><td>점검목적</td><td colspan="8">네트워크와 네트워크 내부 정보의 보안을 보장한다</td></tr>
<tr><td>참고</td><td colspan="8">• ISMS-P 2.10.1 보안시스템 운영
• ISO/IEC 27017 8.20 네트워크 보안</td></tr>
</table>

점검항목 해설

점검항목 1)

■ 내·외부 네트워크 보호를 위한 정보보호시스템을 운영하여야 한다.

- 정보보호시스템 운영절차 수립
- 정보보호시스템의 운영 및 관리 등은 외부 위탁 가능하며, 외부 위탁되는 경우 계약서 또는 SLA에 정보보호시스템 운영 및 관리 등의 내용을 포함
- 외부 위탁의 경우 정기적(예: 월 1회)으로 관리현황을 보고 받아야 함
  - 보고 내용에는 보안정책 적용, 변경, 보안 업데이트, 장비 점검 내역 등 포함

점검항목 2)

■ 정보보호시스템 관리자 등 접근이 허용된 인원 이외의 비인가자 접근을 통제하여야 한다.

- 정보보호시스템 관리자는 최소 인원으로 운영
- 사용자 인증
- 관리자 단말 IP 또는 MAC 지정
- 주기적인 접속 로그 분석 등

점검항목 3)

■ 정보보호시스템의 정책을 관리(등록, 변경, 삭제 등)하는 절차를 수립하고 이행하여야 한다.

- 정보보호시스템별 적절한 보안정책(룰셋) 적용
- 정보보호시스템의 정상동작 여부 점검 수행
- 정보보호시스템의 패턴 등 보안패치 적용
- 정보보호시스템의 보안정책(룰셋)에 대한 주기적인 검토 수행

※ 정보보호시스템 보안정책 타당성 검토 대상 예시

- 미승인 정책 유무
- 장기간 미사용 정책
- 중복 또는 사용 기간 만료 정책
- 퇴직자 또는 직무 변경자 관련 정책 등

증거자료

- 정보자산목록 (정보보호시스템)
- 네트워크 구성도
- 정보보호시스템 관리자 및 관리자 PC 현황
- 정보보호시스템 로그
- 정보보호시스템 정책 관리 절차
- 정보보호시스템 정책 타당성 검토 현황
- 정보보호 정책서
- 네트워크보안지침

부적합 사례

- **사례 1 :** 침입차단시스템 보안정책에 대한 주기적 검토가 수행되지 않아 불필요하거나 과도하게 허용된 정책이 다수 존재하는 경우
- **사례 2 :** 정보보호시스템 보안정책의 신청, 변경, 삭제, 주기적 검토에 대한 절차 및 기준이 없거나, 절차는 있으나 이를 준수하지 않은 경우
- **사례 3 :** 관리자 접속 단말 지정 없이 모든 IP 허용, 클라우드 관리 콘솔, 관리용 서버 접속 시 방화벽 보안 룰셋에서 0.0.0.0/0(모든 IP) 허용함. 지정된 단말기를 통한 접속 요구사항을 충족하지 못하며, 관리자 개인 노트북에서 공공 와이파이로도 접속 가능한 상태임

항목	11.1.4 네트워크 암호화		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○	○	○	○	○
인증기준	클라우드 시스템에서 중요정보가 이동하는 구간에 대해서는 암호화된 통신 채널을 사용하여야 한다.							
점검항목	공통	1) 클라우드 시스템에서 중요정보를 송·수신하는 경우 암호화 통신 채널을 사용하고 있는가?						
점검목적	네트워크를 통해 이동하는 데이터의 기밀성, 무결성 또는 진정성을 보장한다							
참고	• ISMS-P 2.7.1 암호정책 적용 • ISO/IEC 27017 8.20 네트워크 보안, 8.24 암호 사용							

점검항목 해설

점검항목 1)

■ 클라우드 시스템에서 중요정보가 이동하는 구간에 대해서는 암호화된 통신 채널을 사용하여야 한다.

※ 암호화된 통신 채널 예시

- 서버 원격 접근 시 암호화된 통신수단(VPN, SSH 등)을 사용
- 이용자 데이터 이관 시 VPN을 통해 이관
- 기타 관리를 위한 접근 시 OpenSSH 및 OpenSSL(TLS V1.2 이상) 사용

■ 암호화된 통신 채널을 사용하는 경우 지원되는 암호의 보안 강도가 요구되는 수준을 만족하여야 한다.

- 요구되는 보안 강도 : 2^{112}
- 만족하는 알고리즘의 예
  - 블록 암호 알고리즘 : SEED, ARIA, AES 등 키 길이 128bit 이상 지원
  - 공개키 암호 알고리즘 : RSA 등 키 길이 2048bit 이상 지원
  - 해쉬 알고리즘 : SHA-256 이상 등

※ 암호이용 안내서(KISA 발간) 참고

■ DaaS의 경우 내부망(업무환경)에서 가상PC 접근 시, 암호화된 통신채널인 VPN(또는 전용회선)을 필수적으로 적용하여야 한다.

증거자료

- 클라우드서비스 내에 암호화 통신 채널 사용 현황 (대상, 방법, 알고리즘 등)
- 정보보호 정책서
- 네트워크보안지침

부적합 사례

- **사례 1 :** 내부 정책·지침에 암호통제 관련 법적 요구사항을 고려한 암호화 대상, 암호 강도, 저장 및 전송 시 암호화 방법, 암호화 관련 담당자의 역할 및 책임 등에 관한 사항이 적절히 명시되지 않은 경우
- **사례 2 :** 웹서버에 SSL(Secure Socket Layer) 인증서를 설치하여 전송하는 정보를 암호화 송·수신하는 기능을 제공하고 있으나, 취약한 버전인 TLS 1.0 및 TLS 1.1 프로토콜을 사용하고 있는 경우

항목	11.1.5 네트워크 분리		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○	○	○	○	○
인증기준	클라우드컴퓨팅서비스 제공자의 관리 영역과 이용자의 서비스 영역, 이용자 간 서비스 영역의 네트워크 접근은 물리적 또는 논리적으로 분리하여야 한다.							
점검항목	공통	1) 클라우드서비스, 사용자 그룹, 정보자산의 중요도, 법적 요구사항 등에 따라 네트워크 영역을 물리적 또는 논리적으로 분리하고 있는가?						
점검목적	서로 다른 신뢰 수준을 가진 정보 서비스, 이용자 및 정보 시스템의 그룹을 분리한다.							
참고	• ISMS-P 2.6.1 네트워크 접근 • ISO/IEC 27017 8.22 네트워크 분리, CLD.8.35 가상 컴퓨팅 환경의 분리							

점검항목 해설

점검항목 1)

■ 클라우드서비스 핵심 업무와 관련된 내부 네트워크는 물리적 또는 논리적으로 분리하고 영역 간 접근통제를 하여야 한다.

- DMZ영역은 공개서버를 경유하여 내부망으로 접근이 이뤄지지 않도록 접근통제 수행
- 이용자의 중요정보 등이 저장된 DB는 네트워크 별도 분리
- 클라우드 시스템을 운영하는 인력이 사용하는 네트워크 별도 분리
- 신뢰수준이 다른 환경(개발망, 테스트망, 서비스 망 등)에 사용되는 네트워크는 별도 구성
- 이용자 간 서비스 영역은 물리적 또는 논리적으로 분리
- 기타 업무 특성 및 중요도에 따라 네트워크 분리 기준 수립 후 적용
- 네트워크 분리 정책 준수 여부는 네트워크 구조 변경 시, 주기적(예시: 분기 1회)으로 검토
- 내부 서버에서 외부 인터넷 접근 제한
- 망간 자료전송 통제 방안 마련
- 우회 경로 차단 및 조치

※ 영역별 네트워크 분리 예시

구분	설명
DMZ망	외부로부터의 접근이 불가피한 영역 공개서버를 경유하여 내부망으로의 접근이 이루어지지 않도록 접근통제 수행
DB망	이용자의 중요정보 등 DB가 위치한 영역 다른 네트워크 영역과 분리
관리망	서버, 보안장비, 네트워크장비 등 중요 클라우드 시스템을 운영하는 인력이 사용하는 영역 다른 네트워크 영역과 분리
개발망	개발업무(개발자PC, 개발서버, 테스트서버 등)에 사용되는 영역 운영 네트워크 영역과 분리
이용자망	이용자 간 서비스 영역 물리적 또는 논리적으로 분리
기타	업무망의 경우 업무의 특성, 중요도에 따라 네트워크 대역 분리 기준 수립 후 운영

■ 외부 네트워크에서 접근할 필요가 없는 클라우드서비스 제공자의 사용자 포탈은 이용자 포탈과 별도 분리하여 내부망에 설치 운영하여야 한다.

■ IaaS의 경우 분리된 네트워크 간에는 방화벽과 같은 정보보호시스템 또는 네트워크 접근제어목록(Network ACL), 보안그룹(Security Group), 접근제어그룹(Access Control Group) 등과 같은 접근통제 기능을 제공하는 수단을 이용하여 접근통제를 적용하여야 한다.

증거자료

- 네트워크 구성도 (네트워크 분리 및 연계 방법)
- 정보보호 정책서
- 네트워크보안지침

부적합 사례

- **사례 1 :** 클라우드서비스 네트워크 내부에서 운영 네트워크와 개발 네트워크가 분리되지 않는 경우
- **사례 2 :** 클라우드서비스 네트워크 내부에서 DBMS 등을 Public Zone에서 운영하는 경우
- **사례 3 :** DMZ 및 내부망에 위치한 일부 서버에서 불필요하게 인터넷으로의 직접 접속이 가능한 경우
- **사례 4 :** 개발/운영 환경을 동일 가상 네트워크에 배치, 개발(dev), 스테이징(staging), 운영(prod) 환경을 모두 동일 가상 네트워크(10.0.0.0/16) 내 서브넷으로만 분리한 경우
- **사례 5 :** 네트워크 피어링이나 보안 룰셋으로 격리하지 않아 개발 서버에서 프로덕션 데이터베이스에 직접 접속이 가능한 경우

항목	11.1.6 무선 접근통제		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	클라우드 시스템은 무선망과 분리하고, 무선접속에 대한 접근을 통제하여야 한다. 무선접속을 사용하는 경우 그 사유와 타당성을 검토하고 책임자의 승인을 받아야 한다.							
점검항목	공통	1) 무선 네트워크 환경을 구축(AP 설치)할 경우 허가(승인), 보안성 검토 등 절차를 마련하고 구축에 따른 보호대책을 적용하고 있는가?						
	공통	2) 외부인에게 제공하는 무선 네트워크를 내부 네트워크(업무망)와 분리하고 있는가?						
점검목적	네트워크 서비스의 정보보안 메커니즘, 서비스 수준 및 서비스 요구사항이 결정되고 구현되어 모니터링되도록 보장한다.							
참고	• ISMS-P 2.6.5 무선 네트워크 접근							

점검항목 해설

점검항목 1)

■ 무선을 통한 접근이 필요한 경우 안전한 통신 채널 설정, 비인가자 사용 제한 등 사내 보안 지침에 따라 통제되어야 한다.

■ 내부 네트워크에 연결이 가능한 무선 네트워크 환경을 구축하는 경우 내부 승인절차를 마련하고 비인가된 사설 무선 네트워크가 운영되지 않도록 관리하여야 한다.

- 무선 네트워크 접속 단말 인증 방안(IP, MAC 인증 등)
- 무선 접속 시도 및 연결 이력을 기록으로 남기고 관리

■ 사전 보안성 검토 및 무선 네트워크 운영 시 다음과 같은 사항이 적용되어야 한다.

- 무선 네트워크 장비 접속 단말기 인증 및 보안
- 무선 네트워크 장비 (예 : AP, Access Point) 보안 설정 및 허용 장비 리스트
- 무선 네트워크를 통하여 접근할 수 있는 정보 시스템 범위 정의
- 무선 네트워크 사용권한 신청/변경/삭제 절차
- 사용자 식별 및 인증
- 무선 네트워크 서비스 거리 제한
- 정보 송수신 시 무선망 암호화는 안전성이 인정되는 암호화 방식* 적용

  * WPA3 또는 WPA2-Enterprise 등 서비스 시점의 최신 기술 적용 필요

- 전산실 등 통제구역 내 무선 네트워크 사용 제한
- SSID(Service Set IDentification) 브로드캐스팅 중지 및 추측 어려운 SSID 사용 등

점검항목 2)

■ 회의실, 교육장, 기자실, 민원실 등 외부인의 접근이 빈번한 장소인 경우 외부인에게 무선 네트워크 사용을 허용할 수 있으나 내부 네트워크(업무망)과 분리하여 무선 네트워크를 통한 내부 네트워크 침투 및 내부 정보유출을 방지하여야 한다.

- 임직원이 사용하는 무선 네트워크와 외부인에게 제공하는 무선 네트워크 대역 분리

증거자료

- 네트워크 구성도
- 무선 네트워크 현황
- 무선 네트워크 보호대책
- 무선 네트워크 사용 절차
- 주요 단말기 지정 현황 (IP정보 포함)
- 정보보호 정책서
- 네트워크보안지침

부적합 사례

- **사례 1 :** 외부인용 무선 네트워크와 내부 무선 네트워크 영역대가 동일하여 외부인도 무선네트워크를 통하여 별도의 통제 없이 내부 네트워크에 접근이 가능한 경우
- **사례 2 :** 무선 AP 설정 시 정보 송수신 암호화 기능을 설정하였으나, 안전하지 않은 방식으로 설정한 경우
- **사례 3 :** 업무 목적으로 내부망에 연결된 무선AP에 대하여 SSID 브로드캐스팅 허용, 무선AP 관리자 패스워드 노출(디폴트 패스워드 사용), 접근제어 미적용 등 보안 설정이 미흡한 경우
- **사례 4 :** 내부 정책·지침에는 무선네트워크를 통한 클라우드서비스의 운영 클라우드 시스템에 대한 접근을 허용하지 않고 있으나 무선 네트워크를 이용하여 운영 클라우드 시스템에 접근하는 경우

12. 데이터 보호 및 암호화

12.1 데이터 보호

항목	12.1.1 데이터 분류	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○		

인증기준	데이터 유형, 법적 요구사항, 민감도 및 중요도에 따라 데이터를 분류하고 관리하여야 한다.	
점검항목	공통	1) 클라우드 시스템 상에서 기밀성, 무결성, 가용성, 법적요구사항 등을 고려하여 데이터의 중요도를 평가하기 위한 기준을 수립하고 있는가?
	SaaS	2) 클라우드컴퓨팅서비스 제공을 위해 이용자 데이터에 대한 생명주기를 수립하고 이용자 데이터에 대한 안전한 관리 방안을 마련하고 있는가?
점검목적	조직의 정보보안 요구사항에 따라 정보에 대한 적절한 수준의 보호를 보장한다.	
참고	• ISMS-P 1.2.1 정보자산 식별 • ISO/IEC 27017 5.12 정보 분류	

점검항목 해설

점검항목 1)

■ 데이터의 유출, 장애 및 침해 발생 시 클라우드 시스템 및 이용자에게 미치는 영향을 고려하여 식별된 데이터의 중요도를 평가할 수 있도록 기준을 수립하여야 한다.

- 기밀성, 무결성, 가용성, 법적요구사항 등을 고려
- 그 외에 서비스 영향, 이익손실, 고객 상실, 대외 이미지 등 추가 고려 가능
- 이용자가 수립한 데이터 기준을 준수하도록 요청 시 반영 고려
- 클라우드 시스템 상의 데이터 식별 및 중요도 평가(IaaS, DaaS 인증일 경우)
- 중요도 등급별 적절한 보안 정책 적용(IaaS, DaaS 인증일 경우)

■ 데이터에 미치는 위험은 데이터의 중요도가 높을수록 증가하며, 비용 효과적인 방법으로 정보보호대책을 선정할 수 있다.(IaaS, DaaS 인증일 경우)

- 데이터의 중요도가 높을수록 이를 처리하는 시스템의 중요도 또한 영향을 미침 (3.3.3. 위험분석 및 평가와 연계)

※ 클라우드서비스 이용자 데이터 목록 및 중요도 평가 예시

방법	데이터 유형	보관 장소	암호화 여부	담당	C	I	A	법적 요구 사항	중요도
회원 가입 시	성명, 전화번호, 이메일, 비밀번호	이용자 DB	비밀번호 (해쉬)	홍길동	2	2	2	2	2
본인 인증 시	이름, 생년월일, 전화번호, CI, DI	이용자 DB		홍길동	2	2	2	1	2
서비스 이용 시	쿠키, 접속 로그(IP)	이용자 DB		홍길동	1	1	1	1	3
서비스 제공	클라우드서비스 데이터 (메일)	클라우드서비스 DB		홍길동	3	3	3	1	1
서비스 제공	클라우드서비스 데이터 (게시판)	클라우드서비스 DB		홍길동	3	3	3	1	1

- 중요도 평가 및 정보보호 대책 선정 시 매체(스토리지, 백업 드라이브 등), 가상머신 이미지, 스냅샷 등에 대해서도 고려

점검항목 2)

■ 클라우드서비스에서 생성 및 처리되는 데이터를 이용자 데이터와 사용자 데이터로 분류하고, 중요도 및 민감도에 따른 데이터 분류를 수행하여야 한다.

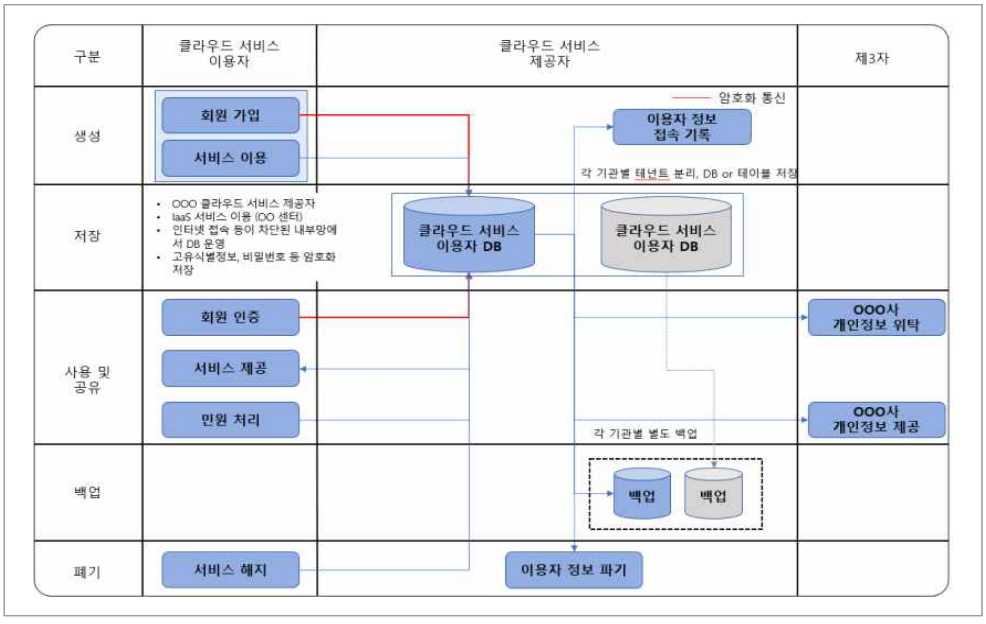
※ 데이터 분류 예시

구분	데이터	중요도			민감도		
		상	중	하	상	중	하
이용자 데이터	이용자 기관의 직원 정보	○				○	
사용자 데이터	서버 로그	○			○		
	사용자 계정 및 패스워드	○			○		

■ 이용자 데이터의 안전한 관리방안을 수립하여 적용하여야 한다.

- 이용자 데이터의 생성, 전송, 저장, 사용, 이전, 폐기, 백업, 복구, 이용자 데이터에 대한 접근통제, 이용자 데이터의 변조방지 등 포함
- 이용자 데이터가 클라우드 시스템에서 처리되는 프로세스를 파악할 수 있도록 흐름도나 흐름표 등을 이용하여 표현

※ 클라우드서비스 이용자 흐름도/흐름표 예시



증거자료

- 데이터 분류표
- 데이터 중요도 평가기준
- 데이터 흐름도/흐름표
- 데이터 현황/목록
- 정보보호 정책서
- 데이터보호 및 암호화 지침

부적합 사례

- **사례 1 :** 데이터 분류 및 중요도 평가 기준을 준수하여 데이터 목록, 분류표에 분류 현황 및 평가 결과가 반영되지 않은 경우
- **사례 2 :** 계정정보, 로그, 직원 개인정보 등의 데이터가 분류되어 있지 않아 이용자 데이터와 사용자 데이터의 구분이 명확하지 않은 경우
- **사례 3 :** 데이터 흐름도/흐름표를 작성하였으나 이용자 데이터의 생성, 저장, 사용, 폐기 등 처리 단계별 흐름이 누락되어 있거나, 실 데이터 흐름과 상이한 경우
- **사례 4 :** 이용자의 데이터 흐름이 변경(추가, 삭제 등)되었으나, 데이터 흐름도/흐름표를 현행화하지 않은 경우
- **사례 5 :** 데이터 분류 체계는 있으나 실제 데이터에 미적용, '데이터 분류 정책' (Public/Internal/Restricted/Confidential 4단계)이 있으나, 객체 스토리지 버킷, 데이터베이스 인스턴스에 분류 태그가 적용되지 않음. 1,200개 스토리지 버킷 중 민감도 태그가 있는 버킷은 3개인 경우

항목	12.1.2 데이터 소유권	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○	○	
인증기준	이용자와 서비스 수준 협약 단계에서 데이터의 소유권을 명확하게 확립하여야 한다.						
점검항목	공통	1) 이용자와의 클라우드컴퓨팅서비스 수준 협약 시 협약서 내에 생성되는 데이터에 대한 소유권(정의, 분류, 책임 등)을 명시하고 있는가?					
점검목적	조직의 정보, 기타 관련 자산 및 정보 처리 시설을 식별하고 이들 목록이 작성·유지되는지 확인한다						
참고	• 클라우드컴퓨팅법 제27조(이용자 정보의 보호), 시행령 제19조(계약 종료 또는 사업 종료 사실의 통지 등)						

점검항목 해설

점검항목 1)

■ 클라우드서비스 제공자는 서비스 제공 시 발생하는 데이터의 소유권을 명확하게 정의하여야 하며, 데이터 소유권은 클라우드 사업자와 이용자 사이의 계약에 의해 정의하여야 한다.

- 모든 데이터의 소유권(정의, 분류, 전달된 책임 등)을 지정

※ 데이터 소유권 및 보안서비스 제공 관련 계약서 예시

- 클라우드서비스를 이용하면서 발생하는 데이터의 소유는 이용자에게 있으며 클라우드서비스 제공자는 법령이 정하는 바에 따라 데이터를 보호하여야 한다.
- 클라우드서비스 제공자는 적절한 수준의 보안서비스를 제공하고 사고를 방지할 의무가 있으며 이용자는 이용자의 주의의무 위반으로 인한 이용자 정보의 도용 및 유출 등에 대해서 책임을 진다.

증거자료

- 클라우드서비스 제공 계약서, 약관, SLA 등
- 정보보호 정책서
- 데이터보호 및 암호화 지침

부적합 사례

- **사례 1 :** 클라우드서비스 표준계약서에 서비스 수준을 포함하여 계약을 체결하였으나, 생성되는 데이터 소유권 내용이 포함되어 있지 않은 경우
- **사례 2 :** 서비스 제공 시 발생하는 데이터의 소유권을 명확하게 정의한 문서가 없으며, 계약 시 일부 내용(분류, 책임 등)이 누락되어 있는 경우

항목	12.1.3 데이터 무결성	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○		
인증기준	입·출력, 전송 또는 데이터 교환 및 저장소의 데이터에 대해 항상 데이터 무결성을 확인하여야 한다.						
점검항목	공통	1) 클라우드 시스템 내 이용자 데이터의 입력, 출력, 전송, 저장 시 데이터의 무결성을 보장하기 위해 기술적인 방안을 마련하고 있는가?					
점검목적	클라우드컴퓨팅서비스에서 처리되는 데이터의 무결성이 유지되는지 확인한다						
참고	• ISMS-P 2.10.5 정보전송 보안 • ISO/IEC 27017 5.14 정보 전송						

점검항목 해설

점검항목 1)

■ 클라우드 시스템 내 이용자 데이터가 입력, 출력, 전송, 저장되는 경우 이용자 데이터에 대한 무결성을 보장하기 위한 기술적인 방안을 수립하여야 한다.

- 시스템 설계 시 이용자 데이터 처리 유형별 무결성 보장 방안을 고려
- 무결성 보장이 필요한 이용자 데이터에 대한 분류 및 정의 수행

※ 데이터 처리 유형별 무결성 보장 예시

구분	설명
데이터 입력, 출력 시 (클라우드서비스 이용 시)	· 서비스 이용자 또는 서비스 관리자 App에서 데이터 입력, 출력 시 무결성 보장
데이터 전송 시	· 데이터 전송 시 암호화 및 체크섬(해시) 적용
데이터 저장 시	· 중요 데이터 저장 시 체크섬(해시) 적용 또는 암호화

증거자료

- 데이터 무결성 조치 기술
- 시스템 설계서 등
- 데이터 흐름도/흐름표 상의 무결성 보장 방안

부적합 사례

- **사례 1 :** 무결성 보장이 필요한 이용자 데이터에 대한 분류 및 정의가 되어 있지 않거나 일부 데이터만 분류되어 있는 경우
- **사례 2 :** 이용자 데이터 처리 유형별 무결성을 보장하기 위한 기술적인 방안이 수립되어 있지 않거나 처리 유형 일부만 방안이 수립되어 있는 경우
- **사례 3 :** 클라우드서비스 제공자가 문제 파악, 해결 등 필요시 이용자 정보에 접근이 가능하나 데이터 무결성 검증 방안이 수립되어 있지 않은 경우

항목	12.1.4 데이터 보호		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○	○	○		
인증기준	데이터에 대한 접근제어, 위·변조 방지 등 데이터 처리에 대한 보호 기능을 이용자에게 제공하여야 한다.							
점검항목	공통	1) 데이터에 대한 접근제어 및 위·변조 방지 등의 데이터 보호 기능 방안을 마련하고 있는가?						
	공통	2) 이용자 데이터에 대하여 정부 또는 제3자의 요청 시 제공하는 절차를 마련하고 있는가?						
	공통	3) 클라우드컴퓨팅서비스 제공자는 법적으로 허용된 범위 외에는 이용자 소유의 파일에 접근하거나 파일 내용을 볼 수 없도록 하고 있는가?						
점검목적	정보 및 기타 관련 자산에 대한 접근을 허가된 이용자로 제한한다.							
참고	• ISO/IEC 27017 8.12 데이터 유출 방지							

점검항목 해설

점검항목 1)

■ 모든 매체(스토리지, 백업 드라이브 등), 가상화된 이미지, 스냅샷에 대해 엄격한 접근 통제가 이루어져야 된다.

- 데이터에 대한 논리적 접근제어(가상화 이미지 및 스냅샷 등)
  - 가상화 이미지 및 스냅샷에 대한 무단 변경을 탐지하기 위한 암호 체크섬
- 시스템 자원, 데이터 자산, 백업 매체에 대한 물리적 접근제어
- 데이터 입력, 처리, 통신, 전송, 출력, 저장 및 검색과 관련된 처리 및 전송 통제
- 접근 가능한 인원을 최소화하고 접근권한 부여 등을 통해 접근통제 수행
- 데이터에 접근할 수 있는 모든 경로 식별하여 접근통제 정책 적용
- 데이터 접근은 역할기반 접근통제(RBAC)를 고려하여 최소 권한 원칙을 적용

■ 다음의 경우 데이터의 분실 방지 대책이 마련되어 있는지 확인하여야 한다.

- 저장 데이터 : 클라우드 시스템 내 스토리지에 저장된 데이터
- 전송 데이터 : 클라우드서비스 중 내·외부 네트워크에서 전송중인 이용자 데이터

■ 다수 이용자에게 서비스를 제공할 경우 데이터 개별 분리 (테넌트 분리, 테이블 분리, 물리적 분리 등)가 적용되어야 한다.

- NAS의 디렉토리 접근 권한 방식 적용 불가
- Object Storage를 통한 이용자별 접근통제 적용 가능

• Block Storage를 통한 이용자별 스토리지 테넌트 분리

※ SaaS 서비스의 경우 이용자별 데이터는 최소한 테이블 단위 분리 보관 권고

■ SaaS의 경우 클라우드서비스 제공자는 중요 데이터(로그정보, 이용자 데이터 등)에 대한 접근을 통제하여야 한다.

- 접근 가능한 인원을 최소화하고 접근 권한 부여 등을 통해 접근통제 수행

■ SaaS의 경우 클라우드서비스 제공자는 중요 데이터의 위변조를 방지하는 보호대책을 수립하여 적용하여야 한다.

- 데이터의 전송 및 저장 시 데이터의 위변조 방지를 위한 기술적 보호조치 적용
  - 암호 알고리즘, 해시 알고리즘 등을 이용한 위변조 방지기능 적용

점검항목 2)

■ 이용자 데이터에 대하여 정부 또는 제3자의 요청이 있는 경우 제공하는 절차를 수립하여야 한다.

- 이용자 데이터를 정부 또는 제3자에게 제공하는 경우 데이터 소유자의 동의 필요
- 개인정보가 포함된 경우 개인정보 보호법에 정의된 절차 준수

점검항목 3)

■ 클라우드서비스 제공자는 법적으로 허용된 범위 외에는 이용자 데이터에 접근하거나 내용을 볼 수 없도록 조치하여야 한다.

- 이용자 데이터에 대한 암호화 등 엄격한 접근통제 정책의 수립 및 적용
- 법적 허용범위 등 이용자 데이터 접근이 가능한 경우에 대한 기준 및 절차 마련
- 비인가된 이용자 데이터 접근에 대한 탐지 및 모니터링 체계 마련 등

증거자료

- 데이터 분류표
- 데이터 중요도 평가 기준
- 데이터 현황
- 데이터 보호조치 기술
- 데이터 무결성 조치 기술
- 이용자 데이터 접근통제 방안
- 시스템 설계서 등

부적합 사례

- **사례 1 :** 중요 데이터(로그정보, 이용자 데이터 등)에 접근할 수 있는 사용자 권한을 업무 연관성이 없는 내부 임직원 또는 부서에 부여하고 있는 경우
- **사례 2 :** 이용자의 동의 또는 요청에 의한 일시적 접근 및 법적으로 허용된 범위 외에 이용자 데이터에 접근한 접속 이력이 확인되는 경우
- **사례 3 :** 이용자의 데이터를 분리하여 서비스를 제공하지 않아 A기관의 관리자가 B기관의 서비스 제공에 영향(데이터 수정, 삭제 등)을 미치는 경우
- **사례 4 :** 스토리지 접근 권한을 1년간 검토하지 않은 경우
- **사례 5 :** 500개 객체 스토리지 버킷에 IAM 사용자 80명이 접근 권한을 보유한 경우
- **사례 6 :** 퇴사자 3명의 계정이 삭제되지 않고 여전히 전체 읽기/쓰기 권한을 유지고 있으며 접근 권한 최종 검토일로부터 13개월이 지난 경우

항목	12.1.5 데이터 추적성	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○		
인증기준	이용자에게 데이터를 추적하기 위한 방안을 제공하고, 이용자가 요구하는 경우 구체적인 제공정보(이용자의 정보가 저장되는 국가의 명칭 등)를 공개하여야 한다.						
점검항목	공통	1) 클라우드 이용자의 데이터가 어디에 저장·관리되고 있는지 확인할 수 있는 방안을 마련하고 있는가?					
점검목적	이벤트를 기록하는 로그가 작성되고 저장되며 보호된다.						
참고	• 클라우드컴퓨팅법 제26조(이용자 보호 등을 위한 정보 공개) • ISO/IEC 27017 5.14 정보 전송						

점검항목 해설

점검항목 1)

■ 서비스 제공 전에 이용자와 합의하여 데이터가 저장 및 처리되는 위치를 계약서 또는 SLA에 명확히 포함하여야 한다.

- 클라우드서비스 제공자와 이용자가 서비스 제공에 관한 계약 체결 시 계약서 또는 SLA에 저장 및 처리 위치를 명시

※ 계약서 내 이용자의 데이터 저장 및 처리 위치 포함 예시

> **제OO조**(목적) 이 계약은 OOOO (이하 "사업자"라 한다)이 제공하는 클라우드서비스 (데이터 저장 및 처리 위치 : OOO사 가나다클라우드 IaaS 서비스) 이용과 관련하여 사업자와 클라우드서비스를 이용하고자 하는 이용자(이하 "이용자"이라 한다)간의 권리와 의무 및 책임범위, 그밖에 필요한 기본적인 사항을 규정함을 목적으로 한다.

■ IaaS, DaaS의 경우 클라우드서비스 이용자에게 데이터의 물리적 위치를 확인할 수 있는 메커니즘을 제공하여야 한다.

- 데이터의 물리적 위치정보는 데이터센터의 위치 등을 포함

증거자료

- 클라우드서비스 제공 계약서, SLA 등
- 클라우드서비스 이용 홈페이지 화면 (시스템으로 메커니즘 구현 시)

부적합 사례

- **사례 1 :** 클라우드서비스 제공 계약서에 데이터 저장 및 처리되는 위치 내용이 누락되어 있거나, 일부 내용만 포함되어 있어 현황 파악이 어려운 경우
- **사례 2 :** 데이터의 물리적 위치를 확인할 수 있도록 홈페이지 및 모바일 웹사이트에 링크를 제공하고 있으나, 접속이 되지 않아 파악이 어려운 경우
- **사례 3 :** 이용자의 데이터가 저장되어 있는 물리적 위치를 확인할 수 있으나, 백업 데이터 등 일부 데이터에 대한 물리적 위치는 확인할 수 없는 경우

항목	12.1.6 데이터 폐기	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○
인증기준	클라우드컴퓨팅서비스 종료, 이전 등에 따른 데이터 폐기 조치 시 이용자와 관련된 모든 데이터를 폐기하여야 하며, 폐기된 데이터를 복구할 수 없도록 삭제 방안을 마련하여야 한다.						
점검항목	공통	1) 클라우드컴퓨팅서비스 이용 종료 또는 이전 시 이용자가 생산한 데이터의 폐기 시 정보가 복구되지 않는 방법으로 처리하고 있는가?					
점검목적	정보가 더 이상 필요하지 않을 때 정보의 노출을 방지한다.						
참고	• 클라우드컴퓨팅법 제27조(이용자 정보의 보호) • ISMS-P 2.9.7 정보자산의 재사용 및 폐기 • ISO/IEC 27017 7.14 장비의 안전한 폐기 또는 재사용, 8.10 정보 삭제						

점검항목 해설

점검항목 1)

■ 이용자와의 계약 종료 또는 이전 시, 이용자의 데이터를 재사용할 수 없도록 정보를 완전히 삭제하여야 한다.

- 시스템 설계 시 이용자 데이터 완전삭제 기능 적용
  - 표준화된 방법 적용(NIST 800-88r2, HMG IAS No.5, Russian GOST R 50739-95, German VSITR 등)
  - 새로운(무의미한) 데이터, 0 또는 1 등을 여러 차례 덮어쓰기 적용
- 보존기한이 경과한 데이터는 자동 파기 정책 적용
- 이용자의 데이터를 백업해 놓은 경우, 백업데이터도 일정 기간 이내(이용자와 협의하여 기한을 정함)에 삭제
- 데이터 폐기 이후 폐기 사실에 대하여 이용자에게 통보

※ 계약서 내 이용자의 데이터 반환 및 파기 예시

> **제OO조**(이용자 정보의 처리 등) ① 계약이 해제, 해지 또는 종료되면 이용자 정보를 이용자에게 반환하여야 하고, 이용자가반환을 받지 아니하거나 반환을 원하지 아니하는 등의 이유로 사실상 반환이 불가능한 경우에는 이용자와 협의하여 이용자 정보를 파기한다.
> ② 이용자의 이용자 정보를 폐기할 때 사업자는 복구가 불가능한 방법으로 완전히 폐기해야 하며, 이용자는 완전히 폐기 되었는지를 확인하여야 한다.

■ SaaS의 경우 클라우드서비스 이용자의 SaaS 애플리케이션 사용 종료, 이전 등에 따른 데이터 폐기 조치 시 폐기된 데이터를 복구할 수 없도록 데이터 삭제

증거자료

- 클라우드서비스 제공 계약서, SLA 등
- 데이터 폐기 관련 기법/기술
- 시스템 설계서 등
- 데이터 폐기 적용 기술

부적합 사례

- **사례 1 :** 클라우드서비스를 이전한 이용자의 백업테이블에 저장되어 있는 데이터가 파기되지 않고 보관되고 있는 경우
- **사례 2 :** 클라우드서비스 제공 계약서에 계약 종료 후 이용자의 데이터 폐기 사실을 이용자에게 통보하도록 관련 내용이 포함되어 있으나 준수하고 있지 않는 경우
- **사례 3 :** 서비스 종료 신청 절차 및 데이터 파기 확인서 양식은 마련되어 있으나, 해당 이용자의 데이터를 파기하는 담당부서, 담당자 및 상세 절차가 수립되어 있지 않음
- **사례 4 :** 이용자의 데이터를 백업해 놓은 경우, 저장된 백업 데이터에 대한 폐기 상세 절차가 수립되어 있지 않은 경우
- **사례 5 :** 회원 탈퇴 시 개인정보를 즉시 삭제하지 않은 경우
- **사례 6 :** 회원 탈퇴 시 사용자 테이블의 삭제 플래그만 true로 변경하고 실제 개인정보(이름, 이메일, 전화번호)는 삭제하지 않은 경우
- **사례 7 :** 탈퇴 후 90일 경과한 계정 1,200개의 개인정보가 여전히 데이터베이스에 존재하는 경우

12.2 매체 보안

항목	12.2.1 저장매체 관리		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	중요정보를 담고 있는 하드디스크, 스토리지 등의 저장매체 폐기 및 재사용 절차를 수립하고 매체에 기록된 중요정보는 복구 불가능하도록 완전히 삭제하여야 한다.							
점검항목	공통	1) 클라우드시스템 폐기 또는 재사용 발생 시 중요정보를 담고 있는 저장매체 처리(폐기, 재사용) 절차를 수립·이행하고 있는가?						
	공통	2) 저장 또는 이동 매체 폐기 또는 재사용 시 정보가 복구되지 않는 방법으로 처리하고 있는가?						
	공통	3) 자체적으로 저장매체를 폐기할 경우, 관리대장을 통해 폐기 이력을 남기고 폐기확인 증적을 함께 보관하고 있는가?						
	공통	4) 외부업체를 통해 저장매체를 폐기할 경우, 폐기 절차를 계약서에 명시하고 완전한 폐기에 대한 확인을 하고 있는가?						
점검목적	저장 매체가 수명주기 전반에 걸쳐 안전하게 관리되는지 확인한다.							
참고	• ISMS-P 2.9.7 정보자산의 재사용 및 폐기 • ISO/IEC 27017 7.10 저장 매체							

점검항목 해설

점검항목 1)

■ 사용기한 경과, 고장 등의 사유로 정보 시스템을 폐기 또는 재사용(양도, 내부 판매, 재활용 등)할 경우 저장매체 처리에 관한 절차를 수립하여 저장매체에 저장된 중요정보 유출을 방지하여야 한다.

- 저장매체 용도 변환 계획 수립·승인 후 처리 결과 기록 및 보고
- 저장매체 폐기, 재사용에 따른 처리방법 정의 (예: 폐기 시에는 물리적 폐기 또는 디가우징 등, 재사용 시에는 덮어쓰기 후 완전 포맷 등)

점검항목 2)

■ 저장매체를 폐기할 경우 물리적, 전자적으로 완전 파괴하고, 재사용할 경우 완전포맷 또는 로우레벨 포맷 방식으로 정보를 삭제하여야 한다.

- 완전포맷은 저장매체 전체의 자료저장 위치에 임의의 자료를 중복하여 저장한 후 빠른 포맷이 아닌 0으로 채우거나 초기화하는 방식으로 임의 자료를 중복하여 저장하는 횟수는 조직이 스스로 정하여 적용 가능
- 로우레벨 포맷은 물리적인 공장 출고시 초기화 상태 또는 Zero-fill과 같은 전문 SW를 이용한 삭제 방식

점검항목 3)

■ 자체적으로 저장매체 폐기할 경우 폐기이력에 대한 감사증적을 확보할 수 있도록 다음 항목이 포함된 관리대장을 작성하고 관련 책임자가 확인하여야 한다.

- 폐기일자, 담당자, 확인자, 방법, 폐기확인 증적 등

점검항목 4)

■ 아웃소싱 등 외부업체를 통해 저장매체를 폐기할 경우, 내부 폐기정책과 절차 내용을 계약서에 명시하여야 한다.

- 폐기 시 폐기현장을 실사
- 폐기증적을 사진, 동영상 등으로 받아 확인
- 완전한 폐기 여부 점검

증거자료

- 저장매체 처리 절차 및 방법
- 저장매체 폐기관리대장
- 저장매체 용역 계약서 및 확인서
- 저장매체 폐기 확인 증적
- 정보보호 정책서
- 데이터보호 및 암호화 지침

부적합 사례

- **사례 1 :** 폐기된 클라우드 시스템 저장매체의 일련번호가 아닌 시스템 명을 기록하거나 폐기 대장을 작성하지 않아 폐기 이력이 관리되지 않는 경우
- **사례 2 :** 클라우드 시스템 저장매체를 자체적으로 폐기하고 있으나 저장매체 폐기관리대장이 현행화되어 있지 않으며 담당자, 폐기방법, 폐기확인 증적 등이 누락되어 있는 경우
- **사례 3 :** 클라우드 시스템 재사용 목적으로 회수한 중요정보를 담고 있는 저장매체가 완전 삭제되지 않은 상태로 잠금장치가 없거나 일반 캐비닛에 방치되고 있는 경우
- **사례 4 :** 외부업체를 통해 저장매체를 폐기하고 있으나, 계약 내용상 안전한 폐기 절차, 보호대책 관련 내용이 누락되어 있거나 폐기 이행 증적 확인, 완전한 폐기 여부 점검 및 폐기 현장 실사 등의 관리·감독이 이루어지지 않은 경우

<table>
<tr><th rowspan="3">항목</th><th rowspan="3" colspan="2">12.2.2 이동매체 관리</th><th colspan="4">기존</th><th colspan="2">등급제(하)</th></tr>
<tr><th>IaaS</th><th>SaaS
표준</th><th>SaaS
간편</th><th>DaaS</th><th>하등급</th><th>하등급
SaaS</th></tr>
<tr><td>○</td><td></td><td></td><td>○</td><td></td><td></td></tr>
<tr><td>인증기준</td><td colspan="7">중요정보 유출을 예방하기 위해 외장하드, USB, CD 등 이동매체 취급, 보관, 폐기, 재사용에 대한 절차를 수립하여야 한다. 또한 매체를 통한 악성코드 감염 방지 대책을 마련하여야 한다.</td></tr>
<tr><td rowspan="4">점검항목</td><td>공통</td><td colspan="6">1) 외장하드, USB, CD 등 이동매체 취급(사용), 보관, 폐기, 재사용에 대한 정책 및 절차를 수립·이행하고 있는가?</td></tr>
<tr><td>공통</td><td colspan="6">2) 클라우드 시스템 중 중요 시스템이 위치한 통제구역, 중요 제한구역 등에서 이동매체 사용을 제한하고 있는가?</td></tr>
<tr><td>공통</td><td colspan="6">3) 이동매체를 통한 악성코드 감염 및 중요정보 유출 방지를 위한 대책을 마련하고 있는가?</td></tr>
<tr><td>공통</td><td colspan="6">4) 이동매체 보유현황 및 관리 실태를 주기적으로 점검하고 있는가?</td></tr>
<tr><td>점검목적</td><td colspan="7">저장 매체가 수명주기 전반에 걸쳐 안전하게 관리되는지 확인한다.</td></tr>
<tr><td>참고</td><td colspan="7">• ISMS-P 2.10.7 보조저장매체 관리
• ISO/IEC 27017 7.10 저장 매체</td></tr>
</table>

점검항목 해설

점검항목 1)

■ 업무용으로 개인 휴대용 저장매체를 사용하는 것은 원칙적으로 금지하여야 하며, 업무 목적상 외장하드, USB 메모리, CD 등 휴대용 저장매체를 사용하여야 하는 경우 허가된 저장매체만 사용할 수 있도록 다음과 같은 정책 및 절차를 수립하고 이행하여야 한다.

- "이동매체"란 디스켓, 외장형 하드디스크, USB 메모리, CD, DVD 등 자료를 저장할 수 있는 일체의 것으로, PC 등의 정보통신시스템과 분리할 수 있는 기억장치를 말함
- 외부업체가 이동매체를 사용할 경우, 관련절차를 수립하고 이행하여야 함
  - 이동매체 취급(사용)범위 : 통제구역, 제한구역 등 보호구역 별 저장매체 사용 가능 여부
  - 이동매체 사용허가 및 등록
  - 이동매체 반출, 반입
  - 이동매체 폐기, 재사용
  - 이동매체 보호대책 등
  - 이동매체 보유현황 관리대장
  - 이동매체 사용기록 컴퓨터 레지스트리 확인

점검항목 2)

■ 클라우드 시스템 중 중요 시스템이 위치한 통제구역(전산실 등), 조직 내 중요정보에 접근이 가능한 제한구역(운영실, 관제실 등)에서는 이동매체의 사용 및 반입을 엄격하게 제한하여야 한다.

- 불가피하게 사용할 경우 책임자의 허가절차를 거친 후 적법한 절차에 따른 사용여부 확인을 위하여 지속적인 점검 수행
- 중요 제한구역 내 이동매체 사용현황을 불시 점검

점검항목 3)

■ 이동매체를 통해 바이러스, 악성코드가 유포되지 않도록, 이동매체가 연결되는 PC 등 단말기에 보호대책을 적용하고 주기적으로 점검하여야 한다.

- 이동매체 자동실행 기능 해지
- 이동매체 이용 시 바이러스 및 악성코드 사전(자동) 검사
- 이동매체 내 숨김 파일 및 폴더 등이 표시되도록 PC 등 단말기 옵션 변경 등
- 보안USB 등 안전한 이동매체 사용
- 이동매체 사용통제 솔루션 사용 등

■ 클라우드 사업자 조직 및 시스템의 중요정보(개인정보, 기밀정보 등)의 경우 이동매체 저장을 제한하여야 한다.

- 업무상 저장이 필요한 경우에는 암호화 등의 보호대책을 마련하여 매체 분실, 도난 등에 따른 중요정보 유출을 방지

점검항목 4)

■ 업무 목적으로 사용이 허용된 이동매체의 경우, 식별번호, 유형, 사용목적, 관리자, 책임자 등이 명시된 보유목록을 작성하고, 주기적인 자산실사를 통해 목록을 현행화하여야 한다.

- 수기 관리대장을 통해 기록하는 경우 최소 3개월 동안 유지
- 관리대장 및 이동매체는 안전한 장소(잠금장치 등)에 보관

증거자료

- 이동매체 관리절차서
- 이동매체 관리대장
- 이동매체 사용 신청서

- 이동매체 실태점검 이력
- 정보보호 정책서
- 데이터보호 및 암호화 지침

부적합 사례

- **사례 1 :** 클라우드 중요시스템 또는 조직 내 중요정보 접근이 가능한 보호구역(통제구역, 제한구역 등)에서의 이동매체 관리 절차가 수립되어 있으나 예외 승인 절차를 준수하지 않고 이동매체를 사용한 이력이 다수 확인되는 경우
- **사례 2 :** 개인정보가 포함된 이동매체를 잠금장치가 있는 안전한 장소에 보관하지 않고 사무실서랍 등에 방치하고 있는 경우
- **사례 3 :** 클라우드 사업자 조직 및 시스템 중요정보(개인정보, 기밀정보 등)의 이동매체 저장을 위해 일부 사용자에 대하여 적절한 승인절차 없이 예외적용으로 쓰기 등이 허용된 경우
- **사례 4 :** 클라우드 시스템 중 중요 시스템이 위치한 통제구역(전산실 등)에 위치한 일부 공용 PC 등 단말기에서 일반 USB에 대한 쓰기가 가능한 상황이나 매체 반입 및 사용 제한, 이력 기록 및 검토 등 통제되고 있지 않은 경우

12.3 암호화

항목	12.3.1 암호 정책 수립	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○
인증기준	기존	클라우드컴퓨팅서비스에 저장 또는 전송 중인 데이터를 보호하기 위해 암호화 대상, 암호 강도(복잡도), 키관리, 암호 사용에 대한 정책을 마련하여야 한다. 또한 정책에는 개인정보 저장 및 전송 시 암호화 적용 등 암호화 관련 법적 요구사항을 반드시 반영하여야 한다.					
	등급제 (하)	클라우드컴퓨팅서비스에 저장 또는 전송 중인 데이터를 보호하기 위해 암호화 대상, 암호 강도(복잡도), 키관리, 암호 사용에 대한 정책을 마련하여야 한다.					
점검항목	공통	1) 클라우드 시스템에서 중요정보의 전송 및 저장 시 안전한 보호를 위한 암호 정책을 수립·이행하고 있는가?					
	공통	2) 이용자(고객 등) 및 사용자(임직원 등)의 비밀번호 저장 시 암호 정책을 수립·이행하고 있는가?					
점검목적	정보의 기밀성, 무결성 또는 진정성을 보장한다						
참고	• ISMS-P 2.7.1 암호정책 적용 • ISO/IEC 27017 8.24 암호 사용						

점검항목 해설

점검항목 1)

■ 클라우드 시스템에서 개인정보 및 시스템 정보 등 중요 정보를 전송하거나 저장하는 경우 다음과 같은 내용이 포함된 암호정책을 수립하여야 한다.

- (예시) 암호 정책을 연 1회 이상 검토하고 최신 권고사항을 반영
- 암호대상 : 취급하는 정보의 민감도 및 중요도와 법적 요구사항 유무에 따라 정의

구분	대상
중요 정보	· 클라우드 시스템 운영과 관련된 정보 (정보자산목록, 네트워크 구성도, 취약점점검결과, 위험분석평가결과보고 등) · 클라우드서비스와 관련하여 이용자와 협의된 정보 · 기타 IaaS, SaaS 등 클라우드서비스 사업자가 중요도를 판단한 정보
법적 요구사항에 따른 암호화 대상	· 개인정보, 인증정보, 금융정보, 고유식별정보 등 · 개인정보가 미포함된 '하'등급 인증의 경우 적용 제외

- 암호화 방식과 암호 알고리즘 예시

암호화 방식	암호화 알고리즘	암호키 길이
대칭키 암호화 방식	SEED, ARIA, AES,	128 bits 이상
비대칭키 암호화 방식	RSA, ECDSA	2048 bits 이상
일방향 암호화 방식	SHA-256/384/512, bcrypt, scrypt, Argon2id,	-

※ 취약한 알고리즘 사용 금지(예: DES, 3DES, MD5, SHA-1 등)

- 중요 정보 전송 및 저장 시 암호화 방안

구분	암호화 방안
서버와 클라이언트 간 전송	· SSL 방식 · 응용프로그램 방식
개인정보처리시스템 간 전송	· IPSec 방식, SSL 방식, SSH 방식
개인정보처리시스템 암호화 방식	· 응용프로그램 자체 암호화 · DB 서버 암호화 · DBMS 자체 암호화 · DBMS 암호화 기능 호출 · 운영체제 암호화
업무용 컴퓨터, 보조저장매체 암호화 방식	· 문서 도구 자체 암호화 · 암호 유틸리티 이용 암호화 · DRM · 디스크 암호화

- 암호키 관리를 위한 관리지침 (암호화 대상 및 대상별 적절한 암호화 방식의 구현 여부) 점검

※ 개인정보의 암호화 조치 안내서 (KISA 발간) 참고

※ 암호 알고리즘 및 키 길이 이용 안내서 (KISA 발간) 참고

- 양자컴퓨팅에 의해 취약점이 발견된 암호 알고리즘은 사용을 제한(공개키 기반 일부 취약 암호알고리즘 등)하고 양자내성암호 사용을 권고

점검항목 2)

■ 관련 법률에 따라 이용자 및 사용자의 비밀번호는 안전한 알고리즘(예시: SHA 256, SHA 512, bcrypt, scrypt, Argon2id 등)을 통해 일방향 암호화하여야 한다.

- 법률에 따른 대상 이외의 서비스 및 시스템 비밀번호도 일방향 암호 알고리즘 적용

증거자료

- 암호화 대상 및 방법
- 정보보호 정책서
- 데이터보호 및 암호화 지침

부적합 사례

- **사례 1 :** 내부 정책에 법적 요구사항을 고려한 암호화 대상, 암호 강도, 저장 및 전송 시 암호화 방법 등 내용이 포함되어 있지 않은 경우
- **사례 2 :** 클라우드서비스 및 시스템에 적용되는 암호화 대상이 명확하게 정의되어 있지 않거나, 정의한 대상의 암호화 적용이 되어 있지 않은 경우
- **사례 3 :** 이용자 및 사용자(임직원 등) 비밀번호를 일방향 암호화 알고리즘을 적용하였으나, 안전하지 않은 MD5, SHA-1 알고리즘으로 적용한 경우
- **사례 4 :** 클라우드 시스템에서 중요정보(개인정보, 시스템 운영 정보, API 인증 정보) 전송 시 SSL v3, TLS 1.0, TLS 1.1 등 안전하지 않은 전송구간 암호화 방식을 지원하고 있는 경우

항목	12.3.2 암호키 관리	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○		
인증기준	암호키 생성, 이용, 보관, 배포, 파기에 관한 안전한 절차를 수립하고, 암호키는 별도의 안전한 장소에 보관하여야 한다.						
점검항목	공통	1) 암호키 생성, 이용, 보관, 배포, 복구, 파기 등에 관한 절차를 수립·이행하고 있는가?					
	공통	2) 암호키 생성 후 암호키는 별도의 안전한 장소에 소산 보관하고, 암호키 사용에 관한 접근권한 부여를 최소화하고 있는가?					
	공통	3) 암호키 변경에 관한 정책을 수립·이행하고 있는가?					
점검목적	정보의 기밀성, 무결성 또는 진정성을 보장한다						
참고	• ISMS-P 2.7.2 암호키 관리 • ISO/IEC 27017 8.24 암호 사용						

점검항목 해설

점검항목 1)

■ 암호키 생성, 이용, 보관, 배포, 파기에 대해 다음과 같은 항목이 포함된 정책 및 절차를 수립하고 이행하여야 한다.

구분	방법
암호키 관리 담당 지정	· 암호키 생성, 배포, 백업, 복구, 폐기를 수행하는 담당자
암호키 생성 방법	· 대칭키 또는 비대칭키 알고리즘의 암호키 생성 · 난수발생기를 이용하거나 미리 공유된 키를 이용하여 암호키 유도
암호키 보관 방법	· 유효기간 만료 전까지 장비 모듈 또는 저장매체에 보관 · 무결성 및 접근통제 적용 (물리적으로 분리된 서버에 저장, 소산백업, 암호화 키 접근 권한 최소화 등)
암호키 배포 방법	· 수동 키 분배 (수동적으로 키를 분배하고 적용) · 자동 키 분배 (인터넷 등을 통해 자동 키 분배)
암호키 사용 유효기간	· 암호화 방식별 암호키 유효기관 관리 · 최대 2년 이내 (개인정보의 암호화 조치 안내서 내의 '키 유형에 따라 권장하는 키 유효기간' 참조)
암호키 복구 방법	· 보관된 암호키 반출 및 적용 또는 암호키 재생성
암호키 폐기 방법	· 키와 관련된 자료 완전삭제

※ 암호 키 관리 안내서(KISA 발간) 참고

※ 암호 알고리즘 및 키 길이 이용 안내서 (KISA 발간) 참고

점검항목 2)

■ 생성된 암호키는 암호키 손상 시 시스템 또는 암호화된 정보의 복구를 위하여 별도의 매체에 저장 후 안전한 장소에 보관(소산백업 포함)하여야 한다.

- 소산 보관 : 천재지변 등 비상사태를 대비하여 일정거리 이상 떨어진 장소에 보관하는 방법
- 암호키는 소스코드, 설정 파일 등에 하드코딩 방식으로 구현 금지
- 암호키 접근권한 최소화
- 암호키를 서버 또는 하드웨어 토큰에 저장 시 물리적으로 떨어진 서버 사용
- 중요 암호키 및 서명키(예: JWT signing key 등)는 주기적(예: 최소 1년)으로 키 변경

점검항목 3)

■ 암호키 변경과 관련한 지침은 암호화 정책에 포함하여 수립하여야 한다.

■ 암호키의 사용 기간은 최대 2년 유효기간은 최대 5년을 권고하고 있으나, 암호키 변경 시 비용과 기업의 정보자산 및 업무 중요도를 고려하여 자체적으로 정하여 적용할 수 있다.

■ 암호키의 유효기간 만료가 가까워지는 경우, 암호키가 유출되거나 유출이 의심되는 경우, 즉시 암호키를 변경하여야 한다.

■ 암호키 유효기간 설정 시 키 노출 가능성, 노출시 위험 요소, 대응 비용 등을 고려해야 한다.

■ 담당자는 암호키 복구 및 폐기절차를 숙지하여야 한다.

증거자료

- 암호키 관리 절차
- 암호키 관리대장
- 암호키 소산 백업
- 암호키 백업현황, 암호키 백업 매체, 암호키 파기대장

부적합 사례

- **사례 1 :** 내부 정책에 암호키 관리 절차가 수립되어 있지 않거나, 각 담당자의 암호키 관리 방법이 내부 절차와 상이한 경우
- **사례 2 :** 암호키 생성 시 책임자 승인 하에 암호키를 생성하고 관리대장을 작성하도록 관련 절차가 수립되어 있으나 암호키 관리대장에 일부 암호키 작성이 누락되는 등 현행화되어 있지 않은 경우
- **사례 3 :** 암호키 관리시스템에 암호키를 보관하고 있으나, 업무와 연관이 없는 내부 사용자에게 과도한 권한(암호키 접근, 삭제 등)을 부여한 경우
- **사례 4 :** 개인정보 등 중요정보를 암호화 한 암호키를 소스코드에 하드코딩 방식으로 보관하고 있거나, 안전한 장소에 소산 보관하고 있지 않은 경우

13. 시스템 개발 및 도입 보안

13.1 시스템 분석 및 설계

항목	13.1.1 보안요구사항 정의		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○	○	
인증기준	신규 시스템 개발 및 기존 시스템 변경 시 정보보호 관련 법적 요구사항, 최신 보안취약점, 정보보호 기본요소(기밀성, 무결성, 가용성) 등을 고려하여 보안요구사항을 명확히 정의하고 이를 적용하여야 한다.							
점검항목	공통	1) 신규 시스템 개발 및 기존 시스템 변경 시 최신 보안취약점 대응, 인증, 로깅, 권한, 암호화, 접근제어 등 정보보호 기본요소, 법적 요구사항 등을 포함한 보안 요구사항을 정의하고 설계 단계에서부터 반영하고 있는가?						
점검목적	새로운 애플리케이션 또는 기존 애플리케이션의 개선 시 정보보안을 보장한다.							
참고	• ISMS-P 2.8.2 보안 요구사항 정의 • ISO/IEC 27017 8.26 응용프로그램 보안 요구사항							

점검항목 해설

점검항목 1)

■ 클라우드서비스를 개발하기 위하여 정보보호 관련 법적 요구사항, 최신 보안 취약점, 정보보호 기본요소(기밀성, 무결성, 가용성) 등을 고려한 보안 요구사항을 정의하여 적용하여야 한다.

- 기밀성/무결성/가용성이 요구되는 데이터 분류
- 데이터의 상태에 따른 기밀성/무결성 적용 여부(저장, 전송 등)
- 기밀성/무결성 적용 시 적용되는 암호 알고리즘의 적정성 여부

■ 정의된 보안 요구사항을 반영하여 설계하고 개발하여야 한다.

■ 신규 클라우드 시스템 개발 및 기존 시스템 변경 시 아래의 정보를 참고하여 요구사항 정의부터 운영까지 일관성 있게 적용할 수 있도록 하여야 한다.

- 개인정보처리에 관련된 법적 요구사항 (예 : 개인정보취급자 권한 부여 기록, 접속기록, 암호화 대상 정보 등)
- 이용자 및 기관의 정보보호 요구사항 (예 : 접근권한 정의 및 통제 원칙, 암호화 대상 선정, 외주 위탁 시 보안요구사항 등)
- 정보보호 관련 기술적인 요구사항 등 (예 : 개발보안, 인증, 암호화 등)

증거자료

- 시스템 설계서
- 시스템 변경 내역서
- 보안요구사항 정의/반영 절차
- 백업 관리대장, 백업 절차서

부적합 사례

- **사례 1 :** 클라우드서비스 개발 시 정보보호 관련 법적 요구사항, 최신 보안 취약점, 정보보호 기본요소(기밀성, 무결성, 가용성) 등을 고려한 보안 요구사항이 정의되어 있지 않거나, 적용되어 있지 않은 경우
- **사례 2 :** 신규 클라우드 시스템 개발 시 보안설계 기준(입력데이터 검증, 보안기능, 에러처리, 세션통제 등)을 정의하여 구현하도록 내부 정책이 수립되어 있으나 반영되어 있지 않은 경우
- **사례 3 :** 이용자 및 기관의 정보보호 요구사항(접근권한 정의 및 통제 원칙, 암호화 대상 선정, 외주 위탁 시 보안요구사항 등)이 반영되어 있지 않은 경우
- **사례 4 :** 신규 API 개발 시 보안 요구사항 명세서 미작성, 신규 결제 API 프로젝트의 요구사항 명세서에 '인증', '인가', '입력값 검증', '암호화', '로깅' 등 보안 요구사항 누락. 기능 요구사항만 15페이지 작성, 보안 요구사항은 0건인 경우

항목	13.1.2 인증 및 암호화 기능	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○

인증기준	클라우드 시스템 설계 시 사용자 인증에 관한 보안요구사항을 반드시 고려하여야 하며 중요정보의 입·출력 및 송·수신 과정에서 무결성, 기밀성이 요구될 경우 법적 요구사항을 고려하여야 한다.	
점검항목	공통	1) 클라우드서비스 설계 시 사용자 인증에 대한 보안 요구사항을 정의하여 반영하고 있는가?
	공통	2) 중요정보의 입·출력(저장 및 조회) 시 암호화가 요구되는 경우 법적 요구사항을 고려한 적절한 암호화 방법을 사용하고 있는가?
	공통	3) 개인정보 및 인증정보 등의 중요한 정보 전송 시 기밀성 및 무결성을 지원하는 안전한 채널을 통하여 송·수신하고 있는가?
점검목적	시스템, 애플리케이션 및 네트워크에 대한 접근에 대해 보안 인증이 구현되는지 확인한다.	
참고	• ISMS-P 2.7.1 암호정책 적용 • ISO/IEC 27017 8.24 암호 사용, 8.26 응용프로그램 보안 요구사항	

점검항목 해설

점검항목 1)

■ 클라우드 시스템 설계 시 사용자 인증에 대한 보안요구사항을 정의하여야 한다.

- 인증 시기 : 클라우드 시스템이 사용자를 인증해야 하는 시점
- 패스워드 관련 : 패스워드 잠김 임계치 설정, 패스워드 암호화, 패스워드 길이 및 조합규칙, 패스워드 변경 주기 등
- 접근 권한 : 동일사용자 동시접근 제한, 동일권한 동시접근 제한, 접근 IP 또는 MAC 제한 등
- 세션 관리 : 관리자 등 접근 후 관리 활동을 수행하지 않는 경우 타임아웃 설정 등
- 추가적인 사용자 인증 : 중요한 시스템(예 : 개인정보처리시스템 등)의 경우 추가적인 인증(예 : OTP, 생체인증, 인증서 등) 요구
- SaaS의 경우 어플리케이션 설계 시 API 등을 통해 연동 서비스 호출에 대한 안전한 인증 방안 적용 등

■ 사용자 인증 시 고려대상은 다음을 포함하여야 된다.

- 서비스 이용자를 위한 웹 포털 및 어플리케이션 인증
- 하이퍼바이저 및 관리 스택 인증
- 관리서버 사용자 인증
- 개인정보 수집서버 및 과금, API 관련 서버 등

- 관리자 기능은 일반 사용자와 분리하고 추가 인증을 요구

■ SaaS의 경우 애플리케이션 설계 및 개발단계에서 SaaS 애플리케이션 접근을 위한 안전한 인증 방안이 마련되어야 하고, 접근 권한 정책을 수립하여 사용 및 관리 권한을 부여하여야 한다.

- SaaS 애플리케이션 설계 및 개발 시 안전한 인증 방안 적용
- SaaS 애플리케이션 사용을 위한 권한 정책을 수립하고 그에 따른 사용 및 관리권한을 부여하도록 설계 및 개발단계에서 고려
- API 등을 통해 연동 서비스 호출 시 안전한 인증 방안 적용
- 인증 시 사용되는 인증키에 대한 보호 방안을 마련
- SaaS 사용자 데이터에 대한 접근 권한 정책을 수립하고 그에 따른 사용 및 관리 권한을 부여

점검항목 2)

■ 중요 정보로 분류된 데이터에 대하여 저장 시에 암호화 및 복호화를 적용하도록 설계하여야 한다.

- 이때 사용되는 암호 알고리즘은 안전성이 입증된 알고리즘과 키 길이를 사용(클라우드 정보보호 기준 12.3.1 암호정책 수립 참고)

점검항목 3)

■ 클라우드 시스템을 통해 중요 정보를 송·수신하는 경우 기밀성 및 무결성을 지원하는 안전한 채널을 통하여 중요 정보를 송·수신하도록 설계하여야 한다.

- 기밀성 및 무결성이 보장되는 통신은 일반적으로 VPN, TLS V1.2 이상이 적용된 SSL 통신 및 SSH 통신 등이 존재함

증거자료

- 시스템 설계서
- 시스템 변경 내역서
- 보안요구사항 정의/반영 절차
- 사용자 인증 기능
- 중요 데이터 전송 및 보관 시 적용 기술/기법
- 정보보호 정책서, 시스템개발보안지침

부적합 사례

- **사례 1 :** 개발 관련 지침에 사용자 인증과 관련된 보안 요구사항이 정의되어 있지 않거나 패스워드, 접근권한, 세션관리 등 중요 보안요구사항이 누락되어 있는 경우
- **사례 2 :** 안전한 전송구간 암호화 프로토콜을 사용하도록 시스템 설계서에 보안요구사항이 정의되어 있으나 SSL v3, TLS v1.0, TLS v1.1 등 취약한 암호화 프로토콜을 지원하는 경우
- **사례 3 :** 사용자 인증 관련 보안요구사항이 정의되어 있으나 접속 시도 횟수 제한, 임계치를 초과한 접속 시도 시 계정 잠김 등 정의한 보안요구사항이 반영되어 있지 않는 경우
- **사례 4 :** 사용자 입력값 검증 없이 SQL 쿼리에 직접 사용, 검색 기능에서 사용자가 입력한 검색어를 검증 없이 SQL 쿼리 문자열에 직접 연결함(String concatenation). Prepared Statement를 사용하지 않아 SQL Injection 취약점이 존재하는 경우

항목	13.1.3 보안로그 기능		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○		
인증기준	클라우드 시스템 설계 시 사용자의 인증, 권한 변경, 중요정보 이용 및 유출 등에 대한 감사증적을 확보할 수 있도록 하여야 한다.							
점검항목	공통	1) 클라우드컴퓨팅서비스 설계 시 보안관련 로그, 감사증적 등을 확보할 수 있는 기능을 반영하고 있는가?						
	공통	2) 클라우드컴퓨팅서비스 설계 시 보안로그를 보호하기 위한 대책을 마련하고 있는가?						
점검목적	보안 이벤트를 기록하는 로그가 작성되고 저장되며 보호되는지 확인한다.							
참고	• ISMS-P 2.9.4 로그 및 접속기록 관리 • ISO/IEC 27017 8.15 로깅							

점검항목 해설

점검항목 1)

■ 보안사고 발생 시, 책임 추적을 위하여 클라우드 시스템은 다음과 같은 감사증적(로그)을 확보할 수 있도록 설계하여야 한다.

- 사용자, 관리자의 접속기록 (로그인 및 로그아웃)
- 사용자 권한 부여, 변경, 말소 기록
- 중요 정보에 대한 접근 및 다운로드 기록
- 특수권한으로의 접근기록
- 감사증적은 발생일시, 발생 주체(ID, IP 등), 주체의 활동 내역이 포함되어야 함
- 보안로그 예시: 웹 접속(로그인) 로그, 웹 수행 로그, OS 접근 및 운영시 생성 로그, DB 접근 및 질의 로그, 서버/DB 접근제어 등 정보보호 솔루션 접근 및 수행 로그

점검항목 2)

■ 클라우드 시스템 설계 시 감사증적의 변조 및 비인가된 삭제를 방지하기 위한 대응이 가능하도록 설계하여야 한다.

- 감사증적에 대한 접근통제
- 감사증적에 대한 무단 변경 방지 등 무결성 확보
- 이용자 또는 관리자라 하더라도 감사증적에 대한 변경이나 삭제 불가

- 보안로그는 위변조 방지를 위하여 별도 저장소 또는 로그 서버에 전송하여 저장

증거자료

- 시스템 설계서
- 시스템 변경 내역서
- 보안요구사항 정의/반영 절차
- 시스템 감사 증적 생성 및 보호 기능
- 정보보호 정책서, 시스템개발보안지침

부적합 사례

- **사례 1 :** 개발 관련 지침에 감사증적(로그) 관련된 주요 보안 요구사항이 정의되어 있지 않거나 로그 대상, 보관, 접근통제 등 주요 보안요구사항이 누락되어 있는 경우
- **사례 2 :** 로그시스템 설계시 법적 요구사항 및 내부 정책과 달리 보존기간을 짧게 정의한 경우(예를 들어, 개인정보처리시스템의 접속기록 보존기간을 최소 1년 또는 2년 이상이 아닌 6개월로 설계한 경우 등)
- **사례 3 :** 클라우드 시스템 사용자의 감사증적의 변조 및 비인가된 삭제를 방지하도록 설계하였으나, 설계 상 오류 등으로 인해 이용자 또는 관리자가 감사증적 변경 또는 삭제가 가능한 경우

항목	13.1.4 접근권한 기능	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○		
인증기준	클라우드 시스템 설계 시 업무의 목적 및 중요도에 따라 접근권한을 부여할 수 있도록 하여야 한다.						
점검항목	공통	1) 클라우드서비스 설계 시 시스템 사용자의 업무 목적, 기능, 중요도에 따라 접근권한이 부여될 수 있도록 접근권한 부여 기능을 보안 요구사항 및 설계에 반영하고 있는가?					
점검목적	비즈니스 및 정보보안 요구사항에 따라 정보 및 기타 관련 자산에 대한 접근을 통제하는 규칙이 수립되고 구현된다.						
참고	• ISMS-P 2.6.2 정보시스템 접근 • ISO/IEC 27017 5.15 접근 통제						

점검항목 해설

점검항목 1)

■ 클라우드 시스템에 접근이 가능한 사용자에 대하여 분류하여야 하고 각 사용자의 역할에 따라 접근범위, 접근권한을 부여할 수 있도록 설계하여야 한다.

- 사용자별
- 사용자 업무 역할별(일반 사용자, 관리자, 개인정보취급자 등)
- 기능별(보안 기능, 서비스 기능, 관리기능 등)
- 메뉴별 등(설정 메뉴, 조회 메뉴 등)

■ 어플리케이션 접근통제 규칙을 수립하고 최소 권한 부여 원칙을 적용하여야 한다.

- 역할기반 접근통제(RBAC) 또는 속성기반 접근통제(ABAC)를 구현
- 관리자 기능은 일반 사용자와 분리하고 추가 인증을 요구

증거자료

- 시스템 설계서
- 시스템 변경 내역서
- 보안요구사항 정의/반영 절차
- 시스템 접근권한 부여 기능
- 정보보호 정책서, 시스템개발보안지침

부적합 사례

- **사례 1 :** 개발 관련 지침에 접근이 가능한 사용자에 대하여 분류하고 각 사용자의 역할에 따라 접근권한을 부여할 수 있도록 보안 요구사항이 정의되어 있지 않은 경우
- **사례 2 :** 클라우드시스템에 접근이 가능한 사용자에 대하여 접근권한 부여 기능 설계 내용이 포함되어 있지 않거나, 구현되어 있지 않은 경우
- **사례 3 :** 클라우드시스템 개인정보취급자 등 사용자 별 권한을 부여할 수 있는 기능이 설계 및 구현되어 있지 않는 경우

\

항목	13.1.5 시각 동기화	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○	○	
인증기준	로그기록의 정확성을 보장하고 법적인 자료로서 효력을 지니기 위해 클라우드 시스템 시각을 공식 표준시각으로 정확하게 동기화하여야 한다. 또한 서비스 이용자에게 시각 정보 동기화 기능을 제공하여야 한다.						
점검항목	공통	1) 클라우드서비스 설계 시 보안로그의 생성일시를 동기화하기 위하여 표준시각을 동기화하는 기능을 제공하고 있는가?					
점검목적	이벤트를 기록하는 로그가 작성되고 저장될 때 정확한 시간을 포함할 수 있도록 한다.						
참고	• ISMS-P 2.9.6 시각 동기화 • ISO/IEC 27017 8.17 시각 동기화						

점검항목 해설

점검항목 1)

■ 클라우드서비스 설계 시 감사증적(로그)의 생성일시를 동기화하기 위하여 표준시각을 동기화하는 기능을 제공하여야 한다.

- IaaS 클라우드서비스 제공자는 자체 시각 동기화 서버를 두고 Stratum 2 또는 3 수준을 이용하여 클라우드 시스템 시간을 동기화
- 서비스 제공자는 이용자에게 시각 정보 동기화 기능이 적용된 OS 이미지 제공 및 시각 동기화 안내
- 운영체제에서 제공하는 NTP 서버 동기화 기능 활용
- 클라우드 시스템이 직접 NTP 서버와 동기화를 위해 NTP 서버를 설정하는 기능 제공

■ 로그기록의 정확성을 보장하고 법적인 자료로서 효력을 지니기 위해 각 클라우드시스템의 시각을 표준시각으로 동기화하여야 한다.

- 로그, 백업 관련 주요 클라우드시스템의 시각을 표준시각으로 동기화
- 클라우드시스템의 시각이 표준시각으로 동기화되는지 주기적 점검

증거자료

- 시스템 설계서
- 시스템 변경 내역서

- 보안요구사항 정의/반영 절차
- 시스템 표준 시각 동기화 설정
- 정보보호 정책서, 시스템 개발보안지침

부적합 사례

- **사례 1 :** 클라우드서비스 설계 시 표준시각을 동기화하는 기능 제공 관련 요구사항을 반영한 시스템 설계서 등 증적이 확인되지 않은 경우
- **사례 2 :** 클라우드서비스 이용자에게 감사증적(로그)의 생성일시를 동기화하기 위한 표준 시각 동기화 기능을 제공하지 않는 경우
- **사례 3 :** 클라우드서비스 제공자가 제공하는 VM 이미지에 시각 동기화 기능을 제공하지 않는 경우
- **사례 4 :** 클라우드서비스 제공자가 운용하는 VM 서버가 정기적으로 시각동기화 하는 기능을 사용하지 않는 경우

13.2 구현 및 시험

항목	13.2.1 구현 및 시험	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○
인증기준	안전한 코딩방법에 따라 클라우드컴퓨팅서비스를 구현하고, 분석 및 설계 과정에서 도출한 보안 요구사항이 정보시스템에 적용되었는지 확인하기 위하여 시험을 수행하여야 한다.						
점검항목	공통	1) 클라우드컴퓨팅서비스의 안전한 구현을 위한 코딩표준이 마련되어야 하며 이에 따라 구현하고 있는가?					
	공통	2) 구현된 기능이 사전 정의된 보안 요구사항을 충족하는지 시험을 수행하고 있는가?					
점검목적	소프트웨어 개발 시 시큐어 코딩 원칙을 적용하여 개발 및 시험하는지 확인한다.						
참고	• ISMS-P 2.8.2 보안 요구사항 검토 및 시험 • ISO/IEC 27017 8.28 안전한 코딩, 8.29 개발 및 인수 시 보안 테스트						

점검항목 해설

점검항목 1)

■ 클라우드 시스템을 안전하게 개발하기 위하여 안전한 코딩표준 및 규약에 따라 구현하여야 한다.

- 외부 환경 분석(법, 제도, 규정 등)을 통한 항목 식별 및 적용
- 보안 기능 등을 결정하는 입력값에 대한 검증은 서버 측에서 수행
- 기능에 대한 보안항목 식별
  - 사용자가 입력한 데이터의 유효성 확인 및 안전한 오류 처리
  - SQL 삽입 방지
  - 검증되지 않은 URL 리다이렉션 방지
  - 안전한 세션 관리 등

※ 참고: 소프트웨어 개발 보안 가이드(KISA), OWASP Secure Coding Practices, CERT Coding Standards 등

점검항목 2)

■ 클라우드 시스템 구현 완료 후 사전 정의된 보안요구사항이 설계된 대로 구현되었는지 확인하기 위하여, 시험 시나리오, 체크리스트 등을 작성하여 시험을 수행하여야 한다.

- 모든 보안요구사항이 구현되었는지 확인

■ 시험이 수행하기 위해 시험목적, 시험의 대상 기능, 시험환경(도구 포함), 시험절차 등이 포함된 시험계획을 수립하고, 시험계획에 따라 시험을 수행한 후 시험결과를 포함하여 문서로 기록하여야 한다.

증거자료

- 시큐어 코딩 기준
- 보안 요구사항 충족 시험 증적
- 시스템 시험 문서
- 개발에 적용된 코딩표준 및 규약 목록

부적합 사례

- **사례 1 :** 클라우드 시스템을 안전하게 개발하기 위한 코딩표준이 마련되어 있으나, 입력데이터 검증, 보안기능, 에러처리, 세션관리 등 중요 보안항목을 반영하여 구현이 되지 않은 경우
- **사례 2 :** 사전 정의된 보안요구사항이 설계된 대로 구현되었는지 확인하기 위해 시험계획을 수립하였으나 시험 수행 이력 및 결과가 포함되어 있는 증적이 확인되지 않는 경우
- **사례 3 :** 구현 또는 시험 과정에서 알려진 기술적 취약성이 존재하는지 여부를 점검하지 않았거나 수행 이력이 없는 경우
- **사례 4 :** 보안 SW개발 생명주기(S-SDLC) 프로세스가 없고, 연간 20개 이상의 신규 프로젝트를 진행하고 있으나 '보안 개발 생명주기' 프로세스가 없는 경우
- **사례 5 :** 요구사항 단계부터 배포 단계까지 보안 활동(위협 모델링, 보안 코드 리뷰, 취약점 진단 등)이 정의되지 않은 경우

항목	13.2.2 개발과 운영환경 분리		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○	○	
인증기준	개발 및 시험 시스템은 운영시스템에 대한 비인가 접근 및 변경의 위험을 감소하기 위해 원칙적으로 분리하여야 한다. 단 분리하여 운영하기 어려운 경우 그 사유와 타당성을 검토하고 안전성 확보 방안을 마련하여야 한다.							
점검항목	공통	1) 클라우드컴퓨팅서비스의 개발 및 시험 시스템을 운영시스템과 분리하고 있는가?						
	공통	2) 운영환경으로의 이관 절차를 수립하고, 이에 따라 이행하고 있는가?						
점검목적	권한이 없는 인원의 무단 접근 및 운영 환경의 비인가 변경을 방지한다.							
참고	• ISMS-P 2.8.3 시험과 운영 환경 분리 • ISO/IEC 27017 8.31 개발, 테스트 및 운영 환경의 분리							

점검항목 해설

점검항목 1)

■ 클라우드서비스는 원칙적으로 개발/시험 환경과 운영환경이 분리되어야 한다.

- 개발 및 시험 시스템과 운영 시스템의 분리
- 환경별 암호화 키 분리 및 별도의 VPC, 네임스페이스, 계정 사용
- 운영 환경으로의 배포는 승인된 배포 절차를 통해서만 수행

■ 개발/시험 환경과 운영환경을 분리하기 어려운 경우 다음 사항을 포함한 보안대책을 수립한 후 적용하여야 한다.

- 개발/시험으로 인하여 영향을 받는 부분에 대한 범위 산정
- 개발/시험의 오류로 인하여 발생할 수 있는 장애의 유형 및 복구 대책
- 장애 발생 시 대응을 위한 상세한 시험절차(입력 매개변수 등 포함) 수립
- 개발/시험 중 서비스 운영의 정상 여부를 지속적으로 모니터링하기 위한 대책
- 운영환경에서 개발/시험을 수행하기 전에 정보보호 책임자 등으로부터의 승인
- 운영데이터가 시험데이터로 사용되는 경우 운영데이터 보호를 위한 대책

점검항목 2)

■ 개발/시험이 완료된 결과를 운영환경으로 이관하기 위한 절차를 수립하여야 한다.

- 개발환경에서 운영환경으로의 이관방법
- 이관 중 발생 가능한 문제 예상 및 대응방안
- 이관에 대한 책임자 승인절차

증거자료

- 개발/시험 및 운영 네트워크 구성도
- 운영환경 이관 절차
- 정보보호 정책서, 시스템 개발보안지침

부적합 사례

- **사례 1 :** 클라우드서비스의 개발 및 시험 시스템을 운영시스템과 분리하지 않고 타당한 사유 또는 승인 없이 운영환경에서 개발을 수행하고 있는 경우
- **사례 2 :** 클라우드서비스의 개발/시험 시스템이 별도로 구성되어 있으나, 개발환경에서 운영환경으로의 접근이 통제되지 않아 개발자들이 개발환경의 시스템을 경유하여 운영시스템 불필요한 접근이 가능한 경우
- **사례 3 :** 개발/시험이 완료된 결과를 운영환경으로 이관 시 책임자에 대한 승인 등 절차 없이 개발자가 직접 이관하고 있는 경우
- **사례 4 :** 이관 중 발생 가능한 문제 및 대응방안, 이관 담당자 지정, 이관 방법 등이 포함된 절차가 수립되어 있지 않거나, 운영환경으로의 배포 승인 이력이 확인되지 않는 경우
- **사례 5 :** 개발 환경에서 운영 데이터베이스에 직접 접근 가능, 개발자는 로컬 개발 환경에서 운영 데이터베이스 엔드포인트에 직접 연결 가능. 데이터베이스 접속 정보를 팀 공유 문서에 평문으로 기재하는 경우

항목	13.2.3 시험 데이터 보안		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○		
인증기준	시스템 시험 과정에서 운영데이터 유출을 예방하기 위해 시험데이터 생성, 이용 및 관리, 파기, 기술적 보호조치에 관한 절차를 수립하여 이행하여야 한다.							
점검항목	공통	1) 시험데이터는 임의의 데이터를 생성하거나 운영데이터를 가공하여 사용하고 있는가?						
	공통	2) 운영데이터를 시험 환경에서 불가피하게 사용할 경우 책임자 승인 등의 인가 후 제한된 환경에서 사용하고 있는가?						
	공통	3) 시스템 및 어플리케이션이 활성화되기 전에 시험데이터와 계정을 제거하고 있는가?						
참고	• ISMS-P 2.8.4 시험 데이터 보안 • ISO/IEC 27017 테스트 정보							

점검항목 해설

점검항목 1)

■ 시험에 사용되는 데이터의 생성, 이용 및 관리, 파기에 관한 절차를 수립하여 적용하여야 한다.

- 시험데이터 변환 및 사용에 따른 기준·절차 수립·이행
- 운영데이터 사용에 대한 시험환경에서의 접근통제 대책 적용
- 운영데이터 복제·사용에 대한 모니터링 및 정기검토 수행

■ 시험에 사용되는 데이터는 가급적 임의로 생성한 데이터를 이용하여야 하며, 필요한 경우 가공된 운영데이터를 이용할 수 있다.

점검항목 2)

■ 부득이하게 운영데이터를 시험데이터로 사용하는 경우 책임자의 승인을 받아야 하며, 제한된 시험환경에서 사용되어야 한다.

- 데이터 중요도에 따른 보고 및 승인체계 정의 등 운영데이터 사용 승인 절차 마련
- 운영데이터 사용에 대한 시험환경에서의 접근통제 대책 적용

■ 운영데이터의 사용에 대한 기록(사용된 시험항목, 사용자, 폐기 여부 등)을 남겨야 하며, 사용이 완료된 운영데이터는 즉시 폐기하여야 한다.

- 시험 기한 만료 후 데이터 폐기절차 마련 및 이행

점검항목 3)

■ 시험이 완료된 시스템 및 어플리케이션은 운영 전 시험에 사용된 시험데이터 및 계정은 모두 삭제하여야 한다.

- 시험 데이터, 테스트 계정,
- 테스트 및 디버깅 툴, 소스프로그램 등

증거자료

- 시험데이터 관리 절차
- 운영데이터의 시험 환경 사용 여부
- 운영 전 시험데이터 및 시험 계정 삭제 여부
- 운영데이터를 시험에 사용한 경우 사용 데이터 목록
- 정보보호 정책서, 시스템개발보안지침

부적합 사례

- **사례 1 :** 시험에 사용되는 데이터의 구체적인 기준 및 생성, 이용, 관리, 파기, 기술적 보호조치에 대한 시험데이터 사용 절차가 수립되어 있지 않은 경우
- **사례 2 :** 실제 운영데이터를 가공하지 않고 시험 데이터로 사용하고 있으나, 책임자 승인 등 보안통제 증적 확인이 되지 않는 경우
- **사례 3 :** 시험에 사용된 시험데이터 및 계정을 삭제하도록 내부 정책을 수립하여 운영하고 있으나, 시험에 사용된 데이터 및 계정 일부가 삭제되지 않은 경우

항목	13.2.4 소스 프로그램 보안		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○		○	○	
인증기준	소스 프로그램에 대한 변경관리를 수행하고 인가된 사용자만이 소스 프로그램에 접근할 수 있도록 통제절차를 수립하여 이행하여야 한다. 또한 소스 프로그램은 운영환경에 보관하지 않는 것을 원칙으로 한다.							
점검항목	공통	1) 클라우드서비스 구현과 관련된 소스 프로그램(소스코드)에 대해 변경관리를 수행하고 있는가?						
	공통	2) 클라우드서비스의 소스 프로그램(소스코드)은 인가된 사용자만이 소스 프로그램(소스코드)에 접근할 수 있도록 통제를 구현하고 있는가?						
점검목적	프로그램 소스 코드, 개발 도구 및 소프트웨어 라이브러리에 대한 접근이 적절히 관리되도록 보장한다.							
참고	• ISMS-P 2.8.5 소스 프로그램 관리 • ISO/IEC 27017 8.4 소스 코드 접근							

점검항목 해설

점검항목 1)

■ 소스 프로그램(이하 “소스 코드”)의 변경(예 : 수정, 추가, 삭제 등)을 관리하고 소스 코드에 대한 접근통제를 수행하기 위한 절차를 수립하여야 한다.

- 소스 코드에 대한 변경관리를 위하여 형상관리 베이스라인을 정의
  - 베이스라인 : 각 형상항목의 기술적 통제 시점으로 개발과정의 각 단계별 산출물을 검토, 평가, 조정, 처리 등의 변화를 통제하는 시점의 기준
  - 예를 들면, OOO 소프트웨어 V1.0을 릴리즈한 시점을 베이스라인으로 설정하였다면 V1.0 이후 변경에 대한 관리를 수행하여야 한다는 의미
  - 변경에는 소스 코드의 수정, 추가, 삭제 등이 포함되며, 이러한 작업을 수행하는 경우 정해진 절차에 따라 수행 필요

■ 소스코드 저장소는 접근통제를 적용하고 인가된 개발자만 접근 가능하도록 하여야 한다.

- 소스코드 변경 이력을 버전관리 시스템(예: Git 등)으로 추적
- 중요 소스코드 반출 시 승인 절차후 반출

점검항목 2)

■ 소스 코드는 별도의 서버(형상관리 서버)에 보관하고 서버는 안전한 위치에 설치하여 운영하여야 하며, 소스코드 관리담당자만 접근할 수 있도록 서버에 대한 접근통제를 수행하여야 한다.

증거자료

- 소스코드 관리 절차
- 소스코드 관리 방법
- 소스코드 권한 관리 및 접근 통제
- 형상관리 도구
- 형상관리 도구의 계정 현황
- 정보보호 정책서, 시스템개발보안지침

부적합 사례

- **사례 1 :** 형상관리서버, 소스코드 저장소 등 형상관리절차가 수립되어 있지 않거나, 이전 버전의 소스코드를 운영 서버 또는 개발자 PC에 승인 및 이력관리 없이 보관하고 있는 경우
- **사례 2 :** 형상관리시스템에 저장되어 있는 소스 프로그램에 업무 연관성이 없는 개발자 등 사용자의 접근이 가능하거나 변경(수정, 삭제 등)에 대한 이력 관리가 되고 있지 않는 경우
- **사례 3 :** 소스코드 저장소를 통해 형상관리를 하고 있으나, 소스 프로그램 다운로드/업로드, 변경 등에 대한 검토 수행 이력이 확인되지 않는 경우

13.3 외주 개발 보안

항목	13.3.1 외주 개발 보안	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○		○		
인증기준	클라우드 시스템 개발을 외주 위탁하는 경우 분석 및 설계단계에서 구현 및 이관까지의 준수해야 할 보안요구사항을 계약서에 명시하고 이행여부를 관리·감독하여야 한다.						
점검항목	공통	1) 클라우드 시스템 개발을 외주 위탁하는 경우, 개발 시 준수해야할 보안 요구사항을 제안요청서에 기재하고 계약시에 반영하고 있는가?					
	공통	2) 외주 위탁업체가 계약서에 명시된 보안요구사항을 준수하는지 여부를 관리·감독하고 있는가?					
	공통	3) 클라우드 시스템 개발 완료 후, SW 보안취약점 제거여부 진단, SW 보안취약점 발견사항 조치 여부 등을 확인 후 검수·인수하고 있는가?					
점검목적	운영 체제에 소프트웨어를 안전하게 설치하기 위한 절차와 조치를 구현한다.						
참고	• ISO/IEC 27017 8.30 외주 개발						

점검항목 해설

점검항목 1)

■ 시스템 개발에 적용되어야 할 보안요구사항을 계약서에 명시하여야 한다.

- 설계, 구현, 시험에 대한 요구사항
- 개발환경에 대한 요구사항
- 소스 코드 관리에 대한 요구사항
- 코딩 표준 및 규약에 대한 요구사항
- 개발 완료 후 이관에 대한 요구사항

점검항목 2)

■ 수탁사가 계약서에 명시된 요구사항을 준수하고 있는지에 대한 관리·감독을 수행하여야 한다.

- 계약서 상에 명시된 요구사항을 준수하는지 주기적으로 점검 수행

점검항목 3)

■ 운영 환경에 소프트웨어 설치 시 보안 검토 및 승인을 거쳐야 한다.

- 컨테이너 이미지는 취약점 스캔(예: Trivy, Snyk 등)을 통과한 이미지만 배포
- 소프트웨어 무결성 검증(예: 해시값, 디지털 서명) 또는 취약점 점검(이미지 실행 점검)을 수행

■ 클라우드 시스템 개발 완료 후 보안요구사항 반영 여부, SW 보안취약점 점검 및 보완 여부, 개발자 계정 및 권한 삭제 여부 등을 확인한 후 검수 또는 인수하여야 한다.

증거자료

- 외주 개발 제안요청서/계약서
- 보안요구사항 점검 증적
- 검수(인수) 확인서
- 정보보호 정책서, 시스템개발보안지침

부적합 사례

- **사례 1 :** 클라우드 시스템 개발을 외주 위탁하는 경우 준수해야 할 보안요구사항이 포함된 위탁계약서가 없거나, 일부 중요 요구사항이 계약서에 포함되어 있지 않은 경우
- **사례 2 :** 외주 위탁업체가 계약서에 명시된 보안요구사항을 준수하는지 여부를 확인하기 위한 점검 양식이 마련되어 있지 않거나, 점검 수행 이력이 확인되지 않는 경우
- **사례 3 :** 외주 위탁업체를 통한 개발 완료 후 보안요구사항 반영 여부, 입력데이터 검증, 보안기능 등 SW 보안취약점 점검 및 보완 여부 등을 확인하기 위한 점검 양식이 마련되어 있지 않거나, 수행 이력이 확인되지 않는 경우
- **사례 4 :** 컨테이너 이미지 취약점 검증 없이 배포, 퍼블릭 레지스트리에서 다운로드한 써드파티 이미지(nginx:latest, postgres:12)를 취약점 스캔 없이 운영 컨테이너 클러스터에 배포한 경우
- **사례 5 :** 가상 서버 인스턴스 보안 설정 기준 미수립, 80개 가상 서버 인스턴스를 운영하나, '인스턴스 보안 설정 기준'(SSH 포트 변경, root 로그인 금지, 불필요한 서비스 비활성화 등)이 문서화되지 않고 담당자 개인 판단으로 설정하여 인스턴스마다 설정이 상이한 경우

13.4 시스템 도입 보안

항목	13.4.1 시스템 도입 계획	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○			○		
인증기준	클라우드 시스템의 처리 속도와 용량에 대하여 주기적인 모니터링을 수행하고 안정성의 확보에 필요한 시스템 도입 계획을 수립하여야 한다.						
점검항목	공통	1) 신규 클라우드 시스템 또는 보안시스템의 도입 계획을 수립하고 있는가?					
점검목적	시스템 도입과 같은 변경 실행 시 정보보안 수준을 유지한다.						
참고	• ISMS-P 2.8.1 보안 요구사항 정의 • ISO/IEC 27017 8.27 안전한 시스템 아키텍처 및 엔지니어링 원칙						

점검항목 해설

점검항목 1)

■ 운영 중인 클라우드시스템 및 정보보호시스템에 대한 주기적인 모니터링을 수행하여 시스템의 안전성을 점검하여야 한다.

- 시스템의 점검결과를 분석하고 신규 시스템 도입을 위한 계획을 수립

■ 시스템 (신규) 도입 계획 수립 시 호환성, 운영환경, 제공되는 성능 수준 등을 분석하고 추가 도입의 필요성, 도입 시기 등을 결정할 수 있도록 계획을 수립하여야 한다.

- 성능, 안전성, 호환성, 신뢰성, 보안성, 법적 요구사항 등을 고려한 기능적, 운영적 요구사항을 정의하고 제품 선정 시 요구되는 규격의 만족 여부 등을 검토
- 운영 환경 변경 시 변경관리 절차 준수 및 승인(예: 변경자문위원회, CAB: Change Advisory Board) 필요
- 변경 전 백업 및 롤백 계획을 수립
- 변경 이력 기록 및 사후 검토 수행

증거자료

- 시스템 도입 계획서
- 시스템 안전성 점검 결과
- 정보보호 정책서, 시스템개발보안지침

부적합 사례

- **사례 1 :** 클라우드시스템 및 정보보호시스템 도입 계획 수립 시 법적 요구사항, 성능, 안정성, 보안성 등 요구사항이 정의되어 있지 않은 경우
- **사례 2 :** 신규 클라우드시스템 도입을 위한 계획을 수립하였으나 운영 중인 클라우드시스템에 대한 안전성 점검 수행 및 점검결과를 분석한 증적이 확인되지 않는 경우
- **사례 3 :** 운영환경으로 배포 시 담당자가 승인 절차 없이 직접 변경한 경우
- **사례 4 :** 개발자는 운영 환경 컨테이너 클러스터에 명령줄 도구로 직접 배포가 가능하고 변경 승인, 테스트 검증, 롤백 계획 없이 개발자 개인 판단으로 배포하여 최근 3개월간 20건의 배포 중 승인 기록이 0건인 경우

항목	13.4.2 시스템 인수		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○			○		
인증기준	새로 도입되는 시스템에 대한 인수 기준이 수립되어야 하며, 인수 전에 테스트가 수행되어야 한다.							
점검항목	공통	1) 신규 클라우드 시스템의 인수 여부를 판단하기 위하여 기본 보안설정 등이 반영된 인수 승인 기준을 수립하고 있는가?						
	공통	2) 신규 클라우드 시스템의 인수 전 수립된 인수 승인 기준에 따른 적합성 테스트를 수행하고 있는가?						
점검목적	시스템 인수 테스트 등의 활동이 운영 체제, 업무 프로세스 등 서비스에 미치는 영향을 최소화한다.							
참고	• ISMS-P 2.8.6 운영환경 이관 • ISO/IEC 27017 8.29 개발 및 인수 시 보안 테스트							

점검항목 해설

점검항목 1)

■ 신규 클라우드시스템 및 정보보호시스템을 구축 후 인수 전 13.4.1. 시스템 도입 계획 단계에서 식별되었던 요구사항의 만족 여부를 확인하기 위한 인수 기준을 수립하여야 한다.

■ 초기 설정 변경 또는 삭제 여부, 보안업데이트 적용 여부, 불필요한 계정(디폴트 계정, 임시 계정, 시험용 계정 등) 삭제 여부, 불필요한 서비스 및 포트 등의 차단 조치 여부, 이중화, 취약점 점검 후 이행조치 등 클라우드시스템 운영에 적합한 기준을 수립하여야 한다.

■ 보안 감사 또는 취약점 점검 후 시스템 도입 시 운영 환경 영향을 최소화하는 절차를 수립하여야 한다.

- 인수를 위한 사전 침투 테스트는 사전 승인과 비운영 시간대에 수행
- 감사를 위한 점검 도구 접근은 임시 권한으로 제한하고 종료 후 즉시 회수

점검항목 2)

■ 수립된 기준에 따라 인수과정에서 점검(필요한 경우 인수 테스트 등)을 수행하고 그 결과를 기록 보존하여야 한다.

- 클라우드시스템 도입 계획 수립 시 정의한 요구사항(성능, 안전성, 호환성, 신뢰성, 보안성, 법적 요구사항 등)을 준수하여 적합성 테스트 수행

- 신규 도입한 클라우드시스템 인수테스트 등 점검 수행 증적 관리

증거자료

- 시스템 인수 기준
- 검수(인수) 확인서
- 정보보호 정책서, 시스템개발보안지침

부적합 사례

- **사례 1 :** 클라우드시스템 및 정보보호시스템 인수 전 도입 기준(인수 요구사항 검증, 보안적합성 검증 등) 및 절차가 마련되어 있지 않은 경우
- **사례 2 :** 클라우드시스템 도입 시 취약점 점검 등의 인수테스트를 수행하도록 내부 정책이 수립되어 있으나 관련 증적이 확인되지 않은 경우
- **사례 3 :** 운영 환경 배포 후 보안 점검 미실시, 주 2회 운영 환경 배포를 진행하나, 배포 후 보안 점검(방화벽 규칙 변경 확인, 접근 권한 검토 등)을 수행하지 않음. 배포 후 점검 체크 리스트가 없으며, 모니터링 로그만 확인한 경우

14. 국가기관등의 보안요구 사항

14.1 관리적 보호조치

항목	14.1.1 보안서비스 수준 협약		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○	○	○	○	○
인증기준	국가기관등의 보안 요구사항이 반영된 보안서비스 수준 협약을 체결하고, 클라우드컴퓨팅서비스 관련 정보보호 정보를 국가기관등에게 제공하여야 한다.							
점검항목	공통	1) 국가기관등에 클라우드서비스 제공 시, 국가기관등의 보안요구사항을 정의하여 계약(보안서비스 수준 협약 등) 시 반영하고 있는가?						
	공통	2) 정보보호 대책 내 국가기관등의 보안요구사항의 정확한 구현 여부, 보안운영 및 모니터링 결과산출 여부 등에 대해 국가기관등에 주기적으로 보고하고 있는가?						
관련 근거	• 행정기관 및 공공기관의 클라우드컴퓨팅서비스 이용 기준 및 안전성 확보 등에 관한 고시 제6조(표준계약서 및 서비스 수준 등) • 국가 사이버보안 기본지침 제24조의4(클라우드컴퓨팅 서비스의 도입·운영·이용), 제25조(계약 특수조건), 제41조(클라우드컴퓨팅 보안) • ISO/IEC 19086 클라우드서비스 수준협약							

점검항목 해설

점검항목 1)

■ 국가기관등에 클라우드서비스 제공을 위한 계약 시, 국가기관등의 보안요구사항을 정의하고 계약서(보안서비스 수준 협약 등)에 반영하여야 한다.

■ 국가기관등에 클라우드서비스를 제공하는 경우, 계약 또는 보안서비스 수준 협약 과정에서 다음 사항들을 고려하여야 한다.

- 클라우드서비스 제공 범위
- 국가기관등과 클라우드사업자의 책임 명시
- 이용자 데이터 소유권, 저장 위치, 이관 및 보호 방법 (국가기관등 클라우드서비스의 물리적 위치는 국내로

한정)

- 계약의 만료 또는 종료 시 데이터의 처리
- 고객에게 영향을 미치는 제3자 또는 하도급 업체 관계에 대한 정보
- 서비스 수준 미달성시의 대응 절차 및 보상 방법
- 사전인증이 필요한 제품군은 국가정보원장이 안전성을 확인한 제품을 도입
- 사고 또는 장애발생 시 대내·외 관련 기관 및 전문가와 협조체계를 구성하여 대응하고, 국가정보원 및 이용기관의 사고·장애 대응 및 예방보안 활동 등에 협조
- 클라우드 보안관제 수행 및 정부보안관제체계와 연계하기 위한 제반환경 지원 대한 사항 명기
- 클라우드 컴퓨팅 서비스 망 운용 관리에 따른 보안 취약점 개선·발굴, 사이버공격 위협에 대한 예방, 대응, 실태평가, 안전성 및 보안대책의 적합성과 이행여부 확인 등의 목적으로 클라우드 사업자 시설에 대한 현장실사 방문, 안전성 보안 측정 실시, 보안진단·점검 등 수행 협조 사항 명기
- 현장실사, 안전성 보안측정 실시, 보안점검 등 수행 목적으로 기술적 지원을 요청할 시에 모니터링 도구, 로그 수집 기술 등의 제반 환경을 제공 사항 명기
- 기타 국가기관등 보안 요구사항 (기관의 특성에 따라 달라질 수 있음)

점검항목 2)

■ 클라우드서비스 제공자는 클라우드서비스를 구축하면서 적용한 정보보호대책이 국가기관등의 보안요구사항을 정확하게 반영하고 있는지 지속적으로 모니터링하고 서비스를 이용하는 국가기관등의 정보보호대책이 유지되는지 검토하여야 한다.

- 서비스 제공자는 자신이 수립한 정보보호대책이 도입 국가기관등의 정보보호대책과 일관성을 유지하고 있는지 확인
- 서비스를 이용하는 국가기관등의 정보보호대책이 의도한 대로 운영되는지 확인
  (자산목록, 가상머신 내 운영체제, 가상 소프트웨어, 보안정책 등의 변경여부에 대한 모니터링 결과, 형상변경시의 보안영향분석결과 등)
- 서비스 제공자가 산출된 결과물을 서비스를 이용하는 국가기관등에게 보고하는 절차의 수립 및 이행 여부

■ 국가기관등의 보안요구사항 구현 여부 등에 대해서 주기적으로 국가기관등에 보고하여야 한다.

증거자료

- 표준계약서, 서비스수준협약서(SLA), 서비스 약관 등
- 국가기관등 보안요구사항 보고 증적

부적합 사례

- **사례 1 :** 클라우드서비스를 제공하기 위한 표준계약서 또는 보안 사항을 포함한 서비스수준협약서가 없는 경우
- **사례 2 :** 데이터 저장위치, 클라우드서비스 제공 범위, 계약 만료시 데이터 처리(완전삭제) 등 계약서 및 표준계약서 내에 이용자의 보안요구사항이 명시되어 있지 않은 경우
- **사례 3 :** 클라우드서비스 제공자의 정보보호 대책이 국가기관등의 보안요구사항을 정확하게 반영하고 있는지 여부를 지속적으로 모니터링하는 절차가 마련되어 있지 않은 경우

항목	14.1.2 도입 전산장비 안전성	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○
인증기준	클라우드컴퓨팅서비스 구축을 위해 도입되는 보안기능을 가진 정보통신제품 중에서 전자정부법 제56조에 규정된 전자문서의 위조·변조·훼손 또는 유출을 방지하기 위한 목적으로 도입하는 제품은 국가정보원장이 안전성을 확인한 제품을 사용하여야 한다.						
점검항목	공통	1) 클라우드 시스템을 보호하기 위해 도입하는 정보통신 제품이 국가정보원장이 공지한 바에 따른 인증 요건을 만족하는가?					
관련 근거	• 전자정부법 제56조(정보통신망 등의 보안대책 수립·시행) • 국가 사이버보안 기본지침 제20조(정보통신제품 도입), 제5절 보안적합성 검증						

점검항목 해설

점검항목 1)

■ 클라우드서비스를 제공하기 위해 구축되는 정보보호시스템과 네트워크 장비 중에 CC 인증 또는 보안기능 확인서 등 사전 인증이 필수적인 제품군은 국가정보원장이 안전성을 확인한 제품을 도입하여야 한다.

- 안전성 검증필 제품 목록에 포함되지 않은 제품의 경우 보안적합성 검증 제도를 통해 검증 과정에서 발견된 취약점을 제거한 후에 사용 가능
  - 국가사이버안보센터 (https://www.ncsc.go.kr)
  - IT보안인증사무국(https://www.itscc.kr)

※ 기타 세부사항은 국가정보원이 공지한 보안적합성 검증 정책을 따름

보안적합성 검증제도 개요

사전 인증이 필요한 제품 유형

국가 · 공공기관이 도입하는 정보보호제품 중에서 침입차단시스템, 가상사설망 등 주요 제품유형은 공인시험기관이 발급한 '보안기능 확인서' 또는 우리나라(IT보안인증사무국)을 비롯, CCRA회원국이 발행한 CC인증을 받아야 하며, △네트워크 장비 △호스트 · 네트워크 자료유출 방지제품 △S/W기반 보안USB 제품 △가상화 관리제품 △망간 자료전송 제품(2022.1.1부터)은 보안기능 확인서를 받아야 합니다.

양자암호통신장비를 도입하는 경우 보안기능확인서를 발급받은 제품을 도입하거나 도입 시 보안적합성검증을 신청해야 합니다.아울러 가상사설망(VPN), 소프트웨어 기반 보안USB, 호스트 자료유출방지 등 제품은 검증필 암호모듈을 탑재해야 합니다. 아래 표에 포함되지 않은 제품 유형일지라도 보안기능 확인서를 발급받아 검증필 제품목록에 등재될 경우, 보안적합성 검증절차를 생략하고 운용할 수 있습니다.

도입시 유의사항

국가 · 공공기관은 CC인증 · 보안기능 확인서 등 사전인증을 받은 제품을 도입할 경우 아래 유의사항을 확인 하시기 바랍니다.

①도입하려는 제품의 사전인증 필수 유형 해당 여부와 발급받은 인증서(보안기능 확인서)가 도입시점에서 유효한지 확인해야 합니다. 인증서(보안기능 확인서)의 효력이 만료된 제품은 인증제품으로 인정되지 않습니다.

②평가(시험)기관과 사전 협의중이거나 평가(시험)가 진행중일지라도 인증제품으로 인정되지 않습니다. 평가(시험) 협의 · 진행이 인증을 담보하지 않습니다.

③국제CC인증 제품의 경우 도입 기관이 사용을 원하는 보안기능이 인증범위에 포함되지 않을 수 있기 때문에 인증범위에 대한 확인이 필요합니다.

④도입기관이 사용하고자 하는 보안기능이 인증범위(TOE)에 포함되었는지 확인이 필요합니다.

⑤CC 인증 및 보안기능 확인서內 다양한 하드웨어가 탑재, 배포되는 경우 인증보고서에 해당 하드웨어 모델명칭이 기재되었는지 확인이 필요합니다.

⑥CC인증은 등급 제한(스마트카드 제외)이 없습니다.

증거자료

- 정보자산목록
- 정보보호제품 CC인증서
- 보안기능 확인서
- 성능평가서

부적합 사례

- **사례 1 :** 클라우드서비스의 안전성을 확보하기 위하여 보안기능이 있는 정보통신 제품을 도입하였으나, CC인증·보안기능확인서·성능평가 등 국가공공기간의 도입 요건을 충족하지 않은 정보통신 제품을 도입한 경우
- **사례 2 :** 클라우드서비스 제공자가 운영중인 정보통신제품이 사전 인증 효력이 없는(미인증 버전, 형상 변경, 인증 유효기간 초과 등) 정보통신제품을 도입 및 운영하는 경우

항목	14.1.3 보안관리 수준	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○
인증기준	클라우드컴퓨팅서비스 운영 장소 및 망은 국가기관등 내부 정보시스템 운영 보안수준에 준하여 보안관리하여야 한다.						
점검항목	공통	1) 국가기관등의 공통적인 보안 요구사항을 반영하여 그에 준하는 보안 대책을 수립하고 있는가?					
관련 근거	• 정보통신망 이용촉진 및 정보보호 등에 관한 법률 제46조(집적된 정보통신시설의 보호) • 국가 사이버보안 기본지침 제24조의4(클라우드컴퓨팅 서비스의 도입·운영·이용) • 행정기관 및 공공기관 정보시스템 구축·운영 지침 제6장 소프트웨어 개발보안						

점검항목 해설

점검항목 1)

■ 클라우드서비스 제공자는 국가기관등에서 요구되는 시설 및 물리적 통제에 대한 보안요구 사항을 만족할 수 있도록 서비스를 제공하여야 한다.

- 국가기관 클라우드서비스 제공을 위한 시스템의 물리적 위치 식별
- 식별된 물리적 공간에 대한 접근통제 정책 수립하고, 물리적 출입통제에 대한 산출물(작업내용 기록, 장비 반출입 기록, 출입 로그 등)을 유지·관리 및 이상 유무를 주기적 검토하여야 함
- 화재, 전력 이상 등 인재 및 자연재해 등에 대비하여 필요한 설비를 갖추고 이에 대한 보호 방안을 수립 적용하여야 함

※ 화재감지 및 소화설비, 누수감지기, CCTV, 외부침입감지 및 경보, 출입통제 시스템, UPS, 항온항습기, 비상발전기, 전압유지기, 전력선 이중화 등

※ IaaS사업자가 아닌 타 사업자(SaaS 등)는 CSAP 인증받은 IaaS 클라우드서비스 이용시 해당 부분에 대하여 시설 및 물리적 통제에 대한 보안요구사항을 준수하는 것으로 간주 함

■ 국가기관등이 이용하는 클라우드서비스는 「행정기관 및 공공기관 정보시스템 구축·운영 지침」 및 「소프트웨어 개발보안 가이드」(행정안전부)에 따라, 소프트웨어 개발단계부터 보안취약점의 원인인 보안약점을 배제하여 개발하여야 한다.

※ 소프트웨어 개발보안 가이드라인에서 확인 가능

■ 클라우드서비스가 국가기관등의 보안수준을 만족할 수 있도록 다음과 같은 보안성 강화 방안을 마련하여 운영하여야 한다.

- 애플리케이션의 데이터 처리(송·수신, 저장, 연산 등) 과정에서 데이터 보호 방안

- 기관의 중요 데이터에 대한 입·출력, 전송 또는 교환 및 저장에 대한 민간 사업자의 데이터 무결성 확인 방안
- 기관의 데이터(백업 포함)에 대한 물리적 위치 확인 및 추적 방안
- 인증범위 내 서버는 각각 최소한의 목적을 유지하여 서비스 별로 분리
- 개발 및 운영에 불필요한 IP 및 포트 등을 제거·차단 조치

※ 세부 보안 요구사항은 국가 사이버보안 기본지침 및 클라우드 컴퓨팅 보안 가이드라인을 준수하여야 함

※ 공공 및 민간을 위한 공용자산, 개발 자산 등은 인증평가팀의 판단에 따라 진단 대상에서 제외 가능

■ 공공영역에 제공하는 DaaS의 경우 필수적으로 요구하는 SW 제품군을 도입하여 제공하여야 한다. (백신, 유해사이트, 상용메일차단, 망연계, 내PC지키미)

- 배포된 OS이미지에 필수 SW(5종)를 설치한 형태로 배포
- 필수 SW(5종) 중, 사전인증(CC인증 등)이 필요한 유형은 사전인증을 취득한 SW를 설치하여 배포

※ 백신의 경우, 월1회 정기적으로 보안패치하여 배포(긴급 보안패치의 경우, 예외)

※ 유해사이트차단솔루션의 경우, 솔루션 도입 외 기술적 보안대책(URL 기반 IPS 룰 설정 등)을 통해 해당 기능 제공 가능시 대체 가능 단, 방화벽 솔루션의 IP 기반 차단은 미해당

※ 내PC지키미는 가상PC의 보안수준 관리 여부를 점검하기 위해 도입되는 솔루션으로 Pooled 방식(가상PC 종료시 자원 초기화) 가상PC를 제공하는 경우 내PC지키미 미도입 가능

증거자료

- 물리적 위치 및 물리적 접근통제 정책 현황
- 관련 시설에 대한 주기적인 점검 이력

부적합 사례

- **사례 1 :** 국가기관등에 제공하는 클라우드서비스 정보자산 및 이용자 데이터의 물리적 위치가 식별되지 않은 경우
- **사례 2 :** 국가기관등에 제공하는 클라우드서비스의 정보자산을 보호하기 위한 물리적 출입통제 증적을 보관·관리 하지 않거나, 출입통제 증적에 대한 주기적인 검토가 확인되지 않은 경우
- **사례 3 :** 클라우드서비스의 소프트웨어 보안약점을 제거하기 위한 보안활동 증적이 없거나, 인증평가 시 소프트웨어 보안약점이 확인되는 경우
- **사례 4 :** DaaS 서비스 이용 시 가상 PC 환경 보호를 위한 필수 가상 소프트웨어가 설치되어 있지 않는 경우

<table>
<tr><th rowspan="3">항목</th><th rowspan="3" colspan="2">14.1.4 사고 및 장애 대응</th><th colspan="4">기존</th><th colspan="2">등급제(하)</th></tr>
<tr><th>IaaS</th><th>SaaS
표준</th><th>SaaS
간편</th><th>DaaS</th><th>하등급</th><th>하등급
SaaS</th></tr>
<tr><td>○</td><td>○</td><td>○</td><td>○</td><td>○</td><td>○</td></tr>
<tr><td>인증기준</td><td colspan="8">클라우드컴퓨팅서비스를 제공하는 민간 사업자는 사고 또는 장애 발생시 관계 법령이 정하는 바에 따라 해당 국가기관, 대내·외 관련 기관 및 전문가와 협조체계를 구성하여 대응하여야 하며, 피해확산 및 재발방지와 복구 등에 필요한 조치를 위해 국가정보원 및 이용기관의 보안관제 및 사고조사, 예방보안활동 등에 적극 협조하여야 한다.</td></tr>
<tr><td rowspan="2">점검항목</td><td>공통</td><td colspan="7">1) 국가기관등 클라우드서비스의 사고 및 장애 대응절차는 국가기관등의 사고 및 장애 대응절차를 반영하였는가?</td></tr>
<tr><td>공통</td><td colspan="7">2) 국가기관등 클라우드서비스의 사고 및 장애 대응절차에는 해당 국가기관등, 대내외 관련기관과의 협조체계가 반영되어 있는가?</td></tr>
<tr><td>관련 근거</td><td colspan="8">• 클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률 제25조(침해사고 등의 통지 등)
• 개인정보 보호법 제34조(개인정보 유출 등의 통지·신고)
• 정보통신망 이용촉진 및 정보보호 등에 관한 법률 시행령 제41조(집적된 정보통신시설 임차사업자의 조치의무)
• 국가 사이버보안 기본지침 제41조(클라우드컴퓨팅 보안), 제135조(초동 조치), 제140조(사이버 공격·위협으로 인한 사고), 제145조(기관간 정보공유 협력)</td></tr>
</table>

점검항목 해설

점검항목 1)

■ 국가기관등 클라우드서비스의 사고 및 장애 대응절차는 국가기관등의 사고 및 장애 대응절차를 반영하여 수립, 운영되어야 한다.

- 발생내용, 원인, 조치현황 등을 신속 파악
- 국가기관(이용기관) 등의 정보보안담당관에게 신고 절차 포함

■ 사고 및 장애 발생 시 국가기관등의 클라우드 보안사고 및 장애 대응 절차에 따라 진행되도록 사업자의 침해사고 대응 절차를 점검하고, 아래의 내용을 포함한 사고 발생 보고서를 해당 국가기관등에 제공할 수 있어야 한다.

- 사고 발생일시
- 보고자와 보고일시
- 사고내용 (원인, 발견사항, 피해내용 등)
- 사고대응 경과 내용
- 사고대응까지의 소요시간

- 사고자 및 관계자의 인적 사항
- 조치 내용 등

■ 클라우드서비스 제공자는 다음의 하나에 해당하는 경우 지체없이 이용자에게 알려야 한다.

구분	신고	통지
침해사고 발생 시	정보통신망법 등 관계법령에 따른 신고	• 사고 및 장애 관련 근거에 따라 이용자에게 통지 [예시] - 클라우드컴퓨팅발전법 제25조(침해사고 등의 통지 등) [통지 내용] 1. 발생 내용 2. 발생 원인 3. 클라우드서비스 제공자의 피해 확산 방지 조치 현황 4. 클라우드서비스 이용자 (이하 "이용자"라 한다)의 피해 예방 또는 확산 방지 방법 5. 담당부서 및 연락처 [통지방법] 전화, 휴대전화, 우편, 전자우편, 문자메시지, 클라우드서비스 접속화면 등 ※ 개인정보 유출 시 개인정보 보호법 제34조(개인정보 유출 등의 통지·신고)에 따른 통지 필요
이용자 정보 유출 시	클라우드컴퓨팅법에 따른 신고 개인정보 유출 시에는 개인정보 보호법에 따른 신고	
서비스 중단 • 클라우드컴퓨팅법 사전 예고 없이 일정한 기간 이상 서비스 중단 시 - 중단기간이 연속 10분이상의 경우 - 중단 사고가 발생한 때로부터 24시간 이내 2회 이상 중단된 경우로서 중단된 기간이 15분 이상인 경우 • 정보통신망법 재난 등으로 인하여 일정한 기간 이상 서비스 중단시(집적정보통신시설 사업자등인 경우) 연속해서 30분이상 - 24시간 이내 2회 이상 중단된 경우로서 중단된 기간의 합이 45분 이상인 경우	-	

점검항목 2)

■ 클라우드서비스 제공자는 신속한 사고 및 장애대응을 위하여 대내외 관련 기관 및 전문가와 협조 및 연락체계를 구축하여야 한다.

■ 클라우드서비스 제공자는 아래와 같이 사이버공격과 관련한 정보를 확인한 경우에는 전화·팩스·이메일 등 통신수단을 활용하여 지체없이 그 사실을 국가기관등의 정보보안담당관에게 통보하고 국가정보원 및 국가기관등 에서 사고조사·예방활동 등에 협조하여야 한다.

- 대규모 사이버공격 발생시
- 사이버공격으로 인하여 피해가 발생하거나 피해 발생이 예상되는 경우

- 사이버공격이 확산될 우려가 있는 경우
- 그 밖에 사이버공격 계획 등 사이버안전에 위협을 초래할 수 있는 정보를 입수한 경우

증거자료

- 침해사고/장애 대응 절차
- 침해사고/장애 대응조직도 및 비상연락망
- 침해사고/장애 발생 보고서
- 침해사고/장애 신고/통지 절차
- 침해사고/장애 조치 보고서

부적합 사례

- **사례 1 :** 사고 및 장애대응절차 내에 이용기관(담당자) 신고 절차가 포함되지 않은 경우
- **사례 2 :** 사고 및 장애대응 절차 내에 국가정보원 및 국가기관등에 사고조사 및 예방활동 협조 사항이 포함되지 않은 경우

14.2 물리적 보호조치

항목	14.2.1 물리적 위치 및 영역분리		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○	○	○	○	○
인증기준	기존	클라우드 시스템, 백업 시스템 및 데이터와 이를 위한 관리·운영 인력의 물리적 위치는 국내로 한정하여야 한다. 또한, 국가기관용 클라우드컴퓨팅서비스의 물리자원(서버, 네트워크, 보안장비 등), 출입통제, 운영인력 등은 데이터 및 프로세스 등의 간섭없이 국가기관등의 보안관제, 사고조사, 예방보안활동 유지를 위한 제반 환경을 만족시킬 수 있도록 일반 이용자용 클라우드컴퓨팅서비스 영역과 물리적으로 분리하여 운영하여야 한다.						
	등급제(하)	클라우드 시스템, 백업 시스템 및 데이터와 이를 위한 관리·운영 인력의 물리적 위치는 국내로 한정하여야 한다. 또한, 국가기관용 클라우드컴퓨팅서비스의 물리자원(서버, 네트워크, 보안장비 등), 출입통제, 운영인력 등은 데이터 및 프로세스 등의 간섭없이 국가기관등의 보안관제, 사고조사, 예방보안활동 유지를 위한 제반 환경을 만족시킬 수 있도록 일반 이용자용 클라우드컴퓨팅서비스 영역과 물리적 또는 논리적으로 영역을 분리하여 운영하여야 한다						
점검항목	공통	1) 국가기관용 클라우드 시스템, 데이터, 관리·운영 인력이 물리적으로 국내에 위치하고 있는가?						
	공통	2) 공공기관용 클라우드 시스템과 민간용 클라우드 시스템 간 분리(출입통제 및 기록, 네트워크 분리 등)하는 방안이 마련되어 있는가?						
관련 근거	• 국가 사이버보안 기본지침 제24조의3(클라우드컴퓨팅 도입 가능 목록)							

점검항목 해설

점검항목 1)

■ 국가기관 등에 클라우드서비스 제공과 관련된 시스템, 데이터, 관리·운영 인력은 물리적으로 국내에 위치하여야 한다.

- 국가기관등의 클라우드서비스를 운영하기 위한 구성요소(시스템, 데이터)는 국내에 위치하여야 함

※ 대한민국의 배타적 법적관할하에 있는 시설에 위치해야 함

- 클라우드서비스 운영·관리(사고 및 장애대응, 이용자 계정 권한 부여/변경/삭제 등) 인력은 국내에 거주하여야 함

점검항목 2)

■ 국가기관 등에 클라우드서비스를 제공하는 시스템과 민간기관에 클라우드서비스를 제공하는 시스템은 영역을 분리하여야 한다. 이때 하등급에 해당하는 경우에는 물리적 또는 논리적으로 영역을 분리할 수 있다.

- 국가기관등의 클라우드서비스를 위한 물리적 장치(서버, 네트워크장비 등)가 설치된 시설에 대한 물리적인 출입통제 수행
- 물리적인 출입통제에 대한 출입기록 등 유지

■ 클라우드 보안인증을 받은 인프라를 이용하여 SaaS, DaaS 등 구축하는 경우 운영 측면만 확인한다.

증거자료

- 자산목록
- 네트워크 구성도
- 시설구성도

부적합 사례

- **사례 1 :** 국가기관등에 클라우드서비스의 주요 기능을 제공할 때, 이용자 데이터를 인증받지 않은 영역(국외, 민간 등)에 저장하는 경우
- **사례 2 :** 국외에서 원격으로 클라우드서비스를 운영 및 관리하는 경우

항목	14.2.2 중요장비 이중화 및 백업체계 구축		기존				등급제(하)	
			IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
			○	○	○	○	○	○
인증기준	클라우드컴퓨팅서비스를 제공하는 사업자는 네트워크 스위치, 스토리지 등 중요장비를 이중화하고 서비스의 가용성을 보장하기 위해 백업체계를 구축하여야 한다.							
점검항목	IaaS	1) 국가기관등 클라우드 시스템에 대해 네트워크 스위치, 스토리지 등 중요장비가 이중화로 구축되어 있는가?						
	IaaS	2) 국가기관등 클라우드 시스템에 대한 백업 및 복원에 대한 표준운영절차(SOP)를 수립하였는가?						
	SaaS	3) 서비스의 가용성을 보장하기 위한 백업체계가 마련되어 있는가?						
관련 근거	• 행정기관 및 공공기관의 클라우드컴퓨팅서비스 이용 기준 및 안전성 확보 등에 관한 고시 제15조(클라우드컴퓨팅서비스의 연속성 확보) • 국가 사이버보안 기본지침 제92조(재해 복구체계)							

점검항목 해설

점검항목 1)

■ 장애 및 사고 발생에 대비하여 네트워크 장비, 스토리지 등 서비스 제공에 중요한 역할을 담당하는 물리적인 자원에 대하여 이중화를 구축하여 운영하여야 한다.

※ IaaS사업자가 아닌 타 사업자(DaaS 등)는 CSAP 인증받은 IaaS 클라우드서비스 이용시 해당 부분에 대하여 물리적인 자원이 이중되었다고 보고 클라우드서비스 운영 측면에서 확인한다.

점검항목 2)

■ 서비스를 이용하는 국가기관등의 업무 관련 정보를 안전하게 유지하기 위하여 백업 및 복원 체계를 구축하고 유지하여야 한다.

■ 백업 및 복원을 위한 백업사이트 구축 및 운영 지침(표준운영절차)를 수립하여 적용하여야 한다.

■ 사고 발생 시 즉시 복원이 가능한지 지속적으로 모니터링을 수행하여야 하며, 백업사이트 구축 및 운영 지침 등에 복원을 위한 절차를 포함하여야 한다.

점검항목 3)

■ SaaS의 장애 및 사고 발생에 대비하여 가상자원, 데이터 등을 백업하기 위한 방안 또는 체계가 구축·운영되어야 한다.

- SaaS 환경 운영과 관련된 백업, 비상복구, 변경관리, 침해사고대응 등에 대한 전반적인 절차를 수립
- IaaS 사업자와 DR 서비스 계약을 맺은 경우 충족

증거자료

- 복구 시스템 상세 복구절차서
- 정보자산목록
- 네트워크 구성도
- 백업지침(표준운영절차), 백업 관리대장 (IaaS일 경우)
- DR 서비스 계약서 (SaaS일 경우)

부적합 사례

- **사례 1 :** DR을 구축하였으나 DR 상황 발생시 관련 어플리케이션, 데이터, 장비 설정 등이 누락되어 있는 경우
- **사례 2 :** 시스템 복구를 위한 시스템의 복구 상세매뉴얼이 부재한 경우
- **사례 3 :** 일부 장비 설정 등 백업이 누락된 경우
- **사례 4 :** 클라우드서비스의 가용성에 영향을 미치는 중요 장비를 이중화하여 구축하지 않은 경우

14.3 기술적 보호조치

항목	14.3.1 검증필 암호화 기술 제공	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○
인증기준	클라우드컴퓨팅서비스를 통해 생성된 중요자료를 암호화하는 수단을 제공하는 경우에는 검증필 국가표준암호화 기술을 제공하여야 한다.						
점검항목	공통	1) 보안적합성검증 제품 유형 중 가상사설망, 보안 USB, 호스트 자료유출 방지제품(암호화 저장가능 존재 시) 등 중요자료 전송 및 저장을 위해 사용하는 제품들에 대해서 검증필 암호모듈을 탑재하고 있는가?					
관련 근거	• 국가 사이버보안 기본지침 제20조(정보통신제품 도입), 제22조(검증필 암호모듈 운용 및 관리)						

점검항목 해설

점검항목 1)

■ 클라우드서비스를 운영하는데 사용되는 VPN, 보안USB, 자료유출방지 등의 제품이 운영되는 경우 검증필 암호모듈이 적용된 제품을 사용하여야 한다. 또한, 해당 제품은 CC 인증 또는 보안기능 확인서 등을 획득한 제품을 사용하여야 한다.

※ 기타 세부사항은 국가정보원의 보안적합성 검증 정책, 암호모듈검증 정책에 따름

■ 검증필 암호모듈과 CC인증의 유효기간은 별도이므로 둘 중 하나의 유효기간이 만료되면 해당 제품은 유효하지 않은 것으로 판단하여야 한다.

※ 검증필 암호모듈 탐재 필수 제품 유형은 국가 사이버보안 기본지침 또는 국가정보원 홈페이지에서 확인 가능

- IT보안인증사무국(https://www.itscc.kr)
- 국가정보원(https://www.nis.go.kr)
- 국가사이버안보센터(https://www.ncsc.go.kr)

※ 검증필 암호모듈 적용 제품 유형 및 도입 요건 예시

제품 유형	도입 요건
메일 암호화제품	검증필 암호모듈 탑재
구간 암호화제품	

제품 유형	도입 요건
하드웨어 보안토큰	
디스크·파일 암호화제품	
기타 암호화제품	
SSO제품	검증필 암호모듈 탑재 및 CC인증(국가용 보호프로파일 준수) 또는 보안기능확인 제품
DB 암호화제품	
문서 암호화제품(DRM 등)	

증거자료

- 정보보호제품 목록
- 적용된 검증필 암호모듈 목록(정책서 포함)
- CC 인증서, 보안기능 확인서, 성능평가서 등 사본

부적합 사례

- **사례 1 :** 검증필 암호모듈이 필수인 제품에 검증필 암호모듈이 탑재되지 않은 제품을 도입한 경우
- **사례 2 :** 보안기능확인서 또는 CC인증 효력은 유효하나, 검증필 암호모듈의 유효기간이 만료된 정보통신제품을 도입·운영하는 경우

항목	14.3.2 보안관제 제반환경 지원	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○			○	○	○
인증기준	클라우드컴퓨팅서비스를 국가기관등에 제공하는 민간사업자는 민간 영역을 제외한 공공 영역 대상 사이버공격 및 위협을 탐지하기 위한 국가기관등의 클라우드컴퓨팅서비스 보안관제 수행 및 정부보안관제체계와 연계하기 위해 필요한 제반환경을 지원하여야 한다.						
점검항목	공통	1) 국가기관등에 클라우드서비스 보안관제 수행에 필요한 제반환경을 지원하고 있는가?					
관련 근거	• 사이버안보 업무규정 제14조(사이버공격·위협의 탐지·대응) • 국가 사이버보안 기본지침 제24조의3(클라우드컴퓨팅 도입 가능 목록), 제24조의4(클라우드컴퓨팅 서비스의 도입·운영·이용), 제131조(보안관제센터 설치 · 운영)						

점검항목 해설

점검항목 1)

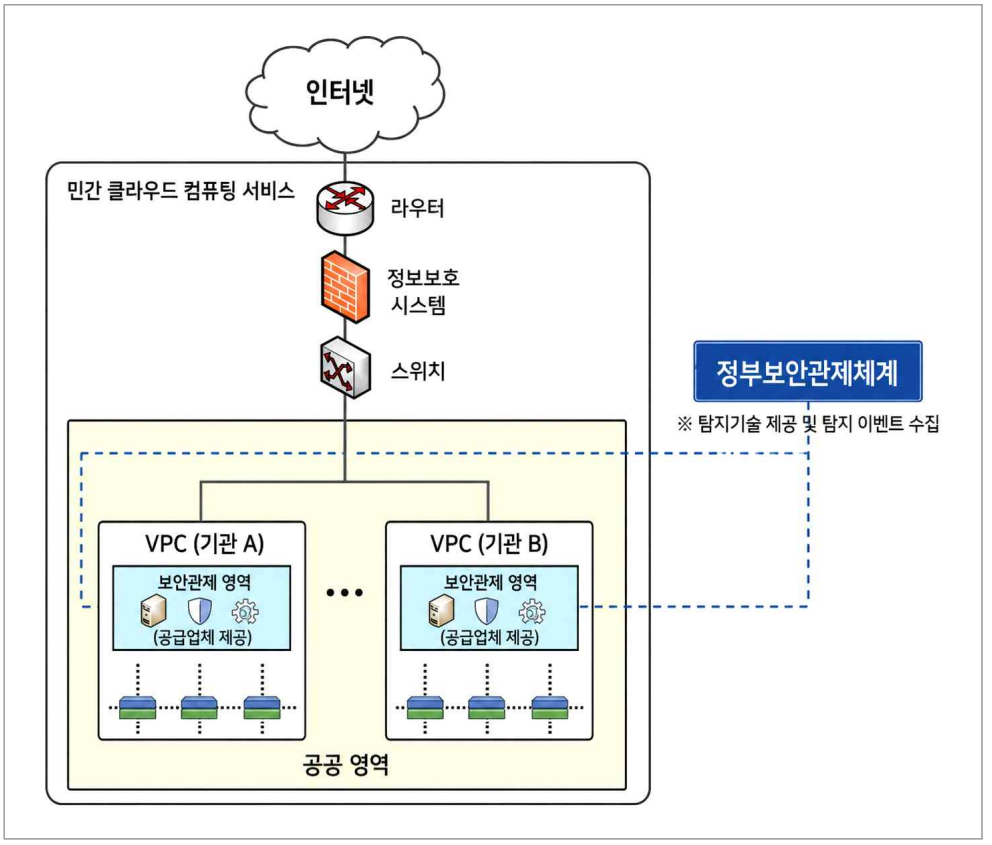
■ 민간 사업자는 국가기관 등에 클라우드 컴퓨팅 서비스 보안관제 수행 및 정부보안관제체계와 연결하기 위해 필요한 제반환경을 지원하여야 한다.

- 이용기관은 보안관제 시스템을 구축하고 직접 보안관제를 수행하거나 다른 국가·공공기관이 운영하는 보안관제시스템을 활용하는 것이 효율적인 경우 다른 기관의 보안관제센터에 위탁가능
- 민간 사업자는 이용기관이 민간 클라우드 컴퓨팅 서비스에 대한 보안관제 수행에 필요한 제반환경을 지원

■ 클라우드에 구축된 보안관제 시스템은 정부보안관제체계와 연계되어야 한다.

- 서비스 공급업체는 기관 VPC 영역에서 보안관제를 수행할 수 있는 기반 제공
- 서비스 공급업체는 기관의 보안관제 영역과 정부보안관제체계를 연계할 수 있는 기반 제공
- 이용기관은 보안관제 영역에서 탐지기술을 적용하여 보안관제를 수행하며, 탐지정보를 정부보안관제체계와 연계

※ 세부사항은 국가 클라우드 컴퓨팅 보안 가이드라인 참조



※ 민간 클라우드 컴퓨팅 서비스 보안관제 체계(국가 클라우드 컴퓨팅 보안 가이드라인 [부록7])

증거자료

- 보안관제 월간보고자료
- 보안관제 수행을 위해 제공되는 환경

부적합 사례

- **사례 1 :** 정부보안관제체계와 연결을 위한 제반환경 마련이 불가한 경우
- **사례 2 :** 이용기관이 요구하는 정부 보안관제체계와 연계하기 위한 제반환경을 지원하지 못하는 경우

항목	14.3.3 데이터 유출 방지	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
						○	○
인증기준	클라우드컴퓨팅서비스를 통해 생성되는 공공의 데이터가 국외로 유출되지 않도록 데이터 저장 위치를 선택할 수 있는 기능 및 로그정보 등을 제공하여야 한다.						
점검항목	공통	1) 공공 데이터에 국외 유출을 차단하기 위하여, 공공 데이터의 물리적 위치를 국내로 제한하고, 물리적 위치를 확인 및 추적하기 위한 기술적 방안을 제공하고 있는가?					
관련 근거	• 행정기관 및 공공기관의 클라우드컴퓨팅서비스 이용 기준 및 안전성 확보 등에 관한 고시 제13조(저장정보의 보호와 관리) • 국가 사이버보안 기본지침 제24조의3(클라우드컴퓨팅 도입 가능 목록)						

점검항목 해설

점검항목 1)

■ 국가기관등이 이용하는 가상자원 및 데이터의 국외 유출을 방지하기 위한 데이터 관리 방안 수립 및 기술적 보호조치를 제공하여야 한다.

- 클라우드서비스 제공자는 국가기관등의 가상자원 및 데이터에 임의 접근 및 국외 유출을 방지하기 위한 데이터 유출 방지 정책을 수립 및 이행하여야 함

※ 클라우드 컴퓨팅 서비스를 운용하기 위한 구성요소(시스템, 데이터)가 해당 됨

※ 공공 클라우드서비스의 주요직무자 외(민간 클라우드 인력 등) 공공 가상자원·데이터의 접근 및 제어 불가

- 국가기관 이용자가 클라우드서비스 이용 시 국외 영역에 가상자원 생성 불가, 데이터 저장 위치 국내 선택 등 데이터 국외 유출 방지를 위한 기술적 보호조치 기능 제공
- 클라우드서비스를 이용하는 이용자가 가상자원 및 데이터의 물리적 위치 증적을 요청할 경우 물리적 위치를 증명하기 위한 증적을 제공하여야 함

증거자료

- 데이터 유출 방지 기능
- 데이터 물리적 위치 추적 및 검토 증적

부적합 사례

- **사례 1 :** 이용자 데이터의 국외 유출 방지를 위한 정책, 지침 등을 수립하지 않은 경우
- **사례 2 :** 이용자가 소유하는 데이터 및 가상자원의 물리적 위치를 증명하기 위한 증적을 제공하지 않은 경우

항목	14.3.4 시스템 격리	기존				등급제(하)	
		IaaS	SaaS 표준	SaaS 간편	DaaS	하등급	하등급 SaaS
		○	○	○	○	○	○
인증기준	클라우드컴퓨팅서비스는 보안관제가 이뤄지는 서비스 네트워크 이외의 비정상 통신경로가 발생하지 않도록 주기적으로 검토하고 점검하는 체계 마련 등 기술적 대책을 수립하여야 한다.						
점검항목	공통	1) 국가기관 등 클라우드서비스에서 비정상 통신경로가 발생하지 않도록 주기적 검토를 수행하고 있는가?					
관련 근거	• 행정기관 및 공공기관의 클라우드컴퓨팅서비스 이용 기준 및 안전성 확보 등에 관한 고시 제11조(보안성 기준) • 국가 사이버보안 기본지침 제131조(보안관제센터 설치·운영)						

점검항목 해설

점검항목 1)

■ 클라우드서비스는 보안관제가 이루어지는 서비스 네트워크 외에 비정상 통신경로가 발생하지 않도록 주기적으로 검토하여야 한다.

- 민간 클라우드컴퓨팅 서비스 관리자가 이용기관에 할당된 자원(메모리·HDD 등), 데이터에 임의 접근하지 못하도록 접근제어 및 격리 등을 통한 기술적 접근통제 수단을 마련
- 이용자가 본인에게 할당된 자원 이외의 자원에 접근하지 못하도록 기술적 통제 수단 마련
- 클라우드 시스템은 무선망과 분리하고 무선접속에 대한 접근을 통제
- 가상머신 탈출, 은닉 채널 생성 등 비정상 통신경로를 발생 시킬 수 있는 최신 보안 취약점을 주기적으로 점검·확인하고 보안패치 적용
- 비정상 통신경로 등을 확인할 수 있는 기술적 대책(스캔, 모니터링 등) 수립
- 클라우드서비스의 접속기록 등을 자동화된 방식으로 분석하여 불법적인 개인정보 유출 및 오용·남용 시도를 탐지하고 그 사유를 소명하도록 하는 기능 마련

증거자료

■ 비정상 통신경로 점검 결과 및 검토 결과

부적합 사례

- **사례 1 :** 클라우드서비스 제공자가 원격관리서버(SSH 등) 설정이 미흡하여, 정상 통신경로 외 통신경로를 차단하지 않은 경우
- **사례 2 :** 클라우드서비스 구성 시 네임스페이스(이용자)간 네트워크 통신을 차단하지 않는 경우(kubernetes NetworkPolicy 미적용)
- **사례 3 :** 클라우드서비스 구성 시 이용자의 컨테이너가 혼용되어 운영되고, 상호 통신이 가능한 경우
- **사례 4 :** 클라우드서비스 제공자가 클라우드서비스 운영·관리 목적 외에 허가되지 않은 접속 경로를 차단하기 위하여, 주기적으로 검토한 보안 활동이 확인되지 않은 경우

<table>
<tr><td rowspan="3">항목</td><td rowspan="3" colspan="2">14.3.5 영역분리</td><td colspan="4">기존</td><td colspan="2">등급제(하)</td></tr>
<tr><td>IaaS</td><td>SaaS
표준</td><td>SaaS
간편</td><td>DaaS</td><td>하등급</td><td>하등급
SaaS</td></tr>
<tr><td>○</td><td>○</td><td>○</td><td>○</td><td>○</td><td>○</td></tr>
<tr><td>인증기준</td><td colspan="8">국가기관용 클라우드컴퓨팅서비스와 일반 이용자용 클라우드컴퓨팅서비스는 영역분리를 통해 데이터 및 프로세스 등의 간섭없이 국가기관등의 보안관제, 사고조사, 예방 보안활동 유지를 위한 제반환경을 만족시킬 수 있도록 기술적 보호조치를 취해야 하며, 영역 분리를 훼손하여 데이터에 접근할 수 있는 취약점을 방지/완화/제거 하고, 비인가 접근을 모니터링 해야 한다.</td></tr>
<tr><td rowspan="2">점검항목</td><td>공통</td><td colspan="7">1) 클라우드서비스는 물리적·논리적 분리를 통해 영역 간 분리가 수행되고 있는가?</td></tr>
<tr><td>공통</td><td colspan="7">2) 일반 이용자용 클라우드컴퓨팅서비스와 영역 분리되어 데이터 및 프로세스 등의 간섭 없이 국가정보원 및 이용기관의 보안관제, 사고조사, 예방활동 유지를 위한 제반 환경을 만족시킬 수 있는 보호조치를 취할 수 있는가?</td></tr>
<tr><td>관련 근거</td><td colspan="8">• 국가 사이버보안 기본지침 제24조의3(클라우드컴퓨팅 도입 가능 목록)</td></tr>
</table>

점검항목 해설

점검항목 1)

■ 일반 이용자용 클라우드와 국가기관용 클라우드서비스는 물리적·논리적 분리를 통해 상호 데이터 등에 접근할 수 없도록 기술적 보호조치를 취해야 한다.

- 국내 민간 사업자 클라우드센터에 위치
- 국가기관용 클라우드 컴퓨팅 서비스 영역과 일반 이용자용 클라우드 컴퓨팅 서비스의 영역 간 물리적·논리적 영역 분리 수행
- 논리적으로 영역 분리를 하는 경우, 영역 분리를 훼손하여 데이터에 접근할 수 있는 취약점을 방지/완화/제거하고 비인가 접근 모니터링 수행 등
- 클라우드서비스를 이용하는 이용자가 영역 분리(물리적 또는 논리적) 및 영역 분리를 위한 보호조치 등에 대한 자료 등을 요청할 경우, 제출하여야 함
- 국가공공기관의 내부망과 연동된 공공 전용 민간클라우드는 기관 내부망으로 간주하고, 인터넷망과 연동된 공공 전용 민간 클라우드는 기관의 인터넷망으로 간주하여 국가 사이버보안 기본지침에 따른 보안관리를 적용

점검항목 2)

■ 국가정보원 및 국가기관에서 사고조사 및 예방활동을 요청하는 경우 활동을 위한 제반환경을 제공하여야 한다.

- 이용기관별로 일반이용자용 클라우드와 영역분리되어 각 영역 마다 사고조사, 예방보안활동 등 국가정보원 및 이용기관의 사이버위협 대응활동 유지를 위한 제반환경 만족하도록 구성

증거자료

- 민간 공공영역 영역 분리증적
- 비인가 접근 모니터링 결과
- 보안관제 및 예방 활동 결과보고서

부적합 사례

- **사례 1 :** 논리적 또는 물리적으로 국가기관용 민간용 클라우드서비스를 분리하였으나, 국가기관용 클라우드서비스 영역 내에 민간 클라우드서비스 영역(자산, 데이터, 가상자산 등)이 존재하는 경우

클라우드컴퓨팅서비스 보안인증기준 해설서

발행일 : 2026년 07월
발행처 : 과학기술정보통신부, 한국인터넷진흥원

〈비매품〉